

The Enterprise GenAI Stack, Layer by Layer

The Enterprise GenAI Stack, Layer by Layer

A Thought-Leadership Series on Building GenAI
That Regulated Firms Can Trust

Bing Zhang



Veyan[®]

The Enterprise GenAI Stack, Layer by Layer: A thought-leadership series

Copyright © 2026 Bing Zhang. All rights reserved. No part of this book may be reproduced, stored in a retrieval system or transmitted in any form or by any means without the prior written permission of the publisher, except for brief quotations in reviews and articles.

Published by Veyan. First edition, October 2026. Evidence as of 9 October 2026.

ISBN (paperback): to be assigned · ISBN (hardcover): to be assigned · ISBN (ebook): to be assigned

Not advice, and not a description of any firm. This book sets out a reference architecture and the author's assessment of products and regulation. It is not investment, legal, regulatory or tax advice. It does not describe any firm's actual platform, vendor choices or internal systems. The worked example is generic and illustrative. Product facts, prices, certifications, ownership and regulatory dates are stated as at the dates given and change frequently; verify them before relying on them.

Trademarks. Product and company names are trademarks or registered trademarks of their respective owners. Their mention does not imply endorsement by, or affiliation with, those owners.

How this book was made. This book grew from a LinkedIn series based on an independent review of the enterprise GenAI stack. The research and drafting were carried out with Claude, an AI model made by Anthropic, under the author's direction. Anthropic's products are treated like every other vendor's, and wherever one is named, an independent alternative is named beside it.

Cover and interior design: Veyan.

Contents

Preface.....vii

How to read this book.....ix

Part I: The argument.....1

 Introduction: The enterprise GenAI stack, layer by layer.....2

Part II: Nine layers and the controls that make them safe.....11

 1. Treat foundation models as a portfolio, not a bet.....12

 2. Cost per task, not cost per token.....22

 3. Self-hosting is a capacity decision, not just cost.....31

 4. The boring component that makes exit real.....41

 5. Most enterprise “agents” should be workflows.....51

 6. Guardrails cannot fix the wrong autonomy.....60

 7. Easy tool connections make governance the architecture.....69

 8. “Who did this?” needs an answer for agents.....78

 9. Build memory last, on purpose.....87

 10. Multi-vendor AI is becoming close to a requirement.....96

 11. You may not need a vector database.....106

 12. Every retrieved document is untrusted input.....115

 13. Retrieval quality is a two-stage problem.....124

14. A prompt change is a production change.....132

15. Many “hallucinations” start in a table parser.....140

16. One client identifier, seven copies to protect.....148

17. Evaluation is a plane, not the last box.....156

18. Your eval suite is your validation evidence.....165

Part III: Putting it together.....175

19. What the agent must never do matters more.....176

20. The most valuable page: “do not build yet”.....183

21. Build where you differentiate, buy where you maintain.....191

22. Portability lives in the artefacts you own.....201

23. Some lock-in is a good trade.....210

24. Select the control plane first.....219

Appendix A: The worked example, step by step.....229

Appendix B: The book at a glance.....237

Appendix C: Glossary.....241

About the author.....245

Preface

This book started as a series of LinkedIn posts. Each post took one layer of the enterprise GenAI stack, from the foundation models at the bottom to evaluation at the top, and paired it with the control that makes it safe to run in a regulated firm ^{AJ}.

The posts were short by design: one argument, one signal to measure, one picture. This book gives each of them the room a post cannot. Every chapter opens with the post as it was written, then goes behind it: the evidence, the trade-offs, what good looks like, the honest objections and the questions worth taking to your own team

^{AJ}.

The view is deliberately narrow. It is written for people who must make GenAI work inside a firm that answers to regulators, auditors and clients: architects, technology and data leaders, risk and compliance teams, and the engineers who build the platform. If your firm is less regulated, most of the advice still holds; you will simply be able to move faster on some of it ^{AJ}.

Two things run through every chapter. The first is a conviction: the products will change every quarter, so the architecture that lasts is the control plane around them, owned by the firm. The second is one worked example: an agent that drafts the monthly performance-attribution commentary for a multi-asset fund, with a portfolio manager approving every draft. It is generic and illustrative, and it grows a piece at a time as the chapters go on ^{AJ}.

The research behind the series was an independent review of 140 products and the regulation around them, completed in October 2026. It was carried out with the help of an AI model made by Anthropic. Anthropic's products are treated like every other vendor's here, and wherever one is named an independent alternative sits beside it ^{AJ}.

Facts carry footnotes with their sources and the date they were checked. Versions, prices, owners and regulatory dates move quickly; treat every fact as true on its date, and check it again before you rely on it ^{AJ}.

How to read this book

Read in any order. Each chapter stands on its own. Part II follows the stack from the bottom up, pairing each layer with its control; Part III puts the pieces together into decisions ^{AJ}.

Each chapter has the same shape ^{AJ}:

Section	What it gives you
The post	The argument in under three hundred words
The figure	The same argument as one picture
Behind the post	The evidence and the trade-offs
What good looks like	The signal to measure, and a starting target
In the worked example	The piece this chapter adds to the commentary agent
Objections worth taking seriously	The strongest counter-arguments, answered
Questions for your team	What to ask tomorrow
In one line	The chapter's point, if you remember nothing else

Follow the worked example. The commentary agent is built one step per chapter. Appendix A lists every step, from the brief to sign-off ^{AJ}.

Footnotes. A footnote marks each sourced fact. Verified facts come from primary sources such as vendor documentation, regulators and standards bodies; reported facts come from secondary sources; everything else is the author's judgement or recommendation ^{AJ}.

Dates. The evidence is as of 9 October 2026 ^{AJ}.

Part I: The argument

Introduction: The enterprise GenAI stack, layer by layer

Series introduction, from Post 0 of the series.

The post

Over the next twelve weeks I am going to take the enterprise GenAI stack apart, one layer at a time. ^{AJ}

Most of us have shared some version of the popular stack diagram: nine layers, rows of product logos. It is a useful map. But by the end of Q3 2026, 39 of its 80 tiles needed a correction. Acquired, renamed, mispositioned, superseded. The logos move faster than any diagram can. ^{AJ}

So I asked a narrower question. What would a regulated asset manager actually need to run GenAI safely in production? ^{AJ}

The answer became a review of 140 products across nine layers and eight cross-cutting controls, built on 1,255 logged sources and checked by two independent verifiers. The finding that shaped everything else: the architecture that matters is the control plane around the products, not the products themselves. ^{AJ}

The series follows that shape. Each week takes one layer of the stack, from foundation models to evaluation, and then the control that makes it safe. One worked example runs throughout: an agent that drafts the monthly performance-attribution commentary for a multi-asset fund, with a portfolio manager approving every draft. ^{AJ}

The posts share judgement, not vendor rankings. No vendor is named in the post itself; sources sit in the first comment. ^{AJ}

The honest caveat: parts of this will date. Versions, owners and prices move monthly, so each post is re-checked in the week it goes out, and where I get something wrong I will say so. ^{AJ}

If one of these weeks saves you a quarter of rework, the series will have done its job. The first post is on foundation models. ^{AJ}

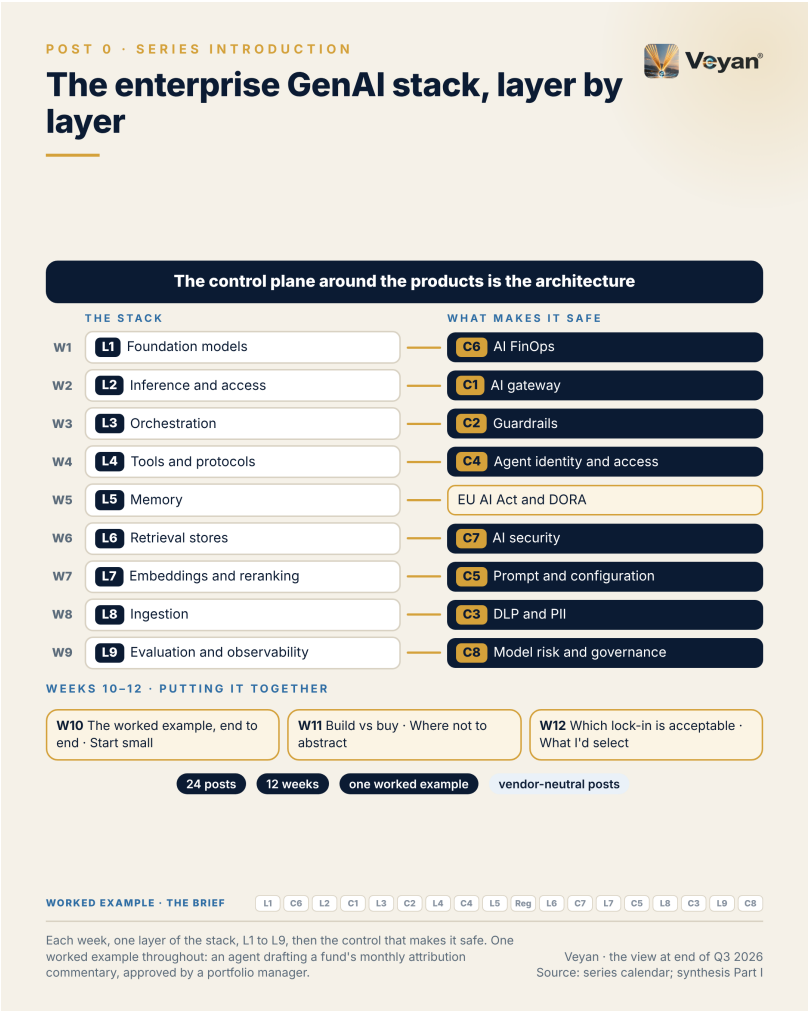


Figure 0. Each week, one layer of the stack, L1 to L9, then the control that makes it safe. One worked example throughout: an agent drafting a fund’s monthly attribution commentary, approved by a portfolio manager. ^{AJ}

Behind the post

The tension in this introduction is simple to state. The logos move faster than any diagram, and the controls around them are what last ^{AJ}. Everything else in this book is an attempt to show why that is true, and what to do about it.

The starting point was a widely shared picture of the GenAI stack: nine layers and 80 product tiles. It is a good teaching device, and its nine-layer spine still maps the work ^{AJ}. But when the review checked each tile against primary sources, and two adversarial verifiers re-checked the high-risk claims, 39 of the 80 tiles needed a correction: 9 acquired, 9 mispositioned, 8 renamed, 8 with a wrong version label, 6 not publicly verifiable, 4 duplicated, 3 superseded and 2 deprecated, with some tiles carrying more than one flag ^{AJ}. Nobody did anything wrong in drawing it. The market simply moved.

It moved in a particular direction. Much of the tooling that firms think of as neutral now belongs to a platform vendor. Dynatrace completed its acquisition of Arize on 1 October 2026 ^{VF1}. ClickHouse announced that it had acquired Langfuse on 16 January 2026 ^{VF2}. Palo Alto Networks bought Portkey and Protect AI, Check Point bought Lakera, Harvey bought Guardrails AI, and Mintlify bought Helicone ^{VF3}.

¹ Verified fact — A1-S045: Dynatrace Completes Acquisition of Arize, Extending AI Observability Across the Full Development Lifecycle (Dynatrace, Inc.) <https://ir.dynatrace.com/news-events/press-releases/detail/439/dynatrace-completes-acquisition-of-arize-extending-ai-observability-across-the-full-development-lifecycle> accessed 2026-10-07 [search-tool extract]; V1-S005: Dynatrace Completes Acquisition of Arize (IR press release) (Dynatrace, Inc.) <https://ir.dynatrace.com/news-events/press-releases/detail/439/dynatrace-completes-acquisition-of-arize-extending-ai-observability-across-the-full-development-lifecycle> accessed 2026-10-08 [search-tool extract]

² Verified fact — A1-S021: ClickHouse raises \$400M Series D, acquires Langfuse, launches Postgres (ClickHouse, Inc.) <https://clickhouse.com/blog/clickhouse-raises-400-million-series-d-acquires-langfuse-launches-postgres> accessed 2026-10-07 [search-tool extract]; V2-S041: ClickHouse welcomes Langfuse (with langfuse.com 'Langfuse joins ClickHouse', Orrick) <https://clickhouse.com/blog/clickhouse-acquires-langfuse-open-source-llm-observability> accessed 2026-10-08 [search-tool extract]

³ Verified fact — A6-S011: Palo Alto Networks Completes Acquisition of Portkey to Secure AI Agents (and 30 Apr 2026 announcement) <https://www.paloaltonetworks.com/company/press/2026/palo-alto-networks-completes-acquisition-of-portkey-to-secure-ai-agents> accessed 2026-10-07 [search-tool extract]; V2-S025: Palo Alto Networks Completes Acquisition of Portkey to Secure AI Agents (with PANW FY2026 10-K and 10-Q, SDxCentral) <https://www.paloaltonetworks.com/company/press/2026/palo-alto-networks-completes-acquisition-of-portkey-to-secure-ai-agents> accessed 2026-10-08 [search-tool extract]; A7-S014: Palo Alto Networks Completes Acquisition of Protect AI <https://www.paloaltonetworks.com/company/press/2025/palo-alto-networks-completes-acquisition-of-protect-ai/> accessed 2026-10-07 [search-tool extract]; V2-S039: Palo Alto Networks Completes Acquisition of Protect AI <https://investors.paloaltonetworks.com/news-releases/news-release-details/palo-alto-networks-completes-acquisition-of-protect-ai/> accessed 2026-10-08 [search-tool extract]; A7-S012: Check Point to Acquire Lakera, Redefining Security for the AI Era (Check Point Software) <https://blog.checkpoint.com/security/check-point-to-acquire-lakera-redefining-security-for-the-ai-era/> accessed 2026-10-07 [search-tool extract]; V2-S038: Check Point Software Reports 2025 Third Quarter Financial Results (with 'Check Point Completes Acquisition of Lakera' release via cxotoday) (Check Point Software Technologies) <https://www.checkpoint.com/press-releases/check-point-software-reports-2025-third-quarter->

Independence, exit planning and effective challenge can no longer be assumed from a product's origins; they have to be designed in ^{AJ}.

The models moved too. Every major vendor now sells a tiered family rather than a single model, the most capable tiers are gated, and lifetimes are short: a Gemini Flash version released on 13 August 2026 retires on 28 January 2027 ^{W4}. Model choice has become a portfolio and lifecycle discipline, not a one-off selection ^{AJ}.

And the rules moved. In the United States, SR 26-2 superseded SR 11-7 on 17 April 2026 and places generative and agentic AI outside its scope ^{W5}. The EU AI Act's enforcement powers over general-purpose models started on 2 August 2026, and Regulation (EU) 2026/1744 moved the Annex III high-risk duties to 2 December 2027 ^{W6}. The DORA critical-provider list and the UK critical third-party designations cover hyperscalers and no model vendor ^{W7}. In the UK, PRA PS7/26 and FCA PS26/2

[financial-results/](#) accessed 2026-10-08 [search-tool extract]; A6-S028: Guardrails AI Joins Harvey <https://www.harvey.ai/blog/guardrails-ai-joins-harvey> accessed 2026-10-07 [search-tool extract]; A7-S112: Helicone Blog: Helicone acquired by Mintlify (and Mintlify announcement) (Helicone / Mintlify) <https://www.helicone.ai/blog> accessed 2026-10-07 [search-tool extract]; V2-S043: Helicone Joins Mintlify (with mintlify.com 'Mintlify acquires Helicone'; PostHog comparison) (Helicone / Mintlify) <https://www.helicone.ai/blog/joining-mintlify> accessed 2026-10-08 [search-tool extract]

⁴ Verified fact — A5-S002: GPT-6 Astra: A new generation of intelligence (plus release notes, Introducing GPT-6 Sol and Luna, GPT-6.1 Sol, GPT-6 for everyone) (OpenAI) <https://openai.com/index/gpt-6-astra/> accessed 2026-10-07 [search-tool extract]; A5-S003: OpenAI announces rollout of GPT-6 Astra model (with Axios and OpenRouter results) (CNBC) <https://www.cnbc.com/2026/09/03/open-ai-astra-gpt-6-cyber.html> accessed 2026-10-07 [search-tool extract]; A5-S016: Introducing Claude Fable 5.1 and Claude Mythos 5.1 (Anthropic) <https://www.anthropic.com/claude-fable-and-mythos-5-1> accessed 2026-10-07; A5-S031: Gemini 4 Argon: our next era of frontier intelligence (Google) <https://blog.google/innovation-and-ai/models-and-research/gemini-models/gemini-4-argon/> accessed 2026-10-07 [search-tool extract]; B-L1-S003: Gemini 3.7 Flash model page and related lifecycle pages (Gemini Enterprise Agent Platform) (Google Cloud) <https://docs.cloud.google.com/gemini-enterprise-agent-platform/models/gemini/3-7-flash> accessed 2026-10-08 [search-tool extract]

⁵ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see [regulatory_facts.json](#)); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]

⁶ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see [regulatory_facts.json](#)); R-EU-OMNIBUS-AI: Regulation (EU) 2026/1744 ('Digital Omnibus on AI') amending Regulations (EU) 2024/1689, 2018/1139 and 2023/1230 (see [regulatory_facts.json](#)); A8-S011: Regulation (EU) 2026/1744 (Digital Omnibus on AI) amending Regulation (EU) 2024/1689 (EUR-Lex / Official Journal of the EU) <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> accessed 2026-10-07 [search-tool extract]

⁷ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see [regulatory_facts.json](#)); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act>

Part I: The argument

require material third-party notifications from 18 March 2027⁸. A regulated firm therefore has to write much of its own GenAI standard^{AJ}.

Put those three movements together and the question changes. It stops being “which tools?” and becomes “what has to stay true whichever tools we use?”^{AJ}. The review’s answer is a control plane of eight components: the gateway, guardrails, data protection, identity, configuration, FinOps, AI security, and governance with its evidence store^{AJ}. The gateway has already become the place where model, tool and agent traffic is governed; LiteLLM, Kong, Azure API Management, Apigee and agentgateway all govern model, MCP and agent-to-agent traffic⁹. The products beneath the plane are replaceable. The plane is not^{AJ}.

The evidence base is worth stating plainly, because the book depends on it. The review covers 140 product records across nine layers and eight controls, of which 138 were scored, and 1,255 logged sources^{AJ}. Every fact carries a source and an access date, and facts that could not be confirmed were marked “not publicly verified” rather than guessed^{AJ}. Vendor benchmark figures were never used as decision inputs^{AJ}. The credit for that discipline belongs to the research streams and the two verifiers whose job was to disagree.

One worked example runs through the book. An agent drafts the monthly Brinson-style attribution commentary for a generic multi-asset fund, covering allocation,

dora accessed 2026-10-07 [search-tool extract]; R-UK-CTP: UK Critical Third Parties regime (FSMA 2023 / FSMA 2000 s312L; PRA/FCA/BoE CTP rules) and the Critical Third Parties (Designation) Regulations 2026 (SI 2026/777) (see regulatory_facts.json); A8-S023: The Critical Third Parties (Designation) Regulations 2026 (SI 2026/777); BoE/FCA/HMT announcements (HM Treasury / legislation.gov.uk / Bank of England)
<https://www.legislation.gov.uk/uksi/2026/777/made> accessed 2026-10-07 [search-tool extract]

⁸ Verified fact — R-PRA-SS221: PRA SS2/21 ‘Outsourcing and third party risk management’ (revised by PS7/26, March 2026) (see regulatory_facts.json); R-FCA-SYSC8: FCA Handbook SYSC 8 (Outsourcing); FG16/5 ‘Guidance for firms outsourcing to the cloud and other third-party IT services’; PS26/2 operational incident and third-party reporting (see regulatory_facts.json); A8-S062: PS7/26 Operational incident and third-party reporting (PRA) and FCA PS26/2; revised SS2/21 (March 2026) (Bank of England / PRA; FCA)
<https://www.bankofengland.co.uk/prudential-regulation/publication/2026/march/operational-incident-and-third-party-reporting-policy-statement> accessed 2026-10-07 [search-tool extract]

⁹ Verified fact — A6-S015: LiteLLM docs: MCP Overview, Agent Gateway (A2A), Caching, Budgets/Rate Limits, v1.89.0 release notes (BerriAI (LiteLLM)) <https://docs.litellm.ai/docs/mcp> accessed 2026-10-07 [search-tool extract]; A6-S016: Kong AI Gateway 2.0 Is Now GA — And It’s Already Moving Faster (Kong Inc.) <https://konghq.com/blog/product-releases/kong-ai-gateway-2-0-ga> accessed 2026-10-07 [search-tool extract]; A6-S053: AI gateway capabilities in Azure API Management (Microsoft Learn source, ms.date 29 May 2026)
<https://raw.githubusercontent.com/MicrosoftDocs/azure-docs/main/articles/api-management/genai-gateway-capabilities.md> accessed 2026-10-07; A6-S024: Apigee AI solutions: gateway to enterprise-ready AI (Google Cloud) <https://cloud.google.com/solutions/apigee-ai> accessed 2026-10-07; A6-S061: agentgateway README (GitHub) (agentgateway project (Linux Foundation))
<https://raw.githubusercontent.com/agentgateway/agentgateway/main/README.md> accessed 2026-10-07

selection and currency effects, and a portfolio manager approves every draft ^{AI}. It is illustrative, not a description of any firm. It was chosen because its one failure that matters, a wrong number in a client document, is easy to state and hard to excuse ^{AI}.

A word on how the book is arranged. Part II takes the nine layers in order, from foundation models (Chapter 1) to evaluation and observability (Chapter 17), and follows each with the control that pairs with it, so that Chapter 2 on cost follows Chapter 1 on models, and Chapter 4 on the gateway follows Chapter 3 on inference ^{AI}. Part III, Chapters 19 to 24, puts the pieces together: the worked example end to end, starting small, build versus buy, abstraction, lock-in and a closing selection ^{AI}. Each chapter stands alone.

Finally, a disclosure that matters for a book about vendors. The review and these chapters were researched and drafted with help from an AI model made by Anthropic ^{AI}. Anthropic's products were scored on the same rubric as everyone else's, and wherever an Anthropic product or standard is named, an independent alternative is named beside it: OpenAI, Google or Mistral models next to Claude, for example, and OpenAPI-described tools behind the same gateway next to MCP ^{AI}.

What good looks like

The introduction has no single metric of its own, but the whole book rests on one: **control-plane coverage**. It is the share of production GenAI calls (model, tool and agent) that pass through the firm's own gateway, and for which a complete evidence record exists: model and version, route and region, guard outcomes, cost and the human approver ^{AI}.

Measure it by reconciling provider usage reports against the gateway log, scanning code repositories for provider keys held outside the gateway, and sampling regulated outputs to check that each one can be traced to its evidence record ^{Rec}. A direct provider key in an application is a defect, not a shortcut ^{AI}.

A reasonable starting target is 100% of in-scope production traffic through the gateway, and an evidence record for every regulated output ^{AI}. Treat these as a starting point, not a benchmark. They are the review's own target guidance, not an industry statistic, and each firm should set its own scope and thresholds ^{AI}.

In the worked example

The brief. The use case and its boundary: the agent writes words around numbers it is given; it never produces a number, and a named portfolio manager approves

every draft. The design file starts empty; each chapter adds one piece, and Appendix A lists every step ^{AI}.

Objections worth taking seriously

“Architecture first is slower. The business wants results this quarter.” It is slower for the first use case. It is much faster for the second and the tenth ^{AI}. A control plane that exists before the first production workload means each later use case inherits the gateway, the evaluation suite and the evidence store rather than rebuilding them ^{AI}. Some of the work cannot be skipped anyway. PRA SS1/23 expects independent validation and ongoing monitoring, including of vendor models ^{VF}¹⁰. Without an evaluation suite there is nothing for a validator to re-perform, so the first use case cannot go live under the firm’s own standard ^{AI}. Chapter 20 shows how small the first version can be.

“Any landscape this detailed will be out of date within months.” True, and the post says so ^{AI}. That is precisely why the book argues from responsibilities and controls rather than from logos. The product named in a chapter may change; the duty it performs, and the evidence a supervisor will ask for, change far more slowly ^{AI}. Each fact carries its date, so a reader can see what to re-check ^{AI}.

“A book drafted with an AI vendor’s model cannot be neutral about AI vendors.” The concern is fair, which is why it is disclosed rather than hidden ^{AI}. The defence is method, not assurance: one rubric for every product, borderline calls on Anthropic-related items resolved against them, the tier decisions taken by the human reader at checkpoints, and an independent alternative named wherever an Anthropic product appears ^{AI}. Readers should still test the reasoning for themselves.

Questions for your team

- If our most-used model vendor withdrew access tomorrow, how long would it take us to move, and have we ever tried? ^{Rec}
- What share of our production AI traffic passes through a gateway we control, and how do we know? ^{Rec}
- Which of the tools we treat as “independent” have changed owner in the last year? ^{Rec}
- For one regulated output, can we produce the model version, the route, the guard results and the approver within an hour? ^{Rec}

¹⁰ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 ‘Model risk management principles for banks’ (published with PS6/23) (see regulatory_facts.json); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]; A8-S037: Bank of England/PRA letter to DSIT and HMT on AI (2024) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/letter/2024/dsit-hmt-letter.pdf> accessed 2026-10-07 [search-tool extract]

- Who owns our GenAI standard, given that the US model-risk guidance now excludes generative and agentic AI? ^{Rec}
- Which dates in 2027 does our roadmap already respect, and which has nobody yet put in a plan? ^{Rec}

In one line

The products will keep changing; build the control plane that lets you change them safely ^{AJ}.

Part II: Nine layers and the controls that make them safe

1. Treat foundation models as a portfolio, not a bet

L1 Foundation models, from Post 1 of the series.

The post

Treat foundation models as a portfolio, not a bet. ^{AJ}

Every major vendor now sells a tiered family rather than a single model, and lifetimes are short. One generally available model version released in August 2026 is already scheduled to retire in January 2027. Earlier this year, one leading vendor's top tier was withdrawn for nearly three weeks before being restored. ^{VF¹¹}

A firm that hard-codes one vendor cannot respond to either. Nor can a firm whose "fallback model" is a line in a design document that was never tested on the real workload. ^{AJ}

A portfolio does not need to be large. Two mid-tier models from unrelated vendors, a small model for high-volume classification, and one open-weight model the firm can run itself. All of them called through the gateway, pinned to exact versions rather than "latest", and each qualified on the same evaluation suite. ^{Rec}

The signal is qualified-alternative coverage: the share of production use cases with a second model, from a different vendor, that passed the same evaluation within the last quarter. For an important business service the target is 100%. ^{AJ}

¹¹ Verified fact — A5-S002: GPT-6 Astra: A new generation of intelligence (plus release notes, Introducing GPT-6 Sol and Luna, GPT-6.1 Sol, GPT-6 for everyone) (OpenAI) <https://openai.com/index/gpt-6-astra/> accessed 2026-10-07 [search-tool extract]; A5-S004: OpenAI API Pricing (and Introducing GPT-6 Sol and Luna pricing) <https://developers.openai.com/api/docs/pricing> accessed 2026-10-07 [search-tool extract]; A5-S010: Models overview - Claude API Docs (Anthropic) <https://platform.claude.com/docs/en/models/overview> accessed 2026-10-07; A5-S019: Introducing Claude Opus 5.5 (Anthropic) <https://www.anthropic.com/claude-opus-5-5> accessed 2026-10-07; B-L1-S003: Gemini 3.7 Flash model page and related lifecycle pages (Gemini Enterprise Agent Platform) (Google Cloud) <https://docs.cloud.google.com/gemini-enterprise-agent-platform/models/gemini/3-7-flash> accessed 2026-10-08 [search-tool extract]; V2-S004: Claude Fable - Anthropic <https://www.anthropic.com/claude/fable> accessed 2026-10-08

1. Treat foundation models as a portfolio, not a bet

The leadership move is to keep the frontier tier switched off until an evaluation shows the mid tier fails a named use case. And to remember that no model, at any tier, is fit to produce authoritative figures. Numbers come from the system of record. ^{Rec}

The honest caveat: a portfolio multiplies validation and contract work. The answer is to keep it small and let the evaluation suite do the re-qualification, not to give up the second vendor. ^{AJ}

Capability changes every quarter. The ability to change your mind safely is the asset worth building. ^{AJ}

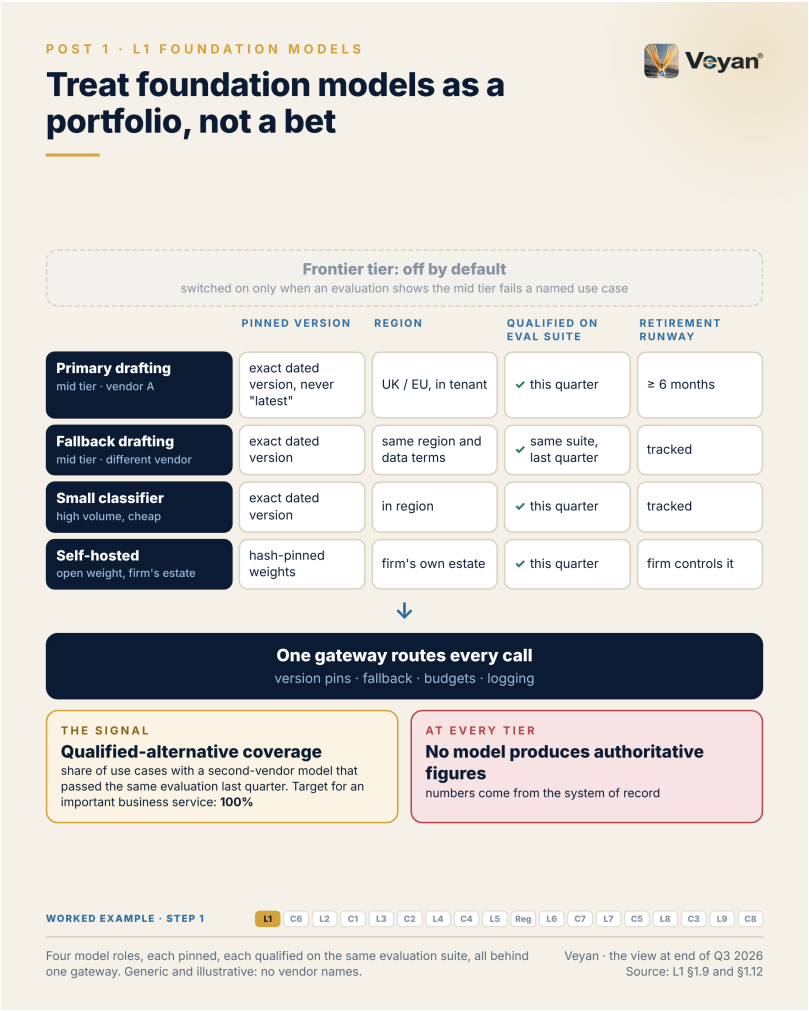


Figure 1. Four model roles, each pinned, each qualified on the same evaluation suite, all behind one gateway. Generic and illustrative: no vendor names. ^{AJ}

Behind the post

An enterprise does not own the foundation-model layer by building models. It owns the choice, the contract, the configuration and the qualification of models it buys or

runs^{AJ}. That is a different job from picking a winner, and the market has made the difference sharper during 2025 and 2026.

Families, not models. Every major vendor now sells a tiered family. OpenAI's GPT-6 comes as Astra, Sol and Luna, with GPT-6.1 Sol alongside^{vr12}. Anthropic sells Claude Fable 5.1 above Opus, Sonnet and Haiku 5.5^{vr13}. Google runs Gemini 3.x alongside a restricted Gemini 4 Argon^{vr14}. Within one family, list prices span two orders of magnitude, from US\$0.10 to US\$10 per million input tokens in both the OpenAI and Anthropic ranges^{vr15}. The tier is a design decision, not a badge.

The top is gated. The most capable tiers are no longer simply for sale. OpenAI rates Astra "Critical" for cybersecurity and requires enterprise administrators to enable it; Anthropic restricts Mythos 5.1; Google released Argon first to cyber defenders^{vr16}. Gated tiers are off by default for a reason, and they should stay off unless a named use case needs them^{AJ}.

Lifetimes are short and notice periods vary. The two events in the post are both on the record. A Gemini Flash version released on 13 August 2026 retires on 28 January 2027^{vr17}. Anthropic's top tier, Claude Fable 5, was unavailable from 12 June 2026 and restored from 1 July 2026^{vr18}. The lesson is about every vendor, not one. OpenAI gives at least six months' notice for generally available models and as little

¹² Verified fact — A5-S002: GPT-6 Astra: A new generation of intelligence (plus release notes, Introducing GPT-6 Sol and Luna, GPT-6.1 Sol, GPT-6 for everyone) (OpenAI) <https://openai.com/index/gpt-6-astra/> accessed 2026-10-07 [search-tool extract]; A5-S004: OpenAI API Pricing (and Introducing GPT-6 Sol and Luna pricing) <https://developers.openai.com/api/docs/pricing> accessed 2026-10-07 [search-tool extract]

¹³ Verified fact — A5-S010: Models overview - Claude API Docs (Anthropic) <https://platform.claude.com/docs/en/models/overview> accessed 2026-10-07; A5-S019: Introducing Claude Opus 5.5 (Anthropic) <https://www.anthropic.com/claude-opus-5-5> accessed 2026-10-07

¹⁴ Verified fact — A5-S030: Gemini API Release notes (with Models, Deprecations, 'What's new in Gemini 3.8 Flash' pages) (Google) <https://ai.google.dev/gemini-api/docs/changelog> accessed 2026-10-07 [search-tool extract]; A5-S031: Gemini 4 Argon: our next era of frontier intelligence (Google) <https://blog.google/innovation-and-ai/models-and-research/gemini-models/gemini-4-argon/> accessed 2026-10-07 [search-tool extract]

¹⁵ Verified fact — A5-S004: OpenAI API Pricing (and Introducing GPT-6 Sol and Luna pricing) <https://developers.openai.com/api/docs/pricing> accessed 2026-10-07 [search-tool extract]; A5-S011: Pricing - Claude API Docs (Anthropic) <https://platform.claude.com/docs/en/about-claude/pricing> accessed 2026-10-07

¹⁶ Verified fact — A5-S002: GPT-6 Astra: A new generation of intelligence (plus release notes, Introducing GPT-6 Sol and Luna, GPT-6.1 Sol, GPT-6 for everyone) (OpenAI) <https://openai.com/index/gpt-6-astra/> accessed 2026-10-07 [search-tool extract]; A5-S003: OpenAI announces rollout of GPT-6 Astra model (with Axios and OpenRouter results) (CNBC) <https://www.cnbc.com/2026/09/03/open-ai-astra-gpt-6-cyber.html> accessed 2026-10-07 [search-tool extract]; A5-S016: Introducing Claude Fable 5.1 and Claude Mythos 5.1 (Anthropic) <https://www.anthropic.com/claude-fable-and-mythos-5-1> accessed 2026-10-07; A5-S031: Gemini 4 Argon: our next era of frontier intelligence (Google) <https://blog.google/innovation-and-ai/models-and-research/gemini-models/gemini-4-argon/> accessed 2026-10-07 [search-tool extract]

as about two weeks for previews; Mistral's Labs models may go with one month's notice ¹⁹. Mistral Medium 3.1 retired on 31 August 2026 ²⁰. A version change is a model change, and a forced retirement is a forced re-validation ^{AI}.

The route matters as much as the model. A model can be reached through the vendor's own API, through a hyperscaler, or as open weights the firm runs itself ^{AI}. Each route has different data terms. Anthropic's first-party API offers only global or US inference geography, while the same models run in EU regions on Google Cloud and Bedrock ²¹. OpenAI and Mistral both offer first-party EU endpoints ²². Residency also has a price: about 10% on several regional routes ²³. For a regulated firm, the residency premium is the real price ^{AI}.

What the portfolio looks like. The review's answer is deliberately small. Two mid-tier models from unrelated vendors, a small model for classification and routing, and one open-weight model the firm can run in its own estate, all reached through the gateway and qualified on the firm's own evaluation suite ^{Res}. Pin exact versions; Google's own documentation recommends versioned model IDs for predictable

¹⁷ Verified fact — B-L1-S003: Gemini 3.7 Flash model page and related lifecycle pages (Gemini Enterprise Agent Platform) (Google Cloud) <https://docs.cloud.google.com/gemini-enterprise-agent-platform/models/gemini/3-7-flash> accessed 2026-10-08 [search-tool extract]

¹⁸ Verified fact — V2-S004: Claude Fable - Anthropic <https://www.anthropic.com/claude/fable> accessed 2026-10-08

¹⁹ Verified fact — B-L1-S001: Deprecations (OpenAI API docs) <https://developers.openai.com/api/docs/deprecations> accessed 2026-10-08 [search-tool extract]; B-L1-S002: Models overview: deprecated and retired models (Mistral Docs) (Mistral AI) <https://docs.mistral.ai/models> accessed 2026-10-08 [search-tool extract]

²⁰ Verified fact — B-L1-S002: Models overview: deprecated and retired models (Mistral Docs) (Mistral AI) <https://docs.mistral.ai/models> accessed 2026-10-08 [search-tool extract]

²¹ Verified fact — A5-S013: Data residency - Claude Platform Docs (Anthropic) <https://platform.claude.com/docs/en/manage-claude/data-residency> accessed 2026-10-07; V2-S075: Data residency - Claude Platform Docs (Anthropic) <https://platform.claude.com/docs/en/build-with-claude/data-residency> accessed 2026-10-08; A5-S027: Generative AI pricing - Google Cloud (Gemini Enterprise Agent Platform, formerly Vertex AI) <https://cloud.google.com/gemini-enterprise-agent-platform/generative-ai/pricing> accessed 2026-10-07

²² Verified fact — A5-S006: Data controls in the OpenAI platform (with Enterprise privacy, EU/UK data residency announcements) <https://developers.openai.com/api/docs/guides/your-data> accessed 2026-10-07 [search-tool extract]; A5-S075: Mistral Help Centre: SOC 2 / ISO 27001; data storage location; ZDR; Regional inference docs; Trust Center (Mistral AI) <https://help.mistral.ai/en/articles/347638-do-you-have-soc-2-or-iso-27001-certification> accessed 2026-10-07 [search-tool extract]

²³ Verified fact — A5-S011: Pricing - Claude API Docs (Anthropic) <https://platform.claude.com/docs/en/about-claude/pricing> accessed 2026-10-07; A5-S027: Generative AI pricing - Google Cloud (Gemini Enterprise Agent Platform, formerly Vertex AI) <https://cloud.google.com/gemini-enterprise-agent-platform/generative-ai/pricing> accessed 2026-10-07; A5-S075: Mistral Help Centre: SOC 2 / ISO 27001; data storage location; ZDR; Regional inference docs; Trust Center (Mistral AI) <https://help.mistral.ai/en/articles/347638-do-you-have-soc-2-or-iso-27001-certification> accessed 2026-10-07 [search-tool extract]

behaviour²⁴. In the review's scoring, OpenAI and Mistral were Strategic, Anthropic Strategic on condition that it is consumed through a hyperscaler UK or EU region with a qualified non-Anthropic fallback, Gemini Strategic where Google Cloud is the primary cloud, and Gemma 4 Strategic as the small self-hosted tier^{AJ}. Wherever a Claude model is the primary, the independent alternatives are GPT-6.1 Sol, Gemini 3.8 Flash or Mistral Medium 3.5^{Rec}. No vendor benchmark, Anthropic's included, was used as a decision input^{AJ}.

Open weights split two decisions. Open weights are now a serious option from US and EU vendors (gpt-oss, Gemma 4, Mistral) and from Chinese-origin vendors (DeepSeek, Qwen, Kimi, GLM)^{vi25}. That makes *where the model runs and who made it* separate questions^{AJ}. DeepSeek's own API stores data in the PRC^{vi26}. The defensible position for a regulated firm is no Chinese-origin vendor APIs for client data, and Chinese-origin weights only by explicit policy, self-hosted and without tool access^{Rec}.

Why no model produces numbers. In the worked example, the attribution engine produces every figure through a read-only tool, and the model only writes narrative around it^{AJ}. A deterministic check compares every figure, sign and direction word in the draft with the engine's output, and a mismatch fails the draft whatever the model tier^{AJ}. A fluent model is not a source of record.

The regulatory frame. PRA SS1/23 applies to all models used to inform business decisions, in-house or vendor, and is technology-agnostic^{vi27}. For an FCA solo-

²⁴ Verified fact — B-L1-S003: Gemini 3.7 Flash model page and related lifecycle pages (Gemini Enterprise Agent Platform) (Google Cloud) <https://docs.cloud.google.com/gemini-enterprise-agent-platform/models/gemini/3-7-flash> accessed 2026-10-08 [search-tool extract]

²⁵ Verified fact — A5-S005: Introducing gpt-oss (and gpt-oss-safeguard; help-centre open-weight article) (OpenAI) <https://openai.com/index/introducing-gpt-oss/> accessed 2026-10-07 [search-tool extract]; A5-S034: Gemma 4: Byte for byte, the most capable open models (with Gemma releases page, Gemma 4 12B post) (Google) <https://blog.google/innovation-and-ai/technology/developers-tools/gemma-4/> accessed 2026-10-07 [search-tool extract]; A5-S074: Mistral Medium 3.5 model card; Introducing Mistral 3 (Large 3, Ministral 3); Mistral-Medium-3.5-128B (Hugging Face) (Mistral AI) <https://docs.mistral.ai/models/model-cards/mistral-medium-3-5-26-04> accessed 2026-10-07 [search-tool extract]; A5-S063: DeepSeek V4 Preview Release (24 April 2026) and deepseek-ai/DeepSeek-V4-Pro model card (MIT) <https://api-docs.deepseek.com/news/news260424/> accessed 2026-10-07 [search-tool extract]

²⁶ Verified fact — A5-S062: DeepSeek Privacy Policy; DeepSeek Open Platform Privacy Policy and Terms of Service <https://cdn.deepseek.com/policies/en-US/deepseek-privacy-policy.html> accessed 2026-10-07 [search-tool extract]

²⁷ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 'Model risk management principles for banks' (published with PS6/23) (see regulatory_facts.json); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]; A8-S037: Bank of England/PRA letter to DSIT and HMT on AI (2024) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/letter/2024/dsit-hmt-letter.pdf> accessed 2026-10-07 [search-tool extract]

regulated manager it is not binding, but it is the natural benchmark ^{AJ}. SR 26-2 places generative and agentic AI outside its scope, so US firms have to set their own standard ^{vi28}. The DORA and UK critical-provider regimes designate hyperscalers and no model vendor, so the oversight burden for a direct model API stays with the firm ^{vi29}. From 18 March 2027, UK firms must notify material third-party arrangements before entering them, so qualifying a second vendor needs lead time ^{vi30}.

The trade-off. A portfolio multiplies validation and contract work ^{AJ}. Two vendors means two data-protection assessments, two contracts and two sets of retirement dates. The answer is to keep the portfolio small and make the evaluation suite do the re-qualification, not to give up the second vendor ^{AJ}. That work is unglamorous. It belongs to the platform, validation and procurement teams who keep the fallback real, and it is the reason a withdrawal becomes a configuration change rather than a crisis.

What good looks like

The signal is **qualified-alternative coverage**: the share of production use cases that have a second model, from a different vendor, which has passed the same evaluation suite within the last quarter ^{AJ}.

²⁸ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see [regulatory_facts.json](#)); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]

²⁹ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see [regulatory_facts.json](#)); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]; R-UK-CTP: UK Critical Third Parties regime (FSMA 2023 / FSMA 2000 s312L; PRA/FCA/BoE CTP rules) and the Critical Third Parties (Designation) Regulations 2026 (SI 2026/777) (see [regulatory_facts.json](#)); A8-S023: The Critical Third Parties (Designation) Regulations 2026 (SI 2026/777); BoE/FCA/HMT announcements (HM Treasury / [legislation.gov.uk](#) / Bank of England) <https://www.legislation.gov.uk/uksi/2026/777/made> accessed 2026-10-07 [search-tool extract]

³⁰ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see [regulatory_facts.json](#)); R-FCA-SYSC8: FCA Handbook SYSC 8 (Outsourcing); FG16/5 'Guidance for firms outsourcing to the cloud and other third-party IT services'; PS26/2 operational incident and third-party reporting (see [regulatory_facts.json](#)); A8-S062: PS7/26 Operational incident and third-party reporting (PRA) and FCA PS26/2; revised SS2/21 (March 2026) (Bank of England / PRA; FCA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2026/march/operational-incident-and-third-party-reporting-policy-statement> accessed 2026-10-07 [search-tool extract]

1. Treat foundation models as a portfolio, not a bet

Measure it by joining the model inventory to the evaluation results. For each production use case, the inventory names the primary and the fallback; the evaluation platform shows the date and outcome of the fallback's last run on that use case's suite ^{AJ}. A fallback whose last pass is older than a quarter does not count.

The review's target guidance is 100% for important business services ^{AJ}. Two companion measures keep it honest. The version pinning rate, the share of production calls that name an exact model version rather than an alias, should be 100%, read from the gateway log ^{AJ}. Retirement runway, the days until the earliest announced retirement of any pinned model, should never fall below the re-qualification lead time, for example 90 days ^{AJ}.

These are a starting point, not a benchmark. They come from the review's KPI tables, not from an industry survey ^{AJ}.

In the worked example

Step 1: models. Four model roles, each pinned to an exact version: a primary drafting model, a fallback from a different vendor, a small classifier for reviewer edits, and a self-hosted open-weight model for anything touching unmasked client data. ^{AJ}

- **Now works:** The agent has a primary and a qualified fallback in the approved region. ^{AJ}
- **Must never:** No alias or preview model, and no model ever generates, rounds or corrects a figure. ^{AJ}
- **Evidence added:** Model ID, version, route and region for every draft. ^{AJ}
- **Signal:** Qualified-alternative coverage: 100% for this use case. ^{AJ}

Objections worth taking seriously

"Two vendors doubles the work for a marginal gain." It does add work: contracts, assessments, a second evaluation run ^{AJ}. The gain is not marginal, though. A three-week withdrawal of a vendor's top tier has already happened ^{vr31}, and short retirement windows are now normal ^{vr32}. The work stays manageable if the portfolio stays small and the same evaluation suite qualifies every member ^{AJ}. There is also a simpler test. If the firm's operational-resilience self-assessment already claims a

³¹ Verified fact — V2-S004: Claude Fable - Anthropic <https://www.anthropic.com/claude/fable> accessed 2026-10-08

³² Verified fact — B-L1-S003: Gemini 3.7 Flash model page and related lifecycle pages (Gemini Enterprise Agent Platform) (Google Cloud) <https://docs.cloud.google.com/gemini-enterprise-agent-platform/models/gemini/3-7-flash> accessed 2026-10-08 [search-tool extract]

multi-vendor fallback for an important business service, the second vendor is not optional; it is a statement the firm has made and must be able to evidence ^{AI}.

“The frontier model is better. Why default to the mid tier?” Sometimes it is better, and the evaluation will say so. But the gated tiers carry cyber-capability ratings that keep them off by default ^{vr33}, and the frontier list price is several times the mid tier’s: US\$10 against US\$2 per million input tokens in OpenAI’s range ^{vr34}. Switch it on for a named use case where the mid tier has failed, not as a habit ^{Rec}.

“Our cloud already offers several vendors’ models, so we are diversified.” Partly. Consuming models through one hyperscaler concentrates on one designated provider ^{vr35}, and the catalogue differs by cloud and region: Gemini is on Google Cloud only ^{vr36}. Keep a second route, such as a self-hosted open-weight model, for the stressed-exit case ^{Rec}. It may be lower quality than the primary. That is acceptable, because its job is continuity under stress, not first place in an evaluation ^{AI}.

Questions for your team

- For each production use case, which second-vendor model has passed our evaluation suite in the last quarter? ^{Rec}
- Do any production calls use an alias such as “latest” rather than a pinned version? ^{Rec}
- What is the earliest retirement date among our pinned models, and is re-qualification already scheduled? ^{Rec}
- Where, geographically, is each model route actually processing prompts, and is that written into the contract? ^{Rec}
- Which use cases run on a frontier tier, and what evaluation result justified it? ^{Rec}
- Could any model in our estate produce a figure that reaches a client without being checked against the system of record? ^{Rec}

³³ Verified fact — A5-S002: GPT-6 Astra: A new generation of intelligence (plus release notes, Introducing GPT-6 Sol and Luna, GPT-6.1 Sol, GPT-6 for everyone) (OpenAI) <https://openai.com/index/gpt-6-astra/> accessed 2026-10-07 [search-tool extract]; A5-S016: Introducing Claude Fable 5.1 and Claude Mythos 5.1 (Anthropic) <https://www.anthropic.com/claude-fable-and-mythos-5-1> accessed 2026-10-07

³⁴ Verified fact — A5-S004: OpenAI API Pricing (and Introducing GPT-6 Sol and Luna pricing) <https://developers.openai.com/api/docs/pricing> accessed 2026-10-07 [search-tool extract]

³⁵ Verified fact — R-UK-CTP: UK Critical Third Parties regime (FSMA 2023 / FSMA 2000 s312L; PRA/FCA/BoE CTP rules) and the Critical Third Parties (Designation) Regulations 2026 (SI 2026/777) (see [regulatory_facts.json](#)); A8-S023: The Critical Third Parties (Designation) Regulations 2026 (SI 2026/777); BoE/FCA/HMT announcements (HM Treasury / legislation.gov.uk / Bank of England) <https://www.legislation.gov.uk/uksi/2026/777/made> accessed 2026-10-07 [search-tool extract]

³⁶ Verified fact — A5-S027: Generative AI pricing - Google Cloud (Gemini Enterprise Agent Platform, formerly Vertex AI) <https://cloud.google.com/gemini-enterprise-agent-platform/generative-ai/pricing> accessed 2026-10-07

1. Treat foundation models as a portfolio, not a bet

In one line

Capability will change every quarter, so build the ability to change models safely, and treat it as the asset ^{AJ}.

2. Cost per task, not cost per token

C6 AI FinOps, from Post 2 of the series.

The post

Cost per token is the number on the price list. Cost per task is the number executives understand, and the one that tells you whether a change saved anything.

AJ

A cheaper token that needs three retries and a longer human review is not cheaper. Teams that optimise price per token can move to a smaller model and lose more in regeneration and review time than they saved. AJ

A portfolio of models needs a fair way to choose between them on cost. Meter every call at the gateway, tagged by use case and run. Join those records to the traces so that failed and regenerated attempts count. Reconcile monthly against provider bills. Keep the result in a dataset the firm owns, shaped to the open billing standard. Rec

In an illustrative cost model for a monthly fund commentary, at current list prices, tokens come to well under a dollar per approved commentary. Reviewer time is the real cost. So the signal to report is cost per approved output, counting every failed and regenerated draft, alongside the regeneration rate. VF³⁷ AJ

Budgets need teeth. The FinOps Foundation puts it plainly: a budget without a quota is a number, not a control. Every cap needs an enforcement point that fails closed, so a runaway agent loop stops itself long before the invoice arrives. VF³⁸ Rec

³⁷ Verified fact — A5-S011: Pricing - Claude API Docs (Anthropic)

<https://platform.claude.com/docs/en/about-claude/pricing> accessed 2026-10-07; A5-S004: OpenAI API Pricing (and Introducing GPT-6 Sol and Luna pricing) <https://developers.openai.com/api/docs/pricing> accessed 2026-10-07 [search-tool extract]

³⁸ Verified fact — A7-S115: FinOps Framework 2026; State of FinOps 2026; FinOps for AI technology category; Tokenomics working group; Who sets the AI budget? (FinOps Foundation) <https://www.finops.org/insights/2026-finops-framework/> accessed 2026-10-07 [search-tool extract]

2. Cost per task, not cost per token

The leadership move is to send cost optimisations through the same change control and evaluation gate as any other change. ^{Rec}

The honest caveat: the open billing standard does not yet have a first-class column for input and output tokens, so part of the mapping is still the firm's own. ^{VF}³⁹

What a task costs is a design question. The invoice only reports the answer. ^{AI}

³⁹ Verified fact — V2-S046: FOCUS 1.5 Release Scope: Confirmed and Stretch Features (with Introducing FOCUS 1.4; FOCUS for AI) (FinOps Foundation (FOCUS)) <https://focus.finops.org/focus-1-5-release-scope/> accessed 2026-10-08 [search-tool extract]; A7-S116: FOCUS 1.5 Release Scope; FOCUS for AI; Introducing FOCUS 1.2; Introducing FOCUS 1.4 (FinOps Foundation (FOCUS)) <https://focus.finops.org/focus-1-5-release-scope/> accessed 2026-10-07 [search-tool extract]



provisioned capacity, it can grow by orders of magnitude when an agent loops, and prices change quickly ^{AJ}. The discipline has caught up with that. The FinOps Foundation's State of FinOps 2026 reports that 98% of respondents now manage AI spend, and that FinOps for AI is the top forward-looking priority ^{vi40}.

The unit is the task. For a multi-step agent, the cost of one task is the sum of every planning call, tool-result summary, retry, evaluation-judge call and regeneration after a reviewer rejects a draft ^{AJ}. A price list cannot see any of that. Only the trace, which groups the calls that make up one task and records its outcome, can assemble the true cost ^{AJ}. That is why a cheaper token that needs three retries and a longer review is not cheaper.

The mechanics have five stages: meter, attribute, reconcile, enforce and optimise

^{AJ}.

Meter at the gateway. The measurement point has settled on the gateway, because every model call passes through it. LiteLLM, Cloudflare AI Gateway, Azure API Management, Apigee and Kong all now ship budgets, rate limits or spend tracking per key, team or user ^{vi41}. Give each use case its own virtual key, and tag each request with the run ID ^{AJ}. Shared keys destroy attribution ^{AJ}.

Attribute to tasks. The gateway knows the tokens per call; the evaluation and observability platform knows which calls form a task and whether the task was approved, edited or rejected ^{AJ}. Join them on the run ID and you have cost per completed task and cost per approved output ^{AJ}.

Reconcile with the provider and the cloud. Gateway prices are estimates from a price table, and invoices are the truth ^{AJ}. Each route has its own reconciliation source. Anthropic's Usage and Cost Admin API reports usage by key, workspace and

⁴⁰ Verified fact — A7-S115: FinOps Framework 2026; State of FinOps 2026; FinOps for AI technology category; Tokenomics working group; Who sets the AI budget? (FinOps Foundation) <https://www.finops.org/insights/2026-finops-framework/> accessed 2026-10-07 [search-tool extract]

⁴¹ Verified fact — A6-S015: LiteLLM docs: MCP Overview, Agent Gateway (A2A), Caching, Budgets/Rate Limits, v1.89.0 release notes (BerriAI (LiteLLM)) <https://docs.litellm.ai/docs/mcp> accessed 2026-10-07 [search-tool extract]; A6-S019: Cloudflare AI Gateway docs: Pricing, Features, Changelog; Cloudflare blog spend limits (Cloudflare, Inc.) <https://developers.cloudflare.com/ai-gateway/reference/pricing/> accessed 2026-10-07 [search-tool extract]; A6-S053: AI gateway capabilities in Azure API Management (Microsoft Learn source, ms.date 29 May 2026) <https://raw.githubusercontent.com/MicrosoftDocs/azure-docs/main/articles/api-management/genai-gateway-capabilities.md> accessed 2026-10-07; A6-S024: Apigee AI solutions: gateway to enterprise-ready AI (Google Cloud) <https://cloud.google.com/solutions/apigee-ai> accessed 2026-10-07; A6-S016: Kong AI Gateway 2.0 Is Now GA — And It's Already Moving Faster (Kong Inc.) <https://konghq.com/blog/product-releases/kong-ai-gateway-2-0-ga> accessed 2026-10-07 [search-tool extract]

model and separates cached from uncached input ^{vr42}. Amazon Bedrock carries cost-allocation tags through application inference profiles, though only per usage type per day ^{vr43}. Microsoft Foundry tags each project's usage automatically, in preview ^{vr44}. Whichever routes a firm uses, one adapter per provider is enough ^{AI}.

Normalise to an open schema. FOCUS, the FinOps Foundation's open billing specification, is the natural shape for the firm's own dataset. FOCUS 1.4 was ratified on 4 June 2026; FOCUS 1.5 adds model-identity properties, and a first-class token-type column has been deferred ^{vr45}. That deferral is the caveat in the post: part of the mapping is still the firm's own ^{AI}.

Enforce, at three levels. Per run, as step and token ceilings in the workflow; per key, as gateway budgets and rate limits; and per month, as a financial budget with alerts ^{AI}. The FinOps Foundation's guidance is to measure for 30 to 60 days, budget at 110% to 120% of that baseline, and alert at 80% and 100%; it adds that "a budget without a quota is a number, not a control" ^{vr46}. The fail-closed point is not academic. In LiteLLM, `max_budget` does not enforce without a database, and the proxy admin key bypasses budget checks ^{vr47}. Every gateway has details like these. Test the budget by exceeding it in a test environment and confirming that requests are refused ^{Rec}.

The worked example's arithmetic. The review's illustrative cost model assumes about 40,000 input tokens and 3,000 output tokens per draft commentary ^{AI}. At

⁴² Verified fact — A7-S070: Usage and Cost Admin API (Claude Platform docs) (Anthropic) <https://platform.claude.com/docs/en/manage-claude/usage-cost-api> accessed 2026-10-07

⁴³ Verified fact — B-C6-S004: Amazon Bedrock user guide: Application inference profiles; Best practices for cost attribution (Amazon Web Services) <https://docs.aws.amazon.com/bedrock/latest/userguide/cost-mgmt-application-inference-profiles.html> accessed 2026-10-08 [search-tool extract]

⁴⁴ Verified fact — B-C6-S005: Plan and manage costs - Microsoft Foundry <https://learn.microsoft.com/en-us/azure/foundry/concepts/manage-costs> accessed 2026-10-08 [search-tool extract]

⁴⁵ Verified fact — V2-S046: FOCUS 1.5 Release Scope: Confirmed and Stretch Features (with Introducing FOCUS 1.4; FOCUS for AI) (FinOps Foundation (FOCUS)) <https://focus.finops.org/focus-1-5-release-scope/> accessed 2026-10-08 [search-tool extract]; A7-S116: FOCUS 1.5 Release Scope; FOCUS for AI; Introducing FOCUS 1.2; Introducing FOCUS 1.4 (FinOps Foundation (FOCUS)) <https://focus.finops.org/focus-1-5-release-scope/> accessed 2026-10-07 [search-tool extract]

⁴⁶ Verified fact — A7-S115: FinOps Framework 2026; State of FinOps 2026; FinOps for AI technology category; Tokenomics working group; Who sets the AI budget? (FinOps Foundation) <https://www.finops.org/insights/2026-finops-framework/> accessed 2026-10-07 [search-tool extract]

⁴⁷ Verified fact — A6-S015: LiteLLM docs: MCP Overview, Agent Gateway (A2A), Caching, Budgets/Rate Limits, v1.89.0 release notes (BerriAI (LiteLLM)) <https://docs.litellm.ai/docs/mcp> accessed 2026-10-07 [search-tool extract]

US\$2 and US\$10 per million tokens, which as of 7 October 2026 was the list price of both Claude Sonnet 5.5 and OpenAI's gpt-6.1-sol, one draft costs about US\$0.11⁴⁸. With an average of 2.5 drafts per approved commentary and a few small-model judge calls, the token cost is roughly US\$0.30 per approved commentary, or about US\$12 a month for 40 funds^{AJ}. The assumptions are the review's own. The conclusion is robust to them: tokens are not the cost driver here, reviewer time is, so the regeneration and edit rate is the number to watch^{AJ}.

Optimisation is a model change. The levers are real. Batch APIs from OpenAI and Anthropic are 50% off list price, and month-end drafting reviewed the next morning is a batch workload⁴⁹^{AJ}. Within one range, OpenAI's small Luna tier lists at US\$0.10 per million input tokens against US\$10 for Astra⁵⁰. But routing a step to a cheaper model, trimming the context or turning on a cache changes the system's behaviour^{AJ}. PRA SS1/23 covers vendor models used to inform business decisions⁵¹, so a cost-driven change belongs in the same change control and evaluation gate as any other change^{Rec}. One lever is ruled out: a semantic cache that returns an answer to a *similar* question can serve last month's narrative, which is unacceptable for regulated outputs^{AJ}.

Budgets are also a resilience control. A runaway agent can exhaust a shared provider rate limit and starve a client-facing service on the same account^{AJ}. Separate keys and limits per important business service prevent that^{Rec}. Spend per provider also feeds the DORA register of information and, from 18 March 2027, the UK's material third-party notifications⁵².

⁴⁸ Verified fact — A5-S011: Pricing - Claude API Docs (Anthropic) <https://platform.claude.com/docs/en/about-claude/pricing> accessed 2026-10-07; A5-S004: OpenAI API Pricing (and Introducing GPT-6 Sol and Luna pricing) <https://developers.openai.com/api/docs/pricing> accessed 2026-10-07 [search-tool extract]

⁴⁹ Verified fact — A5-S011: Pricing - Claude API Docs (Anthropic) <https://platform.claude.com/docs/en/about-claude/pricing> accessed 2026-10-07; A5-S004: OpenAI API Pricing (and Introducing GPT-6 Sol and Luna pricing) <https://developers.openai.com/api/docs/pricing> accessed 2026-10-07 [search-tool extract]

⁵⁰ Verified fact — A5-S004: OpenAI API Pricing (and Introducing GPT-6 Sol and Luna pricing) <https://developers.openai.com/api/docs/pricing> accessed 2026-10-07 [search-tool extract]

⁵¹ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 'Model risk management principles for banks' (published with PS6/23) (see regulatory_facts.json); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]; A8-S037: Bank of England/PRA letter to DSIT and HMT on AI (2024) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/letter/2024/dsit-hmt-letter.pdf> accessed 2026-10-07 [search-tool extract]

Tools, in their place. Vantage and CloudZero have added AI-provider integrations, described mainly in their own blog posts⁵³. They are useful reporting layers, fed from the firm's dataset, not the record itself^{Rec}. Helicone, which combined a gateway with cost tracking, was acquired by Mintlify and is in maintenance mode⁵⁴. This is quiet work, and it rewards the platform and finance colleagues who build the joins, because without them nobody can say what a task costs.

What good looks like

The signal is **cost per approved output**: all model, judge and tool-call cost for a task, including every failed and regenerated attempt, divided by the number of outputs a human approved^{AJ}. Report it alongside the **regeneration rate**, the number of drafts per approved output, because that is where the real cost hides^{AJ}.

Measure it by joining gateway records to traces on the run ID, and reconcile the total each month to provider usage data and cloud bills^{AJ}.

The review's target guidance is a figure set per use case, compared with the cost of the manual process it replaces, and falling at constant quality^{AJ}. Three supporting measures make the number trustworthy: attribution coverage of at least 98% of AI spend; reconciliation to invoices within plus or minus 2% a month; and 100% of production keys with a budget and rate limit tested to fail closed^{AJ}. These are a starting point, not a benchmark^{AJ}.

⁵² Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see regulatory_facts.json); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]; R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see regulatory_facts.json); R-FCA-SYSC8: FCA Handbook SYSC 8 (Outsourcing); FG16/5 'Guidance for firms outsourcing to the cloud and other third-party IT services'; PS26/2 operational incident and third-party reporting (see regulatory_facts.json); A8-S062: PS7/26 Operational incident and third-party reporting (PRA) and FCA PS26/2; revised SS2/21 (March 2026) (Bank of England / PRA; FCA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2026/march/operational-incident-and-third-party-reporting-policy-statement> accessed 2026-10-07 [search-tool extract]

⁵³ Verified fact — A7-S113: Vantage blog: Managed AI Tags; Support for Anthropic Costs; Support for Claude Enterprise Costs; OpenAI cost tools <https://www.vantage.sh/blog/managed-ai-tags> accessed 2026-10-07 [search-tool extract]; A7-S114: CloudZero blog posts on AI cost (token-based pricing, Bedrock, Anthropic, Azure OpenAI) <https://www.cloudzero.com/blog/token-based-pricing/> accessed 2026-10-07 [search-tool extract]

⁵⁴ Verified fact — A7-S112: Helicone Blog: Helicone acquired by Mintlify (and Mintlify announcement) (Helicone / Mintlify) <https://www.helicone.ai/blog> accessed 2026-10-07 [search-tool extract]; V2-S043: Helicone Joins Mintlify (with mintlify.com 'Mintlify acquires Helicone'; PostHog comparison) (Helicone / Mintlify) <https://www.helicone.ai/blog/joining-mintlify> accessed 2026-10-08 [search-tool extract]

In the worked example

Step 2: cost. A run ID on every call, tagged with use case and fund, joined to the trace; a monthly budget set from two month-end cycles; a per-run ceiling on model calls and tokens. ^{AJ}

- **Now works:** Cost is reported per approved commentary and per fund, not per token. ^{AJ}
- **Must never:** A runaway loop fails the run instead of the budget. ^{AJ}
- **Evidence added:** Token counts and cost per draft, including regenerations. ^{AJ}
- **Signal:** Cost per approved commentary, with the regeneration rate beside it. ^{AJ}

Objections worth taking seriously

“The token bill is tiny. Why build all this?” In the worked example it is tiny, and that is the point ^{AJ}. The machinery is not there to save tokens. It is there to show where the cost actually sits, to stop a runaway loop within an hour rather than at the invoice, and to give the risk committee spend by provider for concentration and exit sizing ^{AJ}. A small bill with no enforcement is still an unbounded one. The same data also exposes waste early: the FinOps Foundation lists retry rate and tool calls per task as diagnostics, and both are signs of a workflow going wrong before they are signs of a cost problem ^{VF⁵⁵ AJ}.

“We already have a FinOps platform. Let it do this.” Use it, as a reporting layer fed from the firm’s own FOCUS-shaped dataset, so that replacing the tool never means losing the history ^{Rec}. Two cautions apply. Allocation rules held only in a proprietary engine are finance policy the firm cannot export ^{AJ}. And a cost tool that holds a provider admin key with read-write access is a privileged-access risk, so grant the least privilege the provider allows ^{VF⁵⁶ Rec}.

“A fail-closed budget could stop a critical service at month-end.” It could, if it is sized badly or shared ^{AJ}. The answer is separate keys and limits per service, budgets sized from measured peaks, alerts at 80% so humans act first, and a defined degraded mode ^{Rec}. The alternative, a budget that alerts but never blocks, protects nothing when it matters ^{AJ}.

⁵⁵ Verified fact — A7-S115: FinOps Framework 2026; State of FinOps 2026; FinOps for AI technology category; Tokenomics working group; Who sets the AI budget? (FinOps Foundation) <https://www.finops.org/insights/2026-finops-framework/> accessed 2026-10-07 [search-tool extract]

⁵⁶ Verified fact — A7-S113: Vantage blog: Managed AI Tags; Support for Anthropic Costs; Support for Claude Enterprise Costs; OpenAI cost tools <https://www.vantage.sh/blog/managed-ai-tags> accessed 2026-10-07 [search-tool extract]

Questions for your team

- Can we state the fully loaded cost of one approved output for our largest GenAI use case, including regenerations? Rec
- Does every production use case have its own key, or do several share one? Rec
- When did we last test that a gateway budget actually refuses requests once exceeded? Rec
- Where is the step or token ceiling that would stop an agent loop within an hour? Rec
- Does our last cost-saving change have an evaluation result attached to it? Rec
- Who reconciles gateway-metered cost against provider invoices, and what was last month's variance? Rec

In one line

What a task costs is decided in the design, and the invoice only reports the answer

3. Self-hosting is a capacity decision, not just cost

L2 Inference, serving and model access, from Post 3 of the series.

The post

Self-hosting a model is a capacity and operating-model decision. It is only partly a cost decision. ^{AJ}

The usual case for it is a spreadsheet: GPU hours against per-token prices. What the spreadsheet leaves out is the team that patches inference engines monthly, runs on-call, keeps weights scanned and pinned, and re-qualifies every change of engine version or quantisation, because each of those can change outputs. ^{VF⁵⁷ AJ}

Inference is really three jobs: serving engines that run the model, an optional optimisation layer for firms with their own GPU fleets, and model access through managed services. For regulated workloads the sensible default is managed access in an approved region, through the cloud estate already in place, called only through the firm's gateway. A private open-weight route earns its place where capacity, residency or exit planning justify it. ^{VF⁵⁸ Rec}

Two details catch people out. Where a prompt is processed is a property of the endpoint, not the model: the same model can run in one geography or anywhere, depending on the deployment type. And overflow from reserved capacity can silently cross a residency boundary if the default allows it. ^{VF⁵⁹}

⁵⁷ Verified fact — A4-S009: PyPI JSON metadata: vllm (Python Package Index) <https://pypi.org/pypi/vllm/json> accessed 2026-10-07; B-L2-S004: Security Advisories - vllm-project/vllm (vLLM project (GitHub)) <https://github.com/vllm-project/vllm/security/advisories> accessed 2026-10-08 [search-tool extract]

⁵⁸ Verified fact — A4-S090: NVIDIA Dynamo README (GitHub) <https://raw.githubusercontent.com/ai-dynamo/dynamo/main/README.md> accessed 2026-10-07; A4-S089: llm-d README (GitHub) (llm-d project) <https://raw.githubusercontent.com/llm-d/llm-d/main/README.md> accessed 2026-10-07

⁵⁹ Verified fact — B-L2-S006: Understanding deployment types in Microsoft Foundry Models <https://learn.microsoft.com/en-us/azure/foundry/foundry-models/concepts/deployment-types> accessed 2026-10-08

Part II: Nine layers and the controls that make them safe

The signal is capacity headroom at peak: reserved throughput minus observed demand in the month-end window, when every fund's draft is requested at once. It should be positive, with a margin, before go-live. ^{AJ}

The leadership move is to write the peak, the reserved amount, the overflow behaviour and the degraded mode into one capacity plan. ^{Rec}

The honest caveat: managed access concentrates dependence on one cloud. The answer is a small portfolio, the primary cloud's service plus one qualified second route, not a retreat into running everything yourself. ^{AJ}

The cheapest token is irrelevant if it arrives late, or in the wrong country. ^{AJ}

[search-tool extract]; B-L2-S008: Data residency (with Deployments and endpoints; Single Zone Provisioned Throughput) - Vertex AI (Google Cloud) <https://docs.cloud.google.com/vertex-ai/generative-ai/docs/learn/data-residency> accessed 2026-10-08 [search-tool extract]

3. Self-hosting is a capacity decision, not just cost

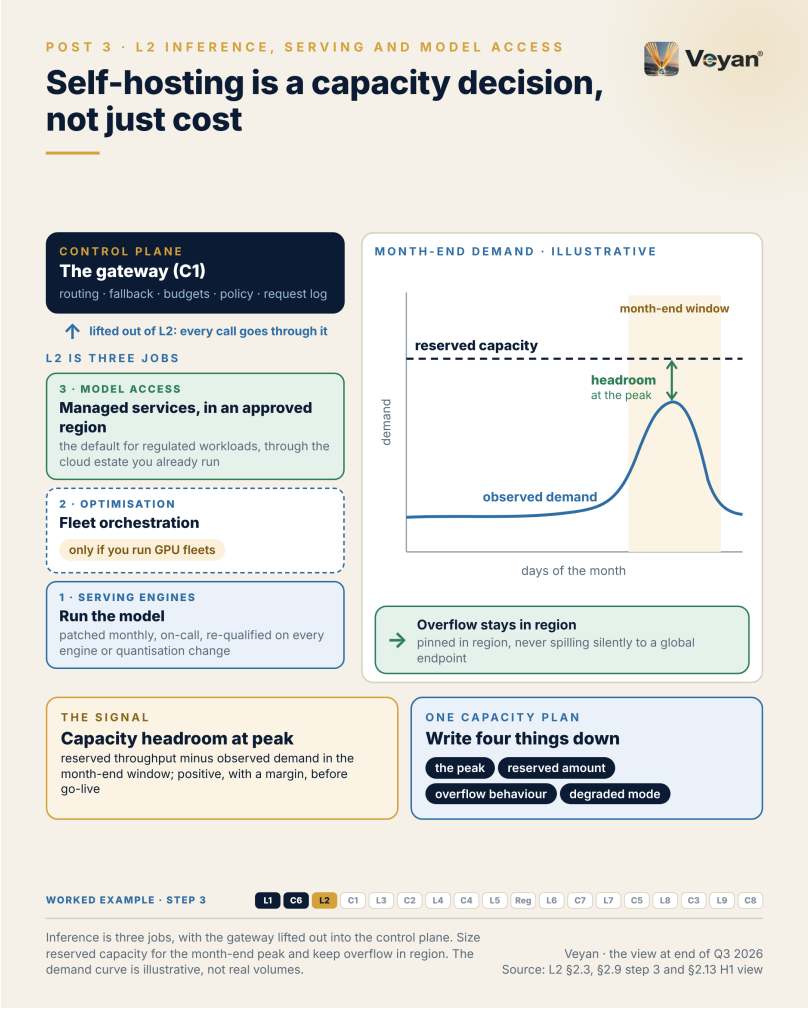


Figure 3. Inference is three jobs, with the gateway lifted out into the control plane. Size reserved capacity for the month-end peak and keep overflow in region. The demand curve is illustrative, not real volumes. ^{AJ}

Behind the post

The popular picture of the stack draws inference as one box. The review found three distinct jobs inside it, each with its own risks and its own owner ^{AJ}.

Three jobs, not one. *Serving engines* run the model: vLLM, which is Apache-2.0 and has been hosted by the PyTorch Foundation since May 2025, and SGLang, also Apache-2.0⁶⁰. *Inference optimisation* sits above the engines and coordinates fleets of them: NVIDIA Dynamo calls itself “the orchestration layer above inference engines”, and llm-d provides orchestration “above model servers”⁶¹. *Model access* is someone else’s served model under a contract: managed inference clouds, routers and the hyperscalers’ own model services⁶². The review’s verdict was that model access is the sub-layer most firms will actually operate; serving engines matter only where a private route is justified, and the optimisation layer is relevant only to firms running their own GPU fleets⁶³. Routing, fallback, budgets and the request log leave this layer altogether and move to the gateway, the subject of Chapter 4⁶⁴.

What the spreadsheet leaves out. The case for self-hosting is usually a comparison of GPU hours with token prices. It omits the operating model. vLLM shipped 28 releases in 2026⁶⁵. It also published advisories in which a malicious model repository or crafted input could execute code, including a critical one fixed from

⁶⁰ Verified fact — A4-S009: PyPI JSON metadata: vllm (Python Package Index) <https://pypi.org/pypi/vllm/json> accessed 2026-10-07; A4-S146: PyTorch Foundation Welcomes vLLM as a Hosted Project (and umbrella-foundation press release, 7 May 2025) (PyTorch Foundation (Linux Foundation)) <https://pytorch.org/blog/pytorch-foundation-welcomes-vllm/> accessed 2026-10-07 [search-tool extract]; A4-S010: PyPI JSON metadata: sglang (Python Package Index) <https://pypi.org/pypi/sglang/json> accessed 2026-10-07; A4-S147: RadixArk Launches with \$100 Million in Seed Funding Led by Accel to Grow SGLang (Business Wire, May 2026) (RadixArk (Business Wire)) <https://www.morningstar.com/news/business-wire/20260505077157/radixark-launches-with-100-million-in-seed-funding-led-by-accel-to-grow-sglang-and-democratize-frontier-ai-infrastructure> accessed 2026-10-07 [search-tool extract]

⁶¹ Verified fact — A4-S090: NVIDIA Dynamo README (GitHub) <https://raw.githubusercontent.com/ai-dynamo/dynamo/main/README.md> accessed 2026-10-07; A4-S089: llm-d README (GitHub) (llm-d project) <https://raw.githubusercontent.com/llm-d/llm-d/main/README.md> accessed 2026-10-07

⁶² Verified fact — A4-S131: Pricing - Together AI docs (serverless, dedicated endpoints, GPU clusters) <https://docs.together.ai/docs/inference/pricing> accessed 2026-10-07 [search-tool extract]; A4-S135: Fireworks - Pricing (and Serverless Pricing docs) (Fireworks AI) <https://fireworks.ai/pricing> accessed 2026-10-07 [search-tool extract]; A4-S139: Pricing - Build with Cerebras Inference (Cerebras Systems) <https://inference-docs.cerebras.ai/support/pricing> accessed 2026-10-07 [search-tool extract]; A4-S081: About Inference Endpoints (Hugging Face) <https://raw.githubusercontent.com/huggingface/hf-endpoints-documentation/main/docs/source/about.md> accessed 2026-10-07; A4-S111: OpenRouter Docs: Guardrails <https://raw.githubusercontent.com/OpenRouterTeam/docs/main/guides/features/guardrails.mdx> accessed 2026-10-07; A4-S075: Hugging Face Inference Providers <https://raw.githubusercontent.com/huggingface/hub-docs/main/docs/inference-providers/index.md> accessed 2026-10-07; A5-S010: Models overview - Claude API Docs (Anthropic) <https://platform.claude.com/docs/en/models/overview> accessed 2026-10-07

⁶³ Verified fact — A4-S009: PyPI JSON metadata: vllm (Python Package Index) <https://pypi.org/pypi/vllm/json> accessed 2026-10-07

3. Self-hosting is a capacity decision, not just cost

version 0.14.1⁶⁴. SGLang's critical CVE-2026-3059 allowed unauthenticated code execution in versions up to 0.5.9⁶⁵. Someone has to patch, scan weights, run on-call for accelerators and forecast peaks^{AI}. And every change of engine version or quantisation level is a change to the numerical system that produced the validated output, so it needs re-qualification^{AI}. None of that is a reason not to self-host. It is the reason to call self-hosting what it is: a capacity and operating-model decision^{AI}.

Two less obvious duties come with a private route. Running an open-weight model at FP8 or INT4 on vLLM⁶⁶ produces a different numerical system from the provider's reference, so the quantisation level belongs in the model inventory^{Rec}. And the caches that make engines fast hold prompt state. Shared prefix caches and tiered key-value stores, such as those in LMCache, Dynamo and llm-d, can carry one request's context into another's memory or storage⁶⁷. Partition them by tenant or data class, encrypt the offload tiers, and bring them into retention scope^{Rec}.

Processing location belongs to the endpoint. This is the detail that catches people out. On Microsoft Foundry, Global deployments may process prompts in any geography, while Data Zone deployments process only within the US or EU zone⁶⁸. On Amazon Bedrock, a geographic profile keeps EU-originated requests within EU regions, and CloudTrail records the region that actually processed each request⁶⁹. On Google Cloud, regional endpoints keep processing within a jurisdiction, while

⁶⁴ Verified fact — B-L2-S004: Security Advisories - vllm-project/vllm (vLLM project (GitHub)) <https://github.com/vllm-project/vllm/security/advisories> accessed 2026-10-08 [search-tool extract]

⁶⁵ Verified fact — B-L2-S009: SGLang multimodal generation module unauthenticated RCE via ZMQ broker (CVE-2026-3059) - GitHub Advisory Database <https://github.com/advisories/GHSA-rgq9-fqf5-fv58> accessed 2026-10-08 [search-tool extract]; B-REVC-S002: NVD CVE-2026-3059 (with OSV and GitHub Advisory Database GHSA-rgq9-fqf5-fv58) (NIST NVD) <https://nvd.nist.gov/vuln/detail/CVE-2026-3059> accessed 2026-10-08 [search-tool extract]

⁶⁶ Verified fact — A4-S063: vLLM README (GitHub) (vLLM project) <https://raw.githubusercontent.com/vllm-project/vllm/main/README.md> accessed 2026-10-07

⁶⁷ Verified fact — A4-S091: LMCache README (GitHub) (LMCache project) <https://raw.githubusercontent.com/LMCache/LMCache/dev/README.md> accessed 2026-10-07; A4-S090: NVIDIA Dynamo README (GitHub) <https://raw.githubusercontent.com/ai-dynamo/dynamo/main/README.md> accessed 2026-10-07; A4-S089: llm-d README (GitHub) (llm-d project) <https://raw.githubusercontent.com/llm-d/llm-d/main/README.md> accessed 2026-10-07

⁶⁸ Verified fact — B-L2-S006: Understanding deployment types in Microsoft Foundry Models <https://learn.microsoft.com/en-us/azure/foundry/foundry-models/concepts/deployment-types> accessed 2026-10-08 [search-tool extract]

⁶⁹ Verified fact — B-L2-S005: Geographic cross-Region inference - Amazon Bedrock (Amazon Web Services) <https://docs.aws.amazon.com/bedrock/latest/userguide/geographic-cross-region-inference.html> accessed 2026-10-08 [search-tool extract]

the global endpoint gives no residency guarantee ^{vf70}. Storage residency and processing residency are different promises: OpenAI's UK endpoint, for instance, provides storage only, with no UK processing ^{vf71}. Contracts and configurations should name processing location, not only storage location ^{Rec}.

There is a UK-specific wrinkle. Bedrock's EU profile does not route EU-originated requests to London, and London-originated requests can route to EU regions ^{vf72}. A firm that needs UK-only processing has to check per model whether an in-region London option exists ^{Rec}.

Overflow is a residency decision. On Vertex AI, traffic above a Provisioned Throughput quota goes to the global endpoint by default unless overridden ^{vf73}. The Single Zone variant keeps overflow in the purchased region, but is excluded from the Gemini online inference SLA ^{vf74}. For each route, decide which property matters more, residency or the SLA, and write it down ^{AJ}.

Defaults, not just options. Provider defaults differ. Together AI stores prompts and responses unless zero data retention is switched on ^{vf75}. Fireworks has zero data retention on by default for open models, except its Response API, which stores conversations for 30 days unless told not to ^{vf76}. Record the retention setting per route ^{Rec}.

⁷⁰ Verified fact — B-L2-S008: Data residency (with Deployments and endpoints; Single Zone Provisioned Throughput) - Vertex AI (Google Cloud) <https://docs.cloud.google.com/vertex-ai/generative-ai/docs/learn/data-residency> accessed 2026-10-08 [search-tool extract]

⁷¹ Verified fact — V2-S079: Data controls in the OpenAI platform (with help article 'Data residency for the OpenAI API'; 'Expanding data residency access') <https://developers.openai.com/api/docs/guides/your-data> accessed 2026-10-08 [search-tool extract]

⁷² Verified fact — B-L2-S005: Geographic cross-Region inference - Amazon Bedrock (Amazon Web Services) <https://docs.aws.amazon.com/bedrock/latest/userguide/geographic-cross-region-inference.html> accessed 2026-10-08 [search-tool extract]

⁷³ Verified fact — B-L2-S008: Data residency (with Deployments and endpoints; Single Zone Provisioned Throughput) - Vertex AI (Google Cloud) <https://docs.cloud.google.com/vertex-ai/generative-ai/docs/learn/data-residency> accessed 2026-10-08 [search-tool extract]

⁷⁴ Verified fact — B-L2-S008: Data residency (with Deployments and endpoints; Single Zone Provisioned Throughput) - Vertex AI (Google Cloud) <https://docs.cloud.google.com/vertex-ai/generative-ai/docs/learn/data-residency> accessed 2026-10-08 [search-tool extract]

⁷⁵ Verified fact — A4-S130: Zero data retention / Privacy and security - Together AI docs (and EU data centers support article) <https://docs.together.ai/docs/zero-data-retention> accessed 2026-10-07 [search-tool extract]

⁷⁶ Verified fact — A4-S134: Zero Data Retention / Data residency / Regions - Fireworks AI Docs https://docs.fireworks.ai/guides/security_compliance/data_handling accessed 2026-10-07 [search-tool extract]

Capacity is a resilience issue. Serverless per-token tiers carry no reserved capacity, and Together AI's serverless tier has no SLA, while its provisioned tier does⁷⁷. All three hyperscalers sell reserved or provisioned capacity⁷⁸. In the worked example, every fund's draft is requested in a narrow window after the attribution runs complete, so capacity must be sized for that peak, rehearsed in the month before go-live, and backed by batch processing for non-urgent regeneration^{79c}.

Why managed access is the default. The DORA critical-provider list and the UK critical third-party designations include AWS, Google Cloud and Microsoft, and no AI model provider⁷⁹. Consuming a model through the primary cloud therefore places inference inside an already-overseen, already-contracted relationship; a direct contract with an inference cloud or router does not⁸⁰. Ownership is also moving among access providers: Stripe agreed to acquire OpenRouter, with closing pending⁸¹. From 18 March 2027 a new material provider needs UK notification lead time⁸¹.

⁷⁷ Verified fact — A4-S131: Pricing - Together AI docs (serverless, dedicated endpoints, GPU clusters) <https://docs.together.ai/docs/inference/pricing> accessed 2026-10-07 [search-tool extract]

⁷⁸ Verified fact — B-L2-S006: Understanding deployment types in Microsoft Foundry Models <https://learn.microsoft.com/en-us/azure/foundry/foundry-models/concepts/deployment-types> accessed 2026-10-08 [search-tool extract]; B-L2-S008: Data residency (with Deployments and endpoints; Single Zone Provisioned Throughput) - Vertex AI (Google Cloud) <https://docs.cloud.google.com/vertex-ai/generative-ai/docs/learn/data-residency> accessed 2026-10-08 [search-tool extract]; B-L2-S005: Geographic cross-Region inference - Amazon Bedrock (Amazon Web Services) <https://docs.aws.amazon.com/bedrock/latest/userguide/geographic-cross-region-inference.html> accessed 2026-10-08 [search-tool extract]

⁷⁹ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see regulatory_facts.json); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]; R-UK-CTP: UK Critical Third Parties regime (FSMA 2023 / FSMA 2000 s312L; PRA/FCA/BoE CTP rules) and the Critical Third Parties (Designation) Regulations 2026 (SI 2026/777) (see regulatory_facts.json); A8-S023: The Critical Third Parties (Designation) Regulations 2026 (SI 2026/777); BoE/FCA/HMT announcements (HM Treasury / legislation.gov.uk / Bank of England) <https://www.legislation.gov.uk/uksi/2026/777/made> accessed 2026-10-07 [search-tool extract]

⁸⁰ Verified fact — V1-S059: Stripe agrees to acquire OpenRouter to help businesses optimize token routing and usage <https://stripe.com/newsroom/news/stripe-agrees-to-acquire-openrouter> accessed 2026-10-08 [search-tool extract]; V1-S060: Stripe to buy OpenRouter as fintech expands deeper into AI (and TechCrunch 16 Aug 2026 report) (CNBC / TechCrunch) <https://www.cnbc.com/2026/08/19/stripe-openrouter-fintech-ai-model-marketplace-.html> accessed 2026-10-08 [search-tool extract]

⁸¹ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see regulatory_facts.json); R-FCA-SYSC8: FCA Handbook SYSC 8 (Outsourcing); FG16/5 'Guidance for firms outsourcing to the cloud and other third-party IT services'; PS26/2 operational incident and third-party reporting (see regulatory_facts.json); A8-S062: PS7/26 Operational incident and third-party reporting (PRA) and FCA PS26/2; revised SS2/21 (March 2026) (Bank of England / PRA; FCA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2026/march/operational-incident-and-third-party-reporting-policy-statement> accessed 2026-10-07 [search-tool extract]

The stressed exit. PRA SS2/21 expects documented and tested exit plans, including a stressed exit ⁸². In this layer, the credible stressed-exit route is an open-weight model already qualified on a portable engine such as vLLM, switched by gateway configuration ^{AJ}. An exit plan that names a second provider but has never been drilled is not tested ^{AJ}. Capacity plans are rarely celebrated. The site reliability engineers who see the month-end peak coming deserve more credit than they usually get.

What good looks like

The signal is **capacity headroom at peak**: reserved or provisioned throughput minus observed demand in the busiest window, for this example the month-end hours when every fund's draft is requested at once ^{AJ}.

Measure it by comparing the capacity plan with peak-hour metrics from the gateway, and rehearse the peak before go-live rather than discovering it in production ⁸³. Re-measure after each month-end, because the number of funds, and so the peak, tends to grow faster than the reservation ^{AJ}.

The review's target guidance is positive headroom at the forecast peak plus a margin, before go-live ^{AJ}. Three companions complete the picture. The throttle rate on reserved routes should be near zero, with an alert on any sustained rate ^{AJ}. The in-region processing rate for client-data routes should be 100%, evidenced per call from records such as Bedrock's processing-region field ⁸³ ^{AJ}. And the exit drill, moving a route to the qualified alternative, should take hours, by configuration only ^{AJ}. These are a starting point, not a benchmark ^{AJ}.

In the worked example

Step 3: model access. Drafting through the primary cloud's in-region model service, with capacity sized for the month-end peak and an open-weight route kept ready as the stressed exit. ^{AJ}

- **Now works:** Every fund's draft can be produced in the narrow month-end window. ^{AJ}

⁸² Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see `regulatory_facts.json`); A8-S048: SS2/21 Outsourcing and third party risk management (and PS7/26, March 2026) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2021/ss221-march-21.pdf> accessed 2026-10-07 [search-tool extract]

⁸³ Verified fact — B-L2-S005: Geographic cross-Region inference - Amazon Bedrock (Amazon Web Services) <https://docs.aws.amazon.com/bedrock/latest/userguide/geographic-cross-region-inference.html> accessed 2026-10-08 [search-tool extract]

3. Self-hosting is a capacity decision, not just cost

- **Must never:** No router or provider that cannot guarantee region and retention. ^{AJ}
- **Evidence added:** Endpoint, region, retention setting and fallback flag per call. ^{AJ}
- **Signal:** Capacity headroom at the month-end peak. ^{AJ}

Objections worth taking seriously

“At our volume, self-hosting is simply cheaper.” It may be. But compare like with like. Pricing units differ: per million tokens, per replica-minute, per GPU-second and per instance-minute ^{vr84}. Model the cost at forecast utilisation, including idle reserved capacity and the staff who patch and run the engines ^{rec}. If the case still holds, self-host. Just do it for capacity, residency or exit reasons you can name ^{AJ}.

“Managed access just moves our concentration to one cloud.” It does, and the post says so ^{AJ}. The concentration runs deeper still: most self-hosted and many managed routes depend on one GPU vendor ^{vr85}. The answer is a small portfolio, the primary cloud’s service plus one qualified second route, not running everything in-house ^{rec}. Retreating into a private estate swaps a concentration the supervisors already oversee for operational risks the firm carries alone ^{AJ}.

“A router gives us every provider through one contract.” Convenient, but it puts a third party between the firm and its model providers, and adds fees: OpenRouter charges 5.5% on credit purchases ^{vr86}. Use a router only behind the firm’s gateway, never as the gateway, and never for client data without contractual zero retention and residency ^{rec}. If a router is used, it should fail rather than fall back out of region; OpenRouter’s in-region routing behaves that way ^{vr87}. Every router or inference

⁸⁴ Verified fact — A4-S131: Pricing - Together AI docs (serverless, dedicated endpoints, GPU clusters) <https://docs.together.ai/docs/inference/pricing> accessed 2026-10-07 [search-tool extract]; A4-S135: Fireworks - Pricing (and Serverless Pricing docs) (Fireworks AI) <https://fireworks.ai/pricing> accessed 2026-10-07 [search-tool extract]; A4-S139: Pricing - Build with Cerebras Inference (Cerebras Systems) <https://inference-docs.cerebras.ai/support/pricing> accessed 2026-10-07 [search-tool extract]; A4-S083: Inference Endpoints Pricing (Hugging Face) <https://raw.githubusercontent.com/huggingface/hf-endpoints-documentation/main/docs/source/support/pricing.md> accessed 2026-10-07

⁸⁵ Verified fact — A4-S090: NVIDIA Dynamo README (GitHub) <https://raw.githubusercontent.com/ai-dynamo/dynamo/main/README.md> accessed 2026-10-07; A4-S132: Together AI Raises \$800 Million at \$8.3 Billion Valuation (press release, 1 Jul 2026; TechCrunch coverage) (Together AI (Business Wire)) <https://www.businesswire.com/news/home/20260701243402/en/Together-AI-Raises-00-Million-at-.3-Billion-Valuation-to-Make-Frontier-AI-Accessible-to-All> accessed 2026-10-07 [search-tool extract]; A4-S141: Fireworks Raises a \$1.5 Billion Series D (press release; CNBC 16 Jul 2026) (Fireworks AI (Business Wire)) [https://www.businesswire.com/news/home/20260716264405/en/Fireworks-Raises-a-\\$1.5-Billion-Series-D-to-Lead-the-Specialized-Intelligence-Revolution](https://www.businesswire.com/news/home/20260716264405/en/Fireworks-Raises-a-$1.5-Billion-Series-D-to-Lead-the-Specialized-Intelligence-Revolution) accessed 2026-10-07 [search-tool extract]

⁸⁶ Verified fact — V1-S062: Simplifying Our Platform Fee (OpenRouter) <https://openrouter.ai/blog/announcements/simplifying-our-platform-fee/> accessed 2026-10-08 [search-tool extract]

cloud used for a function is also an ICT third-party arrangement for the DORA register ⁸⁸.

Questions for your team

- For each production route, where are prompts processed, as distinct from stored, and how do we evidence it per call? ^{Rec}
- What happens to traffic above our reserved capacity, and has anyone checked the default? ^{Rec}
- What was our peak demand in the last month-end window, against what we have reserved? ^{Rec}
- Who patches our inference engines, and how many days does a critical advisory take to reach production? ^{Rec}
- Is there an open-weight route already qualified for the stressed-exit case, and when was it last drilled? ^{Rec}
- Which provider defaults, such as data retention, have we accepted without checking? ^{Rec}

In one line

The cheapest token is worth nothing if it arrives late or is processed in the wrong country ^{AJ}.

⁸⁷ Verified fact — A4-S109: OpenRouter Docs: In-Region Routing (EU/US) <https://raw.githubusercontent.com/OpenRouterTeam/docs/main/guides/features/in-region-routing.md> accessed 2026-10-07; A4-S150: In-Region Routing: keep your data in the US or EU (OpenRouter blog) and OpenRouter Pricing/Enterprise pages <https://openrouter.ai/blog/announcements/us-in-region-routing/> accessed 2026-10-07 [search-tool extract]

⁸⁸ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see [regulatory_facts.json](#)); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]

4. The boring component that makes exit real

C1 AI / LLM gateway, from Post 4 of the series.

The post

The most boring component in the AI stack is the one that makes an exit plan real. ^{AJ}

UK supervisors expect documented and tested exit plans for material outsourcing, including a stressed exit. Without a gateway, provider SDKs and keys spread through application code, and switching model becomes a programme of code changes. The plan exists on paper; it cannot be carried out in the time a stressed exit allows. ^{VI⁸⁹ AJ}

Managed model access is a sensible default only if it stays reversible. Every model call, and now every tool and agent call, passes through one firm-controlled point that owns routing, fallback, budgets, policy and the request log. Guardrails, data protection, identity checks and cost attribution are all invoked there. ^{VI⁹⁰ AJ}

That concentration cuts both ways. In March 2026, malicious releases of a popular open-source gateway were published to a public package index. A component that holds every provider key is a prime target. So run it like payments infrastructure:

⁸⁹ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see regulatory_facts.json); A8-S048: SS2/21 Outsourcing and third party risk management (and PS7/26, March 2026) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2021/ss221-march-21.pdf> accessed 2026-10-07 [search-tool extract]

⁹⁰ Verified fact — A6-S015: LiteLLM docs: MCP Overview, Agent Gateway (A2A), Caching, Budgets/Rate Limits, v1.89.0 release notes (BerriAI (LiteLLM)) <https://docs.litellm.ai/docs/mcp> accessed 2026-10-07 [search-tool extract]; A6-S016: Kong AI Gateway 2.0 Is Now GA — And It's Already Moving Faster (Kong Inc.) <https://konghq.com/blog/product-releases/kong-ai-gateway-2-0-ga> accessed 2026-10-07 [search-tool extract]; A6-S053: AI gateway capabilities in Azure API Management (Microsoft Learn source, ms.date 29 May 2026) <https://raw.githubusercontent.com/MicrosoftDocs/azure-docs/main/articles/api-management/genai-gateway-capabilities.md> accessed 2026-10-07; A6-S024: Apigee AI solutions: gateway to enterprise-ready AI (Google Cloud) <https://cloud.google.com/solutions/apigee-ai> accessed 2026-10-07; A6-S061: agentgateway README (GitHub) (agentgateway project (Linux Foundation)) <https://raw.githubusercontent.com/agentgateway/agentgateway/main/README.md> accessed 2026-10-07

Part II: Nine layers and the controls that make them safe

two independent deployments, pinned and signed builds, and budgets, guards and fallbacks that fail closed.^{VF⁹¹ Rec}

The signal is time to switch provider: how long it takes to move a route to a pre-qualified alternative by configuration alone. Hours, not weeks, and drilled at least once a year.^{AJ}

The leadership move is to treat “add a provider” as a third-party risk event, not a configuration tweak. From 18 March 2027, UK firms must notify material third-party arrangements before entering them.^{VF⁹² Rec}

The honest caveat: ownership matters. Several gateways now belong to security, payments or platform companies, and a gateway that is not neutral weakens the one component meant to keep you neutral.^{VF⁹³ AJ}

Neutrality is a design property. It has to be built, and then rehearsed.^{AJ}

⁹¹ Verified fact — A6-S008: Security Update: Suspected Supply Chain Incident (and Security Townhall Updates) (BerriAI (LiteLLM)) <https://docs.litellm.ai/blog/security-update-march-2026> accessed 2026-10-07 [search-tool extract]; V2-S027: LiteLLM PyPI supply chain attack (with NetSPI, Comet, Snyk/Datadog reporting) (FutureSearch) <https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/> accessed 2026-10-08 [search-tool extract]

⁹² Verified fact — R-PRA-SS221: PRA SS2/21 ‘Outsourcing and third party risk management’ (revised by PS7/26, March 2026) (see regulatory_facts.json); R-FCA-SYSC8: FCA Handbook SYSC 8 (Outsourcing); FG16/5 ‘Guidance for firms outsourcing to the cloud and other third-party IT services’; PS26/2 operational incident and third-party reporting (see regulatory_facts.json); A8-S062: PS7/26 Operational incident and third-party reporting (PRA) and FCA PS26/2; revised SS2/21 (March 2026) (Bank of England / PRA; FCA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2026/march/operational-incident-and-third-party-reporting-policy-statement> accessed 2026-10-07 [search-tool extract]

⁹³ Verified fact — A6-S011: Palo Alto Networks Completes Acquisition of Portkey to Secure AI Agents (and 30 Apr 2026 announcement) <https://www.paloaltonetworks.com/company/press/2026/palo-alto-networks-completes-acquisition-of-portkey-to-secure-ai-agents> accessed 2026-10-07 [search-tool extract]; V2-S025: Palo Alto Networks Completes Acquisition of Portkey to Secure AI Agents (with PANW FY2026 10-K and 10-Q, SDxCentral) <https://www.paloaltonetworks.com/company/press/2026/palo-alto-networks-completes-acquisition-of-portkey-to-secure-ai-agents> accessed 2026-10-08 [search-tool extract]; V1-S059: Stripe agrees to acquire OpenRouter to help businesses optimize token routing and usage <https://stripe.com/newsroom/news/stripe-agrees-to-acquire-openrouter> accessed 2026-10-08 [search-tool extract]



Behind the post

The popular picture of the stack has no gateway. Its nearest equivalent is a hosted router drawn inside the inference layer ^{AJ}. That absence matters, because the gateway turned out to be the component the rest of the architecture depends on.

What the gateway decides. For every outbound AI request, the gateway decides who may make it, which model or tool receives it, in which region, at what cost ceiling, under which policies, and what record is kept ^{AJ}. In practice that means one OpenAI-compatible API in front of many providers, so applications hold no provider SDKs or keys; routing, retry and fallback; token and spend limits per key, team or user; caching; inline calls to guardrails, data protection and authorisation; and one log record per request ^{W94 AJ}.

Why exit depends on it. PRA SS2/21 expects documented and tested exit plans, including a stressed exit ^{W95}. Without a gateway, provider SDKs and keys spread through application code, so switching model becomes a programme of code changes that cannot be executed in the time a stressed exit allows ^{AJ}. With one, a model exit is a configuration change, re-qualified by the evaluation suite described in Chapter 1 ^{AJ}. An exit plan that has never been drilled through the gateway is not tested ^{AJ}.

It now carries three kinds of traffic. The most significant change during 2025 and 2026 is scope. LiteLLM, Kong, Azure API Management, Apigee and agentgateway all now govern model calls, tool calls over the Model Context Protocol (MCP) and agent-to-agent (A2A) calls ^{W96}. MCP originated at Anthropic and was donated to the Agentic AI Foundation under the Linux Foundation; the independent alternative is

⁹⁴ Verified fact — A6-S015: LiteLLM docs: MCP Overview, Agent Gateway (A2A), Caching, Budgets/Rate Limits, v1.89.0 release notes (BerriAI (LiteLLM)) <https://docs.litellm.ai/docs/mcp> accessed 2026-10-07 [search-tool extract]; A6-S049: Portkey AI Gateway README (GitHub) (Portkey (Palo Alto Networks)) <https://raw.githubusercontent.com/Portkey-AI/gateway/main/README.md> accessed 2026-10-07; A6-S063: Envoy AI Gateway / Agent Router README (GitHub) (Envoy AI Gateway project (Agentic AI Foundation)) <https://raw.githubusercontent.com/envoyproxy/ai-gateway/main/README.md> accessed 2026-10-07; A6-S024: Apigee AI solutions: gateway to enterprise-ready AI (Google Cloud) <https://cloud.google.com/solutions/apigee-ai> accessed 2026-10-07; A6-S020: Azure API Management AI gateway docs and Tech Community announcements (AI Gateway tier preview; Build 2026 updates) (Microsoft) <https://learn.microsoft.com/en-us/azure/api-management/ai-gateway-overview> accessed 2026-10-07 [search-tool extract]; A6-S105: AgentCore Gateway: Inference targets; Inference connector/provider targets; Add rate limits to a gateway (Amazon Web Services) <https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/gateway-targets-inference.html> accessed 2026-10-07 [search-tool extract]

⁹⁵ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see regulatory_facts.json); A8-S048: SS2/21 Outsourcing and third party risk management (and PS7/26, March 2026) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2021/ss221-march-21.pdf> accessed 2026-10-07 [search-tool extract]

OpenAPI-described tools behind the same gateway⁹⁷^{AJ}. For tool traffic the gateway becomes a federator, exposing only the tools each caller may use⁹⁸. The MCP 2026-07-28 authorisation specification forbids token passthrough, so a gateway in front of tool servers must exchange tokens rather than forward the caller's own⁹⁹^{AJ}. The other controls are invoked here too: guardrails, data protection, tool policy and cost attribution all run inline at the gateway¹⁰⁰. That is why the review moved the gateway out of the inference layer and into the control plane as an "AI traffic gateway"^{AJ}.

The concentration cuts both ways. A component that holds every provider credential and sees every prompt is a high-value target^{AJ}. On 24 March 2026, malicious LiteLLM releases 1.82.7 and 1.82.8 were published to PyPI after release

⁹⁶ Verified fact — A6-S015: LiteLLM docs: MCP Overview, Agent Gateway (A2A), Caching, Budgets/Rate Limits, v1.89.0 release notes (BerriAI (LiteLLM)) <https://docs.litellm.ai/docs/mcp> accessed 2026-10-07 [search-tool extract]; A6-S016: Kong AI Gateway 2.0 Is Now GA — And It's Already Moving Faster (Kong Inc.) <https://konghq.com/blog/product-releases/kong-ai-gateway-2-0-ga> accessed 2026-10-07 [search-tool extract]; A6-S053: AI gateway capabilities in Azure API Management (Microsoft Learn source, ms.date 29 May 2026) <https://raw.githubusercontent.com/MicrosoftDocs/azure-docs/main/articles/api-management/genai-gateway-capabilities.md> accessed 2026-10-07; A6-S024: Apigee AI solutions: gateway to enterprise-ready AI (Google Cloud) <https://cloud.google.com/solutions/apigee-ai> accessed 2026-10-07; A6-S061: agentgateway README (GitHub) (agentgateway project (Linux Foundation)) <https://raw.githubusercontent.com/agentgateway/agentgateway/main/README.md> accessed 2026-10-07

⁹⁷ Verified fact — A3-S018: MCP joins the Agentic AI Foundation (9 Dec 2025) (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/2025-12-09-mcp-joins-agentic-ai-foundation/> accessed 2026-10-07; V1-S038: Linux Foundation Announces the Formation of the Agentic AI Foundation (AAIF) (The Linux Foundation) <https://www.linuxfoundation.org/press/linux-foundation-announces-the-formation-of-the-agentic-ai-foundation> accessed 2026-10-08 [search-tool extract]

⁹⁸ Verified fact — A6-S016: Kong AI Gateway 2.0 Is Now GA — And It's Already Moving Faster (Kong Inc.) <https://konghq.com/blog/product-releases/kong-ai-gateway-2-0-ga> accessed 2026-10-07 [search-tool extract]; A6-S026: Policy in Amazon Bedrock AgentCore is now generally available; AgentCore Policy docs; Why Policy in AgentCore chose Cedar (Amazon Web Services) <https://aws.amazon.com/about-aws/whats-new/2026/03/policy-amazon-bedrock-agentcore-generally-available/> accessed 2026-10-07 [search-tool extract]

⁹⁹ Verified fact — A6-S033: MCP specification 2026-07-28: Authorization (Model Context Protocol project) <https://raw.githubusercontent.com/modelcontextprotocol/modelcontextprotocol/main/docs/specification/2026-07-28/basic/authorization/index.mdx> accessed 2026-10-07; A6-S034: MCP specification 2026-07-28: Authorization security considerations (Model Context Protocol project) <https://raw.githubusercontent.com/modelcontextprotocol/modelcontextprotocol/main/docs/specification/2026-07-28/basic/authorization/security-considerations.mdx> accessed 2026-10-07

¹⁰⁰ Verified fact — A6-S017: Kong AI Gateway changelog; Kong Gateway changelog; AI Proxy Advanced plugin docs (Kong Inc.) <https://developer.konghq.com/ai-gateway/changelog/> accessed 2026-10-07 [search-tool extract]; A6-S053: AI gateway capabilities in Azure API Management (Microsoft Learn source, ms.date 29 May 2026) <https://raw.githubusercontent.com/MicrosoftDocs/azure-docs/main/articles/api-management/genai-gateway-capabilities.md> accessed 2026-10-07; A6-S026: Policy in Amazon Bedrock AgentCore is now generally available; AgentCore Policy docs; Why Policy in AgentCore chose Cedar (Amazon Web Services) <https://aws.amazon.com/about-aws/whats-new/2026/03/policy-amazon-bedrock-agentcore-generally-available/> accessed 2026-10-07 [search-tool extract]; A7-S010: litellm on PyPI (JSON API) (PyPI / BerriAI) <https://pypi.org/pypi/litellm/json> accessed 2026-10-07

credentials were stolen through a compromised CI scanner^{vf101}. A clean 1.83.0 followed, and the container images have been cosign-signed from that version^{vf102}. The lesson is not about one project. Any gateway, open or closed, concentrates risk in the way it concentrates control^{AI}. Run it like payments infrastructure: at least two independent deployments, builds installed from pinned and verified artefacts, and a defined degraded mode, preferably “no AI” for regulated outputs and never a direct path for client data^{Rec}.

Fail closed, explicitly. Defaults deserve suspicion. In LiteLLM, limits are unset by default, `max_budget` fails open without a database, prompt-injection guardrails are off by default, and the proxy admin key bypasses budget checks^{vf103}. Every product has its equivalents, so test each failure mode rather than trusting the configuration screen^{Rec}. Caches deserve the same care. Apigee shipped a fix for a server-side request forgery flaw in its semantic-cache lookup on 30 September 2026^{vf104}. For client-specific routes, turn semantic caching off^{Rec}.

Fallback must respect residency and qualification. A fallback model must be in the same approved region and must have passed the route’s regression suite^{Rec}. “Fall back to anything available” is how out-of-region processing happens on a busy month-end^{AI}.

The market is real but uneven. Kong AI Gateway 2.0 reached general availability on 1 September 2026^{vf105}. Apigee’s MCP support has been generally available since 31

¹⁰¹ Verified fact — A6-S008: Security Update: Suspected Supply Chain Incident (and Security Townhall Updates) (BerriAI (LiteLLM)) <https://docs.litellm.ai/blog/security-update-march-2026> accessed 2026-10-07 [search-tool extract]; A6-S010: Your AI Gateway Was a Backdoor: Inside the LiteLLM Supply Chain Compromise (Trend Micro Research) https://www.trendmicro.com/en_us/research/26/c/inside-litellm-supply-chain-compromise.html accessed 2026-10-07 [search-tool extract]

¹⁰² Verified fact — A6-S009: v1.83.0 - Official Release (Post Supply Chain Incident) (BerriAI (LiteLLM)) https://docs.litellm.ai/release_notes/v1.83.0/v1-83-0 accessed 2026-10-07 [search-tool extract]; A6-S051: LiteLLM README (GitHub) (BerriAI (LiteLLM)) <https://raw.githubusercontent.com/BerriAI/litellm/main/README.md> accessed 2026-10-07

¹⁰³ Verified fact — A6-S015: LiteLLM docs: MCP Overview, Agent Gateway (A2A), Caching, Budgets/Rate Limits, v1.89.0 release notes (BerriAI (LiteLLM)) <https://docs.litellm.ai/docs/mcp> accessed 2026-10-07 [search-tool extract]

¹⁰⁴ Verified fact — A6-S025: Apigee release notes (all; hybrid) (Google Cloud) <https://docs.cloud.google.com/apigee/docs/release-notes> accessed 2026-10-07 [search-tool extract]

¹⁰⁵ Verified fact — A6-S016: Kong AI Gateway 2.0 Is Now GA — And It’s Already Moving Faster (Kong Inc.) <https://konghq.com/blog/product-releases/kong-ai-gateway-2-0-ga> accessed 2026-10-07 [search-tool extract]; V2-S034: Kong AI Gateway 2.0 Is Now GA (with Kong press release 30 Sep 2026 on AI Gateway 2.2 GA) <https://konghq.com/blog/product-releases/kong-ai-gateway-2-0-ga> accessed 2026-10-08 [search-tool extract]

March 2026¹⁰⁶. The Azure API Management AI Gateway tier is in preview with no SLA, while its AI policies are generally available¹⁰⁷. No AWS product called “AI gateway” was found; AWS offers AgentCore Gateway for tools, with new inference targets, and a LiteLLM-based reference pattern¹⁰⁸. Microsoft describes its AI gateway as an extension of the API gateway, “not a separate offering”¹⁰⁹. The review therefore draws the gateway as a logical control that may live on the firm’s existing API-management platform¹¹⁰.

Ownership is the caveat. Palo Alto Networks completed its acquisition of Portkey on 29 May 2026 and sells it as Prisma AI Gateway¹¹⁰. Stripe agreed to acquire OpenRouter, with closing pending¹¹¹. A gateway owned by a model vendor, a

¹⁰⁶ Verified fact — A6-S024: Apigee AI solutions: gateway to enterprise-ready AI (Google Cloud) <https://cloud.google.com/solutions/apigee-ai> accessed 2026-10-07; A6-S023: Apigee docs: AI gateway capabilities; semantic caching tutorial; MCP support for Apigee (Google Cloud) <https://docs.cloud.google.com/apigee/docs/api-platform/get-started/ai-capabilities> accessed 2026-10-07 [search-tool extract]

¹⁰⁷ Verified fact — A6-S020: Azure API Management AI gateway docs and Tech Community announcements (AI Gateway tier preview; Build 2026 updates) (Microsoft) <https://learn.microsoft.com/en-us/azure/api-management/ai-gateway-overview> accessed 2026-10-07 [search-tool extract]; V2-S073: AI Gateway tier (preview) overview - Azure API Management (with Tech Community 'AI Gateway tier of API Management now in public preview') (Microsoft) <https://learn.microsoft.com/en-us/azure/api-management/ai-gateway-overview> accessed 2026-10-08 [search-tool extract]

¹⁰⁸ Verified fact — A6-S021: Amazon Bedrock AgentCore Pricing; AgentCore GA announcement (Oct 2025); AgentCore Gateway docs (Amazon Web Services) <https://aws.amazon.com/bedrock/agentcore/pricing/> accessed 2026-10-07 [search-tool extract]; A6-S022: Guidance for Multi-Provider Generative AI Gateway on AWS; Implementing resilience patterns with Amazon Bedrock and LLM gateway (Amazon Web Services) <https://aws.amazon.com/solutions/guidance/multi-provider-generative-ai-gateway-on-aws/> accessed 2026-10-07 [search-tool extract]; A6-S105: AgentCore Gateway: Inference targets; Inference connector/provider targets; Add rate limits to a gateway (Amazon Web Services) <https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/gateway-targets-inference.html> accessed 2026-10-07 [search-tool extract]

¹⁰⁹ Verified fact — A6-S053: AI gateway capabilities in Azure API Management (Microsoft Learn source, ms.date 29 May 2026) <https://raw.githubusercontent.com/MicrosoftDocs/azure-docs/main/articles/api-management/genai-gateway-capabilities.md> accessed 2026-10-07

¹¹⁰ Verified fact — A6-S011: Palo Alto Networks Completes Acquisition of Portkey to Secure AI Agents (and 30 Apr 2026 announcement) <https://www.paloaltonetworks.com/company/press/2026/palo-alto-networks-completes-acquisition-of-portkey-to-secure-ai-agents> accessed 2026-10-07 [search-tool extract]; A6-S012: Palo Alto Networks Inc - Form 10-K - FY2026 (fiscal year ended 31 July 2026) (US SEC EDGAR / Palo Alto Networks) <https://www.sec.gov/Archives/edgar/data/0001327567/000132756726000023/panw-20260731.htm> accessed 2026-10-07 [search-tool extract]; V2-S025: Palo Alto Networks Completes Acquisition of Portkey to Secure AI Agents (with PANW FY2026 10-K and 10-Q, SDxCentral) <https://www.paloaltonetworks.com/company/press/2026/palo-alto-networks-completes-acquisition-of-portkey-to-secure-ai-agents> accessed 2026-10-08 [search-tool extract]

¹¹¹ Verified fact — V1-S059: Stripe agrees to acquire OpenRouter to help businesses optimize token routing and usage <https://stripe.com/newsroom/news/stripe-agrees-to-acquire-openrouter> accessed 2026-10-08 [search-tool extract]; V1-S060: Stripe to buy OpenRouter as fintech expands deeper into AI (and TechCrunch 16 Aug 2026 report) (CNBC / TechCrunch) <https://www.cnbc.com/2026/08/19/stripe-openrouter-fintech-ai-model-marketplace.html> accessed

payments company or a security vendor is not neutral, and that matters most for the component meant to keep you neutral ^{AJ}.

The regulatory hooks. From 18 March 2027, PRA PS7/26 and FCA PS26/2 require notification before entering a material third-party arrangement, so “add a provider” belongs with third-party risk ^{VF}¹¹² ^{Rec}. Where a use is high-risk under the EU AI Act, Article 26 requires deployers to keep logs for at least six months ^{VF}¹¹³. The gateway sees every request with its model version, so its log is the natural evidence base ^{AJ}. The people who rehearse exits rarely get noticed until the day an exit works. They should be noticed before.

What good looks like

The signal is **time to switch provider**: how long it takes to move a production route to a pre-qualified alternative by configuration alone, with no code change ^{AJ}.

Measure it in a scheduled exit drill. Pick a route, move it to the qualified fallback through the gateway, confirm that quality stays within the evaluation thresholds and that processing stays in region, then move it back. Keep the drill record as evidence ^{Rec}.

The review’s target guidance is hours, not weeks, tested at least once a year ^{AJ}. Three companion measures make the number credible. Gateway coverage, the share of production model, tool and agent calls that pass through the gateway, should be 100% in scope; any direct provider key in an application is a defect ^{AJ}. Residency conformance should show zero requests processed outside the approved region ^{AJ}. And budget enforcement should show zero breaches that were neither blocked nor alerted, including when the spend store is lost ^{AJ}. These are a starting point, not a benchmark ^{AJ}.

2026-10-08 [search-tool extract]

¹¹² Verified fact — R-PRA-SS221: PRA SS2/21 ‘Outsourcing and third party risk management’ (revised by PS7/26, March 2026) (see [regulatory_facts.json](#)); R-FCA-SYSC8: FCA Handbook SYSC 8 (Outsourcing); FG16/5 ‘Guidance for firms outsourcing to the cloud and other third-party IT services’; PS26/2 operational incident and third-party reporting (see [regulatory_facts.json](#)); A8-S062: PS7/26 Operational incident and third-party reporting (PRA) and FCA PS26/2; revised SS2/21 (March 2026) (Bank of England / PRA; FCA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2026/march/operational-incident-and-third-party-reporting-policy-statement> accessed 2026-10-07 [search-tool extract]

¹¹³ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see [regulatory_facts.json](#)); A8-S011: Regulation (EU) 2026/1744 (Digital Omnibus on AI) amending Regulation (EU) 2024/1689 (EUR-Lex / Official Journal of the EU) <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> accessed 2026-10-07 [search-tool extract]

In the worked example

Step 4: gateway. One gateway route, attribution-commentary-draft: the workflow calls the route with its own identity and never holds a provider key; residency, fallback, budgets and inline guards live on the route. ^{AJ}

- **Now works:** Switching to the qualified fallback is a configuration change, drilled in hours. ^{AJ}
- **Must never:** If both models are unavailable, the route fails closed and the analyst is told the draft is delayed. ^{AJ}
- **Evidence added:** The gateway's request record for every call. ^{AJ}
- **Signal:** Gateway coverage: 100% of model calls. ^{AJ}

Objections worth taking seriously

"A single gateway is a single point of failure." It is, and the answer is not to remove it ^{AJ}. Deploy at least two independent instances, per region or per criticality tier, sharing configuration from one source ^{Rec}. Decide in advance what an outage means. For regulated outputs, "no AI until restored" is a better degraded mode than a direct path that bypasses every control ^{Rec}. Then treat it like any other critical service: tested failover, synthetic probes per route, and an incident classification under DORA's ICT incident regime ^{vf¹¹⁴ Rec}. Concentration improves control and worsens resilience; good engineering keeps the first and limits the second ^{AJ}.

"Our API-management platform can already do this." Perhaps it can, and Microsoft makes the same argument about its own ^{vf¹¹⁵}. Use it if it carries model, tool and agent traffic with the controls above ^{AJ}. Two cautions. Use generally available features only, not a preview tier without an SLA ^{vf¹¹⁶}. And remember that policies in

¹¹⁴ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see [regulatory_facts.json](#)); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]

¹¹⁵ Verified fact — A6-S053: AI gateway capabilities in Azure API Management (Microsoft Learn source, ms.date 29 May 2026) <https://raw.githubusercontent.com/MicrosoftDocs/azure-docs/main/articles/api-management/genai-gateway-capabilities.md> accessed 2026-10-07

¹¹⁶ Verified fact — A6-S020: Azure API Management AI gateway docs and Tech Community announcements (AI Gateway tier preview; Build 2026 updates) (Microsoft) <https://learn.microsoft.com/en-us/azure/api-management/ai-gateway-overview> accessed 2026-10-07 [search-tool extract]; V2-S073: AI Gateway tier (preview) overview - Azure API Management (with Tech Community 'AI Gateway tier of API Management now in public preview') (Microsoft) <https://learn.microsoft.com/en-us/azure/api-management/ai-gateway-overview> accessed 2026-10-08 [search-tool extract]

a proprietary dialect are part of the exit cost, so document their intent in plain terms ^{Rec}.

“An open-source gateway was compromised. Why trust one?” The compromise was real ^{vr}¹¹⁷. But every gateway, open or closed, holds the keys, so the question is supply-chain discipline, not licence model ^{AI}. Mirror packages internally, verify signatures at admission and pin versions ^{Rec}. A managed gateway moves that work to a vendor, along with the ownership question this chapter has already raised ^{AI}.

Questions for your team

- How long would it take us to move our most important AI route to its fallback, and when did we last do it? ^{Rec}
- Are there provider keys anywhere outside the gateway's secret store? ^{Rec}
- If the gateway lost its budget or policy store, would requests fail open or fail closed? ^{Rec}
- Does every fallback model sit in the same approved region, and has it passed the route's regression suite? ^{Rec}
- Who owns the gateway product we depend on, and has that changed in the last year? ^{Rec}
- Does adding a model provider trigger our third-party risk process, with lead time for UK notification? ^{Rec}

In one line

Neutrality is a design property: build it into the gateway, then rehearse the exit until it is routine ^{AI}.

¹¹⁷ Verified fact — A6-S008: Security Update: Suspected Supply Chain Incident (and Security Townhall Updates) (BerriAI (LiteLLM)) <https://docs.litellm.ai/blog/security-update-march-2026> accessed 2026-10-07 [search-tool extract]

5. Most enterprise “agents” should be workflows

L3 Agent frameworks and orchestration, from Post 5 of the series.

The post

Most enterprise “agents” worth approving are not agents at all. They are deterministic workflows with one judgement step. ^{AJ}

The trap is handing a task with a known sequence to an autonomous loop. Each run takes a slightly different path, so evaluation results stop transferring between runs and validation can no longer cover the space of behaviours. When something goes wrong, the behaviour turns out to be a property of that run, not of the design. ^{AJ}

Every major framework now ships both modes, a workflow graph and an agent loop, so this is a design choice rather than a vendor choice. Make it before choosing a framework. If the steps are known in advance, even with branches, build a graph. Let the model draft, classify or judge inside a bounded step; do not let it choose the next tool. ^{VF} ¹¹⁸ ^{Rec}

Two things sit underneath. Durable execution, so a crash resumes from a checkpoint instead of re-running and mixing two versions of the data. And an approval step that only a named, authorised person can release. ^{Rec}

The signal is path conformance: the share of runs whose executed steps match the approved graph. For a regulated workflow the target is 100%, and any deviation is a defect. ^{AJ}

¹¹⁸ Verified fact — A4-S039: LangGraph Persistence / Durable execution / Interrupts - Docs by LangChain <https://docs.langchain.com/oss/python/langgraph/durable-execution> accessed 2026-10-07 [search-tool extract]; A4-S066: Microsoft Agent Framework README (GitHub) <https://raw.githubusercontent.com/microsoft/agent-framework/main/README.md> accessed 2026-10-07; A4-S050: CrewAI Introduction / Flows / Evaluating Use Cases - CrewAI docs <https://docs.crewai.com/en/introduction> accessed 2026-10-07 [search-tool extract]; A4-S114: Agent Development Kit (ADK) 2.0 README (GitHub) (Google) <https://raw.githubusercontent.com/google/adk-python/main/README.md> accessed 2026-10-07

Part II: Nine layers and the controls that make them safe

The leadership move is to treat autonomy as a budget that is declared, approved and owned for each use case. Often the right number is zero or one. ^{Rec}

The honest caveat: autonomous harnesses are moving fastest, and some open-ended tasks genuinely need them. Isolate them as one sandboxed sub-step with read-only tools rather than banning them. ^{VR} ¹¹⁹ ^{Rec}

Autonomy is a tool, not a maturity level. The best agent design is often the least agentic one that does the job. ^{AJ}

¹¹⁹ Verified fact — A4-S053: The next evolution of the Agents SDK (OpenAI) <https://openai.com/index/the-next-evolution-of-the-agents-sdk/> accessed 2026-10-07 [search-tool extract]; A4-S027: Agent SDK overview - Claude Code Docs (Anthropic) <https://code.claude.com/docs/en/agent-sdk/overview> accessed 2026-10-07; A4-S057: Build AI agents with the Mistral Agents API (and Agents & Conversations / Handoffs docs) (Mistral AI) <https://mistral.ai/news/agents-api/> accessed 2026-10-07 [search-tool extract]

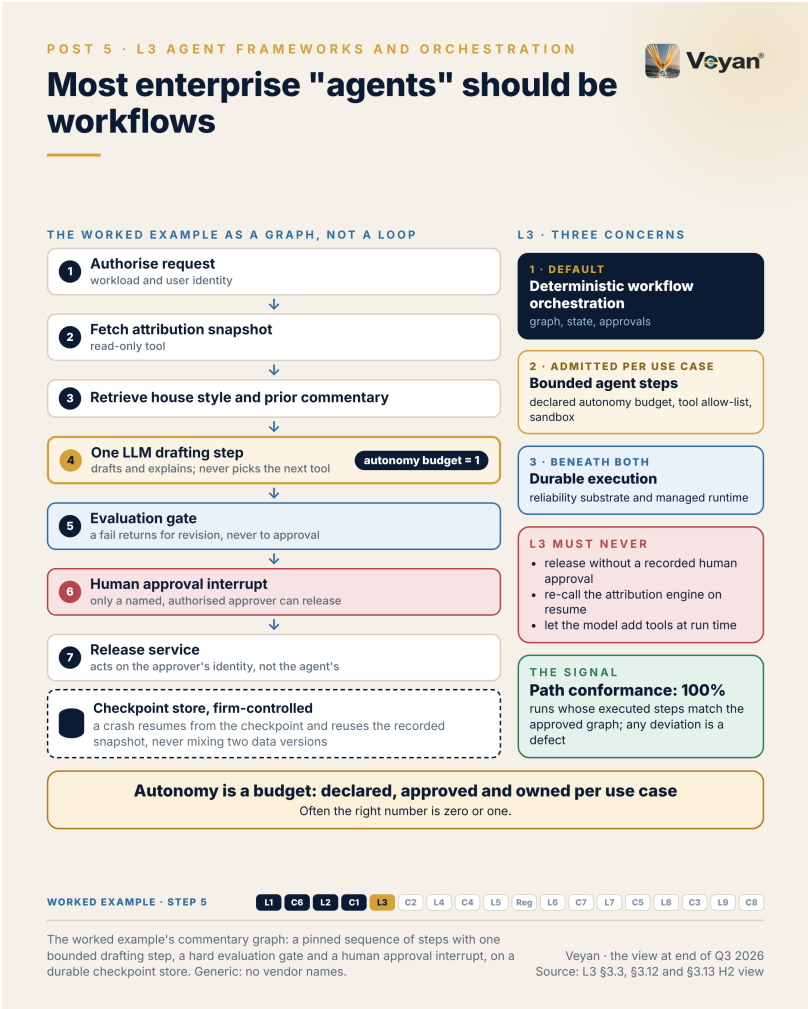


Figure 5. The worked example's commentary graph: a pinned sequence of steps with one bounded drafting step, a hard evaluation gate and a human approval interrupt, on a durable checkpoint store. Generic: no vendor names. ^{AJ}

Behind the post

This layer decides how an AI application sequences model calls, tool calls, state and human decisions, and what happens when a step fails half-way ^{AJ}. Most of that is

plumbing. One part of it is not: the decision, for each use case, about how much of the control flow the model is given ^{AJ}. That decision shapes validation, audit and incident response more than any choice of framework does.

Two kinds of orchestration. The useful line runs between workflows, where models and tools are orchestrated through predefined code paths, and agents, where the model dynamically directs its own process and tool use. Anthropic's published guidance draws the line in those terms ^{VF120}. It is not one vendor's view: Microsoft Agent Framework separates Agents from Workflows, and CrewAI separates Crews from Flows and recommends Flows as the outer process ^{VF121}.

Why autonomy is expensive in a regulated firm. When the model chooses the next step, each run can take a different path. A test suite that passed last week tells you about last week's paths, not tomorrow's ^{AJ}. The validated object should therefore be the workflow version (the graph, prompts, model versions and tool contracts) rather than the model alone, and a change to any of them is a change requiring re-evaluation ^{AJ}. The deterministic parts are not exempt because they are code. PRA SS1/23 says relevant model risk management aspects can be applied to material, complex deterministic quantitative methods that are not models ^{VF122}. In the US, SR 26-2 superseded SR 11-7 on 17 April 2026 and places generative and agentic AI expressly outside its scope, which leaves the firm to set its own standard ^{VF123}. Deterministic graphs make that standard testable ^{AJ}.

What changed in 2025-26. Four shifts, all pointing the same way.

¹²⁰ Verified fact — A4-S030: Building effective agents (Anthropic) <https://www.anthropic.com/engineering/building-effective-agents> accessed 2026-10-07

¹²¹ Verified fact — A4-S066: Microsoft Agent Framework README (GitHub) <https://raw.githubusercontent.com/microsoft/agent-framework/main/README.md> accessed 2026-10-07; A4-S050: CrewAI Introduction / Flows / Evaluating Use Cases - CrewAI docs <https://docs.crewai.com/en/introduction> accessed 2026-10-07 [search-tool extract]

¹²² Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 'Model risk management principles for banks' (published with PS6/23) (see regulatory_facts.json); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]

¹²³ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see regulatory_facts.json); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]

- *Both modes in every major framework.* LangGraph combines deterministic logic and model-driven decisions in one graph; Microsoft Agent Framework reached general availability on 2 April 2026 as the successor to Semantic Kernel and AutoGen, with AutoGen in maintenance mode; Google ADK 2.0 added a Workflow Runtime ^{vr124}. The choice between a graph and a loop is now made inside one framework, not between vendors ^{AI}.
- *Durability separated out.* Pydantic AI v2 attaches durability through Temporal, DBOS or Prefect; the OpenAI Agents SDK integrates Temporal and DBOS; Mistral Workflows is built on Temporal ^{vr125}.
- *Runtimes separated from frameworks.* Amazon Bedrock AgentCore runs agents written with several frameworks and gives each session its own microVM ^{vr126}. Its session state is ephemeral by default, and AWS says it should not be used for long-term durability ^{vr127}. A managed runtime is an isolation choice, not a substitute for durable workflow state ^{AI}.
- *Visual builders retreating.* OpenAI’s Agent Builder shuts down on 30 November 2026, and OpenAI points code users to its SDK ^{vr128}.

Durable execution, in plain terms. A durable engine records the result of each side-effecting step, so that after a failure the workflow is replayed and completed steps

¹²⁴ Verified fact — A4-S039: LangGraph Persistence / Durable execution / Interrupts - Docs by LangChain <https://docs.langchain.com/oss/python/langgraph/durable-execution> accessed 2026-10-07 [search-tool extract]; A4-S008: PyPI JSON metadata: agent-framework (Python Package Index) <https://pypi.org/pypi/agent-framework/json> accessed 2026-10-07; A4-S012: PyPI JSON metadata: semantic-kernel (Python Package Index) <https://pypi.org/pypi/semantic-kernel/json> accessed 2026-10-07; A4-S021: PyPI JSON metadata: autogen-agentchat (Python Package Index) <https://pypi.org/pypi/autogen-agentchat/json> accessed 2026-10-07; V1-S050: PyPI JSON metadata: agent-framework (1.0.0 uploaded 2026-04-02; latest 1.20.0) (Python Package Index) <https://pypi.org/pypi/agent-framework/json> accessed 2026-10-08; A4-S114: Agent Development Kit (ADK) 2.0 README (GitHub) (Google) <https://raw.githubusercontent.com/google/adk-python/main/README.md> accessed 2026-10-07

¹²⁵ Verified fact — A4-S045: Pydantic AI Durable Execution (overview, Temporal, DBOS, Prefect) https://pydantic.dev/docs/ai/capabilities/durable_execution/overview/ accessed 2026-10-07 [search-tool extract]; A4-S052: OpenAI Agents SDK documentation (agents, sessions, handoffs, guardrails, tracing, running agents) <https://openai.github.io/openai-agents-python/> accessed 2026-10-07 [search-tool extract]; A4-S058: Workflows for work that runs the business (Mistral Workflows) (Mistral AI) <https://mistral.ai/news/workflows/> accessed 2026-10-07 [search-tool extract]

¹²⁶ Verified fact — A4-S116: Bedrock AgentCore SDK README (GitHub) (AWS) <https://raw.githubusercontent.com/aws/bedrock-agentcore-sdk-python/main/README.md> accessed 2026-10-07; B-L3-S004: AgentCore Runtime sessions / microVMs / quotas / security best practices (Amazon Web Services) <https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/runtime-sessions.html> accessed 2026-10-08 [search-tool extract]

¹²⁷ Verified fact — B-L3-S004: AgentCore Runtime sessions / microVMs / quotas / security best practices (Amazon Web Services) <https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/runtime-sessions.html> accessed 2026-10-08 [search-tool extract]

¹²⁸ Verified fact — A4-S054: OpenAI Deprecations (Agent Builder) and Introducing AgentKit update <https://developers.openai.com/api/docs/deprecations> accessed 2026-10-07 [search-tool extract]; V1-S051: OpenAI API Deprecations (Agent Builder row); Introducing AgentKit (updated) <https://developers.openai.com/api/docs/deprecations> accessed 2026-10-08 [search-tool extract]

return their recorded results instead of running again ^{vf129}. For a commentary workflow, that means a crash after the attribution snapshot was fetched resumes with the same snapshot. The draft and its evidence refer to the same numbers ^{AI}. Without it, a retry can silently pick up a late price correction and produce a document nobody can trace to its data ^{AI}. The checkpoint store holds that evidence, so it is also a security boundary: LangGraph has published three checkpoint deserialisation advisories since 2025, all patched ^{vf130}.

Approval as a control, not a convention. A “human review” step that code can skip, or that does not record who approved, is not a gate ^{AI}. LangGraph interrupts, Microsoft Agent Framework human-in-the-loop, ADK tool confirmation and the OpenAI Agents SDK’s resumable approvals all support an approval that pauses the run until a person resumes it ^{vf131}. Supervisors are watching this point. ESMA holds management bodies responsible for decisions taken by AI tools, and the Bank of England reported that 55% of AI use cases had some autonomous decision-making and 2% were fully autonomous ^{vf132}.

The worked example. The review’s generic example is an agent that drafts monthly performance-attribution commentary for a multi-asset fund. Its graph is pinned: authorise the request, fetch the attribution snapshot through a read-only tool, retrieve house style and prior commentary, run one model drafting step, pass an

¹²⁹ Verified fact — A4-S019: PyPI JSON metadata: temporalio (Python Package Index) <https://pypi.org/pypi/temporalio/json> accessed 2026-10-07; A4-S045: Pydantic AI Durable Execution (overview, Temporal, DBOS, Prefect) https://pydantic.dev/docs/ai/capabilities/durable_execution/overview/ accessed 2026-10-07 [search-tool extract]

¹³⁰ Verified fact — B-L3-S007: LangGraph security advisories (GitHub) and NVD entries (LangChain / GitHub / NIST NVD) <https://github.com/langchain-ai/langgraph/security> accessed 2026-10-08 [search-tool extract]

¹³¹ Verified fact — A4-S118: LangGraph README (GitHub) (LangChain) <https://raw.githubusercontent.com/langchain-ai/langgraph/main/README.md> accessed 2026-10-07; A4-S066: Microsoft Agent Framework README (GitHub) <https://raw.githubusercontent.com/microsoft/agent-framework/main/README.md> accessed 2026-10-07; A4-S114: Agent Development Kit (ADK) 2.0 README (GitHub) (Google) <https://raw.githubusercontent.com/google/adk-python/main/README.md> accessed 2026-10-07; A4-S120: OpenAI Agents SDK README (GitHub) <https://raw.githubusercontent.com/openai/openai-agents-python/main/README.md> accessed 2026-10-07

¹³² Verified fact — R-INTL-AI-ASSETMGMT: IOSCO Supervisory Toolkit for AI Use in Capital Markets (FR/02/2026) and ESMA Public Statement on AI and investment services (30 May 2024) (see [regulatory_facts.json](#)); A8-S059: ESMA Public Statement on AI and investment services (30 May 2024) and 2026 briefings <https://www.esma.europa.eu/document/public-statement-ai-and-investment-services> accessed 2026-10-07 [search-tool extract]; R-UK-AI-STATEMENTS: FCA, Bank of England and PRA statements and initiatives on AI, 2024-2026 (see [regulatory_facts.json](#)); A8-S056: Financial Policy Committee Record April 2026; FSR July 2026; 2026 AI survey (Bank of England) <https://www.bankofengland.co.uk/financial-policy-committee-record/2026/april-2026> accessed 2026-10-07 [search-tool extract]

evaluation gate, stop for a human approval interrupt, then hand to a separate release service that acts on the approver’s identity ^{Rec}. The model drafts and explains. It never picks the next tool, and a failed numeric check routes back for revision, never to approval ^{Rec}. That is an autonomy budget of one.

Where autonomous harnesses fit. They are useful for open-ended, file- or code-centric sub-tasks ^{AJ}. The review assessed two from model vendors. The OpenAI Agents SDK is pre-1.0 and its tracing defaults to OpenAI’s dashboard; the Claude Agent SDK carries an Alpha classifier and keeps session transcripts on local disk unless a session store is configured ^{vr}¹³³. At the review’s fourth checkpoint both were given the same maturity score, and they were rated Tactical and Experimental respectively ^{AJ}. A disclosure: this book was prepared with the help of an Anthropic model, and the review resolved borderline calls on the Anthropic product against it ^{AJ}. Either harness belongs inside a firm-owned workflow as one replaceable, sandboxed node, with a model-agnostic equivalent on LangGraph or Pydantic AI kept available ^{Rec}.

The credit for this design rarely goes where it should. It belongs to the engineers who make the boring path reliable ^{AJ}.

What good looks like

The signal is **path conformance**: the share of runs whose executed node sequence matches the approved graph version ^{AJ}. Measure it by comparing each run’s trace with the graph version recorded at the start of the run, which requires every node to emit a span and every run to carry its graph version ^{Rec}. For a regulated workflow the starting target is 100%, and any deviation is treated as a defect to be investigated, not a statistic to be averaged ^{AJ}.

Two companion measures make the number meaningful. *Resume without re-execution*: in fault-injection tests, every interrupted run resumes from its last checkpoint without repeating a completed side-effecting step. *Approval-gate integrity*: every release carries a recorded approval by an authorised person, with zero bypasses, reconciled against publish events ^{AJ}. Track the declared autonomy

¹³³ Verified fact — A4-S005: PyPI JSON metadata: openai-agents (Python Package Index) <https://pypi.org/pypi/openai-agents/json> accessed 2026-10-07; A4-S052: OpenAI Agents SDK documentation (agents, sessions, handoffs, guardrails, tracing, running agents) <https://openai.github.io/openai-agents-python/> accessed 2026-10-07 [search-tool extract]; A4-S006: PyPI JSON metadata: claude-agent-sdk (Python Package Index) <https://pypi.org/pypi/claude-agent-sdk/json> accessed 2026-10-07; A4-S122: Hosting the Agent SDK - Claude Code Docs (Anthropic) <https://code.claude.com/docs/en/agent-sdk/hosting> accessed 2026-10-07

budget per use case alongside them: steps where the model chooses the next action, and the maximum tool calls per run ^{AJ}.

These targets are a starting point drawn from the review's guidance, not an industry benchmark ^{AJ}. Where a use case genuinely needs an autonomous sub-step, path conformance applies to the outer graph, and the sub-step is measured on its own allow-list and trajectory checks ^{Rec}.

In the worked example

Step 5: workflow. A pinned workflow graph: authorise, fetch the attribution snapshot, retrieve style and prior commentary, one drafting step, an evaluation gate, a human approval interrupt, then release by a separate service. ^{AJ}

- **Now works:** Every run follows the same path; a failed run resumes from its checkpoint with the same numbers. ^{AJ}
- **Must never:** Autonomy budget of one: the model drafts, but never chooses tools or order. ^{AJ}
- **Evidence added:** The run's path through the graph and its checkpoints. ^{AJ}
- **Signal:** Path conformance: 100% of runs on the approved path. ^{AJ}

Objections worth taking seriously

"This throws away what makes agents valuable." It does not ban them; it admits them where they earn their place ^{AJ}. Because every major framework now ships both modes, moving a step from a graph into a bounded agent loop later is a design change inside one framework, not a migration ^{vf¹³⁴ AJ}. What the approach refuses is autonomy by default for a process whose sequence is already known ^{Rec}. The value of a model in most regulated processes lies in drafting, classifying and explaining, all of which fit inside a bounded step ^{AJ}.

"Real processes have exceptions; a graph will be brittle." Graphs can branch, loop and route exceptions to a person ^{vf¹³⁵ AJ}. The test is whether the steps are known in advance, even with branches, not whether the process is simple ^{Rec}. A bounded retry edge back to the drafting step, with a limit, handles most of what teams expect

¹³⁴ Verified fact — A4-S039: LangGraph Persistence / Durable execution / Interrupts - Docs by LangChain <https://docs.langchain.com/oss/python/langgraph/durable-execution> accessed 2026-10-07 [search-tool extract]; A4-S066: Microsoft Agent Framework README (GitHub) <https://raw.githubusercontent.com/microsoft/agent-framework/main/README.md> accessed 2026-10-07

¹³⁵ Verified fact — A4-S114: Agent Development Kit (ADK) 2.0 README (GitHub) (Google) <https://raw.githubusercontent.com/google/adk-python/main/README.md> accessed 2026-10-07

autonomy to solve ^{Rec}. Where the exceptions really are open-ended, that is the signal to carve out one sandboxed agent step, not to make the whole process autonomous ^{Rec}.

“Durable execution is heavy infrastructure for one use case.” It can be. Self-hosting Temporal means operating Kubernetes and persistence stores and upgrading in sequence ^{vf}¹³⁶. But Temporal Cloud runs the same server, DBOS describes itself as ultra-lightweight, and a LangGraph-only estate can use its own checkpointers ^{vf}¹³⁷. The alternative cost is a run that cannot be reconstructed after a crash, which is harder to explain to an auditor than a database is to operate ^{AJ}.

Questions for your team

- For each use case in flight, is the sequence of steps known in advance? If so, why is it built as a loop? ^{Rec}
- What is the declared autonomy budget for each workflow, and who approved it? ^{Rec}
- If a run crashes after fetching data, does it resume with the same data, and can we prove it in a kill-and-resume test? ^{Rec}
- Can our code skip the human approval step, and does the record show who approved what? ^{Rec}
- Do we record the graph version on every run, and measure path conformance against it? ^{Rec}
- Where an autonomous harness is in use, is it sandboxed, read-only, and replaceable by a model-agnostic equivalent? ^{Rec}

In one line

Decide how much autonomy a process deserves before choosing a framework, and the answer for most regulated work will be zero or one. ^{AJ}

¹³⁶ Verified fact — B-L3-S002: Temporal server repository; production deployment and Cloud overview docs (Temporal Technologies Inc.) <https://github.com/temporalio/temporal> accessed 2026-10-08 [search-tool extract]

¹³⁷ Verified fact — B-L3-S002: Temporal server repository; production deployment and Cloud overview docs (Temporal Technologies Inc.) <https://github.com/temporalio/temporal> accessed 2026-10-08 [search-tool extract]; A4-S020: PyPI JSON metadata: dbos (Python Package Index) <https://pypi.org/pypi/dbos/json> accessed 2026-10-07; A4-S039: LangGraph Persistence / Durable execution / Interrupts - Docs by LangChain <https://docs.langchain.com/oss/python/langgraph/durable-execution> accessed 2026-10-07 [search-tool extract]

6. Guardrails cannot fix the wrong autonomy

C2 Guardrails, from Post 6 of the series.

The post

Guardrails cannot fix a workflow that should never have been autonomous. ^{AJ}

A guardrail is a filter on a stream of actions. It lowers the chance that a bad action passes; it does not reduce the number of actions an agent is allowed to attempt. If an agent has write access to a client-facing system, a content filter on its output is not a control over that access. ^{AJ}

Deterministic workflows with one judgement step do most of the safety work. Guardrails are the second line, and they fail in predictable ways. They screen only the user's prompt while retrieved documents pass unchecked. A content-safety classifier is asked to catch a business error it was never trained for, such as a reversed sign. Or a guard times out and the request goes through. ^{AJ}

So layer them by mechanism. Deterministic rules first, for business invariants such as figures, signs and forbidden phrases. Small classifiers next, including on every retrieved chunk. Model-based judges only where nothing simpler can decide, and never as the only check on numbers. Everything fails closed. ^{Rec}

The signal worth watching is the false-positive rate on a labelled set of real, approved finance text, for example below 1% on a drafting route. Over-sensitive filters block legitimate vocabulary, people route around them, and the control quietly disappears. ^{AJ}

The leadership move is to own the guardrail policy and its test sets, whichever detectors you buy. ^{Rec}

The honest caveat: several open-source guardrail components have slowed or changed hands. Using two detectors from different owners is a concentration control as well as a security one. ^{VF¹³⁸ AJ}

A guardrail is evidence of care. It is not a substitute for deciding what the system may do. ^{AJ}

¹³⁸ Verified fact — A6-S003: nemoguardrails - PyPI JSON metadata (Python Package Index) <https://pypi.org/pypi/nemoguardrails/json> accessed 2026-10-07; A6-S107: Llama Guard 4 model card; Llama Prompt Guard 2 model card; Llama Protections (Meta) <https://developer.meta.com/ai/docs/model-cards-and-prompt-formats/llama-guard-4/> accessed 2026-10-07 [search-tool extract]; A6-S028: Guardrails AI Joins Harvey <https://www.harvey.ai/blog/guardrails-ai-joins-harvey> accessed 2026-10-07 [search-tool extract]

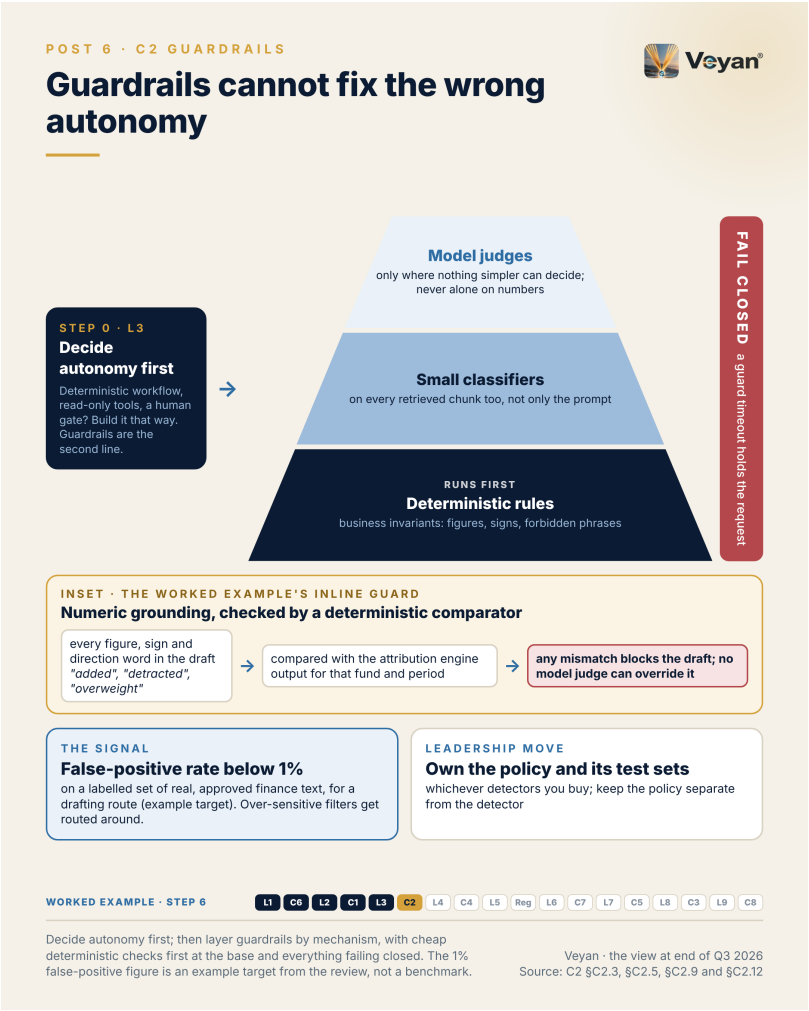


Figure 6. Decide autonomy first; then layer guardrails by mechanism, with cheap deterministic checks first at the base and everything failing closed. The 1% false-positive figure is an example target from the review, not a benchmark. ^{AJ}

Behind the post

Guardrails are the run-time checks on either side of a model or agent call. They inspect what goes in (user input, retrieved documents, tool results) and what comes

out (text, tool calls), and they block, transform or flag it against policy ^{AJ}. They are distinct from evaluation and red-teaming, which test a system before release but block nothing at run time ^{AJ}. They are also distinct from two decisions they are often asked to stand in for: how much autonomy a workflow has, and whether a given tool call is authorised ^{AJ}.

The mechanism, and its limit. A guardrail reduces the probability that a bad action passes. It does not reduce the number of actions an agent may attempt ^{AJ}. That matters most for the first entry on the OWASP Top 10 for Agentic Applications for 2026, Agent Goal Hijack ^{VF139}. The most effective mitigation for goal hijack is to give the agent no goal it can be hijacked towards: fixed steps, read-only tools and a scoped identity ^{AJ}. In the review's worked example, a deterministic workflow drafting monthly attribution commentary, most of the safety comes from that design, and the guardrails are the second line ^{AJ}.

Four predictable failures. Badly designed guardrails go wrong in the *wrong place*, screening only the user's prompt while retrieved documents and tool results, the real injection path for agents, pass unchecked. They use the *wrong mechanism*, asking a content-safety classifier to catch a business error such as a wrong sign on a currency effect. They generate *false positives that drive bypass*. And they *fail open* when a guard times out ^{AJ}.

Three mechanisms, layered. The distinction matters for latency, cost, explainability and false positives ^{AJ}.

- *Deterministic rules:* word filters, denied topics, entity patterns and numeric comparators. Fast and explainable, with false positives that are predictable and fixable ^{AJ}.
- *Small classifiers.* Prompt Guard 2's 22M-parameter variant is designed for low-latency, low-compute use, while Llama Guard 4 is a 12B model needing GPU-class serving ^{VF140}. Prompt Guard 2 has a 512-token window, so long documents must be chunked before screening ^{VF141 AJ}.

¹³⁹ Verified fact — R-OWASP-AGENTIC: OWASP Top 10 for Agentic Applications for 2026 (see [regulatory_facts.json](#)); A8-S042: OWASP Top 10 for Agentic Applications for 2026 (launched 9-10 December 2025) (OWASP GenAI Security Project) <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> accessed 2026-10-07 [search-tool extract]

¹⁴⁰ Verified fact — A6-S030: meta-llama/llama-guard-4-12B model card and LICENSE (Hugging Face); Llama Prompt Guard 2 model cards (Meta (via Hugging Face)) <https://huggingface.co/meta-llama/llama-guard-4-12B> accessed 2026-10-07 [search-tool extract]

¹⁴¹ Verified fact — A6-S030: meta-llama/llama-guard-4-12B model card and LICENSE (Hugging Face); Llama Prompt Guard 2 model cards (Meta (via Hugging Face)) <https://huggingface.co/meta-llama/llama-guard-4-12B> accessed 2026-10-07 [search-tool extract]

Part II: Nine layers and the controls that make them safe

- *Model-based judges*: an LLM checking the output. Flexible but slow and costly, and they can be manipulated by the same text they judge ^{AJ}.

Route design follows: rules everywhere, small classifiers on all untrusted input, and judges only where nothing cheaper can decide ^{Rec}. Unit costs differ by mechanism as well. As of 7 October 2026, Amazon Bedrock Guardrails billed content filters and denied topics at US\$0.15 per 1,000 text units per policy, while Google's Model Armor was free to 2M tokens a month and then US\$0.10 per 1M tokens ^{vf142}.

Failing closed is a design choice. NVIDIA NeMo Guardrails' IORails engine distinguishes policy blocks from rail execution failures ^{vf143}, which is what lets a route fail closed on errors without treating every error as a policy event ^{AJ}. Defaults vary: LiteLLM's prompt-injection guardrails are off by default ^{vf144}. Configure and test the behaviour explicitly ^{Rec}.

What changed in 2025–26. The hyperscalers now ship broad managed services. Bedrock Guardrails covers content and prompt-attack filters, denied topics, PII, contextual grounding and Automated Reasoning checks ^{vf145}. Azure Prompt Shields has been generally available since August 2024, with Task Adherence for agent tool use in preview ^{vf146}. Model Armor enforces data residency by default ^{vf147}. The review rates each as Strategic only where that cloud is the firm's primary cloud ^{AJ}.

¹⁴² Verified fact — A6-S101: Amazon Bedrock Pricing (Guardrails); Guardrails reduces pricing by up to 85% (Dec 2024); Safeguard tiers (June 2025) (Amazon Web Services) <https://aws.amazon.com/bedrock/pricing/> accessed 2026-10-07 [search-tool extract]; A6-S067: Model Armor product page (incl. pricing) (Google Cloud) <https://cloud.google.com/security/products/model-armor> accessed 2026-10-07

¹⁴³ Verified fact — A6-S036: NeMo Guardrails CHANGELOG.md (NVIDIA) <https://raw.githubusercontent.com/NVIDIA-NeMo/Guardrails/develop/CHANGELOG.md> accessed 2026-10-07

¹⁴⁴ Verified fact — A6-S015: LiteLLM docs: MCP Overview, Agent Gateway (A2A), Caching, Budgets/Rate Limits, v1.89.0 release notes (BerriAI (LiteLLM)) <https://docs.litellm.ai/docs/mcp> accessed 2026-10-07 [search-tool extract]

¹⁴⁵ Verified fact — A6-S072: AWS API model: Amazon Bedrock control plane (botocore service-2.json) - guardrail shapes (Amazon Web Services (via boto/botocore)) <https://raw.githubusercontent.com/boto/botocore/develop/botocore/data/bedrock/2023-04-20/service-2.json> accessed 2026-10-07

¹⁴⁶ Verified fact — A6-S055: What's new in Azure AI Content Safety? (Microsoft Learn source) <https://raw.githubusercontent.com/MicrosoftDocs/azure-ai-docs/main/articles/ai-services/content-safety/whats-new.md> accessed 2026-10-07

¹⁴⁷ Verified fact — A6-S067: Model Armor product page (incl. pricing) (Google Cloud) <https://cloud.google.com/security/products/model-armor> accessed 2026-10-07; B-C2-S003: Model Armor: Data residency and endpoints (Google Cloud) <https://docs.cloud.google.com/model-armor/data-residency> accessed 2026-10-08 [search-tool extract]

The open-source side is more fragile. NeMo Guardrails is still 0.x Beta ^{vr148}. Meta has released no new Llama Guard, Prompt Guard or LlamaFirewall since May 2025 ^{vr149}. Harvey announced its acquisition of Guardrails AI on 9 September 2026, after the project had retired hosted remote inference ^{vr150}. Security vendors are consolidating the field: Check Point bought Lakera and Palo Alto Networks bought Protect AI ^{vr151}. A two-detector design from different owners is therefore a concentration control as well as a security one ^{AI}.

The newest features target agent behaviour, checking whether a tool call fits the task, and those are in preview or unmaintained ^{vr152}. That supports the order of operations in the post: decide autonomy first, and treat guardrails as the second line, not the reason an agent is allowed to act ^{AI}.

The worked example's inline guard. Every retrieved chunk is screened for prompt attacks before it enters the prompt, and a flagged chunk is dropped and logged, not sanitised ^{rec}. A deterministic comparator extracts every figure, sign and direction word ("added", "detracted", "overweight") from the draft and checks each against the attribution engine output for that fund and period. Any mismatch blocks the

¹⁴⁸ Verified fact — A6-S003: nemoguardrails - PyPI JSON metadata (Python Package Index) <https://pypi.org/pypi/nemoguardrails/json> accessed 2026-10-07

¹⁴⁹ Verified fact — A6-S006: llamafirewall - PyPI JSON metadata (Python Package Index) <https://pypi.org/pypi/llamafirewall/json> accessed 2026-10-07; A6-S107: Llama Guard 4 model card; Llama Prompt Guard 2 model card; Llama Protections (Meta) <https://developer.meta.com/ai/docs/model-cards-and-prompt-formats/llama-guard-4/> accessed 2026-10-07 [search-tool extract]

¹⁵⁰ Verified fact — A6-S028: Guardrails AI Joins Harvey <https://www.harvey.ai/blog/guardrails-ai-joins-harvey> accessed 2026-10-07 [search-tool extract]; V2-S026: Guardrails AI Joins Harvey (with Artificial Lawyer 9 Sep 2026, The Next Web, unite.ai) <https://www.harvey.ai/blog/guardrails-ai-joins-harvey> accessed 2026-10-08 [search-tool extract]; V2-S071: Guardrails HUB_UPDATE.md (Guardrails AI (Harvey)) https://raw.githubusercontent.com/guardrails-ai/guardrails/main/HUB_UPDATE.md accessed 2026-10-08

¹⁵¹ Verified fact — A7-S012: Check Point to Acquire Lakera, Redefining Security for the AI era (Check Point Software) <https://blog.checkpoint.com/security/check-point-to-acquire-lakera-redefining-security-for-the-ai-era/> accessed 2026-10-07 [search-tool extract]; A7-S013: Check Point Software Technologies Completes Acquisition of Lakera to Secure the World's AI Transformation (CXOtoday (republished Check Point press release)) <https://cxotoday.com/press-release/check-point-software-technologies-completes-acquisition-of-lakera-to-secure-the-worlds-ai-transformation/> accessed 2026-10-07 [search-tool extract]; A7-S014: Palo Alto Networks Completes Acquisition of Protect AI <https://www.paloaltonetworks.com/company/press/2025/palo-alto-networks-completes-acquisition-of-protect-ai> accessed 2026-10-07 [search-tool extract]

¹⁵² Verified fact — A6-S055: What's new in Azure AI Content Safety? (Microsoft Learn source) <https://raw.githubusercontent.com/MicrosoftDocs/azure-ai-docs/main/articles/ai-services/content-safety/whats-new.md> accessed 2026-10-07; A6-S039: LlamaFirewall README (GitHub) (Meta) <https://raw.githubusercontent.com/meta-llama/PurpleLlama/main/LlamaFirewall/README.md> accessed 2026-10-07; A6-S107: Llama Guard 4 model card; Llama Prompt Guard 2 model card; Llama Protections (Meta) <https://developer.meta.com/ai/docs/model-cards-and-prompt-formats/llama-guard-4/> accessed 2026-10-07 [search-tool extract]

draft, and no model judge can override it ^{Rec}. If any guard times out, the draft is held and the analyst is told ^{Rec}.

The regulatory reading. ESMA expects “ex-ante input controls and frequent ex-post output controls” for AI in investment services ^{vr153}. Input guardrails are the ex-ante control; output guardrails plus online evaluation are the ex-post one ^{AI}. PRA SS1/23 includes model risk mitigants and ongoing performance monitoring ^{vr154}. A classifier or judge used as a guardrail is itself a model, and its false-positive and false-negative rates deserve monitoring like any other ^{AI}.

Policy is the asset. Keep the policy (what is forbidden, on which route) separate from the detector (which product detects it), and a vendor change swaps detectors without rewriting policy ^{AI}. The teams who curate the attack and benign test sets do the work that makes that swap safe, and they deserve the credit when it goes quietly ^{AI}.

What good looks like

The signal is the **false-positive rate**: the share of a labelled benign set, made of real, approved finance text, that the guardrails block ^{AI}. Measure it by running the benign regression set on every threshold or detector-version change, alongside an attack set mapped to the OWASP LLM and Agentic lists ^{Rec}. A starting target for a drafting route is below 1%, set per route rather than firm-wide ^{AI}.

Three companion measures stop the number being gamed. *Fail-closed conformance*: zero guard failures (timeouts, errors) that let a request through on a regulated route, tested with chaos tests. *Indirect-injection coverage*: 100% of external or third-party retrieved content screened before it enters a prompt. *Numeric grounding*: every figure and direction word matches the authoritative source before release ^{AI}.

¹⁵³ Verified fact — R-INTL-AI-ASSETMGMT: IOSCO Supervisory Toolkit for AI Use in Capital Markets (FR/02/2026) and ESMA Public Statement on AI and investment services (30 May 2024) (see [regulatory_facts.json](#)); A8-S059: ESMA Public Statement on AI and investment services (30 May 2024) and 2026 briefings <https://www.esma.europa.eu/document/public-statement-ai-and-investment-services> accessed 2026-10-07 [search-tool extract]

¹⁵⁴ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 ‘Model risk management principles for banks’ (published with PS6/23) (see [regulatory_facts.json](#)); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]

The 1% figure is an example target from the review, not a benchmark ^{AJ}. A firm should set its own threshold from its own benign set, and record every threshold change, with approver and reason, as a configuration change ^{Rec}.

In the worked example

Step 6: guardrails. A deterministic numeric comparator on every draft, injection screening of retrieved text, a PII check on output and denied topics (forecasts, advice). ^{AJ}

- **Now works:** A draft with any figure, sign or direction word that disagrees with the engine is blocked before a human sees it. ^{AJ}
- **Must never:** Guardrails back up the design; they never license more autonomy. ^{AJ}
- **Evidence added:** Guard results for every draft. ^{AJ}
- **Signal:** False-positive rate of the guards on a labelled set. ^{AJ}

Objections worth taking seriously

“Our cloud’s managed guardrail service covers this.” It covers a great deal: content, prompt attacks, PII and grounding ^{VF}¹⁵⁵. It does not know the firm’s business invariants. A polite, harmless, PII-free draft with a reversed currency effect passes every content check ^{AJ}. The deterministic business rules have to be the firm’s own code ^{Rec}. The service also processes the same client data as the model, so it belongs in the same residency and third-party analysis ^{AJ}. And a managed service on the request path is an ICT third-party dependency for the DORA register; if it is down, the route fails closed and the business service degrades ^{VF}¹⁵⁶ ^{AJ}.

“Any blocking slows people down; set thresholds loose.” Loose thresholds and over-sensitive thresholds fail the same way: people stop trusting the control ^{AJ}. The answer is a governed override path, in which an analyst requests release of a blocked draft, a second person approves, and a confirmed false positive joins the benign set ^{Rec}. Without that path, users find their own bypass ^{AJ}.

¹⁵⁵ Verified fact — A6-S072: AWS API model: Amazon Bedrock control plane (botocore service-2.json) - guardrail shapes (Amazon Web Services (via boto/botocore)) <https://raw.githubusercontent.com/boto/botocore/develop/botocore/data/bedrock/2023-04-20/service-2.json> accessed 2026-10-07; A6-S054: What is Azure AI Content Safety? (Microsoft Learn source) <https://raw.githubusercontent.com/MicrosoftDocs/azure-ai-docs/main/articles/ai-services/content-safety/overview.md> accessed 2026-10-07

¹⁵⁶ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see regulatory_facts.json); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]

“Layered guards add latency and cost.” They do, and the costs stack ^{AJ}. Running cheap checks first and stopping early on a block keeps most requests fast ^{AJ}. Give each guard a latency budget, a timeout and a defined outcome on timeout ^{Rec}. Judges cost a model call each, which is why they belong only where nothing simpler can decide ^{AJ}. Emitting each guard decision as a span on the request trace makes the cost and latency visible per route, so the trade-off is argued with data rather than instinct ^{Rec}.

Questions for your team

- Before we discuss guardrails for this use case, have we decided its autonomy and removed every write tool it does not need? ^{Rec}
- Do we screen retrieved documents and tool results, or only the user’s prompt? ^{Rec}
- Which of our business invariants (figures, signs, forbidden phrases) are checked by deterministic code, and which are left to a classifier? ^{Rec}
- What happens when a guard times out, and when did we last test it? ^{Rec}
- Who owns the guardrail policy and the benign and attack test sets, and are they held in our version control rather than a vendor console? ^{Rec}
- If one detector vendor changed hands, could we swap it without rewriting policy? ^{Rec}

In one line

Decide what the system may do first; guardrails then catch what slips through, and only if they fail closed and you own their tests. ^{AJ}

7. Easy tool connections make governance the architecture

L4 Tools, protocols and agent connectivity, from Post 7 of the series.

The post

Open tool protocols have made it easy to connect an agent to almost anything. That is exactly why tool governance now matters. ^{AJ}

A badly governed tool layer turns every weakness of a language model into an action. Prompt injection becomes exfiltration when the agent holds a token that can send email. A hallucinated argument becomes a wrong instruction when a write tool is exposed. A tool description becomes an attack vector when the client trusts whatever a third-party server says about itself. ^{AJ}

This is not theoretical. A benchmark published at AAAI 2026 tested tool-poisoning attacks against 45 live tool servers and 20 models. The average attack success rate was 36.5%, and more capable models were often more susceptible. ^{VF¹⁵⁷}

The protocols have made room for enterprise controls, but authorisation is still optional in the leading specification. So enforcement has to live outside it: one firm-owned tool gateway with mandatory authorisation, a private allow-listed registry, and every reviewed tool definition pinned by hash. ^{VF¹⁵⁸ Rec}

The signal is tool-definition drift: descriptions or schemas that changed since review. Zero unreviewed changes should reach production. A server that quietly updates its own description is a supply-chain change. ^{AJ}

¹⁵⁷ Verified fact — A3-S023: MCPTox: A Benchmark for Tool Poisoning Attack on Real-World MCP Servers (arXiv (academic preprint; AAAI 2026)) <https://arxiv.org/pdf/2508.14925> accessed 2026-10-07 [search-tool extract]

¹⁵⁸ Verified fact — A3-S055: MCP Specification 2026-07-28: Authorization (Model Context Protocol project (GitHub)) <https://raw.githubusercontent.com/modelcontextprotocol/modelcontextprotocol/main/docs/specification/2026-07-28/basic/authorization/index.mdx> accessed 2026-10-07; A3-S015: The 2026-07-28 Specification (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/2026-07-28/> accessed 2026-10-07

Part II: Nine layers and the controls that make them safe

The leadership move is to expose authoritative data through read-only tools owned by the system's team, and to make every write a separate tool, a separate approval and a human confirmation. ^{Rec}

The honest caveat: a gateway in front of every tool adds latency and a new critical dependency. It has to be run like one, with the same resilience as anything else on the request path. ^{AJ}

Connecting tools is now the easy part. Deciding what each one may do, and on whose behalf, is the architecture. ^{AJ}

7. Easy tool connections make governance the architecture

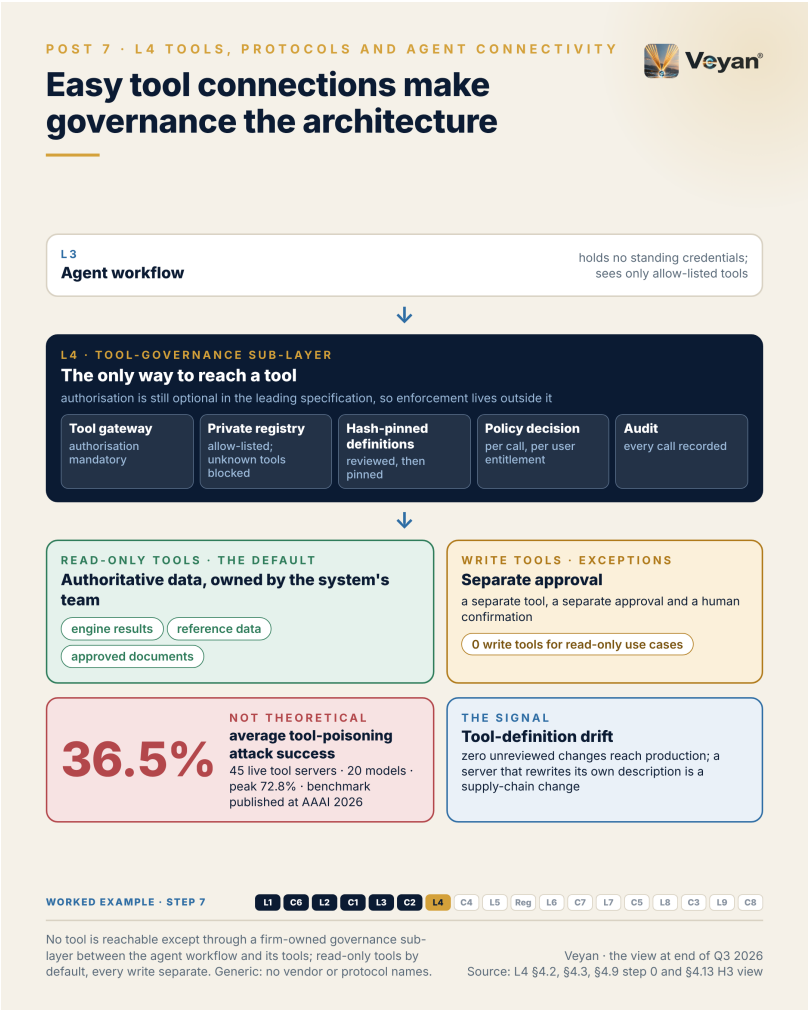


Figure 7. No tool is reachable except through a firm-owned governance sub-layer between the agent workflow and its tools; read-only tools by default, every write separate. Generic: no vendor or protocol names. ^{AJ}

Behind the post

This layer is where an agent stops talking and starts acting. It calls tools, reads enterprise systems, browses, runs code and talks to other agents ^{AJ}. Its jobs are tool

invocation, enterprise-system connectivity, execution sandboxes and protocol interoperability. The review adds a fifth that the protocols leave open: deciding which agent, acting for which person, may call which tool with which arguments and which credential, and recording that decision ^{AJ}.

The evidence that the risk is real. The MCPTox benchmark, published at AAAI 2026, ran tool-poisoning attacks against 45 live servers and 20 models, with an average attack success rate of 36.5% and a peak of 72.8% ^{vf¹⁵⁹}. Cloud Security Alliance research notes describe high-severity issues between mid-2025 and June 2026 in several developer tools that launched project-defined tool servers with developer privileges and no isolation, though CSA's attribution and dates are inconsistent across its notes ^{vf¹⁶⁰}. In May 2026 Composio, a broker that holds end users' OAuth tokens for third-party applications, disclosed unauthorised access to internal systems; by its own account about 0.3% of active connections leaked and 5,241 API keys were flagged as possibly exposed ^{vf¹⁶¹}. A broker that holds every user's tokens is a concentrated breach target and hard to exit ^{AJ}.

What changed in 2025–26: the protocols found neutral homes. The Model Context Protocol (MCP) originated at Anthropic and was donated to the Agentic AI Foundation, under the Linux Foundation, on 9 December 2025 ^{vf¹⁶²}. A2A, the agent-to-agent protocol, reached 1.0.0 on 12 March 2026 and joined the same foundation in August 2026 ^{vf¹⁶³}. A disclosure is due here: this book was prepared with the help

¹⁵⁹ Verified fact — A3-S023: MCPTox: A Benchmark for Tool Poisoning Attack on Real-World MCP Servers (arXiv (academic preprint; AAAI 2026)) <https://arxiv.org/pdf/2508.14925> accessed 2026-10-07 [search-tool extract]

¹⁶⁰ Reported — A3-S022: MCP Attack Surface: Tool Poisoning and IDE Auto-Execution (CSA research note, Jul 2026) (Cloud Security Alliance Labs) <https://labs.cloudsecurityalliance.org/research/csa-research-note-mcp-tool-poisoning-auto-execution-20260701/> accessed 2026-10-07 [search-tool extract]

¹⁶¹ Verified fact — B-L4-S007: Composio May 2026 security incident update <https://composio.dev/blog/composio-may-2026-security-incident> accessed 2026-10-08 [search-tool extract]

¹⁶² Verified fact — A3-S018: MCP joins the Agentic AI Foundation (9 Dec 2025) (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/2025-12-09-mcp-joins-agentic-ai-foundation/> accessed 2026-10-07; V1-S038: Linux Foundation Announces the Formation of the Agentic AI Foundation (AAIF) (The Linux Foundation) <https://www.linuxfoundation.org/press/linux-foundation-announces-the-formation-of-the-agentic-ai-foundation> accessed 2026-10-08 [search-tool extract]

¹⁶³ Verified fact — A3-S079: A2A CHANGELOG (A2A Project (GitHub)) <https://raw.githubusercontent.com/a2aproject/A2A/main/CHANGELOG.md> accessed 2026-10-07; A3-S116: A2A joins AAIF's open agentic stack (17 Aug 2026) (Agentic AI Foundation (AAIF)) <https://aaif.io/blog/a2a-joins-aaif> accessed 2026-10-07 [search-tool extract]; A3-S117: A New Chapter for A2A: Joining the Agentic AI Foundation (27 Aug 2026) (A2A Project) <https://a2a-protocol.org/latest/blog/2026/08/27/a-new-chapter-for-a2a-joining-the-agentic-ai-foundation/> accessed 2026-10-07 [search-tool extract]

of an Anthropic model, and both of MCP's Lead Maintainers are Anthropic staff ¹⁶⁴. The review scored MCP on the same rubric as everything else and names an independent alternative wherever it recommends it: OpenAPI-described tools exposed through the same gateway, with A2A for agent-to-agent delegation ^{Rec.}.

The protocol now makes room for governance, but does not supply it. MCP's 2026-07-28 revision is stateless, puts method and tool names in HTTP headers so that gateways can authorise them without parsing bodies, and deprecates Dynamic Client Registration ¹⁶⁵. The Enterprise-Managed Authorization extension has been stable since June 2026 ¹⁶⁶. Yet authorisation itself remains optional in the specification ¹⁶⁷, and tool annotations such as "read-only" or "destructive" are hints that clients must treat as untrusted unless the server is trusted ¹⁶⁸. MCP's own roadmap says the current model is "built around a person approving access in a browser" ¹⁶⁹. A2A leaves the same gap: Agent Card signing is optional and delegated-authority semantics are undefined ¹⁷⁰. Enforcement therefore has to live somewhere outside the protocol ^{AI.}.

The tool-governance sub-layer. The review's verdict is to draw a sub-layer between the workflow and its tools, so that no tool is reachable except through it ^{AI.}. It has five parts ^{Rec.}.

¹⁶⁴ Verified fact — A3-S082: Expanding the MCP Maintainer Team (8 Apr 2026) (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/2026-04-08-maintainer-update/> accessed 2026-10-07

¹⁶⁵ Verified fact — A3-S015: The 2026-07-28 Specification (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/2026-07-28/> accessed 2026-10-07; A3-S057: MCP Specification 2026-07-28: Key Changes (Model Context Protocol project (GitHub)) <https://raw.githubusercontent.com/modelcontextprotocol/modelcontextprotocol/main/docs/specification/2026-07-28/changelog.mdx> accessed 2026-10-07

¹⁶⁶ Verified fact — A3-S017: Enterprise-Managed Authorization: Zero-touch OAuth for MCP (18 Jun 2026) (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/enterprise-managed-auth/> accessed 2026-10-07

¹⁶⁷ Verified fact — A3-S055: MCP Specification 2026-07-28: Authorization (Model Context Protocol project (GitHub)) <https://raw.githubusercontent.com/modelcontextprotocol/modelcontextprotocol/main/docs/specification/2026-07-28/basic/authorization/index.mdx> accessed 2026-10-07

¹⁶⁸ Verified fact — A3-S020: Tool Annotations as Risk Vocabulary (16 Mar 2026) (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/2026-03-16-tool-annotations/> accessed 2026-10-07

¹⁶⁹ Verified fact — A3-S016: The New MCP Roadmap (22 Aug 2026) (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/mcp-roadmap/> accessed 2026-10-07

¹⁷⁰ Verified fact — A3-S078: A2A Protocol Specification (source, latest released version 1.0.0) (A2A Project (GitHub)) <https://raw.githubusercontent.com/a2aproject/A2A/main/docs/specification.md> accessed 2026-10-07

Part II: Nine layers and the controls that make them safe

- *A tool gateway with mandatory authorisation*, accepting only audience-bound tokens. This is usually the same gateway product that fronts model calls ^{A1}.
- *A private, allow-listed registry*. The official MCP Registry is still in preview, its API frozen at v0.1, and it moderates by denylisting ^{vf171}. GitHub Copilot can be pointed at an organisation's own registry, and Microsoft documents a private registry on Azure that is enforced in Copilot and VS Code ^{vf172}.
- *Hash-pinned definitions*. OWASP's MCP Top 10 recommends signing manifests and hash-pinning reviewed definitions against "rug pulls" ^{vf173}.
- *A policy decision per call*. Amazon Bedrock AgentCore Policy evaluates every agent-to-tool call against Cedar policies before execution and filters denied tools out of the tool list; OPA is the vendor-neutral alternative ^{vf174}.
- *An audit event per call*, recording subject, agent, tool, definition hash, arguments or their hash, decision and timestamp ^{A1}.

Read-only by default. Classify each tool's effect yourself rather than trusting the server's annotations ^{vf175} ^{Rec}. In the worked example, an agent drafting monthly attribution commentary needs exactly four tools: read-only access to the attribution engine's published results, read-only fund reference data, a sandboxed calculator with no network egress and no credentials, and retrieval of approved prior commentary ^{A1}. It holds no write, publish or email tool; publication happens after human approval, outside the agent ^{Rec}. There is a model-risk reason too. PRA SS1/23 allows model risk management to apply to complex deterministic methods that are

¹⁷¹ Verified fact — A3-S019: Introducing the MCP Registry (8 Sep 2025) (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/2025-09-08-mcp-registry-preview/> accessed 2026-10-07; A3-S042: modelcontextprotocol/registry (GitHub README) (Model Context Protocol project) <https://github.com/modelcontextprotocol/registry> accessed 2026-10-07 [search-tool extract]; A3-S036: Official MCP Registry API v0.1 sample response (v0.2 and v1 paths returned HTTP 404 on 7 Oct 2026) (Model Context Protocol project) <https://registry.modelcontextprotocol.io/v0.1/servers?limit=1> accessed 2026-10-07

¹⁷² Verified fact — A3-S043: Configure an MCP registry for your organization or enterprise (GitHub Docs) <https://docs.github.com/en/copilot/how-tos/administer-copilot/manage-mcp-usage/configure-mcp-registry> accessed 2026-10-07 [search-tool extract]; A3-S044: Locking Down MCP: Create a Private Registry on Azure API Center and Enforce It in GitHub Copilot And VS Code (Microsoft (All things Azure devblog)) <https://devblogs.microsoft.com/all-things-azure/locking-down-mcp-create-a-private-registry-on-azure-api-center-and-enforce-it-in-github-copilot-and-vs-code/> accessed 2026-10-07 [search-tool extract]

¹⁷³ Verified fact — A3-S045: OWASP MCP Top 10: MCP03:2025 Tool Poisoning <https://owasp.org/www-project-mcp-top-10/2025/MCP03-2025%E2%80%9393Tool-Poisoning> accessed 2026-10-07 [search-tool extract]

¹⁷⁴ Verified fact — A6-S026: Policy in Amazon Bedrock AgentCore is now generally available; AgentCore Policy docs; Why Policy in AgentCore chose Cedar (Amazon Web Services) <https://aws.amazon.com/about-aws/whats-new/2026/03/policy-amazon-bedrock-agentcore-generally-available/> accessed 2026-10-07 [search-tool extract]; A6-S046: Open Policy Agent README (GitHub) (Open Policy Agent project (CNCF)) <https://raw.githubusercontent.com/open-policy-agent/opa/main/README.md> accessed 2026-10-07

¹⁷⁵ Verified fact — A3-S020: Tool Annotations as Risk Vocabulary (16 Mar 2026) (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/2026-03-16-tool-annotations/> accessed 2026-10-07

not models¹⁷⁶. An agent that recomputes what a validated engine already produces has created an unvalidated shadow model^{AJ}.

Every SaaS tool is a third party. DORA requires a register covering all ICT third-party arrangements¹⁷⁷, and search, browser, sandbox and integration services each belong in it^{AJ}. Ownership moves: Nebius closed its acquisition of Tavily on 19 February 2026¹⁷⁸. No EU processing region was found for Exa or Tavily¹⁷⁹. A search query can disclose confidential intent, such as a planned trade or a client's concern, even with no personal data in it, so the control is “no client context in outbound queries”, enforced at an egress proxy^{AJ}.

The credit for this work goes to the platform teams who build the unglamorous enforcement point, and to the system owners who expose their data through tools they are willing to stand behind^{AJ}.

What good looks like

The signal is **tool-definition drift**: tool descriptions or schemas that have changed since review, detected as a hash mismatch against the pinned definition^{AJ}. Measure it by pinning every reviewed definition by hash in the private registry, alerting on any diff, and blocking the changed tool at the gateway until it is re-reviewed^{REC}. The starting target is zero unreviewed changes reaching production^{AJ}.

Three companion measures cover the rest of the sub-layer. *Authorised-call coverage*: 100% of remote tool calls carry an audience-bound token validated at the gateway. *Write-scope exposure*: zero write or destructive tools exposed to a read-

¹⁷⁶ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 ‘Model risk management principles for banks’ (published with PS6/23) (see [regulatory_facts.json](#)); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]

¹⁷⁷ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see [regulatory_facts.json](#)); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]

¹⁷⁸ Verified fact — A3-S084: Tavily is Joining Nebius (10 Feb 2026) <https://www.tavily.com/blog/tavily-is-joining-nebius> accessed 2026-10-07 [search-tool extract]; V1-S041: Nebius Group N.V. Form 20-F FY2025 (subsequent event: Tavily acquisition) (Nebius Group N.V. (SEC EDGAR)) <https://www.sec.gov/Archives/edgar/data/0001513845/000110465926052948/nbis-20251231x20f.htm> accessed 2026-10-08 [search-tool extract]

¹⁷⁹ Verified fact — A3-S121: Exa Security Overview (and [exa.ai/enterprise](#), [exa.ai/dpa](#)) <https://exa.ai/docs/reference/security> accessed 2026-10-07 [search-tool extract]; A3-S088: Tavily pricing, FAQ and help-centre security pages <https://www.tavily.com/pricing> accessed 2026-10-07 [search-tool extract]

only use case, with each exception named and approved. *Time to revoke*: under an hour from the decision to block a server, tool or credential until it is enforced everywhere, proven by drill ^{AJ}.

These are starting points from the review's guidance, not industry benchmarks ^{AJ}. The drill matters more than the number: a firm that has never revoked a tool does not know how long it takes ^{AJ}.

In the worked example

Step 7: tools. Four tools behind the tool gateway: read-only attribution results with a snapshot hash, read-only fund reference data, a sandboxed calculator for derived figures, and retrieval of approved commentary. ^{AJ}

- **Now works:** Every figure in the draft traces to a snapshot ID and hash. ^{AJ}
- **Must never:** No write, publish or e-mail tool exists, so none can be misused. ^{AJ}
- **Evidence added:** Every tool call with its arguments hash and decision. ^{AJ}
- **Signal:** Write tools in a read-only use case: zero. ^{AJ}

Objections worth taking seriously

“The specification is improving. Wait until it makes authorisation mandatory.” The direction is encouraging, and the 2026-07-28 revision tightened issuer validation ^{VF180}. But the roadmap still describes agent identity as a priority rather than a feature ^{VF181}. A gateway works whatever the next revision says, and pinning the revision at the gateway turns each protocol change into a tested upgrade rather than a surprise ^{Dec}.

“A gateway in front of every tool is a single point of failure.” It is a critical dependency, and the post says so ^{AJ}. The stateless 2026-07-28 revision removes session affinity, so tool servers can sit behind ordinary load balancers ^{VF182}. Run the gateway with the same resilience, monitoring and break-glass procedure as anything else on the request path, and give each workflow a graceful “tool

¹⁸⁰ Verified fact — A3-S057: MCP Specification 2026-07-28: Key Changes (Model Context Protocol project (GitHub)) <https://raw.githubusercontent.com/modelcontextprotocol/modelcontextprotocol/main/docs/specification/2026-07-28/changelog.mdx> accessed 2026-10-07

¹⁸¹ Verified fact — A3-S016: The New MCP Roadmap (22 Aug 2026) (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/mcp-roadmap/> accessed 2026-10-07

¹⁸² Verified fact — A3-S015: The 2026-07-28 Specification (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/2026-07-28/> accessed 2026-10-07

unavailable” route ^{Rec}. The alternative is worse: without a gateway, every agent host becomes its own policy engine, and the firm has as many security models as it has agent hosts ^{AJ}. An agent that silently answers from model memory when a data tool fails is worse than one that stops ^{AJ}.

“A private registry slows developers down.” It slows the first connection, briefly ^{AJ}. In return it makes approved tools discoverable and gives every tool a named owner and risk class ^{Rec}. The slower path is retrofitting governance after a community server has quietly changed its own description ^{AJ}. The registry can also carry the review itself: an owner, a risk class, a definition hash and a change process for each tool, so approval becomes a routine step rather than a negotiation each time ^{Rec}.

Questions for your team

- Can any agent in our estate reach a tool except through a gateway we own? ^{Rec}
- Which remote tool servers accept calls without an audience-bound token today? ^{Rec}
- Do we pin reviewed tool definitions by hash, and what happens when one changes? ^{Rec}
- Which of our agents can reach a write, publish or email tool, and was each one approved? ^{Rec}
- Who classifies a tool's risk: the server's own annotations, or a named owner on our side? ^{Rec}
- Is every search, browser, sandbox and integration service in our third-party register, with its data location known? ^{Rec}
- How long would it take us to revoke one tool everywhere, and have we tested it? ^{Rec}

In one line

Connecting a tool now takes minutes; governing what it may do, for whom, is the part of the architecture that has to be designed. ^{AJ}

8. “Who did this?” needs an answer for agents

C4 Identity and access for agents, from Post 8 of the series.

The post

“Who did this?” is the first question in every incident review. When the actor is an agent, many logs can answer only with the name of a shared service account. ^{AJ}

Agents turn identity mistakes into actions. A person with excessive access usually does nothing with it. An agent with excessive access can be steered into using it by text it reads, which is why the OWASP list for agentic applications names identity and privilege abuse alongside goal hijack and tool misuse. ^{VF¹⁸³ AJ}

A tool gateway decides what can be called. Identity decides who is allowed through it. Five properties hold up. The agent has its own registered identity with a named sponsor. Where a person started the work, it acts on that person’s behalf. Its permissions are the intersection of that person’s and the agent’s own ceiling. It holds no standing secrets, only short-lived tokens scoped to the task. And every action is attributable to both. ^{Rec}

The signal is attribution completeness: the share of audit events recording user, agent, tool, an argument hash, the policy decision and a trace ID. Aim for 99.9% or better. A gap is a question you cannot answer later. ^{AJ}

The leadership move is to carry segregation of duties across unchanged. An agent may draft; it may not approve. The approver is a different, entitled person. And a write tool the agent never calls should still not be reachable. ^{Rec}

¹⁸³ Verified fact — B-C4-S005: OWASP Top 10 for Agentic Applications (release post and related OWASP pages) (OWASP GenAI Security Project) <https://genai.owasp.org/2025/12/09/owasp-top-10-for-agentic-applications-the-benchmark-for-agentic-security-in-the-age-of-autonomous-ai/> accessed 2026-10-08 [search-tool extract]; R-OWASP-AGENTIC: OWASP Top 10 for Agentic Applications for 2026 (see regulatory_facts.json); A8-S042: OWASP Top 10 for Agentic Applications for 2026 (launched 9-10 December 2025) (OWASP GenAI Security Project) <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> accessed 2026-10-07 [search-tool extract]

8. “Who did this?” needs an answer for agents

The honest caveat: no rule yet names an accountable person for an agent. Mapping every agent to a sponsor, and through the business to a senior manager, is a judgement worth making before anyone asks. ^{VF¹⁸⁴, AJ}

Accountability does not disappear when work is automated. It needs a name, and the system has to record it. ^{AJ}

¹⁸⁴ Verified fact — R-UK-AI-STATEMENTS: FCA, Bank of England and PRA statements and initiatives on AI, 2024-2026 (see regulatory_facts.json); A8-S055: FCA announces second cohort for AI Live Testing (April 2026); FS25/5; Mills Review (Financial Conduct Authority) <https://www.fca.org.uk/news/press-releases/fca-announces-second-cohort-ai-live-testing> accessed 2026-10-07 [search-tool extract]



Figure 8. One attribution chain: the agent acts for the analyst on a short-lived, read-only token; a different, entitled person approves. Generic worked example, no vendor names. ^{AJ}

Behind the post

This control answers the question every incident review and every regulator will ask: who did this, on whose authority, and with what permission ^{AJ}? For people,

firms have decades of practice in joiners, movers and leavers, access reviews and segregation of duties. For agents, much of that practice has to be rebuilt, because an agent is neither a person nor a conventional batch job ^{AJ}.

Why agents change the risk. A person with excessive access usually does nothing with it. An agent with excessive access may be steered into using it by text it reads ^{AJ}. The OWASP Top 10 for Agentic Applications for 2026 lists Identity and Privilege Abuse (ASI03), where leaked or excessive credentials let agents operate beyond their intended scope, next to Agent Goal Hijack (ASI01) and Tool Misuse and Exploitation (ASI02) ^{VF185}. Four failures recur ^{AJ}:

- *Shared service accounts*, so logs cannot say which person started an action.
- *Standing credentials*: API keys and refresh tokens in agent configuration or prompts that outlive the task.
- *Token passthrough*, where a tool server forwards the caller's token downstream and becomes a confused deputy. The MCP specification forbids it ^{VF186}.
- *Ungoverned agents*, created by developers with no owner, review or revocation path.

Three identity patterns. Microsoft's Entra Agent ID documentation draws the distinction clearly: a client-credentials flow for autonomous agents, an on-behalf-of flow for delegation, and a refresh-token flow for long-running user-delegated work, with no interactive sign-in for agent entities ^{VF187}. Delegated, on-behalf-of access carries the lowest risk, because the agent's effective permission is at most the user's and attribution is native ^{AJ}. Autonomous access makes the agent's own grants the ceiling, so they must be narrow and reviewed ^{AJ}. An agent given a user account carries the highest risk: it looks like a person in logs and in access reviews ^{AJ}.

Intersection, not union. The right mental model is that effective permission is the intersection of the user's entitlements and the agent's ceiling ^{AJ}. HashiCorp Vault

¹⁸⁵ Verified fact — B-C4-S005: OWASP Top 10 for Agentic Applications (release post and related OWASP pages) (OWASP GenAI Security Project) <https://genai.owasp.org/2025/12/09/owasp-top-10-for-agentic-applications-the-benchmark-for-agentic-security-in-the-age-of-autonomous-ai/> accessed 2026-10-08 [search-tool extract]; R-OWASP-AGENTIC: OWASP Top 10 for Agentic Applications for 2026 (see regulatory_facts.json); A8-S042: OWASP Top 10 for Agentic Applications for 2026 (launched 9-10 December 2025) (OWASP GenAI Security Project) <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> accessed 2026-10-07 [search-tool extract]

¹⁸⁶ Verified fact — A6-S034: MCP specification 2026-07-28: Authorization security considerations (Model Context Protocol project) <https://raw.githubusercontent.com/modelcontextprotocol/modelcontextprotocol/main/docs/specification/2026-07-28/basic/authorization/security-considerations.mdx> accessed 2026-10-07

¹⁸⁷ Verified fact — A6-S060: Authentication protocols for agents (Microsoft Learn source) <https://raw.githubusercontent.com/MicrosoftDocs/entra-docs/main/docs/agent-id/agent-oauth-protocols.md> accessed 2026-10-07

Enterprise 2.1, generally available from 1 September 2026, enforces exactly that, alongside request-scoped authorisation details, and records both user and agent in its audit logs¹⁸⁸. In the worked example, the agent cannot read a fund the analyst cannot, and a write tool is not merely unused but absent from its tool list^{Rec}.

What changed in 2025–26: the products became generally available. Auth0 for AI Agents reached general availability on 19 November 2025¹⁸⁹. Microsoft Entra Agent ID followed in April 2026, with its security features tied to Microsoft Agent 365 licences¹⁹⁰. Okta for AI Agents reached general availability on 30 April 2026 and Okta Agent SSO (Cross App Access) on 24 August 2026¹⁹¹. Policy engines matured too. Amazon Bedrock AgentCore Policy, built on Cedar, became generally available on 3 March 2026, while OPA and SPIFFE/SPIRE (for workload identity) are graduated CNCF projects¹⁹².

¹⁸⁸ Verified fact — A7-S033: Vault release notes 2.x; IBM Vault Self-Managed 2.x.x lifecycle page (HashiCorp (IBM)) <https://developer.hashicorp.com/vault/docs/updates/release-notes> accessed 2026-10-07 [search-tool extract]; A7-S034: HashiCorp Vault agentic IAM is now generally available (HashiCorp (IBM)) <https://www.hashicorp.com/en/blog/hashicorp-vault-agentic-iam-is-now-generally-available> accessed 2026-10-07 [search-tool extract]

¹⁸⁹ Verified fact — A6-S097: Auth0 for AI Agents is Now Generally Available (GA); Auth0 May 2026 product innovations (Auth0 (Okta)) <https://auth0.com/blog/auth0-for-ai-agents-generally-available/> accessed 2026-10-07 [search-tool extract]

¹⁹⁰ Verified fact — A6-S058: What's new in Microsoft Entra Agent ID (Microsoft Learn source) <https://raw.githubusercontent.com/MicrosoftDocs/entra-docs/main/docs/agent-id/whats-new-agent-id.md> accessed 2026-10-07; A6-S059: Microsoft Entra Agent ID licensing (include file) <https://raw.githubusercontent.com/MicrosoftDocs/entra-docs/main/docs/includes/licensing-agent-id.md> accessed 2026-10-07; V2-S032: Microsoft Entra releases and announcements (with What's new in Entra Agent ID; Entra blog 'Build AI agents for production with secure identities from day one'; <https://learn.microsoft.com/en-us/entra/fundamentals/whats-new> accessed 2026-10-08 [search-tool extract]

¹⁹¹ Verified fact — A6-S100: Okta for AI Agents is Now Generally Available; Okta announces new blueprint for the secure agentic enterprise (Okta, Inc.) <https://www.okta.com/blog/ai/okta-for-ai-agents-general-availability/> accessed 2026-10-07 [search-tool extract]; A6-S099: Okta brings first-class identity to AI agents with Agent SSO; Okta Introduces Agent SSO for Cross App Access (XAA) (Okta, Inc.) <https://www.okta.com/newsroom/press-releases/okta-brings-first-class-identity-to-ai-agents-with-agent-ss/> accessed 2026-10-07 [search-tool extract]; V2-S035: Okta brings first-class identity to AI agents with Agent SSO (with Okta support article, OIE release notes, Oktane 2026 release) <https://www.okta.com/newsroom/press-releases/okta-brings-first-class-identity-to-ai-agents-with-agent-ss/> accessed 2026-10-08 [search-tool extract]

¹⁹² Verified fact — A6-S026: Policy in Amazon Bedrock AgentCore is now generally available; AgentCore Policy docs; Why Policy in AgentCore chose Cedar (Amazon Web Services) <https://aws.amazon.com/about-aws/whats-new/2026/03/policy-amazon-bedrock-agentcore-generally-available/> accessed 2026-10-07 [search-tool extract]; V2-S033: Policy in Amazon Bedrock AgentCore is now generally available (with AgentCore policy authoring guide and FAQ) (Amazon Web Services) <https://aws.amazon.com/about-aws/whats-new/2026/03/policy-amazon-bedrock-agentcore-generally-available/> accessed 2026-10-08 [search-tool extract]; A6-S046: Open Policy Agent README (GitHub) (Open Policy Agent project (CNCF)) <https://raw.githubusercontent.com/open-policy-agent/opa/main/README.md> accessed 2026-10-07; A6-S087: SPIRE README (GitHub) (SPIFFE project (CNCF)) <https://raw.githubusercontent.com/spiffe/spire/main/README.md> accessed

The protocol piece. Okta states that Cross App Access is the MCP Enterprise-Managed Authorization extension ^{vf193}. In that pattern the corporate identity provider issues an assertion during single sign-on, which the client exchanges for an access token using the IETF token-exchange standards RFC 8693 and RFC 7523 ^{vf194}. That puts the decision about which tool servers an employee can use in the identity provider ^{vf195}. MCP originated at Anthropic, and this book was prepared with the help of an Anthropic model, so the disclosure applies ^{ai}. MCP authorisation remains optional, and OAuth 2.1 is still an IETF draft ^{vf196}. The independent route is to apply the same token-exchange standards to OpenAPI-described tools behind the same gateway ^{rec}.

Segregation of duties carries over unchanged. An agent may draft but not approve; the approver must be a different, entitled person; a policy change needs a second person ^{rec}. OpenID CIBA lets an agent request asynchronous approval from a person out of band, and Auth0’s AI SDKs implement it ^{vf197}. In the worked example, the portfolio manager approves through single sign-on with step-up authentication, and the approval records the manager’s identity, the draft hash and the time ^{rec}.

The regulatory gap. The FCA has no AI-specific rules and relies on existing frameworks, including the Senior Managers and Certification Regime and Consumer

2026-10-07

¹⁹³ Verified fact — A6-S099: Okta brings first-class identity to AI agents with Agent SSO; Okta Introduces Agent SSO for Cross App Access (XAA) (Okta, Inc.) [https://www.okta.com/newsroom/press-releases/okta-brings-first-class-identity-to-ai-agents-with-agent-sso/](https://www.okta.com/newsroom/press-releases/okta-brings-first-class-identity-to-ai-agents-with-agent-ss/) accessed 2026-10-07 [search-tool extract]; V2-S035: Okta brings first-class identity to AI agents with Agent SSO (with Okta support article, OIE release notes, Oktane 2026 release) <https://www.okta.com/newsroom/press-releases/okta-brings-first-class-identity-to-ai-agents-with-agent-sso/> accessed 2026-10-08 [search-tool extract]

¹⁹⁴ Verified fact — A6-S035: MCP extension: Enterprise-Managed Authorization (overview) (Model Context Protocol project) <https://raw.githubusercontent.com/modelcontextprotocol/modelcontextprotocol/main/docs/extensions/auth/enterprise-managed-authorization.mdx> accessed 2026-10-07; A6-S079: MCP ext-auth: Enterprise-Managed Authorization specification (Stable) (Model Context Protocol project) <https://raw.githubusercontent.com/modelcontextprotocol/ext-auth/main/specification/stable/enterprise-managed-authorization.mdx> accessed 2026-10-07

¹⁹⁵ Verified fact — A6-S035: MCP extension: Enterprise-Managed Authorization (overview) (Model Context Protocol project) <https://raw.githubusercontent.com/modelcontextprotocol/modelcontextprotocol/main/docs/extensions/auth/enterprise-managed-authorization.mdx> accessed 2026-10-07

¹⁹⁶ Verified fact — A6-S033: MCP specification 2026-07-28: Authorization (Model Context Protocol project) <https://raw.githubusercontent.com/modelcontextprotocol/modelcontextprotocol/main/docs/specification/2026-07-28/basic/authorization/index.mdx> accessed 2026-10-07

¹⁹⁷ Verified fact — A6-S078: Auth0 AI for JavaScript README (GitHub) (Auth0 (Okta)) <https://raw.githubusercontent.com/auth0/auth0-ai-js/main/README.md> accessed 2026-10-07; A6-S076: auth0-ai - PyPI JSON metadata (Python Package Index) <https://pypi.org/pypi/auth0-ai/json> accessed 2026-10-07

Duty¹⁹⁸. No rule names an accountable person for an agent, so mapping each agent to a sponsor and, through the business area, to a Senior Manager is a judgement^{AJ}. The FPC said in 2026 that agentic AI had not yet been adopted in a way presenting systemic risk, but that risks were likely to increase, potentially rapidly¹⁹⁹. Under the EU AI Act, Article 26 requires deployers of high-risk systems to keep logs for at least six months²⁰⁰. Logs without user and agent identity cannot show who operated the system^{AJ}. In the US, an NCCoE concept paper on software and AI agent identity and authorisation appeared in February 2026²⁰¹.

The root of trust moves. The workforce identity provider is already a critical dependency. Adding agents makes it the root of trust for automated actions too^{AJ}. An agent's permissions are part of its risk tier: the same model with write access is a different risk from one with read-only access^{AJ}. Identity teams rarely get credit for incidents that never happen; this is a good place to give it^{AJ}.

What good looks like

The signal is **attribution completeness**: the share of audit events that record user, agent, tool, an argument hash, the policy decision and a trace ID^{AJ}. Measure it with a scheduled completeness check on the audit store, and reconcile policy-decision logs against tool calls so that no call escapes evaluation^{Rec}. A starting target is 99.9% or better, and every missing field is investigated as a defect^{AJ}.

Four companion measures make the chain credible. *Delegated-call share*: 100% of tool calls in user-initiated work carry a user-bound, on-behalf-of token. *Standing credentials*: zero long-lived secrets held by agents, with any exception time-limited

¹⁹⁸ Verified fact — R-UK-AI-STATEMENTS: FCA, Bank of England and PRA statements and initiatives on AI, 2024-2026 (see regulatory_facts.json); A8-S055: FCA announces second cohort for AI Live Testing (April 2026); FS25/5; Mills Review (Financial Conduct Authority) <https://www.fca.org.uk/news/press-releases/fca-announces-second-cohort-ai-live-testing> accessed 2026-10-07 [search-tool extract]

¹⁹⁹ Verified fact — R-UK-AI-STATEMENTS: FCA, Bank of England and PRA statements and initiatives on AI, 2024-2026 (see regulatory_facts.json); A8-S056: Financial Policy Committee Record April 2026; FSR July 2026; 2026 AI survey (Bank of England) <https://www.bankofengland.co.uk/financial-policy-committee-record/2026/april-2026> accessed 2026-10-07 [search-tool extract]

²⁰⁰ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see regulatory_facts.json); A8-S011: Regulation (EU) 2026/1744 (Digital Omnibus on AI) amending Regulation (EU) 2024/1689 (EUR-Lex / Official Journal of the EU) <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> accessed 2026-10-07 [search-tool extract]

²⁰¹ Verified fact — R-NIST-AIRMF: NIST AI Risk Management Framework (AI RMF 1.0, NIST AI 100-1) and Generative AI Profile (NIST AI 600-1) (see regulatory_facts.json); A8-S044: NIST AI 600-1 Generative AI Profile; NCCoE agent identity concept paper; CAISI agent security <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence> accessed 2026-10-07 [search-tool extract]

and owned. *Time to revoke*: under 15 minutes from a decision to revoke an agent to its last successful call, proven by drill. *Approval integrity*: every approval made by someone other than the requester, and entitled to approve ^{AJ}.

These targets come from the review’s guidance. They are a starting point, not an industry benchmark ^{AJ}.

In the worked example

Step 8: identity. A registered agent identity with a named sponsor; it acts on behalf of the analyst with a read-only, minutes-long token; a different portfolio manager approves with step-up authentication. ^{AJ}

- **Now works:** Every action answers ‘who did this, on whose behalf, under which policy’. ^{AJ}
- **Must never:** The agent holds no standing credentials and can never approve. ^{AJ}
- **Evidence added:** Audit events linking user, agent, tool, decision and trace ID. ^{AJ}
- **Signal:** Attribution completeness of audit events. ^{AJ}

Objections worth taking seriously

“Our identity provider is already critical. Agents add load, cost and risk to it.”

True, and the costs are real: Entra’s agent security features need Agent 365, Okta for AI Agents is a separate subscription, and AgentCore Policy charges per authorisation request ^{vi202}. Budget for it explicitly ^{Rec}. On load, cache decisions briefly, run the policy decision point as a sidecar where possible, and reuse short-lived tokens within their lifetime rather than lengthening it ^{AJ}. The alternative, shared accounts, is cheaper only until the first incident review ^{AJ}.

“Scheduled agents have no person to act on behalf of.” Then they use the autonomous pattern, with their own narrow ceiling, a named sponsor and a review cycle ^{AJ}. Their runtimes should authenticate with workload identity, such as SPIFFE/SPIRE or the cloud equivalent, rather than stored secrets ^{vi203 Rec}. The point is

²⁰² Verified fact — A6-S059: Microsoft Entra Agent ID licensing (include file) <https://raw.githubusercontent.com/MicrosoftDocs/entra-docs/main/docs/includes/licensing-agent-id.md> accessed 2026-10-07; A6-S099: Okta brings first-class identity to AI agents with Agent SSO; Okta Introduces Agent SSO for Cross App Access (XAA) (Okta, Inc.) <https://www.okta.com/newsroom/press-releases/okta-brings-first-class-identity-to-ai-agents-with-agent-ssu/> accessed 2026-10-07 [search-tool extract]; A6-S021: Amazon Bedrock AgentCore Pricing; AgentCore GA announcement (Oct 2025); AgentCore Gateway docs (Amazon Web Services) <https://aws.amazon.com/bedrock/agentcore/pricing/> accessed 2026-10-07 [search-tool extract]

²⁰³ Verified fact — A6-S087: SPIRE README (GitHub) (SPIFFE project (CNCF)) <https://raw.githubusercontent.com/spiffe/spire/main/README.md> accessed 2026-10-07

not that every call carries a person; it is that every call carries a name somebody answers for ^{AJ}.

“Why 99.9%? Surely attribution must be 100%.” For regulated releases, approval integrity should be 100% ^{AJ}. Attribution completeness is measured across all events, including telemetry gaps outside the agent’s control, so 99.9% is a realistic floor to start from ^{AJ}. Each gap is still traced to a cause and closed, and a firm should tighten the target as its pipeline matures ^{Rec}. What matters is that the number is measured at all. A firm that cannot state its attribution completeness is, in effect, unable to say how many of yesterday’s agent actions it could explain ^{AJ}.

Questions for your team

- For each agent in production, who is its named owner and sponsor, and when was it last certified? ^{Rec}
- Which agents still run under a shared service account or a developer’s personal token? ^{Rec}
- When an analyst starts a run, does every tool call carry that analyst’s identity as well as the agent’s? ^{Rec}
- Is an agent’s effective permission the intersection of the user’s entitlements and its own ceiling, or the union? ^{Rec}
- Can any agent reach a write tool it never calls, and why? ^{Rec}
- How long does it take to revoke an agent everywhere, and when did we last drill it? ^{Rec}
- Which senior manager would answer for each agent if a regulator asked tomorrow? ^{Rec}

In one line

Give every agent a name, act on the requester’s behalf with no more than the requester could do, and record both, because accountability does not automate itself. ^{AJ}

9. Build memory last, on purpose

L5 Memory, from Post 9 of the series.

The post

Memory is the layer I would deliberately build last. What an agent remembers is a governance question before it is a technical one. ^{AJ}

Memory is the one part of the stack that writes its own inputs. A mistaken “fact” extracted from one conversation can be recalled in hundreds of later ones. A stale preference can override a newer instruction. An injected instruction that lands in memory keeps working long after the original input has gone, which is why the OWASP list for agentic applications now names memory and context poisoning as a risk of its own. ^{VF²⁰⁴ AJ}

It also creates a regulatory object that did not exist before: a growing store of extracted personal and business information with no natural expiry. Several memory products keep long-term records indefinitely unless the firm sets a limit. ^{VF²⁰⁵ AJ}

So the design starts with a question: does this use case need long-term memory at all? Often session state plus retrieval of approved knowledge is enough. In the worked example, what looks like memory, such as fund terminology and the portfolio manager’s preferred phrasing, is better held as a versioned style file, with recurring edits proposed as changes and approved by a person. ^{Rec}

²⁰⁴ Verified fact — B-L5-S001: Memory Is a Feature. It Is Also an Attack Surface (OWASP GenAI Security Project) <https://genai.owasp.org/2026/05/13/memory-is-a-feature-it-is-also-an-attack-surface/> accessed 2026-10-08 [search-tool extract]

²⁰⁵ Verified fact — A3-S111: Designing lifecycle policies for AgentCore memory (and AgentCore Memory docs: harness-memory, delete-memory, UpdateMemory, memory-record-streaming) (Amazon Web Services) <https://aws.amazon.com/blogs/machine-learning/designing-lifecycle-policies-for-agentcore-memory/> accessed 2026-10-07 [search-tool extract]; A3-S109: Vertex AI Agent Engine Memory Bank overview / generate memories / Memory Bank REST reference (docs.cloud.google.com, now 'Agent Platform Memory Bank') (Google Cloud) <https://docs.cloud.google.com/vertex-ai/generative-ai/docs/agent-engine/memory-bank/overview> accessed 2026-10-07 [search-tool extract]

Part II: Nine layers and the controls that make them safe

The signal is erasure completion time: from request to deletion confirmed across the store, its indexes, revisions and backups. Within the one-month statutory window, with an internal target well inside it. ^{Ver²⁰⁶ AI}

The leadership move is to treat memory as a governed record class with an approved write path. ^{Rec}

The honest caveat: the independent memory products are moving fast and in different directions, while the platforms absorb the feature. Owning the memory interface in front of them keeps that churn survivable. ^{Ver²⁰⁷ Rec}

Forgetting is a feature. In a regulated firm, it has to be engineered. ^{AI}

²⁰⁶ Verified fact — B-L5-S005: Right to erasure (Information Commissioner's Office) <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/individual-rights/individual-rights/right-to-erasure/> accessed 2026-10-08 [search-tool extract]

²⁰⁷ Verified fact — A3-S081: Mem0 docs source: Open Source migration to the new memory algorithm (Mem0 (GitHub)) <https://raw.githubusercontent.com/mem0ai/mem0/main/docs/migration/oss-v2-to-v3.mdx> accessed 2026-10-07; A3-S059: getzep/zep README: Zep Cloud Examples & Integrations (Zep AI (GitHub)) <https://raw.githubusercontent.com/getzep/zep/main/README.md> accessed 2026-10-07; A3-S093: Letta's Next Phase (Mar 2026) <https://www.letta.com/blog/our-next-phase/> accessed 2026-10-07 [search-tool extract]; A3-S006: PyPI JSON metadata: langmem (Python Package Index (PyPI)) <https://pypi.org/pypi/langmem/json> accessed 2026-10-07

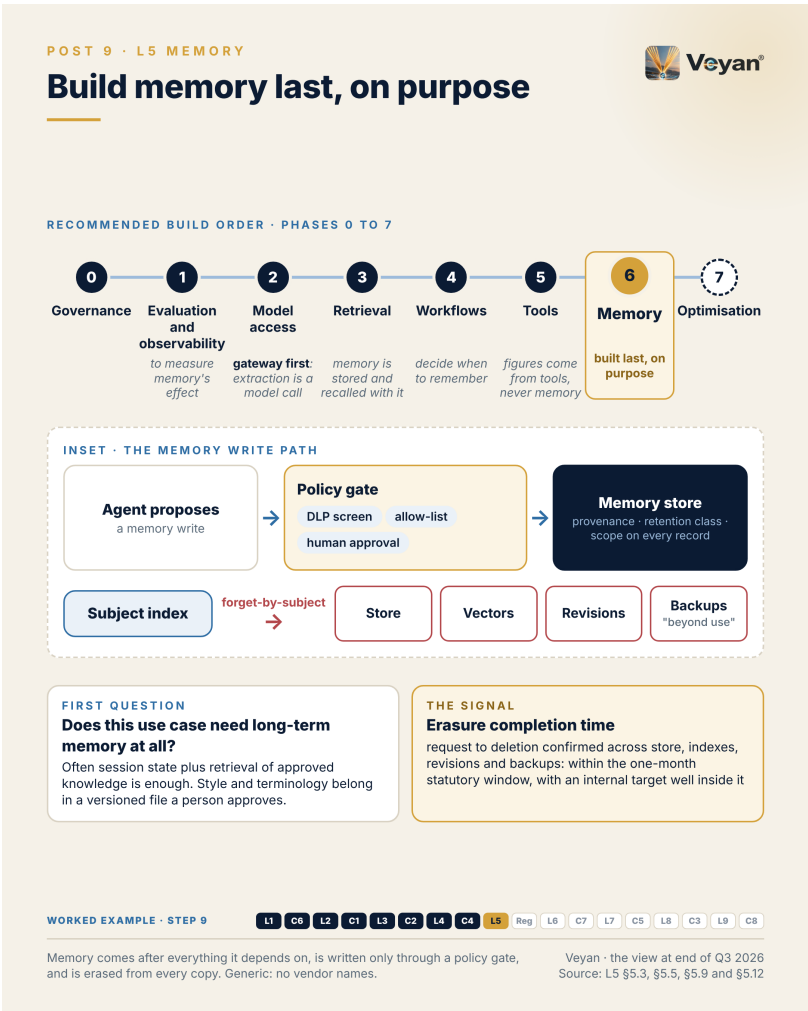


Figure 9. Memory comes after everything it depends on, is written only through a policy gate, and is erased from every copy. Generic: no vendor names. ^{AJ}

Behind the post

This layer decides what an agent carries from one interaction to the next, where that state is stored, and who is allowed to change, inspect or erase it ^{AJ}. The cognitive labels (conversation, working, episodic, semantic, procedural) are less

useful to an architect than one plain question: who writes the record, and how authoritative is it ^{AJ}? A knowledge base is written by an accountable owner through a controlled ingestion process. Memory is written by the agent, or by an extraction model, as a side effect of conversations. That makes it the least authoritative and least reviewed data the agent reads, even though it reaches the prompt in the same way as approved knowledge ^{AJ}.

How it fails. A badly designed memory layer fails slowly and invisibly ^{AJ}. A mistaken fact extracted once is recalled many times; a stale preference overrides a newer instruction; a client's name surfaces in another user's session because the scope key was too broad ^{AJ}. The OWASP Top 10 for Agentic Applications for 2026 names memory and context poisoning (ASI06): attacker-controlled content that the system continues to trust over time, shaping later planning, tool use and behaviour ^{vr208}. Memory also breaks reproducibility. A system whose output depends on what it has accumulated cannot be re-run to the same result unless its memory state at the time was captured ^{AJ}.

Defaults that run against storage limitation. Each product's design is defensible for recall quality, and each makes retention an engineering task rather than a default ^{AJ}. Amazon Bedrock AgentCore Memory's long-term records have no built-in time limit, and AWS recommends a pruner using timestamp filters ^{vr209}. Google's Memory Bank has an optional time-to-live that is off by default, and keeps memory revisions for 365 days by default ^{vr210}. Mem0's open-source extraction is now add-only, so memories accumulate rather than being overwritten ^{vr211}. Graphiti invalidates old facts rather than deleting them, keeping history ^{vr212}. Vendor-hosted chat memory

²⁰⁸ Verified fact — B-L5-S001: Memory Is a Feature. It Is Also an Attack Surface (OWASP GenAI Security Project) <https://genai.owasp.org/2026/05/13/memory-is-a-feature-it-is-also-an-attack-surface/> accessed 2026-10-08 [search-tool extract]

²⁰⁹ Verified fact — A3-S111: Designing lifecycle policies for AgentCore memory (and AgentCore Memory docs: harness-memory, delete-memory, UpdateMemory, memory-record-streaming) (Amazon Web Services) <https://aws.amazon.com/blogs/machine-learning/designing-lifecycle-policies-for-agentcore-memory/> accessed 2026-10-07 [search-tool extract]

²¹⁰ Verified fact — A3-S109: Vertex AI Agent Engine Memory Bank overview / generate memories / Memory Bank REST reference (docs.cloud.google.com, now 'Agent Platform Memory Bank') (Google Cloud) <https://docs.cloud.google.com/vertex-ai/generative-ai/docs/agent-engine/memory-bank/overview> accessed 2026-10-07 [search-tool extract]

²¹¹ Verified fact — A3-S081: Mem0 docs source: Open Source migration to the new memory algorithm (Mem0 (GitHub)) <https://raw.githubusercontent.com/mem0ai/mem0/main/docs/migration/oss-v2-to-v3.mdx> accessed 2026-10-07

²¹² Verified fact — A3-S003: PyPI JSON metadata: graphiti-core (Python Package Index (PyPI)) <https://pypi.org/pypi/graphiti-core/json> accessed 2026-10-07

behaves differently again: deleting a ChatGPT chat does not delete its saved memories, and deleted memory logs may be kept for up to 30 days ^{vi213}.

The regulatory object. Under UK GDPR the ICO expects erasure from live systems, steps for backups (which may be put “beyond use” until overwritten) and a response within one month; the ICO notes that this guidance is under review following the Data (Use and Access) Act ^{vi214}. Storage limitation expects personal data to be kept no longer than necessary, with periodic review and deletion or anonymisation ^{vi215}. A memory store is personal-data processing by default, because extraction picks up names, preferences and circumstances from conversation ^{AJ}. Some content may also be a business record the firm must keep. Whether a records obligation overrides an erasure request is a legal question per record class; the architectural answer is to keep memory and records apart ^{AJ Rec.}.

What changed in 2025–26. The independent products moved apart. Mem0 removed every external graph store from its open-source build on 14 April 2026; Zep deprecated its Community Edition, leaving Graphiti as the open-source path; Letta pivoted to an agent harness; and LangMem has had no release since 27 October 2025 ^{vi216}. Meanwhile the platforms absorbed the feature. AgentCore Memory has been generally available since 13 October 2025 and Memory Bank since December 2025 ^{vi217}. Model vendors ship memory in their own APIs too:

²¹³ Verified fact — A3-S110: OpenAI API: Conversation state (and Help Center: Memory FAQ) <https://developers.openai.com/api/docs/guides/conversation-state> accessed 2026-10-07 [search-tool extract]

²¹⁴ Verified fact — B-L5-S005: Right to erasure (Information Commissioner’s Office) <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/individual-rights/individual-rights/right-to-erasure/> accessed 2026-10-08 [search-tool extract]

²¹⁵ Verified fact — B-L5-S006: Principle (e): Storage limitation (Information Commissioner’s Office) <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/data-protection-principles/a-guide-to-the-data-protection-principles/storage-limitation/> accessed 2026-10-08 [search-tool extract]

²¹⁶ Verified fact — A3-S053: Mem0 docs: Platform vs Open Source (and OSS v2-to-v3 migration notes) <https://docs.mem0.ai/platform/platform-vs-oss> accessed 2026-10-07 [search-tool extract]; V1-S043: Open Source: Migrating to the New Memory Algorithm; SDK changelog; Highlights (Mem0) <https://docs.mem0.ai/migration/oss-v2-to-v3> accessed 2026-10-08 [search-tool extract]; A3-S059: getzep/zep README: Zep Cloud Examples & Integrations (Zep AI (GitHub)) <https://raw.githubusercontent.com/getzep/zep/main/README.md> accessed 2026-10-07; A3-S093: Letta’s Next Phase (Mar 2026) <https://www.letta.com/blog/our-next-phase/> accessed 2026-10-07 [search-tool extract]; A3-S006: PyPI JSON metadata: langmem (Python Package Index (PyPI)) <https://pypi.org/pypi/langmem/json> accessed 2026-10-07

²¹⁷ Verified fact — A3-S047: Amazon Bedrock AgentCore is now generally available (Oct 2025) (Amazon Web Services) <https://aws.amazon.com/about-aws/whats-new/2025/10/amazon-bedrock-agentcore-available/> accessed 2026-10-07 [search-tool extract]; V1-S087: Amazon Bedrock AgentCore is now generally available; AgentCore FAQs; release notes (Amazon Web Services) <https://aws.amazon.com/about-aws/whats-new/2025/10/amazon-bedrock-agentcore-available/> accessed 2026-10-08 [search-tool extract]; V1-S088: Vertex AI release notes (Agent Engine Sessions and

Anthropic's memory tool executes file operations on storage the developer controls, and OpenAI persists conversation state through its Conversations API ^{vr218}. Every product stores memory in ordinary vector, graph, relational or file stores ^{vr219}. The review's synthesis therefore merges memory physically into the retrieval and data stores, while keeping a thin "memory service" visible as a logical component, because its controls are unique and auditors will look for them ^{aj}.

Why last. The review's build order puts memory in phase 6 of 0 to 7: after governance, evaluation and observability, model access through the gateway, retrieval, agent workflows and tools ^{aj}. Each step earns its place ^{aj}. Memory changes behaviour over time, so its effect can only be measured once evaluation and tracing exist. Extraction is a model call, so it should route through the gateway. Memory is stored and recalled with retrieval infrastructure, so that should be settled first. The safe pattern is a workflow that decides when to remember. And authoritative data must already flow through read-only tools, so that memory never becomes the easiest place to find a number ^{aj}.

The governed write path. The design that holds up puts a policy gate between extraction and storage: a data-loss-prevention screen, an allow-list of what may be remembered ("terminology preferences: yes; client facts: no; figures: never") and, for shared memory, human approval ^{rec}. Every record carries provenance, a scope and a retention class ^{rec}. The key design choice is the subject index: every memory that may contain personal data must be findable by data subject, so that one query can erase it across rows, vectors, graph nodes, revisions and caches ^{aj}. Put a thin, firm-owned memory interface (write, recall, forget-by-subject, snapshot) in front of any product, and keep the canonical record in a store the firm controls ^{rec}.

The worked example. For an agent drafting monthly attribution commentary, the "memory" asked for is fund terminology and the portfolio manager's past edits ^{aj}.

Memory Bank GA; pricing) (Google Cloud) <https://docs.cloud.google.com/vertex-ai/docs/release-notes> accessed 2026-10-08 [search-tool extract]

²¹⁸ Verified fact — A3-S069: Memory tool - Claude Platform Docs (Anthropic) <https://docs.claude.com/en/docs/agents-and-tools/tool-use/memory-tool> accessed 2026-10-07; A3-S110: OpenAI API: Conversation state (and Help Center: Memory FAQ) <https://developers.openai.com/api/docs/guides/conversation-state> accessed 2026-10-07 [search-tool extract]

²¹⁹ Verified fact — A3-S053: Mem0 docs: Platform vs Open Source (and OSS v2-to-v3 migration notes) <https://docs.mem0.ai/platform/platform-vs-oss> accessed 2026-10-07 [search-tool extract]; A3-S003: PyPI JSON metadata: graphiti-core (Python Package Index (PyPI)) <https://pypi.org/pypi/graphiti-core/json> accessed 2026-10-07; A3-S005: PyPI JSON metadata: cognee (Python Package Index (PyPI)) <https://pypi.org/pypi/cognee/json> accessed 2026-10-07; A3-S006: PyPI JSON metadata: langmem (Python Package Index (PyPI)) <https://pypi.org/pypi/langmem/json> accessed 2026-10-07; A3-S073: letta-ai/letta-code README (Letta (GitHub)) <https://raw.githubusercontent.com/letta-ai/letta-code/main/README.md> accessed 2026-10-07

That is a governed, versioned style file, not free-form agent memory. A monthly job clusters recurring edits and proposes new style rules as a change request; the manager approves, rejects or amends them; each run reads one pinned version, and its hash goes into the evidence pack ^{Rec}. The slice needs no memory product at all ^{AJ}. Credit for that kind of restraint usually goes unrecorded, which is a pity: it saves a team a year of clean-up ^{AJ}.

What good looks like

The signal is **erasure completion time**: from an erasure request being received to deletion confirmed across the memory store, its indexes, revisions and backups, with backups put “beyond use” ^{AJ}. Measure it from erasure job logs, with the evidence filed alongside other governance records, and test the whole path end to end before go-live, including revisions and indexes ^{Rec}. The outer bound is the one-month UK GDPR response window ^{vr220}. The internal target should sit well inside it, set by the firm from its own drills ^{AJ}. A simple drill uses a synthetic data subject: seed memories about them, request erasure, and confirm that nothing about them can be recalled or restored ^{Rec}.

Three companion measures keep memory honest. *Retention conformance*: zero records older than their retention class. *Provenance coverage*: 100% of memories carry source interaction, writer, timestamp, approval status and version. *Harmful-recall rate*: zero runs where recalled memory contradicted an authoritative source on a number ^{AJ}.

These targets come from the review’s guidance. They are a starting point, not an industry benchmark ^{AJ}.

In the worked example

Step 9: memory. Deliberately little: a versioned glossary and style rules per fund, changed only by an approved pull request, recalled by version hash. ^{AJ}

- **Now works:** Any commentary can be regenerated with exactly the memory it used. ^{AJ}
- **Must never:** The agent may propose memory, never write it; no client identifiers in memory. ^{AJ}
- **Evidence added:** The memory version hash in every trace. ^{AJ}
- **Signal:** Time to complete an erasure request across every copy. ^{AJ}

²²⁰ Verified fact — B-L5-S005: Right to erasure (Information Commissioner’s Office) <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/individual-rights/individual-rights/right-to-erasure/> accessed 2026-10-08 [search-tool extract]

Objections worth taking seriously

“Users expect assistants to remember them. Building memory last makes us look behind.” Per-user preference memory can be committed automatically, provided it passes the write gate and is visible to and editable by the user ^{AJ}. Mainstream assistants already work that way. Anthropic’s Claude app offers a user-editable memory summary and an admin switch to disable memory on its business plans, and ChatGPT’s memory can also be switched off ^{vr221}. What should wait is memory that feeds a regulated output ^{Rec}.

“The hyperscaler memory services are generally available. Why not just use one?” Inside that hyperscaler’s own agent runtime, the review rates this acceptable ^{AJ}. But defaults still need retention settings, and Memory Bank memories are deleted with the Agent Runtime instance, so an export to the firm’s own store is part of the design ^{vr222 Rec}. Check the security settings as well: AgentCore Memory encrypts with an AWS-owned key unless a customer-managed key is set at creation, and Memory Bank lists customer-managed keys but not on its global endpoint ^{vr223}. Wrapping the service in a firm-owned interface keeps memory movable if the agent moves ^{Rec}.

“Erasure and record-keeping pull in opposite directions.” Sometimes they do ^{AJ}. Article 17(3) GDPR sets exceptions to erasure, including legal claims ^{vr224}. The cleaner answer is architectural: business records live in the records archive under the records policy, and memory holds only what the agent needs, under shorter retention ^{Rec}. Then an erasure request touches memory without touching the firm’s obligations to keep records ^{AJ}.

²²¹ Verified fact — A3-S071: Bringing memory to Claude (11 Sep 2025; updated 23 Oct 2025) (Anthropic) <https://www.anthropic.com/news/memory> accessed 2026-10-07; A3-S110: OpenAI API: Conversation state (and Help Center: Memory FAQ) <https://developers.openai.com/api/docs/guides/conversation-state> accessed 2026-10-07 [search-tool extract]

²²² Verified fact — A3-S109: Vertex AI Agent Engine Memory Bank overview / generate memories / Memory Bank REST reference (docs.cloud.google.com, now ‘Agent Platform Memory Bank’) (Google Cloud) <https://docs.cloud.google.com/vertex-ai/generative-ai/docs/agent-engine/memory-bank/overview> accessed 2026-10-07 [search-tool extract]

²²³ Verified fact — B-L5-S002: Encrypt your Amazon Bedrock AgentCore Memory (and AWS Config / Security Hub / SRA pages) (Amazon Web Services) <https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/storage-encryption.html> accessed 2026-10-08 [search-tool extract]; B-L5-S004: Scale your agents / Set up Memory Bank / release notes / data residency terms (Google Cloud) <https://docs.cloud.google.com/gemini-enterprise-agent-platform/scale> accessed 2026-10-08 [search-tool extract]

²²⁴ Verified fact — B-L5-S007: Judgment C-26/22 (and C-484/24) on GDPR Articles 5(1)(e) and 17 (Court of Justice of the EU (EUR-Lex)) <https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX%3A62022CJ0026> accessed 2026-10-08 [search-tool extract]

Questions for your team

- For each agent use case, does it need long-term memory, or would session state plus approved retrieval do? Rec
- What may each agent remember, and where is that allow-list written down and enforced? Rec
- Could we find every memory about one person with a single query, including revisions, indexes and backups? Rec
- Which memory products or features in our estate have no retention limit set? Rec
- Does any workflow read a figure from memory rather than from the system of record? Rec
- Can we reproduce a past output with the memory state it actually used? Rec

In one line

Memory is the one layer that writes its own inputs, so build it last, gate every write, and engineer the forgetting before you switch it on. AJ

10. Multi-vendor AI is becoming close to a requirement

Regulated reality: the EU AI Act, DORA and the UK third-party regime (with C8 Model risk, governance and auditability), from Post 10 of the series.

The post

Concentration risk is turning multi-vendor AI from a preference into something close to a requirement.

Four facts frame it. In the US, SR 26-2 replaced the long-standing model-risk guidance in April 2026 and placed generative and agentic AI outside its scope, so firms write their own standard. In the EU, enforcement of the AI Act's duties on general-purpose model providers began in August 2026, while the high-risk duties for Annex III uses moved to 2 December 2027. For most asset-management uses, today's live duties are literacy and transparency. Under DORA, and the UK's new critical third parties regime, the providers designated for direct oversight are hyperscalers and infrastructure firms; no model vendor is on either list. And from 18 March 2027, UK firms must notify material third-party arrangements before entering or significantly changing them. ^{v6.225 AJ}

²²⁵ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see [regulatory_facts.json](#)); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]; R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see [regulatory_facts.json](#)); R-EU-OMNIBUS-AI: Regulation (EU) 2026/1744 ('Digital Omnibus on AI') amending Regulations (EU) 2024/1689, 2018/1139 and 2023/1230 (see [regulatory_facts.json](#)); A8-S011: Regulation (EU) 2026/1744 (Digital Omnibus on AI) amending Regulation (EU) 2024/1689 (EUR-Lex / Official Journal of the EU) <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> accessed 2026-10-07 [search-tool extract]; R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see [regulatory_facts.json](#)); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]; V2-S051: European Supervisory Authorities designate critical ICT third-party providers under DORA (EBA/EIOPA/ESMA press release; with Morgan Lewis, TLT) (EBA / EIOPA / ESMA) <https://www.eba.europa.eu/publications-and-media/press-releases/european-supervisory-authorities-designate-critical-ict-third-party-providers-under-digital> accessed 2026-10-08 [search-tool extract]; R-UK-CTP: UK Critical Third

Read together, oversight of a direct model-vendor contract rests largely on the firm. No rule says “use two model vendors”. But a tested stressed-exit plan for a model behind an important business service needs a second route that already works: qualified on the same evaluation suite, through the same gateway, in an approved region. International supervisors now name concentration on a few AI providers as a risk in itself.²²⁶ AI

The signal is a concentration ratio: the share of production usage, or of important services, served by the largest single model vendor, reported to the risk committee against a ceiling the firm sets.^{AI}

The leadership move is to use these deadlines as a mandate, building the evidence once.

The honest caveat: the DORA list is updated every year, and nothing guarantees a direct model API stays outside the perimeter.

Regulation rarely tells you what to build. It tells you what you will have to prove.

Parties regime (FSMA 2023 / FSMA 2000 s312L; PRA/FCA/BoE CTP rules) and the Critical Third Parties (Designation) Regulations 2026 (SI 2026/777) (see [regulatory_facts.json](#)); A8-S023: The Critical Third Parties (Designation) Regulations 2026 (SI 2026/777); BoE/FCA/HMT announcements (HM Treasury / [legislation.gov.uk](#) / Bank of England) <https://www.legislation.gov.uk/uksi/2026/777/made> accessed 2026-10-07 [search-tool extract]; V2-S052: The Critical Third Parties (Designation) Regulations 2026 (SI 2026/777) (with Lewis Silkin, National Law Review, Library of Congress) (UK Government ([legislation.gov.uk](#))) <https://www.legislation.gov.uk/uksi/2026/777/made> accessed 2026-10-08 [search-tool extract]; R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see [regulatory_facts.json](#)); R-FCA-SYSC8: FCA Handbook SYSC 8 (Outsourcing); FG16/5 'Guidance for firms outsourcing to the cloud and other third-party IT services'; PS26/2 operational incident and third-party reporting (see [regulatory_facts.json](#)); A8-S062: PS7/26 Operational incident and third-party reporting (PRA) and FCA PS26/2; revised SS2/21 (March 2026) (Bank of England / PRA; FCA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2026/march/operational-incident-and-third-party-reporting-policy-statement> accessed 2026-10-07 [search-tool extract]

²²⁶ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see [regulatory_facts.json](#)); A8-S048: SS2/21 Outsourcing and third party risk management (and PS7/26, March 2026) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2021/ss221-march-21.pdf> accessed 2026-10-07 [search-tool extract]; R-INTL-AI-ASSETMGMT: IOSCO Supervisory Toolkit for AI Use in Capital Markets (FR/02/2026) and ESMA Public Statement on AI and investment services (30 May 2024) (see [regulatory_facts.json](#)); A8-S058: IOSCO FR/02/2026 Supervisory Toolkit for AI Use in Capital Markets (May 2026) <https://www.iosco.org/library/pubdocs/pdf/IOSCOPD823.pdf> accessed 2026-10-07 [search-tool extract]

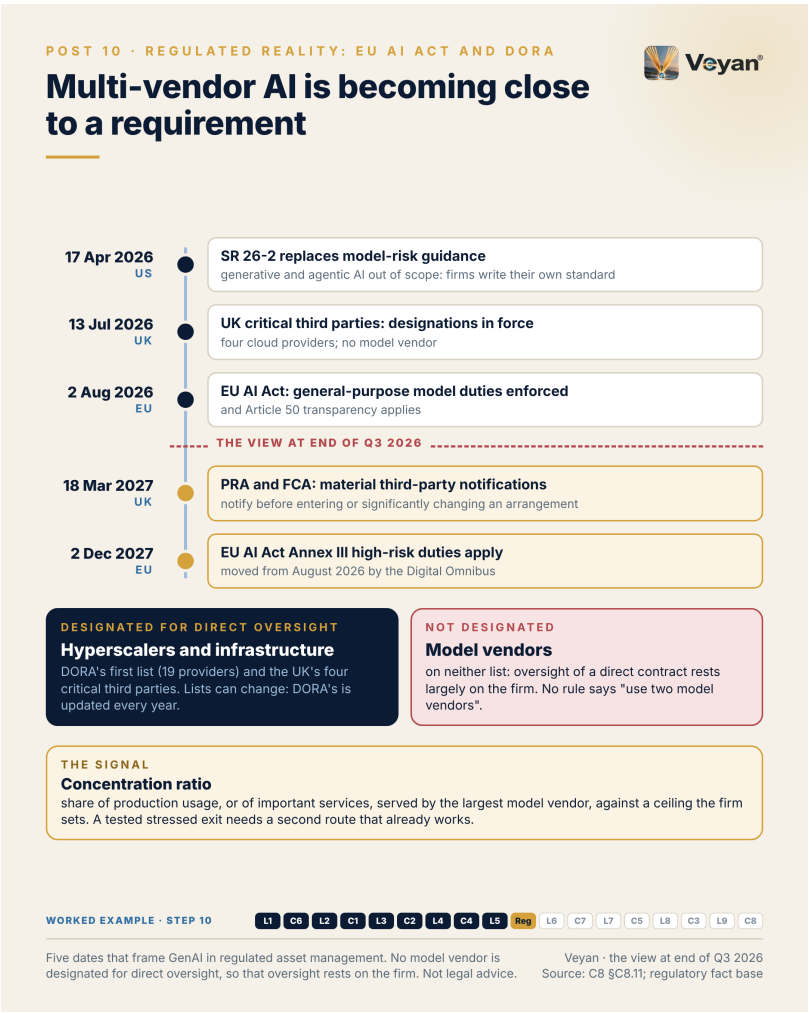


Figure 10. Five dates that frame GenAI in regulated asset management. No model vendor is designated for direct oversight, so that oversight rests on the firm. Not legal advice.^{AJ}

Behind the post

This chapter describes the regulatory frame as the review found it at the end of Q3 2026. It is an architect's reading, not legal advice, and any firm should take its own legal view before acting on it ^{AJ}.

The US anchor moved, and left a gap. SR 26-2, OCC Bulletin 2026-13 and FDIC FIL-15-2026 were issued on 17 April 2026 and replace SR 11-7 and SR 21-8 ^{vi227}. They keep risk-based, materiality-driven model risk management with effective challenge by independent reviewers. They also expressly place generative and agentic AI models out of scope, leaving the firm's own practices to determine controls ^{vi228}. The agencies said they would issue a request for information on AI; none had been published by 7 October 2026 ^{vi229}. The carve-out does not remove the governance need. It moves the burden to the firm, which now has to write its own standard. Writing it to the quality of PRA SS1/23 is the safest course, because the planned request for information may bring expectations back ^{AJ}.

²²⁷ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see [regulatory_facts.json](#)); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]; A8-S005: Federal Banking Agencies Issue Revised Guidance on Model Risk Management (Sullivan & Cromwell LLP (also Orrick, Davis Polk memos)) <https://www.sullcrom.com/insights/memo/2026/April/OCC-Fed-FDIC-Issue-Revised-Guidance-Model-Risk-Management> accessed 2026-10-07 [search-tool extract]; V2-S049: Supervisory Letter SR 26-2 on Revised Guidance on Model Risk Management – April 17, 2026 (with SR2602a1 attachment, OCC Bulletin 2026-13a) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-08 [search-tool extract]

²²⁸ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see [regulatory_facts.json](#)); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]

²²⁹ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see [regulatory_facts.json](#)); R-US-AGENCY-AI: US federal banking agency and NIST statements on generative and agentic AI, 2026 (see [regulatory_facts.json](#)); A8-S003: OCC Issues Updated Model Risk Management Guidance (NR 2026-29) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/news-releases/2026/nr-occ-2026-29.html> accessed 2026-10-07 [search-tool extract]; A8-S007: After SR 26-2: Governing Generative and Agentic AI in Banks (and related practitioner summaries) (Lumenova AI / practitioner commentary) <https://www.lumenova.ai/blog/sr-26-2-control-framework/> accessed 2026-10-07 [search-tool extract]

The EU timetable split in two. The Commission's enforcement powers over general-purpose AI providers, with fines of up to 3% of global turnover, began on 2 August 2026²³⁰. Regulation (EU) 2026/1744, in force from 27 July 2026, moved the Annex III high-risk duties to 2 December 2027 and Annex I to 2 August 2028, leaving the general-purpose, prohibition and transparency timelines unchanged²³¹. An asset manager using third-party models is normally a deployer, and attribution commentary, research summaries and operations are not Annex III uses^{AI}. The live duties are therefore AI literacy, which Article 4 now frames as taking “measures to support” it²³², and Article 50 transparency, which has applied since 2 August 2026²³³. Two traps sit nearby. HR uses, creditworthiness and life and health insurance pricing are Annex III points²³⁴. And under Article 25 a deployer becomes a provider if it changes a system's intended purpose so that it becomes high-risk²³⁵. A system prompt is the easiest place to make that change by accident (Chapter 14)^{AI}.

²³⁰ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see `regulatory_facts.json`); A8-S011: Regulation (EU) 2026/1744 (Digital Omnibus on AI) amending Regulation (EU) 2024/1689 (EUR-Lex / Official Journal of the EU) <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> accessed 2026-10-07 [search-tool extract]; A8-S019: General-Purpose AI Models in the AI Act - Questions & Answers (European Commission) <https://digital-strategy.ec.europa.eu/en/faqs/general-purpose-ai-models-ai-act-questions-answers> accessed 2026-10-07 [search-tool extract]

²³¹ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see `regulatory_facts.json`); R-EU-OMNIBUS-AI: Regulation (EU) 2026/1744 ('Digital Omnibus on AI') amending Regulations (EU) 2024/1689, 2018/1139 and 2023/1230 (see `regulatory_facts.json`); A8-S011: Regulation (EU) 2026/1744 (Digital Omnibus on AI) amending Regulation (EU) 2024/1689 (EUR-Lex / Official Journal of the EU) <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> accessed 2026-10-07 [search-tool extract]; V2-S050: Digital Omnibus on AI in the Official Journal: Regulation (EU) 2026/1744 is published (with CSA research note, ActulA, Licentium) (Law and Technology (secondary)) <https://lawandtechnology.eu/en/digital-omnibus-on-ai-official-journal-regulation-2026-1744/> accessed 2026-10-08 [search-tool extract]

²³² Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see `regulatory_facts.json`); A8-S060: Regulation (EU) 2026/1744 amended Article 4 text; Commission AI Literacy Q&A (EUR-Lex / European Commission) https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=OJ%3AL_202601744 accessed 2026-10-07 [search-tool extract]

²³³ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see `regulatory_facts.json`); A8-S018: AI Act Article 50 Transparency obligations; Commission Article 50 guidelines C(2026) 5054 (European Commission) <https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-50> accessed 2026-10-07 [search-tool extract]; V2-S078: Not Delayed, Not Deferred: EU AI Act Transparency Obligations Are Now in Force (Goodwin; with Orrick, Freshfields on final Digital Omnibus) (Goodwin Procter) <https://www.goodwinlaw.com/en/insights/publications/2026/08/alerts-technology-dpc-eu-ai-act-transparency-obligations-now-in-force> accessed 2026-10-08 [search-tool extract]

²³⁴ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see `regulatory_facts.json`); A8-S017: AI Act Annex III; Article 27 FRIA; Article 72 post-market monitoring (European Commission AI Act Service Desk) <https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3> accessed 2026-10-07 [search-tool extract]

The third-party perimeter stops at the cloud. DORA's first list of critical ICT third-party providers, published on 18 November 2025, named 19 providers, including AWS, Google Cloud, Microsoft, Oracle, IBM, SAP, Bloomberg and LSEG, and no AI model provider; the list is updated every year ²³⁶. The UK designated AWS, Google Cloud, Microsoft and Oracle as critical third parties with effect from 13 July 2026, again with no model vendor, and firms keep their own due-diligence and contingency duties ²³⁷. The mechanism matters more than the lists. A model consumed through a designated hyperscaler sits inside a relationship that is already overseen and already contracted. A direct contract with a model vendor does not, so more of the oversight falls on the firm ^{AI}. That is the strongest regulatory argument for the hyperscaler's model service as the default route ^{AI}.

The UK adds a clock. From 18 March 2027, PRA PS7/26 and FCA PS26/2 require firms to notify before entering into or significantly changing a material third-party arrangement, and to submit an annual register ²³⁸. SS2/21 already expects

²³⁵ Verified fact — R-EUAI: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see regulatory_facts.json); A8-S016: AI Act Article 26 Obligations of deployers; Article 25 Responsibilities along the AI value chain (European Commission AI Act Service Desk) <https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-26> accessed 2026-10-07 [search-tool extract]

²³⁶ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see regulatory_facts.json); A8-S020: The ESAs designate critical ICT third-party providers under DORA (with List_of_designated_CTPPs.pdf, 18 Nov 2025) (EBA / ESMA / EIOPA (Joint ESAs)) <https://www.eba.europa.eu/publications-and-media/press-releases/european-supervisory-authorities-designate-critical-ict-third-party-providers-under-digital> accessed 2026-10-07 [search-tool extract]; A8-S021: Digital Operational Resilience Act (DORA) pages and Rol reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]; V2-S051: European Supervisory Authorities designate critical ICT third-party providers under DORA (EBA/EIOPA/ESMA press release; with Morgan Lewis, TLT) (EBA / EIOPA / ESMA) <https://www.eba.europa.eu/publications-and-media/press-releases/european-supervisory-authorities-designate-critical-ict-third-party-providers-under-digital> accessed 2026-10-08 [search-tool extract]

²³⁷ Verified fact — R-UK-CTP: UK Critical Third Parties regime (FSMA 2023 / FSMA 2000 s312L; PRA/FCA/BoE CTP rules) and the Critical Third Parties (Designation) Regulations 2026 (SI 2026/777) (see regulatory_facts.json); A8-S023: The Critical Third Parties (Designation) Regulations 2026 (SI 2026/777); BoE/FCA/HMT announcements (HM Treasury / legislation.gov.uk / Bank of England) <https://www.legislation.gov.uk/uksi/2026/777/made> accessed 2026-10-07 [search-tool extract]; A8-S024: HM Treasury makes first designations under UK CTP regime (with Lewis Silkin, S&C) (Herbert Smith Freehills Kramer) <https://www.hsfkramer.com/notes/fsrandcorpcrime/2026-posts/hm-treasury-makes-first-designations-under-uk-ctp-regime> accessed 2026-10-07 [search-tool extract]; V2-S052: The Critical Third Parties (Designation) Regulations 2026 (SI 2026/777) (with Lewis Silkin, National Law Review, Library of Congress) (UK Government (legislation.gov.uk)) <https://www.legislation.gov.uk/uksi/2026/777/made> accessed 2026-10-08 [search-tool extract]

²³⁸ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see regulatory_facts.json); R-FCA-SYSC8: FCA Handbook SYSC 8 (Outsourcing); FG16/5 'Guidance for firms outsourcing to the cloud and other third-party IT services'; PS26/2 operational incident and third-party reporting (see regulatory_facts.json); A8-S062: PS7/26 Operational incident and third-party reporting (PRA) and FCA PS26/2; revised SS2/21 (March 2026) (Bank of England / PRA; FCA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2026/march/operational-incident-and-third-party-reporting>

documented and tested exit plans, including stressed exit ^{vr239}. A hosted model behind an important business service is likely to be a material arrangement, so adding a second vendor in a hurry will need notification lead time ^{aj}.

Concentration is now named, and it is not hypothetical. IOSCO's Supervisory Toolkit (FR/02/2026) flags concentration risk from reliance on a few AI technology providers ^{vr240}. The review's evidence shows why. Anthropic's top tier, Claude Fable 5, was made unavailable on 12 June 2026 and restored from 1 July 2026 ^{vr241}. Google's recent Gemini Flash versions live about five to six months, Mistral's Labs models may go with a month's notice, and OpenAI gives as little as about two weeks for previews ^{vr242}. None of this is a criticism of any one vendor. It is the normal life of a fast-moving product line, and it is why the review classifies a single proprietary frontier vendor behind an important service as unacceptable lock-in ^{aj}.

What the second route actually is. A credible stressed exit is not a contract in a drawer. It is a second model from an unrelated vendor, qualified on the same evaluation suite, reached through the same gateway, in an approved region, and switched by configuration ^{aj}. For the deepest stress, the review adds an open-weight model already qualified on vLLM, because that route survives a vendor's commercial or legal event entirely ^{aj}. The review is equally clear about where multi-

[party-reporting-policy-statement](#) accessed 2026-10-07 [search-tool extract]; V2-S053: PS7/26 - Operational resilience: Operational incident and third-party reporting (with SS2/21 March 2026 update; FCA PS26/2 and FG26/4) (Bank of England (PRA) / FCA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2026/march/operational-incident-and-third-party-reporting-policy-statement> accessed 2026-10-08 [search-tool extract]

²³⁹ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see [regulatory_facts.json](#)); A8-S048: SS2/21 Outsourcing and third party risk management (and PS7/26, March 2026) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2021/ss221-march-21.pdf> accessed 2026-10-07 [search-tool extract]

²⁴⁰ Verified fact — R-INTL-AI-ASSETMGMT: IOSCO Supervisory Toolkit for AI Use in Capital Markets (FR/02/2026) and ESMA Public Statement on AI and investment services (30 May 2024) (see [regulatory_facts.json](#)); A8-S058: IOSCO FR/02/2026 Supervisory Toolkit for AI Use in Capital Markets (May 2026) <https://www.iosco.org/library/pubdocs/pdf/IOSCOPD823.pdf> accessed 2026-10-07 [search-tool extract]; V2-S077: IOSCO public reports list: FR/02/2026 Supervisory Toolkit for AI Use in Capital Markets (with A&O Shearman FinReg, Regulation Tomorrow May 2026) https://www.iosco.org/publications/_public_reports.cfm accessed 2026-10-08 [search-tool extract]

²⁴¹ Verified fact — V2-S004: Claude Fable - Anthropic <https://www.anthropic.com/claude/fable> accessed 2026-10-08

²⁴² Verified fact — B-L1-S003: Gemini 3.7 Flash model page and related lifecycle pages (Gemini Enterprise Agent Platform) (Google Cloud) <https://docs.cloud.google.com/gemini-enterprise-agent-platform/models/gemini/3-7-flash> accessed 2026-10-08 [search-tool extract]; B-L1-S002: Models overview: deprecated and retired models (Mistral Docs) (Mistral AI) <https://docs.mistral.ai/models> accessed 2026-10-08 [search-tool extract]; B-L1-S001: Deprecations (OpenAI API docs) <https://developers.openai.com/api/docs/deprecations> accessed 2026-10-08 [search-tool extract]

vendor only adds complexity: two orchestration frameworks, two vector stores for one corpus or two observability platforms of record bring cost without resilience ^{AJ}.

Build the evidence once. The useful insight from setting the regimes side by side is how much of the evidence overlaps. A gateway request log naming model, version, region and fallback serves the firm's model-risk standard, Article 26-style logging, exit drills and data-location questions at once. A use-case inventory entry with its configuration bundle serves model risk, AI Act classification and board accountability ^{AJ}. The team that builds that register first will answer most of the next question from regulators without a new project ^{AJ}.

What good looks like

The signal is the **concentration ratio**: the share of production tokens, or of important business services, served by the largest single model vendor ^{AJ}. Measure it from gateway metering, because the gateway sees every call with its vendor, model and route ^{AJ}. Report it to the risk committee against a ceiling the firm sets; the review deliberately does not suggest a number ^{AJ}.

Two companion measures make the ratio honest. **Qualified-alternative coverage** is the share of production use cases with a second model from a different vendor that has passed the same evaluation suite within the last quarter; the starting target is 100% for important business services ^{AJ}. **Failover drill success** is the share of scheduled drills in which traffic moved to the alternative with quality inside threshold; the starting target is 100% ^{AJ}. Spend gives a cross-check: the share of AI spend with the largest provider, reported quarterly to the third-party risk committee ^{AJ}.

These targets are starting points for a firm to calibrate, not industry benchmarks ^{AJ}. A low ratio with an untested alternative is worse than a high ratio the board has knowingly accepted ^{AJ}.

In the worked example

Step 10: regulation. The regulatory mapping: not an Annex III use; transparency and literacy duties; model vendors as material outsourcing with exit plans; the agent recorded in the model inventory. ^{AJ}

- **Now works:** The design is defensible to a regulator, not only to an architect. ^{AJ}
- **Must never:** Never assume a vendor's oversight covers the firm's duties. ^{AJ}
- **Evidence added:** The regulatory assessment attached to the use-case record. ^{AJ}

- **Signal:** Concentration ratio by provider for important services. ^{AJ}

Objections worth taking seriously

“No rule requires two vendors, so this is gold-plating.” The premise is right: no instrument in the review’s fact base says so ^{AJ}. But SS2/21 expects tested exit plans, including stressed exit ^{VF}²⁴³. An exit that has never been run through the gateway is not tested. For a model behind an important service, a qualified second route is the cheapest way to make the plan real. Where a use is not important, a documented acceptance of single-vendor risk may be the right answer ^{AJ}. The discipline is in deciding which is which, and writing the decision down ^{REC}.

“Route everything through the hyperscaler and the problem goes away.” It helps, because the hyperscaler is overseen and already contracted ^{AJ}. It does not remove the firm’s own due-diligence and contingency duties ^{VF}²⁴⁴. And it moves concentration rather than ending it: the model, gateway, guardrail and data services of one cloud then sit under a single designated provider ^{AJ}. Accept that consciously for the primary cloud, and keep a second route for important services

^{REC}.

“The rules are still moving. Wait for the request for information and the next DORA list.” The dates in this chapter will change, and the DORA list is updated every year ^{VF}²⁴⁵. The evidence will not change much. Inventory, logs, version bundles and exit drills serve every regime in the frame, and they are cheap to build once and expensive to retrofit ^{AJ}. If a model vendor is ever designated, the firm that already measures its concentration will have the shortest conversation with its supervisor ^{AJ}.

Questions for your team

- Which of our GenAI use cases support an important business service, and who decided?

²⁴³ Verified fact — R-PRA-SS221: PRA SS2/21 ‘Outsourcing and third party risk management’ (revised by PS7/26, March 2026) (see [regulatory_facts.json](#)); A8-S048: SS2/21 Outsourcing and third party risk management (and PS7/26, March 2026) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2021/ss221-march-21.pdf> accessed 2026-10-07 [search-tool extract]

²⁴⁴ Verified fact — R-UK-CTP: UK Critical Third Parties regime (FSMA 2023 / FSMA 2000 s312L; PRA/FCA/BoE CTP rules) and the Critical Third Parties (Designation) Regulations 2026 (SI 2026/777) (see [regulatory_facts.json](#)); A8-S023: The Critical Third Parties (Designation) Regulations 2026 (SI 2026/777); BoE/FCA/HMT announcements (HM Treasury / [legislation.gov.uk](#) / Bank of England) <https://www.legislation.gov.uk/ukSI/2026/777/made> accessed 2026-10-07 [search-tool extract]

²⁴⁵ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see [regulatory_facts.json](#)); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]

10. Multi-vendor AI is becoming close to a requirement

- For each one, what share of traffic goes to the largest model vendor, and what ceiling have we agreed?
- Which models do we reach directly rather than through a designated hyperscaler, and who carries that oversight?
- When did we last move live traffic to the second route, and did quality stay inside threshold?
- Which of our arrangements will need notification before a significant change from 18 March 2027?
- Could any prompt or configuration change turn a current use into an Annex III use without anyone noticing?
- Is our own GenAI model-risk standard written to SS1/23 quality, whatever our home regulator? ^{Rec}

In one line

Regulation rarely names the vendors you must use, but it will ask you to prove you can leave one, so build that proof before you need it ^{AJ}.

11. You may not need a vector database

L6 Retrieval and knowledge stores, from Post 11 of the series.

The post

You may not need a vector database. You do need retrieval you can measure.

The category has quietly turned into a feature. General-purpose databases, search engines and even object storage now offer vector search, and hybrid retrieval, lexical plus semantic, is standard rather than advanced. For most regulated asset-management corpora, the database or search platform already in place will do the job.^{246 AJ}

That matters because every extra store is another copy of confidential content to secure, retain, back up and eventually exit. So the first question is not which engine; it is whether a load test on your own data gives you a reason for one. Three reasons hold up: filtered latency or recall fails the budget, tenants must be isolated at a scale schemas cannot manage, or the corpus makes the existing platform's cost disproportionate.^{AJ}

The signal is filtered recall@k: recall measured with production-like entitlement filters applied, not on the open index. A store that looks excellent unfiltered can

²⁴⁶ Verified fact — A2-S061: pgvector 0.8.7 Released (PostgreSQL Global Development Group (news post by pgvector p) <https://www.postgresql.org/about/news/pgvector-087-released-3392/> accessed 2026-10-07 [search-tool extract]; A2-S137: MongoDB Search and Vector Search Now Run Anywhere <https://www.mongodb.com/company/blog/product-release-announcements/mongodb-search-vector-search-now-run-anywhere> accessed 2026-10-07 [search-tool extract]; A2-S133: Elastic 9.5: Columnar, VectorDB index mode & auto-calibration, and AI-driven alert triage <https://www.elastic.co/blog/whats-new-elastic-9-5-0> accessed 2026-10-07 [search-tool extract]; A2-S081: Amazon S3 Vectors is now generally available with 40 times the scale of preview (Amazon Web Services) <https://aws.amazon.com/about-aws/whats-new/2025/12/amazon-s3-vectors-generally-available/> accessed 2026-10-07 [search-tool extract]; A2-S056: turbopuffer (Python SDK) - PyPI (PyPI / turbopuffer) <https://pypi.org/project/turbopuffer/> accessed 2026-10-07; A2-S103: Qdrant 1.17 - Relevance Feedback & Search Latency Improvements <https://qdrant.tech/blog/qdrant-1.17.x/> accessed 2026-10-07 [search-tool extract]; A2-S101: Introducing cascading retrieval: Unifying dense and sparse with reranking (Pinecone) <https://www.pinecone.io/blog/cascading-retrieval/> accessed 2026-10-07 [search-tool extract]

11. You may not need a vector database

collapse once a restrictive filter leaves too few candidates. The tempting fix, retrying without the filter, is how another client's material reaches a draft. ^{AJ}

The leadership move is to treat the store as a derived index, never the system of record. If you can rebuild it from approved sources, with a pinned embedding model, inside a tested time, it is also your backup and your exit plan. ^{Rec}

The honest caveat: dedicated engines still earn their place on filtered search, tenant isolation and scale. The point is to arrive at one with evidence, not by default. ^{Ver²⁴⁷ AJ}

Retrieval is judged by what it returns under real permissions. An open-index benchmark answers a different question.

²⁴⁷ Verified fact — A2-S103: Qdrant 1.17 - Relevance Feedback & Search Latency Improvements <https://qdrant.tech/blog/qdrant-1.17.x/> accessed 2026-10-07 [search-tool extract]; A2-S124: Architecture - turbopuffer <https://turbopuffer.com/docs/architecture> accessed 2026-10-07 [search-tool extract]; A2-S117: Release Notes - Milvus (Milvus project) https://milvus.io/docs/release_notes.md accessed 2026-10-07 [search-tool extract]



Figure 11. Use the platform you already run until a load test shows a trigger, and filter inside the search with no fallback. Generic; the leakage path is illustrative. ^{AJ}

Behind the post

A category became a feature. Three movements in 2025–26 changed this layer. First, hybrid retrieval became standard: turbopuffer ranks by vectors and BM25, Chroma Cloud offers vector, hybrid and full-text search, Milvus ships BM25, and

Elasticsearch, MongoDB, Qdrant and Pinecone all fuse lexical and dense results²⁴⁸. Second, general-purpose databases absorbed vector search. pgvector reached 0.8.7 on 1 October 2026²⁴⁹, and MongoDB Vector Search is generally available on self-managed editions as well as Atlas²⁵⁰. Third, vectors moved onto object storage: Amazon S3 Vectors has been generally available since December 2025, Milvus 3.0 is “lake-native”, and turbopuffer keeps all durable state in object storage²⁵¹. Meanwhile some vendors repositioned above the store. Pinecone now sells Nexus, a “knowledge engine for agents”²⁵². The term “vector database” now describes a feature more than a product category^{AI}.

²⁴⁸ Verified fact — A2-S056: turbopuffer (Python SDK) - PyPI (PyPI / turbopuffer) <https://pypi.org/project/turbopuffer/> accessed 2026-10-07; A2-S060: chromadb - PyPI (PyPI / Chroma) <https://pypi.org/project/chromadb/> accessed 2026-10-07; A2-S054: milvus-lite - PyPI (PyPI / Milvus contributors) <https://pypi.org/project/milvus-lite/> accessed 2026-10-07; A2-S133: Elastic 9.5: Columnar, VectorDB index mode & auto-calibration, and AI-driven alert triage <https://www.elastic.co/blog/whats-new-elastic-9-5-0> accessed 2026-10-07 [search-tool extract]; A2-S141: Context Engineering Has a Retrieval Issue: Introducing rerank-3 and Native Reranking (MongoDB) <https://www.mongodb.com/company/blog/product-release-announcements/introducing-rerank-3-and-native-rerank> accessed 2026-10-07 [search-tool extract]; A2-S103: Qdrant 1.17 - Relevance Feedback & Search Latency Improvements <https://qdrant.tech/blog/qdrant-1.17.x/> accessed 2026-10-07 [search-tool extract]; A2-S101: Introducing cascading retrieval: Unifying dense and sparse with reranking (Pinecone) <https://www.pinecone.io/blog/cascading-retrieval/> accessed 2026-10-07 [search-tool extract]

²⁴⁹ Verified fact — V1-S020: pgvector CHANGELOG.md (pgvector (GitHub)) <https://raw.githubusercontent.com/pgvector/pgvector/master/CHANGELOG.md> accessed 2026-10-08; V1-S022: pgvector 0.8.7 Released (PostgreSQL Global Development Group) <https://www.postgresql.org/about/news/pgvector-087-released-3392/> accessed 2026-10-08 [search-tool extract]

²⁵⁰ Verified fact — A2-S137: MongoDB Search and Vector Search Now Run Anywhere <https://www.mongodb.com/company/blog/product-release-announcements/mongodb-search-vector-search-now-run-anywhere> accessed 2026-10-07 [search-tool extract]; V1-S035: MongoDB Delivers Accurate AI Retrieval Wherever Enterprise Data Lives; Community Edition product page (MongoDB, Inc.) <https://investors.mongodb.com/news-releases/news-release-details/mongodb-delivers-accurate-ai-retrieval-wherever-enterprise-data> accessed 2026-10-08 [search-tool extract]

²⁵¹ Verified fact — A2-S081: Amazon S3 Vectors is now generally available with 40 times the scale of preview (Amazon Web Services) <https://aws.amazon.com/about-aws/whats-new/2025/12/amazon-s3-vectors-generally-available/> accessed 2026-10-07 [search-tool extract]; V1-S030: Amazon S3 Vectors is now generally available with 40 times the scale of preview; S3 Vectors limitations; March 2026 region expansion (Amazon Web Services) <https://aws.amazon.com/about-aws/whats-new/2025/12/amazon-s3-vectors-generally-available/> accessed 2026-10-08 [search-tool extract]; A2-S118: Zilliz Announces Milvus 3.0, Making the World's Most Adopted Open-Source Vector Database Lake-Native <https://zilliz.com/news/milvus-3-0-lake-native-vector-database> accessed 2026-10-07 [search-tool extract]; A2-S124: Architecture - turbopuffer <https://turbopuffer.com/docs/architecture> accessed 2026-10-07 [search-tool extract]

²⁵² Verified fact — A2-S073: General Availability of Pinecone Nexus Proves Knowledge Drives Real Outcomes for Agentic AI <https://www.pinecone.io/newsroom/general-availability-of-pinecone-nexus-proves-knowledge-drives-real-outcomes-for-agentic-ai/> accessed 2026-10-07 [search-tool extract]; V1-S029: General Availability of Pinecone Nexus (press release); Nexus GA blog <https://www.pinecone.io/newsroom/general-availability-of-pinecone-nexus-proves-knowledge-drives-real-outcomes-for-agentic-ai/> accessed 2026-10-08 [search-tool extract]

Why another store is a liability before it is an asset. A retrieval store holds a second representation of the firm's most sensitive unstructured content ^{AI}. Embeddings are derived from that content and should carry the same classification, residency and erasure duties as the text they came from ^{AI}. Residency has to cover vectors, raw text, caches, replicas and backups, and an erasure request has to reach the index as well as the source ^{AI}. For an EU entity, a vector-database SaaS is an ICT third-party service that belongs in the DORA register of information ^{vr253}. And because the specialist SaaS stores all run on the major hyperscalers, their outages correlate with the cloud's ^{vr254 AI}. None of that argues against vectors. It argues against an extra copy that nobody can justify.

The three triggers. The review's decision tree starts from the database or search platform the firm already operates: PostgreSQL with pgvector, Elasticsearch where lexical matching on fund codes and share-class names matters, or MongoDB where it is already the system of record ^{Rec}. It moves to a dedicated engine only when a load test on the firm's own data shows at least one of three triggers: filtered p95 latency or filtered recall fails the budget; tenants must be isolated at a scale schemas cannot manage cleanly; or corpus size or write rate makes the existing platform's cost disproportionate ^{Rec}. If a trigger is real, the choice of engine follows where it must run. Qdrant or Milvus suit the firm's own estate; Pinecone, turbopuffer or Zilliz suit a data plane in the firm's cloud account ^{Rec}. turbopuffer reports Anthropic as a customer ^{vr255}, so the review names Zilliz Cloud BYOC as the independent alternative for that profile ^{AI}. Weaviate stays Tactical while its open-core licence position settles ^{vr256 Rec}.

²⁵³ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see regulatory_facts.json); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]

²⁵⁴ Verified fact — A2-S069: Bring Your Own Cloud (BYOC) - Pinecone Docs <https://docs.pinecone.io/guides/production/bring-your-own-cloud> accessed 2026-10-07 [search-tool extract]; A2-S121: Zilliz Cloud Now Available in AWS Europe (Ireland) <https://zilliz.com/blog/zilliz-cloud-now-available-in-aws-europe-ireland> accessed 2026-10-07 [search-tool extract]; A2-S105: Qdrant Security: Compliance, Isolation, and Encryption Across Every Deployment <https://qdrant.tech/security/> accessed 2026-10-07 [search-tool extract]; A2-S111: Vector Database Pricing - Weaviate <https://weaviate.io/pricing> accessed 2026-10-07 [search-tool extract]; A2-S125: turbopuffer BYOC <https://turbopuffer.com/docs/byoc> accessed 2026-10-07 [search-tool extract]; A2-S140: Search Node Costs - Atlas (MongoDB) <https://www.mongodb.com/docs/atlas/billing/search-node/> accessed 2026-10-07 [search-tool extract]; A2-S135: Elastic Cloud Hosted regions <https://www.elastic.co/docs/reference/cloud/cloud-hosted/regions> accessed 2026-10-07 [search-tool extract]; A2-S129: Chroma Cloud - Chroma Docs <https://docs.trychroma.com/cloud/getting-started> accessed 2026-10-07 [search-tool extract]

²⁵⁵ Reported — A2-S126: Ex-Shopify engineers raise fresh financing to scale Turbopuffer's AI search (BetaKit) <https://betakit.com/ex-shopify-engineers-raise-fresh-financing-to-scale-turbopuffers-ai-search/> accessed 2026-10-07 [search-tool extract]

Where leakage comes from. There are three ways to apply a filter ^{AJ}. Post-filtering runs the nearest-neighbour search first and discards disallowed results. It is cheap, and it is the cause of filter collapse: a restrictive filter leaves too few results, so recall drops or the system quietly widens the filter ^{AJ}. Pre-filtering, or filter-aware traversal, restricts the search to permitted candidates as it runs; Qdrant added ACORN-based filtered search in 1.16, and pgvector 0.8.0 added iterative index scans for filtered queries ^{vi}²⁵⁷. Partitioning gives each tenant its own namespace or collection, so the filter becomes an address ^{AJ}. The review's illustrative scenario shows the failure in practice. A shared index post-filters by fund; a small segregated mandate's query returns nothing permitted; a fallback retries without the filter "to avoid an empty context"; and another client's hedging rationale reaches the draft ^{AJ}. Three choices would each have prevented it: filtering inside the search, a hard empty result instead of a fallback, and a cross-fund leakage test in the evaluation suite ^{AJ}.

The engines provide the mechanism; the firm provides the policy. turbopuffer, for example, states that permissions must be implemented with filters because it has no built-in row- or document-level access control ^{vi}²⁵⁸. Most engines are in the same position ^{AJ}. So the entitlement logic belongs in the firm's identity control and should be compiled into whichever store is used. Held only in one store's proprietary syntax, it becomes lock-in the review classifies as unacceptable ^{AJ}.

Derived, rebuildable, patched. The review's defining rule is that the store is a derived index over approved content, never the system of record ^{Rec}. Keep the raw text and the embedding-model version beside every vector, and the index can be rebuilt without re-parsing (Chapter 13) ^{AJ}. That rebuild is then the primary backup and the exit route. SS2/21 expects documented and tested exit plans ^{vi}²⁵⁹, so rebuild

²⁵⁶ Verified fact — A2-S115: weaviate/weaviate (README and licence files; PR #13360) (Weaviate) <https://github.com/weaviate/weaviate> accessed 2026-10-07 [search-tool extract]; V1-S070: weaviate/weaviate README (Community vs Enterprise Edition), releases, PR #13360, PR #12942 (Weaviate (GitHub)) <https://github.com/weaviate/weaviate> accessed 2026-10-08 [search-tool extract]

²⁵⁷ Verified fact — A2-S103: Qdrant 1.17 - Relevance Feedback & Search Latency Improvements <https://qdrant.tech/blog/qdrant-1.17.x/> accessed 2026-10-07 [search-tool extract]; V1-S020: pgvector CHANGELOG.md (pgvector (GitHub)) <https://raw.githubusercontent.com/pgvector/pgvector/master/CHANGELOG.md> accessed 2026-10-08

²⁵⁸ Verified fact — B-L6-S002: turbopuffer Regions; Security; Permissions; Roadmap & Changelog; Private Networking <https://turbopuffer.com/docs/regions> accessed 2026-10-08 [search-tool extract]

²⁵⁹ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by P57/26, March 2026) (see regulatory_facts.json); A8-S048: SS2/21 Outsourcing and third party risk management (and P57/26, March 2026) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2021/ss221-march-21.pdf> accessed 2026-10-07 [search-tool extract]

time belongs in the exit plan and should be tested twice a year^{Rec}. A “knowledge engine” adopted as the only home of curated knowledge breaks the rule; adopted as a disposable derived layer, it does not^{AI}.

Finally, patch the store like a database, because it is one. pgvector 0.8.7 fixed an index-build buffer overflow rated CVSS 8.8^{VF-260}. Managed hosts lag upstream: the latest Amazon RDS release seen carried pgvector 0.8.2, while Cloud SQL moved to 0.8.5 in August 2026^{VF-261}. Self-hosted defaults need care too. Chroma removed its built-in authentication in 1.0, and Milvus Lite has no authentication or TLS^{VF-262}. A prototype store promoted to production without returning to the decision tree is one of the review’s named anti-patterns^{AI}.

What good looks like

The signal is **filtered recall@k**: recall@k measured on a labelled query set with production-like entitlement filters applied, not on the open index^{AI}. Run the same queries with and without filters. The starting target is filtered recall within an agreed tolerance of unfiltered recall for the same queries^{AI}. A large gap means the store is collapsing under selective filters, which is exactly when teams are tempted to add a fallback^{AI}.

Three companion measures keep it honest. **Entitlement leakage**, tested with adversarial queries per tenant in CI, has a target of zero, and any occurrence is a severity-1 incident^{AI}. **p95 latency under filter** is measured with the most selective realistic filter on tenant-skewed data, against a budget per use case^{AI}. **Rebuild time** from the approved source with the pinned model should sit inside the exit-plan tolerance, tested twice a year^{AI}.

²⁶⁰ Verified fact — V1-S022: pgvector 0.8.7 Released (PostgreSQL Global Development Group) <https://www.postgresql.org/about/news/pgvector-087-released-3392/> accessed 2026-10-08 [search-tool extract]; A2-S061: pgvector 0.8.7 Released (PostgreSQL Global Development Group (news post by pgvector p) <https://www.postgresql.org/about/news/pgvector-087-released-3392/> accessed 2026-10-07 [search-tool extract]

²⁶¹ Verified fact — B-L6-S004: Extension versions for Amazon RDS for PostgreSQL; RDS PostgreSQL release notes; Aurora pgvector announcements (Amazon Web Services) <https://docs.aws.amazon.com/AmazonRDS/latest/PostgreSQLReleaseNotes/postgresql-extensions.html> accessed 2026-10-08 [search-tool extract]; B-L6-S005: Vector search in Azure Database for PostgreSQL flexible server; Cloud SQL vector embeddings; AlloyDB vector search overview (Microsoft; Google Cloud) <https://learn.microsoft.com/en-us/azure/postgresql/extensions/how-to-use-pgvector> accessed 2026-10-08 [search-tool extract]

²⁶² Verified fact — A2-S131: Migration - Chroma Docs <https://docs.trychroma.com/docs/overview/migration> accessed 2026-10-07 [search-tool extract]; A2-S054: milvus-lite - PyPI (PyPI / Milvus contributors) <https://pypi.org/project/milvus-lite/> accessed 2026-10-07

These are starting points to calibrate on the firm's own corpus, not industry benchmarks ^{AJ}.

In the worked example

Step 11: retrieval store. One store already run by the firm, with three collections (prior commentaries, style guide, approved market notes) and fund-level entitlement filters applied inside the search. ^{AJ}

- **Now works:** Context arrives only from documents the analyst is entitled to see. ^{AJ}
- **Must never:** No unfiltered fallback: no permitted result means an empty result. ^{AJ}
- **Evidence added:** Retrieved chunk IDs and versions per draft. ^{AJ}
- **Signal:** Filtered recall against unfiltered recall. ^{AJ}

Objections worth taking seriously

“Dedicated engines are faster. The benchmarks say so.” Some are, on some workloads. But vendor latency figures are context, not decision inputs, and unfiltered benchmarks overstate both recall and speed ^{AJ}. The honest test is a load test with the firm's filters and tenant skew on its own corpus. If that shows a trigger, the dedicated engine has earned its place, and the review recommends one ^{Rec}. Qdrant and Milvus are rated Strategic for exactly that case, which is hardly a bias against the category ^{Rec}.

“Our database team does not want vector workloads on the operational estate.” That is a fair operational concern, not a prejudice. Memory-resident indexes are expensive, and a team can reasonably refuse to carry them on a critical database ^{AJ}. That concern is trigger (c), disproportionate cost, and it should be evidenced in the same load test. A search platform the firm already runs, or a separate instance of the same database, may answer it without a new vendor ^{AJ}.

“An empty result is a poor experience for the analyst.” It is less poor than another client's material in a draft. The review's worked example returns nothing when no permitted passage meets the relevance threshold. The workflow then drafts from the attribution output and the style guide alone, flagged “no comparable commentary” ^{AJ}. A visible gap is a prompt to add content. A silent fallback is an incident waiting for a reviewer to miss it ^{AJ}. Segregated mandates should also get their own partition, so that isolation never depends on a filter clause alone ^{Rec}.

Questions for your team

- How many retrieval stores hold copies of client content today, and who owns each one?
- Is our recall measured with production entitlement filters applied, or on the open index?
- Does any code path retry a query without its filter when results come back empty?
- Can we rebuild each index from approved sources with a pinned model, and how long did it last take?
- Which load-test result, if any, justified each dedicated engine we run?
- Which pgvector or engine version is our managed host actually running against current CVEs?
- Where do our entitlement rules live, and would they survive a change of store? ^{Rec}

In one line

Choose the store you already run until your own filtered load test gives you a reason not to, and make sure you could rebuild it tomorrow ^{AJ}.

12. Every retrieved document is untrusted input

C7 AI security, from Post 12 of the series.

The post

A language model follows instructions it finds in any text it reads. Give it tools, and those instructions become actions.

That is why every retrieved document is untrusted input. Retrieval is about finding the right passages; security is about passages someone else wrote for you. A broker note, a web page or an email can carry hidden text, and it arrives through the same pipeline as the firm's own knowledge. Indirect prompt injection is a supply-chain problem, not a chat problem. ^{AJ}

The supply chain is literal too. In March 2026, malicious releases of a widely used open-source model gateway were published to a public package index using stolen release credentials. The component that holds every provider key was itself the target. ^{V2²⁶³ AJ}

The first design rule needs no product: no agent should hold untrusted input, sensitive data and an outbound channel at the same time. Remove any one of the three and an injected instruction has nowhere to go. ^{AJ}

The signal is simple to count: the number of agents that combine all three. The target is zero, unless there is a documented exception with a named owner. ^{AJ}

²⁶³ Verified fact — A6-S008: Security Update: Suspected Supply Chain Incident (and Security Townhall Updates) (BerriAI (LiteLLM)) <https://docs.litellm.ai/blog/security-update-march-2026> accessed 2026-10-07 [search-tool extract]; A6-S009: v1.83.0 - Official Release (Post Supply Chain Incident) (BerriAI (LiteLLM)) https://docs.litellm.ai/release_notes/v1.83.0/v1-83-0 accessed 2026-10-07 [search-tool extract]; A6-S010: Your AI Gateway Was a Backdoor: Inside the LiteLLM Supply Chain Compromise (Trend Micro Research) https://www.trendmicro.com/en_us/research/26/c/inside-litellm-supply-chain-compromise.html accessed 2026-10-07 [search-tool extract]; V2-S027: LiteLLM PyPI supply chain attack (with NetSPI, Comet, Snyk/Datadog reporting) (FutureSearch) <https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/> accessed 2026-10-08 [search-tool extract]

Part II: Nine layers and the controls that make them safe

Then layer the rest so no single detector has to be right: secrets brokered outside the model, short-lived credentials per request, pinned and hashed dependencies, retrieved text marked as data, and a runtime detector behind the gateway as a replaceable part, not the foundation. The leadership move is to buy detection last.

Rec

The honest caveat: marking retrieved text as data and screening it reduces the risk; it does not remove it. Capability separation is what turns a successful injection into a non-event. ^{AJ}

A design that depends on a filter catching everything is a hope. One that leaves an attacker nothing to call is an architecture.

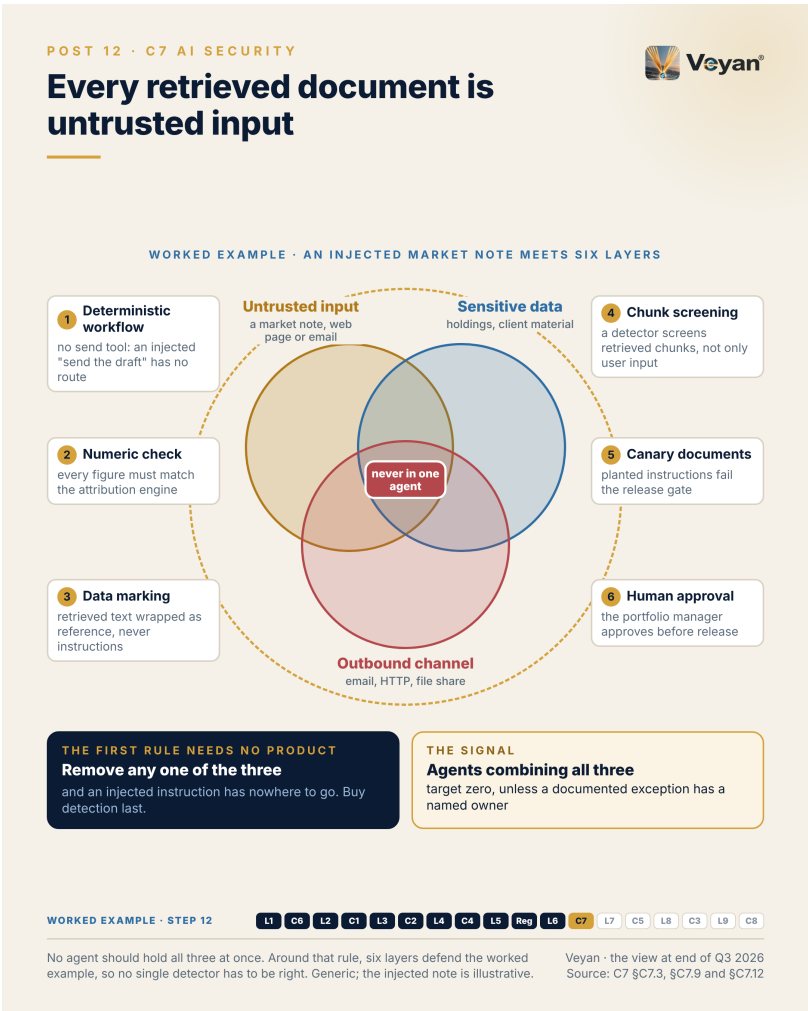


Figure 12. No agent should hold all three at once. Around that rule, six layers defend the worked example, so no single detector has to be right. Generic; the injected note is illustrative. ^{AJ}

Behind the post

Code and data are no longer separate. Conventional software keeps instructions in code and treats content as data. A language model does not make that distinction:

it follows instructions wherever it finds them, and an agent with tools turns them into actions ^{AJ}. Every retrieved document, web page, email, tool result and memory entry is therefore input that an attacker may have written ^{AJ}. The industry taxonomy has caught up. The OWASP Top 10 for Agentic Applications for 2026 opens with ASI01 Agent Goal Hijack ^{vr264}. Later entries include tool misuse, agentic supply-chain vulnerabilities, unexpected code execution, and memory and context poisoning ^{vr265}. Retrieval (Chapter 11) is one of the main routes in, which is why indirect injection is best understood as a supply-chain problem: the payload arrives through the same pipeline as the firm's own knowledge ^{AJ}.

The supply chain is not a metaphor. On 24 March 2026, malicious LiteLLM releases 1.82.7 and 1.82.8 were published to PyPI using stolen release credentials ^{vr266}. They were live for about 40 minutes according to LiteLLM, or about three hours according to Snyk, before quarantine ^{vr267}. The route in is reported two ways. LiteLLM attributes it to a compromised scanner in its build pipeline; other reports describe a hijacked maintainer account ^{vr268}. The first clean build from a rebuilt pipeline, 1.83.0, followed on 31 March after a forensic review, and container

²⁶⁴ Verified fact — R-OWASP-AGENTIC: OWASP Top 10 for Agentic Applications for 2026 (see regulatory_facts.json); A8-S042: OWASP Top 10 for Agentic Applications for 2026 (launched 9-10 December 2025) (OWASP GenAI Security Project) <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> accessed 2026-10-07 [search-tool extract]

²⁶⁵ Verified fact — B-C4-S005: OWASP Top 10 for Agentic Applications (release post and related OWASP pages) (OWASP GenAI Security Project) <https://genai.owasp.org/2025/12/09/owasp-top-10-for-agentic-applications-the-benchmark-for-agentic-security-in-the-age-of-autonomous-ai/> accessed 2026-10-08 [search-tool extract]

²⁶⁶ Verified fact — A6-S008: Security Update: Suspected Supply Chain Incident (and Security Townhall Updates) (BerriAI (LiteLLM)) <https://docs.litellm.ai/blog/security-update-march-2026> accessed 2026-10-07 [search-tool extract]; A6-S009: v1.83.0 - Official Release (Post Supply Chain Incident) (BerriAI (LiteLLM)) https://docs.litellm.ai/release_notes/v1.83.0/v1-83-0 accessed 2026-10-07 [search-tool extract]; A6-S010: Your AI Gateway Was a Backdoor: Inside the LiteLLM Supply Chain Compromise (Trend Micro Research) https://www.trendmicro.com/en_us/research/26/c/inside-litellm-supply-chain-compromise.html accessed 2026-10-07 [search-tool extract]; V2-S027: LiteLLM PyPI supply chain attack (with NetSPI, Comet, Snyk/Datadog reporting) (FutureSearch) <https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/> accessed 2026-10-08 [search-tool extract]

²⁶⁷ Verified fact — A6-S008: Security Update: Suspected Supply Chain Incident (and Security Townhall Updates) (BerriAI (LiteLLM)) <https://docs.litellm.ai/blog/security-update-march-2026> accessed 2026-10-07 [search-tool extract]; A6-S009: v1.83.0 - Official Release (Post Supply Chain Incident) (BerriAI (LiteLLM)) https://docs.litellm.ai/release_notes/v1.83.0/v1-83-0 accessed 2026-10-07 [search-tool extract]; A6-S010: Your AI Gateway Was a Backdoor: Inside the LiteLLM Supply Chain Compromise (Trend Micro Research) https://www.trendmicro.com/en_us/research/26/c/inside-litellm-supply-chain-compromise.html accessed 2026-10-07 [search-tool extract]; V2-S027: LiteLLM PyPI supply chain attack (with NetSPI, Comet, Snyk/Datadog reporting) (FutureSearch) <https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/> accessed 2026-10-08 [search-tool extract]

²⁶⁸ Verified fact — A6-S009: v1.83.0 - Official Release (Post Supply Chain Incident) (BerriAI (LiteLLM)) https://docs.litellm.ai/release_notes/v1.83.0/v1-83-0 accessed 2026-10-07 [search-tool extract]; V2-S027: LiteLLM PyPI supply chain attack (with NetSPI, Comet, Snyk/Datadog reporting) (FutureSearch) <https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/> accessed 2026-10-08 [search-tool extract]

images have been signed since ^{vi269}. The lesson for an architect is uncomfortable and simple. The gateway, the component that holds every provider key, was itself the target ^{AI}. A dependency pinned by hash from a private mirror would not have resolved to the malicious versions ^{AI}. Model files carry a parallel risk. Pickle-based formats can execute code on load, and the safetensors project describes pickle as “Unsafe, runs arbitrary code” ^{vi270}. Scanning helps, but Hugging Face itself notes that it reduces risk rather than removing it ^{vi271}.

The rule that needs no product. The single most effective injection control is architectural: an agent that reads untrusted content should not also hold sensitive data and an outbound channel ^{AI}. Remove any one of the three and an injected instruction has nowhere to go. In practice that means reader agents that cannot act, and actor agents that never read untrusted content. A read-only tool, a deterministic workflow and a human approval gate do most of the work ^{AI}. The review’s illustrative scenario shows the opposite design: a research assistant with URL fetch, internal search and email, and an API key in its system prompt. A planted line in a broker PDF sends holdings out in a URL query string and puts the key in a footnote ^{AI}. Nothing in that design was exotic. It combined all three capabilities in one context, with a secret inside the prompt ^{AI}.

Then the layers. Once the capability rule holds, the review layers the rest so that no single control has to be right ^{AI}.

- *Secrets brokered outside the model.* The agent authenticates as a workload and receives a short-lived credential for one downstream system; the model never sees it ^{AI}. HashiCorp Vault’s agentic IAM enforces the intersection of the user’s permissions, an agent ceiling policy and request-scoped details, and records both user and agent in its audit log ^{vi272}. Vault is IBM-owned and under BUSL 1.1 ^{vi273}; a cloud’s native secrets service with workload identity is the alternative for a single-cloud estate ^{ftcc}.

²⁶⁹ Verified fact — A6-S009: v1.83.0 - Official Release (Post Supply Chain Incident) (BerriAI (LiteLLM)) https://docs.litellm.ai/release_notes/v1.83.0/v1-83-0 accessed 2026-10-07 [search-tool extract]; V2-S027: LiteLLM PyPI supply chain attack (with NetSPI, Comet, Snyk/Datadog reporting) (FutureSearch) <https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/> accessed 2026-10-08 [search-tool extract]; V2-S028: PyPI JSON API: litellm, guardrails-ai, presidio-analyzer, nemoguardrails, llamafirewall, langfuse, promptfoo, modelscan, picklescan, fickle, safetensors, mode <https://pypi.org/pypi/litellm/json> accessed 2026-10-08 [search-tool extract]; A6-S051: LiteLLM README (GitHub) (BerriAI (LiteLLM)) <https://raw.githubusercontent.com/BerriAI/litellm/main/README.md> accessed 2026-10-07

²⁷⁰ Verified fact — A7-S082: ModelScan README (Protect AI (Palo Alto Networks)) <https://raw.githubusercontent.com/protectai/modelscan/main/README.md> accessed 2026-10-07; B-C7-S006: safetensors README (Hugging Face) <https://raw.githubusercontent.com/huggingface/safetensors/main/README.md> accessed 2026-10-08

²⁷¹ Verified fact — A7-S037: Hugging Face Hub Security docs (malware scanning, pickle scanning, third-party scanners Protect AI and JFrog) <https://huggingface.co/docs/hub/security> accessed 2026-10-07 [search-tool extract]

Part II: Nine layers and the controls that make them safe

- *Pinned and hashed dependencies* from a private mirror, with a cooling-off period before production and a software bill of materials for each image ^{Rec.}
- *Retrieved text marked as data*. Each chunk carries its source and trust tier, and the prompt template wraps it as quoted reference material ^{AI}.
- *A runtime detector behind the gateway*, screening retrieved chunks and outputs as well as user input, with its verdicts sent to the SIEM ^{AI}.

Why detection comes last. The specialist market has largely been bought. Check Point acquired Lakera, completed on 22 October 2025. Palo Alto Networks acquired Protect AI in July 2025. Prompt Security, CalypsoAI and Pangea went to SentinelOne, F5 and CrowdStrike, all closing in September 2025 ^{vi}²⁷⁴. HiddenLayer is the main independent left in that set ^{vi}²⁷⁵. AI security is consolidating into network and endpoint security platforms, not into model vendors ^{AI}. That is a reason to buy from an existing security supplier if it fits, and a reason to keep the detector behind

²⁷² Verified fact — A7-S034: HashiCorp Vault agentic IAM is now generally available (HashiCorp (IBM)) <https://www.hashicorp.com/en/blog/hashicorp-vault-agentic-iam-is-now-generally-available> accessed 2026-10-07 [search-tool extract]

²⁷³ Verified fact — A7-S032: IBM Completes Acquisition of HashiCorp, Creates Comprehensive, End-to-End Hybrid Cloud Platform <https://newsroom.ibm.com/2025-02-27-ibm-completes-acquisition-of-hashicorp,-creates-comprehensive,-end-to-end-hybrid-cloud-platform> accessed 2026-10-07 [search-tool extract]; A7-S060: HashiCorp Vault LICENSE (BUSL 1.1) (HashiCorp / IBM) <https://raw.githubusercontent.com/hashicorp/vault/main/LICENSE> accessed 2026-10-07

²⁷⁴ Verified fact — A7-S012: Check Point to Acquire Lakera, Redefining Security for the AI era (Check Point Software) <https://blog.checkpoint.com/security/check-point-to-acquire-lakera-redefining-security-for-the-ai-era/> accessed 2026-10-07 [search-tool extract]; V2-S038: Check Point Software Reports 2025 Third Quarter Financial Results (with 'Check Point Completes Acquisition of Lakera' release via cxotoday) (Check Point Software Technologies) <https://www.checkpoint.com/press-releases/check-point-software-reports-2025-third-quarter-financial-results/> accessed 2026-10-08 [search-tool extract]; A7-S014: Palo Alto Networks Completes Acquisition of Protect AI <https://www.paloaltonetworks.com/company/press/2025/palo-alto-networks-completes-acquisition-of-protect-ai> accessed 2026-10-07 [search-tool extract]; V2-S039: Palo Alto Networks Completes Acquisition of Protect AI <https://investors.paloaltonetworks.com/news-releases/news-release-details/palo-alto-networks-completes-acquisition-protect-ai/> accessed 2026-10-08 [search-tool extract]; A7-S018: SentinelOne Form 10-Q (FY2026) and completion press release for Prompt Security (SentinelOne / US SEC) <https://www.sec.gov/Archives/edgar/data/0001583708/000158370826000041/s-20260430.htm> accessed 2026-10-07 [search-tool extract]; A7-S019: F5, Inc. Form 10-Q (quarter ended 31 Dec 2025) and F5 blog on CalypsoAI (F5 / US SEC) <https://www.sec.gov/Archives/edgar/data/1048695/000104869526000023/ffiv-20251231.htm> accessed 2026-10-07 [search-tool extract]; A7-S020: CrowdStrike to Acquire Pangea to Secure Every Layer of Enterprise AI; CrowdStrike FY2026 Form 10-K <https://ir.crowdstrike.com/news-releases/news-release-details/crowdstrike-acquire-pangea-secure-every-layer-enterprise-ai> accessed 2026-10-07 [search-tool extract]; V2-S040: SEC filings and announcements: SentinelOne completes Prompt Security (8-K, 10-Q); F5 completes CalypsoAI (F5 blog, 10-Q); CrowdStrike completes Pangea (X post, (SEC EDGAR / SentinelOne / F5 / CrowdStrike) <https://www.sec.gov/Archives/edgar/data/1535527/000153552726000010/crwd-20260131.htm> accessed 2026-10-08 [search-tool extract]

²⁷⁵ Verified fact — A7-S017: HiddenLayer Raises \$100M Series B to Advance AI Security <https://www.hiddenlayer.com/news/hiddenlayer-100m-series-b-ai-security> accessed 2026-10-07 [search-tool extract]; V2-S047: HiddenLayer Raises \$100 Million Series B Led By Delta-v Capital (with unite.ai, AI Weekly) (Pulse 2.0) <https://pulse2.com/hiddenlayer-raises-100-million-series-b-led-by-delta-v-capital/> accessed 2026-10-08 [search-tool extract]

one thin interface at the gateway so the choice stays reversible ^{Rec}. Detectors also create a new copy of client data: Lakera's dashboard records all prompts and model outputs by default ^{vr276}. Treat the detector's own store as a client-data store ^{Rec}.

What it looks like in the worked example. The commentary agent faces an approved third-party market note with hidden text telling it to invent a currency effect and send the draft elsewhere ^{AI}. Six layers answer it. The workflow has no email, HTTP or file-write tool. A deterministic check fails any figure that does not match the attribution engine. Retrieved text is marked as data. A detector screens chunks and quarantines the source. Canary documents in staging fail the release if they change an output. A portfolio manager approves every draft ^{AI}. For an EU entity, a successful exfiltration would also be an ICT-related incident to classify under DORA ^{vr277 AI}.

What good looks like

The signal is **agent capability exposure**: the number of agents that combine untrusted input, sensitive data and an outbound channel ^{AI}. Count it by reviewing the tool inventory against each agent's data access and input sources. The starting target is zero, unless an exception is documented with a named owner ^{AI}.

Four companion measures show whether the layers behind the rule work. The **indirect-injection canary rate** is the share of planted canary instructions in a test corpus that cause any unapproved tool call; target zero ^{AI}. **Secrets exposure**, from scanning traces, prompt registries and repositories, should also be zero ^{AI}. **Credential lifetime** for agents should be measured in minutes to hours, not months ^{AI}. **Time to revoke** an agent's or package's credentials after a compromise signal should be under an hour, proven in drills ^{AI}.

These are starting points for a firm to calibrate, not industry benchmarks ^{AI}. The count matters most when it is rising, because that usually means agents are gaining tools faster than anyone is reviewing them ^{AI}.

²⁷⁶ Verified fact — B-C7-S001: AI Guardrails Dashboard (Lakera / Check Point docs) (Lakera (Check Point)) <https://docs.lakera.ai/docs/platform> accessed 2026-10-08 [search-tool extract]

²⁷⁷ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see [regulatory_facts.json](#)); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]

In the worked example

Step 12: ai security. Defence in depth against a poisoned market note: nothing to hijack, numbers that cannot be rewritten, retrieved text marked as data, chunk screening, canary documents and human approval. ^{AJ}

- **Now works:** No single control has to catch an injected instruction. ^{AJ}
- **Must never:** Untrusted input, sensitive data and an outbound channel never meet in one agent. ^{AJ}
- **Evidence added:** Screening and canary results per run. ^{AJ}
- **Signal:** Agents combining all three risk factors: zero. ^{AJ}

Objections worth taking seriously

“An agent without web access and email is not much use.” Sometimes that is true. The answer is to split the work, not to drop the rule ^{AJ}. One agent reads and summarises untrusted material with no outbound channel. A separate step, or a person, decides what is sent and where. Where a single agent genuinely needs all three, record the exception, name its owner and add compensating controls such as an egress allowlist and human approval ^{Rec}. The split usually costs less than expected, because the outbound step was rarely the part that needed a model ^{AJ}.

“A good detector will catch injection. Why design around it?” Detectors reduce the risk; they do not remove it, and the first bypass becomes a breach if the detector is the control ^{AJ}. Five specialist vendors also changed hands in 2025, so a design that depends on one detector depends on its owner's roadmap ^{vi278 AJ}. Use detectors, ideally two from different owners on untrusted input, but as the second line ^{Rec}.

“We only use hosted model APIs, so supply chain is the provider's problem.” For model weights, largely yes ^{AJ}. But the SDKs, the gateway, the agent framework and any tool servers run in the firm's estate. The March 2026 compromise hit a gateway

²⁷⁸ Verified fact — A7-S012: Check Point to Acquire Lakera, Redefining Security for the AI era (Check Point Software) <https://blog.checkpoint.com/security/check-point-to-acquire-lakera-redefining-security-for-the-ai-era/> accessed 2026-10-07 [search-tool extract]; A7-S014: Palo Alto Networks Completes Acquisition of Protect AI <https://www.paloaltonetworks.com/company/press/2025/palo-alto-networks-completes-acquisition-of-protect-ai> accessed 2026-10-07 [search-tool extract]; A7-S018: SentinelOne Form 10-Q (FY2026) and completion press release for Prompt Security (SentinelOne / US SEC) <https://www.sec.gov/Archives/edgar/data/0001583708/000158370826000041/s-20260430.htm> accessed 2026-10-07 [search-tool extract]; A7-S019: F5, Inc. Form 10-Q (quarter ended 31 Dec 2025) and F5 blog on CalypsoAI (F5 / US SEC) <https://www.sec.gov/Archives/edgar/data/1048695/000104869526000023/ffiv-20251231.htm> accessed 2026-10-07 [search-tool extract]; A7-S020: CrowdStrike to Acquire Pangea to Secure Every Layer of Enterprise AI; CrowdStrike FY2026 Form 10-K <https://ir.crowdstrike.com/news-releases/news-release-details/crowdstrike-acquire-pangea-secure-every-layer-enterprise-ai> accessed 2026-10-07 [search-tool extract]

package, not a model²⁷⁹. Pin those by hash, as for any other code^{Rec}. If the firm later fine-tunes its own small model, store it as safetensors, scan it and sign it before it is loaded^{Rec}.

Questions for your team

- How many of our agents combine untrusted input, sensitive data and an outbound channel today?
- For each exception, who owns it and what compensates for it?
- Could any credential, key or token appear in a prompt, a trace or an agent's memory?
- Are our AI dependencies pinned by hash from a private mirror, including the gateway and its plug-ins?
- Do we screen retrieved chunks and tool outputs, or only what users type?
- If our runtime detector's owner changed tomorrow, how long would replacing it take?
- Where does the detector vendor keep our prompts, and for how long?^{Rec}

In one line

Design so that a successful injection has nothing to call, and treat every detector as a replaceable second line^{AI}.

²⁷⁹ Verified fact — A6-S008: Security Update: Suspected Supply Chain Incident (and Security Townhall Updates) (BerriAI (LiteLLM)) <https://docs.litellm.ai/blog/security-update-march-2026> accessed 2026-10-07 [search-tool extract]; V2-S027: LiteLLM PyPI supply chain attack (with NetSPI, Comet, Snyk/Datadog reporting) (FutureSearch) <https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/> accessed 2026-10-08 [search-tool extract]

13. Retrieval quality is a two-stage problem

L7 Embeddings and reranking (retrieval optimisation), from Post 13 of the series.

The post

Retrieval quality is a two-stage problem, and it is easy to tune only one stage.

The first stage casts a wide net: embed the question and pull back fifty or a hundred candidates. The second stage reorders them, so the handful the model actually reads are the right ones. Teams swap the embedding model to fix answers a reranker should have fixed, or add a reranker to rescue a first stage that never found the right passage. ^{AJ}

So measure the stages separately. For the first, the signal is recall@k: the share of questions in an in-domain golden set whose relevant passage appears anywhere in the candidates. A starting target is 0.95. Ranking quality after the reranker is a second number, and only then worth tuning. ^{AJ}

There is a quieter point underneath. The embedding model version is production configuration. Change it and the whole corpus must be re-embedded. Mix two versions in one index and the scores stop being comparable, with no error to tell you. Tag every vector with its model version, refuse queries that would mix versions, and migrate by building a second index behind a regression gate. ^{AJ Rec}

The leadership move is to choose models by your own evaluation, not by leaderboard or vendor claim. One to three hundred labelled questions, written by the analysts who will use the system, will tell you more than any published benchmark. ^{Rec}

The honest caveat: dual-index migration means running two indexes for a while, at roughly twice the storage. That is small next to an unplanned re-embed under time pressure. ^{AJ}

Most retrieval problems are measurement problems first. Once both stages are visible, the fixes are usually plain.

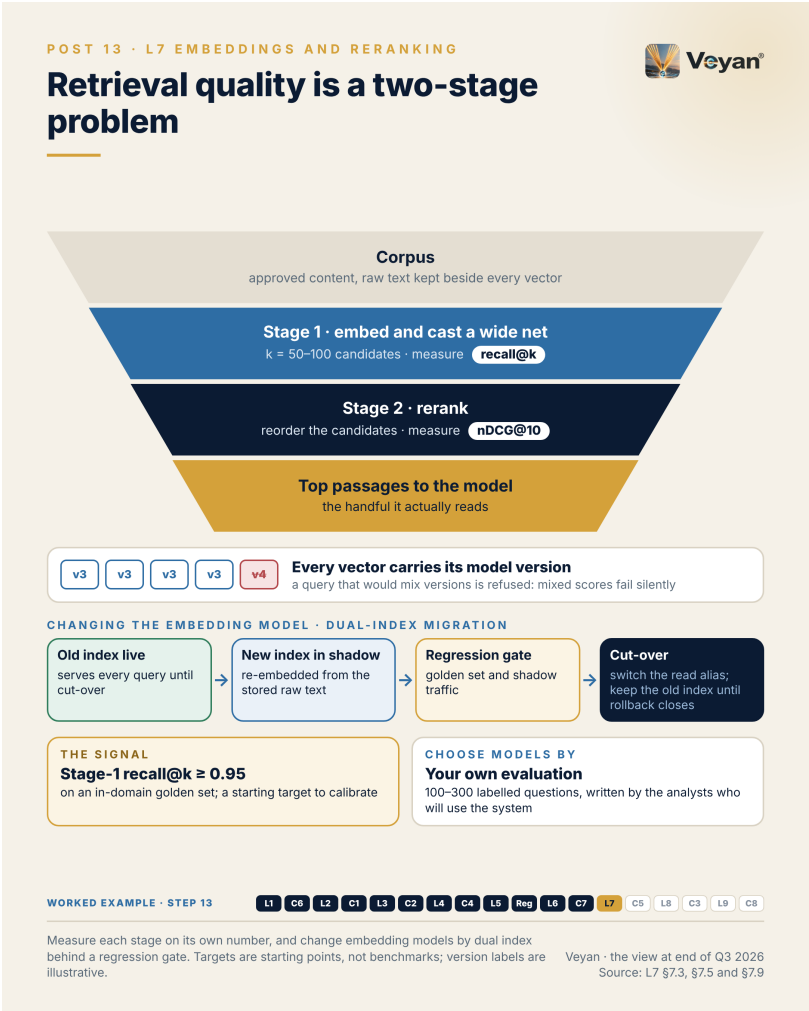


Figure 13. Measure each stage on its own number, and change embedding models by dual index behind a regression gate. Targets are starting points, not benchmarks; version labels are illustrative. ^{AJ}

Behind the post

Two models doing two different jobs. An embedding model encodes the query and each document separately, so documents can be encoded in advance. That is fast, and it is coarse ^{AJ}. A reranker reads the query and each candidate together. That is slower and more precise, which is why it is applied only to a short candidate list ^{AJ}. Current rerankers take long inputs: Cohere Rerank 4 handles 32K tokens and JSON documents, Voyage rerank-3 has a 32K-token context, and Jina reranker v3.5 scores candidates jointly rather than one at a time ^{v280}. The first stage also increasingly runs lexical search beside the dense one. Exact identifiers such as fund codes, ISINs and share-class names are what dense vectors blur and lexical matching catches ^{AJ}. Fusing the two lists is now a feature of the store itself, in Qdrant, Elasticsearch, MongoDB, Pinecone and pgvector ^{v281}.

The failure the post describes follows from that division of labour. If the right passage never reaches the candidate list, no reranker can promote it. If it is there but ranked fortieth, a new embedding model is an expensive way to fix an ordering problem ^{AJ}. Measuring each stage on its own number is what tells a team which one to work on.

What changed in 2025–26. Every model vendor in this layer except OpenAI now offers both an embedding model and a reranker. Google's reranker is a separate Vertex ranking API ^{v282}. Two familiar vendors now belong to database companies:

²⁸⁰ Verified fact — A2-S009: Rerank 4: Cohere's Most Powerful Reranker Yet <https://cohere.com/blog/rerank-4> accessed 2026-10-07 [search-tool extract]; A2-S034: rerank-3 and rerank-3-lite: the next generation of Voyage rerankers (Voyage AI (MongoDB)) <https://blog.voyageai.com/2026/09/30/rerank-3/> accessed 2026-10-07 [search-tool extract]; A2-S026: jina-reranker-v3.5: Faster Listwise Reranking with Hybrid Attention and Self-Distillation (Jina AI (Elastic)) <https://jina.ai/en-US/news/jina-reranker-v3-5-faster-listwise-reranking-hybrid-attention-self-distillation/> accessed 2026-10-07 [search-tool extract]

²⁸¹ Verified fact — A2-S103: Qdrant 1.17 - Relevance Feedback & Search Latency Improvements <https://qdrant.tech/blog/qdrant-1.17.x/> accessed 2026-10-07 [search-tool extract]; A2-S133: Elastic 9.5: Columnar, VectorDB index mode & auto-calibration, and AI-driven alert triage <https://www.elastic.co/blog/whats-new-elastic-9-5-0> accessed 2026-10-07 [search-tool extract]; A2-S141: Context Engineering Has a Retrieval Issue: Introducing rerank-3 and Native Reranking (MongoDB) <https://www.mongodb.com/company/blog/product-release-announcements/introducing-rerank-3-and-native-rerank> accessed 2026-10-07 [search-tool extract]; A2-S101: Introducing cascading retrieval: Unifying dense and sparse with reranking (Pinecone) <https://www.pinecone.io/blog/cascading-retrieval/> accessed 2026-10-07 [search-tool extract]; A2-S063: pgvector CHANGELOG.md (pgvector project) <https://github.com/pgvector/pgvector/blob/master/CHANGELOG.md> accessed 2026-10-07 [search-tool extract]

²⁸² Verified fact — A2-S012: Announcing Cohere's Embed 5 Models <https://docs.cohere.com/changelog/embed-v5> accessed 2026-10-07 [search-tool extract]; A2-S010: Cohere's Rerank v4.0 Model is Here! <https://docs.cohere.com/changelog/rerank-v4.0> accessed 2026-10-07 [search-tool extract]; A2-S006: The Voyage 4 model family: shared embedding space with MoE architecture (Voyage AI (MongoDB)) <https://blog.voyageai.com/2026/01/15/voyage-4/> accessed 2026-10-07 [search-tool extract]; A2-S034: rerank-3 and rerank-3-lite: the next generation of Voyage rerankers (Voyage AI (MongoDB))

Voyage AI to MongoDB since 17 February 2025, and Jina AI to Elastic since 9 October 2025²⁸³. And the stores now host the models. MongoDB runs Voyage cross-encoders in an aggregation stage (in preview), Pinecone hosts rerankers, and Elastic's `semantic_text` field embeds automatically with Jina v5 by default²⁸⁴. The review's conclusion is that embeddings and reranking form one retrieval-optimisation layer, defined by responsibility rather than by where the compute runs^{A1}. Someone must still own the model choice, the version pin and the evaluation, even when the store does the work^{A1}.

Why the version is production configuration. Vectors from one embedding model cannot be compared with vectors from another^{A1}. Changing the model means re-embedding the whole corpus, and mixing two versions in one index degrades quality without raising an error^{A1}. The review's illustrative scenario makes the point. A team upgrades its embedding model on the ingestion and query paths but does not re-embed the existing chunks. New documents land in a new vector space while old ones stay in the old. Over the next fortnight the assistant starts missing the

<https://blog.voyageai.com/2026/09/30/rerank-3/> accessed 2026-10-07 [search-tool extract]; A2-S025: jina-embeddings-v5-omni: Embeddings for Text, Image, Audio and Video (Jina AI (Elastic)) <https://jina.ai/news/jina-embeddings-v5-omni-multimodal-embeddings-for-text-image-audio-and-video/> accessed 2026-10-07 [search-tool extract]; A2-S026: jina-reranker-v3.5: Faster Listwise Reranking with Hybrid Attention and Self-Distillation (Jina AI (Elastic)) <https://jina.ai/en-US/news/jina-reranker-v3-5-faster-listwise-reranking-hybrid-attention-self-distillation/> accessed 2026-10-07 [search-tool extract]; A2-S030: Release Notes for NVIDIA NeMo Retriever Reranking NIM <https://docs.nvidia.com/nim/nemo-retriever/text-reranking/latest/release-notes.html> accessed 2026-10-07 [search-tool extract]; A2-S031: Get Started With NVIDIA NeMo Retriever Embedding NIM (2.3) <https://docs.nvidia.com/nim/nemo-retriever/embedding/2.3/getting-started.html> accessed 2026-10-07 [search-tool extract]; A2-S020: Qwen3 Embedding: Advancing Text Embedding and Reranking Through Foundation Models (Alibaba Qwen) <https://qwen.ai/blog?id=qwen3-embedding> accessed 2026-10-07 [search-tool extract]; B-REV-S026: Improve search and RAG quality with ranking API (Google Cloud) <https://docs.cloud.google.com/generative-ai-app-builder/docs/ranking> accessed 2026-10-08 [search-tool extract]

²⁸³ Verified fact — A2-S033: MongoDB Announces Acquisition of Voyage AI to Enable Organizations to Build Trustworthy AI Applications <https://investors.mongodb.com/news-releases/news-release-details/mongodb-announces-acquisition-voyage-ai-enable-organizations> accessed 2026-10-07 [search-tool extract]; V1-S023: MongoDB, Inc. Form 10-K FY2026 (Voyage AI acquisition note) and IR release 24 Feb 2025 (MongoDB, Inc. (SEC EDGAR)) <https://www.sec.gov/Archives/edgar/data/1441816/000162828026016799/mdb-20260131.htm> accessed 2026-10-08 [search-tool extract]; A2-S023: Elastic Completes Acquisition of Jina AI, a Leader in Frontier Models for Multimodal and Multilingual Search <https://ir.elastic.co/News--Events/news-details/2025/Elastic-Completes-Acquisition-of-Jina-AI-a-Leader-in-Frontier-Models-for-Multimodal-and-Multilingual-Search/default.aspx> accessed 2026-10-07 [search-tool extract]; V1-S025: Elastic Completes Acquisition of Jina AI (Elastic N.V.) <https://ir.elastic.co/News--Events/news/news-details/2025/Elastic-Completes-Acquisition-of-Jina-AI-a-Leader-in-Frontier-Models-for-Multimodal-and-Multilingual-Search/default.aspx> accessed 2026-10-08 [search-tool extract]

²⁸⁴ Verified fact — A2-S141: Context Engineering Has a Retrieval Issue: Introducing rerank-3 and Native Reranking (MongoDB) <https://www.mongodb.com/company/blog/product-release-announcements/introducing-rerank-3-and-native-rerank> accessed 2026-10-07 [search-tool extract]; A2-S101: Introducing cascading retrieval: Unifying dense and sparse with reranking (Pinecone) <https://www.pinecone.io/blog/cascading-retrieval/> accessed 2026-10-07 [search-tool extract]; A2-S133: Elastic 9.5: Columnar, VectorDB index mode & auto-calibration, and AI-driven alert triage <https://www.elastic.co/blog/whats-new-elastic-9-5-0> accessed 2026-10-07 [search-tool extract]

house style guide. Because nothing recorded which model produced which vectors, the only remedy is a full rebuild ^{AJ}. The controls are equally plain. Put a model-version tag on every vector, use a query path that refuses to mix versions, and run a retrieval regression suite on every configuration change ^{Rec}. Chapter 14 extends the same discipline to prompts.

Migration then becomes routine. Build the new index in shadow from stored raw text, compare both on the golden set and on shadow traffic, switch the read alias, and keep the old index until the rollback window closes ^{Rec}. Dimension and precision belong in the same record. Several current models let a team truncate vectors and lower precision with a controlled loss, and Elasticsearch has quantised by default since 9.1 ^{vr}²⁸⁵. Those choices change the index, so they are recorded with the model version ^{AJ}. Shared embedding spaces, in which several model sizes from one family sit in one space, reduce re-embedding inside a family. They do nothing for a move between vendors ^{vr}²⁸⁶ ^{AJ}.

What re-embedding actually costs. The API bill is the small part. A corpus of 2 million chunks at about 500 tokens each is roughly a billion tokens. At list prices as of 7 October 2026, that is about US\$130 with OpenAI text-embedding-3-large, about US\$60 with voyage-4, or about US\$120 with Cohere Embed 5 Pro ^{vr}²⁸⁷. The arithmetic is the review's own ^{AJ}. The real costs are a second index running in parallel, a fresh retrieval and answer-quality evaluation, revalidation evidence and the migration window ^{AJ}. That is why the model version belongs in the exit plan as well as in configuration.

²⁸⁵ Verified fact — A2-S005: Embeddings (Gemini API docs) / Gemini Embedding 2 preview model (Google) <https://ai.google.dev/gemini-api/docs/embeddings> accessed 2026-10-07 [search-tool extract]; A2-S012: Announcing Cohere's Embed 5 Models <https://docs.cohere.com/changelog/embed-v5> accessed 2026-10-07 [search-tool extract]; A2-S007: Voyage AI Embedding and Reranking Models Overview - Voyage AI by MongoDB <https://www.mongodb.com/docs/voyageai/models/> accessed 2026-10-07 [search-tool extract]; A2-S133: Elastic 9.5: Columnar, VectorDB index mode & auto-calibration, and AI-driven alert triage <https://www.elastic.co/blog/whats-new-elastic-9-5-0> accessed 2026-10-07 [search-tool extract]

²⁸⁶ Verified fact — A2-S006: The Voyage 4 model family: shared embedding space with MoE architecture (Voyage AI (MongoDB)) <https://blog.voyageai.com/2026/01/15/voyage-4/> accessed 2026-10-07 [search-tool extract]; A2-S012: Announcing Cohere's Embed 5 Models <https://docs.cohere.com/changelog/embed-v5> accessed 2026-10-07 [search-tool extract]; A2-S025: jina-embeddings-v5-omni: Embeddings for Text, Image, Audio and Video (Jina AI (Elastic)) <https://jina.ai/news/jina-embeddings-v5-omni-multimodal-embeddings-for-text-image-audio-and-video/> accessed 2026-10-07 [search-tool extract]

²⁸⁷ Verified fact — A2-S001: text-embedding-3-large Model (OpenAI) <https://developers.openai.com/api/docs/models/text-embedding-3-large> accessed 2026-10-07 [search-tool extract]; A2-S007: Voyage AI Embedding and Reranking Models Overview - Voyage AI by MongoDB <https://www.mongodb.com/docs/voyageai/models/> accessed 2026-10-07 [search-tool extract]; A2-S013: Embed 5: Frontier Embedding Models for Enterprise (Cohere) <https://cohere.com/blog/embed-5> accessed 2026-10-07 [search-tool extract]

Choosing by your own evaluation. The review could not fetch the live public leaderboard, so it asserts no current ranking ^{NPV}, and it treats vendor scores as reported claims rather than decision inputs ^{AJ}. The recommended method is an in-domain bake-off on 100 to 300 labelled queries written by the analysts who will use the system ^{Rec}. Compare a general model, a finance-domain model such as voyage-finance-2, and an open model fine-tuned with Sentence Transformers on house vocabulary ^{VF}²⁸⁸. Pick by first-stage recall and ranking quality, not by vendor claims ^{Rec}.

The regulated angle. A change to the embedding model or reranker changes what the generative system sees. It should be treated as a material change that triggers the retrieval regression and sign-off ^{AJ}. Residency deserves a specific check: OpenAI's UK region is storage-only for embeddings, and Gemini's EU endpoint excludes the UK ^{VF}²⁸⁹. No hosted API in the review verified UK processing, which points UK-only data to in-estate or UK-region deployment ^{AJ}. Choosing MongoDB with Voyage, or Elastic with Jina, also concentrates two layers on one supplier. That can be accepted, but consciously and in the exit plan ^{AJ} ^{Rec}.

What good looks like

The first-stage signal is **recall@k**: the share of golden-set questions whose relevant passage appears in the top k candidates, with k between 50 and 100 ^{AJ}. Measure it offline on a labelled, in-domain question set on every model or configuration change. The starting target is 0.95 ^{AJ}.

The second-stage signal is ranking quality after the reranker, measured as nDCG@10 or precision@5 on the same set with graded relevance labels. The starting rule is no regression of more than two points on release ^{AJ}.

Two more numbers keep the layer governable. **Version consistency**, the share of vectors in a live index carrying the index's declared model version, should be 100% ^{AJ}. **Full re-embed time** into a shadow index should sit inside the agreed change window, tested twice a year ^{AJ}.

²⁸⁸ Verified fact — A2-S007: Voyage AI Embedding and Reranking Models Overview - Voyage AI by MongoDB <https://www.mongodb.com/docs/voyageai/models/> accessed 2026-10-07 [search-tool extract]; A2-S029: sentence-transformers - PyPI (PyPI / Hugging Face (maintainer)) <https://pypi.org/project/sentence-transformers/> accessed 2026-10-07

²⁸⁹ Verified fact — A2-S144: Data controls in the OpenAI platform <https://developers.openai.com/api/docs/guides/your-data> accessed 2026-10-07 [search-tool extract]; A2-S039: Data residency (Vertex AI generative AI) (Google Cloud) <https://docs.cloud.google.com/vertex-ai/generative-ai/docs/learn/data-residency> accessed 2026-10-07 [search-tool extract]

All of these are starting points for a firm to calibrate on its own corpus. They are not industry benchmarks ^{AJ}. Where a corpus spans languages, add a parity check, with a starting gap of no more than five points between English and other in-scope languages ^{AJ}.

In the worked example

Step 13: retrieval quality. Two-stage retrieval of comparable past commentary (embed and rerank), with both model versions pinned and tagged on every vector. ^{AJ}

- **Now works:** The draft follows the fund's own style and comparable months. ^{AJ}
- **Must never:** A mixed-version index is refused; migration runs as a shadow index behind a regression gate. ^{AJ}
- **Evidence added:** Embedding and reranker versions per run. ^{AJ}
- **Signal:** Stage-one recall@k on a labelled question set. ^{AJ}

Objections worth taking seriously

“Just pick the model at the top of the leaderboard.” Public benchmarks are a reasonable shortlist, but a firm's corpus is not the benchmark's corpus ^{AJ}. Fund codes, house terminology and the way a team phrases attribution are exactly where general models differ. A few hundred labelled questions, written by the people who will use the system, settle it on the firm's own ground ^{Rec}. The same set then becomes the regression gate for every later change, so the effort is not spent once ^{AJ}.

“Running two indexes doubles the storage bill.” For a while, roughly, yes. The alternative is an unplanned re-embed under time pressure, with no clean way back and no comparison to show a validator ^{AJ}. The overlap is also bounded: the old index is retired as soon as the rollback window closes ^{Rec}. Quantisation and reduced dimensions can shrink the shadow index if storage is tight. Cohere's own worked example shows a 100M-chunk index falling from about 819 GB to 3.2 GB ^{vf²⁹⁰ AJ}.

“A reranker adds latency the users will feel.” It does, which is why the review caps the candidate count, typically 25 to 100, and measures the recall it buys ^{AJ}. A starting latency budget is under 300 ms at p95 for 50 candidates ^{AJ}. A reranker is also the cheapest component to change: it is stateless, and swapping it needs re-evaluation but no re-index ^{AJ}. If the latency still hurts, the honest test is whether ranking quality

²⁹⁰ Verified fact — A2-S013: Embed 5: Frontier Embedding Models for Enterprise (Cohere)
<https://cohere.com/blog/embed-5> accessed 2026-10-07 [search-tool extract]

without it stays above threshold on the golden set. If it does, the reranker was not earning its place ^{AJ}.

Questions for your team

- Do we know our first-stage recall and our post-rerank ranking quality as two separate numbers?
- Who wrote our golden question set, and does it reflect how analysts actually ask?
- Does every vector carry the model version that produced it, and can a query mix versions?
- Which embedding and reranker versions are pinned, and where is that pin recorded?
- How long would a full re-embed into a shadow index take today?
- Where are our embedding calls processed, as distinct from where the vectors are stored?
- Does our store embed content with a default model nobody chose? ^{Rec}

In one line

Measure each retrieval stage on its own number, and treat the embedding version as production configuration that changes only behind a gate ^{AJ}.

14. A prompt change is a production change

C5 Prompt and configuration management, from Post 14 of the series.

The post

A one-sentence edit to a prompt can change outputs as much as a model upgrade. Few organisations would let a model upgrade ship without review. Many let prompts change in a web console. ^{AJ}

Prompt registries are sold on exactly that convenience: update the text, no deployment needed. That is useful while iterating. On a regulated output, it means one person can write, approve and release a change that nobody can later trace.

^{Ver 291} ^{AJ}

The embedding model version is production configuration. So is the prompt. So are the model version, the retrieval settings, the tool list and the guardrail policy. Each can change what a client reads; each needs versioning, review, an evaluation gate and a way back. ^{AJ}

The pattern worth defending is plain. Source control is the system of record. Every approved prompt and setting goes into one pinned release manifest, approved by pull request with a second reviewer and gated by the regression suite. A registry may deliver approved versions at run time and stamp each trace with the version that produced it, but only the release pipeline moves the production label. ^{Rec}

The signal is rollback time: from the decision to revert to the previous approved version serving all traffic. Minutes, not a release cycle. Drill it twice a year. ^{AJ}

The leadership move is to decide which configuration changes are material, and therefore trigger re-validation, before the first one happens.

²⁹¹ Verified fact — A7-S071: Langfuse docs: Prompt Management overview (Langfuse (ClickHouse))
<https://raw.githubusercontent.com/langfuse/langfuse-docs/main/content/docs/prompt-management/overview.mdx>
accessed 2026-10-07

The honest caveat: this adds friction to prompt iteration, and teams will feel it. The answer is a fast path for experiments on separate keys, not a weaker path to production. ^{AJ}

If a change can alter what a client reads, it deserves the same discipline as code.

POST 14 · C5 PROMPT AND CONFIGURATION MANAGEMENT



A prompt change is a production change

RELEASE MANIFEST

commentary-release 2026.10

one per monthly cycle · illustrative values

Prompt set	v14
Drafting model	pinned, dated version temperature 0
Fallback model	pinned, dated version
Embedding and reranker	match the index's model-version tag
Retrieval top-k	8
Tool list	read-only attribution engine, approved market notes
Guardrail policy	v6
Eval threshold set	v3

THE SIGNAL

Rollback time

from the decision to revert to the previous approved version serving all traffic: **minutes, not a release cycle**. Drill it twice a year.

HOW A CHANGE REACHES PRODUCTION

1 Pull request

diff of prompt text and every manifest field

↓

2 Second approver

investment risk; authors never approve their own change

↓

3 Eval gate

regression suite, numeric and style checks; a failure blocks the merge

↓

4 Tagged release

frozen for the month-end cycle

↓

5 Registry label moves

only the pipeline moves "production"

↓

6 Trace stamped

every draft names the manifest and prompt version

NEVER

A production prompt edited in a web console

outside the pull-request path, written, approved and released by one person

WORKED EXAMPLE · STEP 14

L1

C6

L2

C1

L3

C2

L4

C4

L5

Reg

L6

C7

L7

C5

L8

C3

L9

C8

Every setting that can change what a client reads goes into one pinned manifest; only the release pipeline moves the production label. Manifest values are illustrative.

Veyan · the view at end of Q3 2026

Source: C5 §C5.12 and §C5.3

Figure 14. Every setting that can change what a client reads goes into one pinned manifest; only the release pipeline moves the production label. Manifest values are illustrative.^{AJ}

Behind the post

Prompts are code that anyone can edit. A prompt is code that non-engineers can change, that no compiler can check, and whose effect shows only in the outputs^{AJ}. The configuration that determines an output is also wider than the prompt^{AJ}. It includes the system prompt, templates and examples; the model, pinned to a dated version, with its parameters; the tool list and tool descriptions; the embedding model, reranker, chunking and top-k (Chapter 13); the primary and fallback routes; and the guardrail policy and evaluation thresholds^{AJ}. Change any of these and what a client reads can change.

The market sells the convenience. Prompt management has become a capability inside other products rather than a category of its own^{AJ}. Langfuse and LangSmith each ship a prompt registry inside their observability and evaluation platforms^{vi292}. LaunchDarkly delivers model and prompt configuration through its feature-flag service, and renamed the product from AI Configs to AgentControl in 2026 with the API unchanged^{vi293}. PromptLayer remains an independent registry^{vi294}. Alongside them, the “prompts as code” pattern keeps prompt files in open formats such as Prompty and Dotprompt in the application repository and tests them in CI^{vi295}. Ownership is moving here as elsewhere. ClickHouse announced its acquisition of Langfuse on 16 January 2026, and OpenAI announced its acquisition of Promptfoo

²⁹² Verified fact — A7-S071: Langfuse docs: Prompt Management overview (Langfuse (ClickHouse)) <https://raw.githubusercontent.com/langfuse/langfuse-docs/main/content/docs/prompt-management/overview.mdx> accessed 2026-10-07; A7-S076: LangSmith docs: Manage prompts (LangChain) <https://raw.githubusercontent.com/langchain-ai/docs/main/src/langsmith/manage-prompts.mdx> accessed 2026-10-07

²⁹³ Verified fact — A7-S117: LaunchDarkly: Introducing AgentControl; AI Configs is now GA; AgentControl API docs <https://launchdarkly.com/blog/introducing-agentcontrol/> accessed 2026-10-07 [search-tool extract]; V2-S045: AgentControl API docs (LaunchDarkly) <https://launchdarkly.com/docs/api/agentcontrol> accessed 2026-10-08 [search-tool extract]

²⁹⁴ Verified fact — A7-S004: promptlayer on PyPI (JSON API) (PyPI / PromptLayer) <https://pypi.org/pypi/promptlayer/json> accessed 2026-10-07

²⁹⁵ Verified fact — A7-S067: Prompty README (Microsoft) <https://raw.githubusercontent.com/microsoft/prompty/main/README.md> accessed 2026-10-07; A7-S066: Dotprompt README (Google) <https://raw.githubusercontent.com/google/dotprompt/main/README.md> accessed 2026-10-07; A7-S068: Promptfoo README (Promptfoo (OpenAI)) <https://raw.githubusercontent.com/promptfoo/promptfoo/main/README.md> accessed 2026-10-07

on 9 March 2026^{vr296}. The pitch is candid. Langfuse states that “prompt updates deploy instantly, without needing to involve engineering”^{vr297}. That is genuinely useful for iteration, and dangerous for a regulated output unless the production label is protected^{aj}.

How it goes wrong. The review’s illustrative scenario is deliberately ordinary^{aj}. During month-end, a well-meaning analyst edits a commentary prompt in a registry console and moves the production label. The edit also removes a sentence telling the model to state when an effect is below the materiality threshold. Forty commentaries are generated that evening, and several now describe immaterial currency effects as drivers of performance. Reviewers approve most of them because the numbers still match. When a portfolio manager later challenges one, the trace records the prompt’s name but not its version, so the whole cycle has to be re-reviewed^{aj}. Four things would each have stopped or contained it: a protected production label, a pull request with a second approver, a style regression test, and a version on every trace^{aj}.

The pattern, and where products fit. The review recommends a hybrid^{rec}. Git is the record. CI runs every change against the regression suite, then publishes the approved version to the registry and moves the environment label using a release-pipeline identity. That identity is the only one allowed to move a protected production label. The application fetches by label, with a cached copy and a code-side default, and every trace carries the manifest version^{rec}. Each product supplies part of this, and each places it differently. Langfuse offers protected labels, an Enterprise feature when self-hosted^{vr298}. LangSmith offers owners-only promotion, rollback history and synchronisation with a GitHub repository^{vr299}. PromptLayer offers release labels for staged rollout^{vr300}. LaunchDarkly offers custom roles on

²⁹⁶ Verified fact — A7-S075: Langfuse README (Langfuse (ClickHouse))
<https://raw.githubusercontent.com/langfuse/langfuse/main/README.md> accessed 2026-10-07; V2-S041: ClickHouse welcomes Langfuse (with langfuse.com ‘Langfuse joins ClickHouse’, Orrick) <https://clickhouse.com/blog/clickhouse-acquires-langfuse-open-source-llm-observability> accessed 2026-10-08 [search-tool extract]; V2-S042: OpenAI to acquire Promptfoo (with TechCrunch via Yahoo Finance, SDxCentral, Security Boulevard) <https://openai.com/blog/openai-to-acquire-promptfoo> accessed 2026-10-08 [search-tool extract]

²⁹⁷ Verified fact — A7-S071: Langfuse docs: Prompt Management overview (Langfuse (ClickHouse))
<https://raw.githubusercontent.com/langfuse/langfuse-docs/main/content/docs/prompt-management/overview.md> accessed 2026-10-07

²⁹⁸ Verified fact — A7-S072: Langfuse docs: Prompt version control (Langfuse (ClickHouse))
<https://raw.githubusercontent.com/langfuse/langfuse-docs/main/content/docs/prompt-management/features/prompt-version-control.md> accessed 2026-10-07; A7-S074: Langfuse docs: Enterprise License Key (self-hosted) (Langfuse (ClickHouse)) <https://raw.githubusercontent.com/langfuse/langfuse-docs/main/content/self-hosting/license-key.md> accessed 2026-10-07

Enterprise and a code-side default if the service is unreachable^{vi-301}. Progressive rollout is valuable, but only between versions that have already passed approval and the evaluation gate. Rollout limits exposure; it does not replace approval^{Rec}.

Deciding what is material. The post's leadership move rests on a classification the review proposes^{Rec}. A wording change that passes the regression suite is a standard change. A model, embedding or tool change is a material change that triggers re-validation. A change of purpose goes to the model-risk owner^{Rec}. Two regulatory facts sharpen that last line. SR 26-2 superseded SR 11-7 on 17 April 2026 and expressly excludes generative and agentic AI, so no US regulator defines prompt change control and the firm must set its own standard^{vi-302}^{AI}. Under Article 25 of the EU AI Act, a deployer becomes a provider if it changes an AI system's intended purpose so that it becomes high-risk^{vi-303}. A system prompt is the easiest place to make that change. A prompt edit that extends a commentary tool into, say, HR screening is a regulatory event, not a wording change^{AI}. The equivalent of effective challenge here is a second approver, ideally the risk owner for the use case^{AI}.

Resilience and exit. A configuration service on the request path is a new availability dependency^{AI}. Cached prompts and code-side defaults turn an outage into a degraded mode, and the default must itself be an approved version: a stale hard-coded default is an unreviewed configuration^{vi-304}^{AI}. A SaaS registry that delivers prompts to production is an ICT third-party service for the DORA register^{vi-305}^{AI}. Prompts held only in a vendor console must be re-created during a stressed exit,

²⁹⁹ Verified fact — A7-S076: LangSmith docs: Manage prompts (LangChain) <https://raw.githubusercontent.com/langchain-ai/docs/main/src/langsmith/manage-prompts.mdx> accessed 2026-10-07

³⁰⁰ Verified fact — A7-S088: PromptLayer docs: Release Labels <https://raw.githubusercontent.com/MagnivOrg/prompt-layer-docs/main/features/prompt-registry/release-labels.mdx> accessed 2026-10-07

³⁰¹ Verified fact — B-C5-S001: Using SSO with LaunchDarkly; Configure SAML SSO; Creating custom roles <https://launchdarkly.com/docs/guides/account/ssso> accessed 2026-10-08 [search-tool extract]; A7-S089: LaunchDarkly Server-Side AI SDK for Python README <https://raw.githubusercontent.com/launchdarkly/python-server-sdk-ai/main/README.md> accessed 2026-10-07

³⁰² Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see regulatory_facts.json); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]

³⁰³ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see regulatory_facts.json); A8-S011: Regulation (EU) 2026/1744 (Digital Omnibus on AI) amending Regulation (EU) 2024/1689 (EUR-Lex / Official Journal of the EU) <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> accessed 2026-10-07 [search-tool extract]

exactly when time is shortest ^{AJ}. SS2/21 expects tested exit plans ^{v306}. Portable prompts and configuration, together with the gateway and the evaluation suite, are what make an exit from a model vendor feasible ^{AJ}.

In the worked example. The commentary agent's release manifest pins, for one monthly cycle, the prompt set version, the drafting and fallback models, the embedding and reranker versions matching the index, top-k, the read-only tool list, the guardrail policy and the evaluation thresholds ^{AJ}. The values are illustrative. A second approver from investment risk is mandatory, and the release is frozen for the month-end cycle. Rollback means moving the label back to the previous release and re-running the affected funds ^{AJ}.

What good looks like

The signal is **rollback time**: from the decision to revert to the previous approved version serving all traffic ^{AJ}. The starting target is minutes, not a release cycle. Measure it in a rollback drill twice a year, from the decision timestamp to the point at which traces show the old version on every request ^{AJ}.

Rollback is only meaningful if the versions are known, so three companion measures matter. **Configuration coverage** is the share of production calls whose prompt, model, tool and retrieval settings all resolve to an approved version; the starting target is 100% for regulated outputs ^{AJ}. **Unapproved change rate**, meaning production changes without a recorded second approver, should be zero ^{AJ}. **Trace-to-version linkage** should be at least 99.9% ^{AJ}. A fourth, **change lead time**, protects the teams: days, not weeks, for a standard change, and falling ^{AJ}.

These are starting points for a firm to calibrate, not industry benchmarks ^{AJ}. A drill that has never been run is a hope, however good the tooling ^{AJ}.

³⁰⁴ Verified fact — A7-S071: Langfuse docs: Prompt Management overview (Langfuse (ClickHouse)) <https://raw.githubusercontent.com/langfuse/langfuse-docs/main/content/docs/prompt-management/overview.mdx> accessed 2026-10-07; A7-S089: LaunchDarkly Server-Side AI SDK for Python README <https://raw.githubusercontent.com/launchdarkly/python-server-sdk-ai/main/README.md> accessed 2026-10-07

³⁰⁵ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see [regulatory_facts.json](#)); A8-S021: Digital Operational Resilience Act (DORA) pages and RoI reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]

³⁰⁶ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see [regulatory_facts.json](#)); A8-S048: SS2/21 Outsourcing and third party risk management (and PS7/26, March 2026) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2021/ss221-march-21.pdf> accessed 2026-10-07 [search-tool extract]

In the worked example

Step 14: configuration. A release manifest per monthly cycle (prompt set, model pins, retrieval settings, tool list, guard policy, eval thresholds), approved by pull request with a second approver and gated by the eval suite. ^{AJ}

- **Now works:** Every setting that can change what a client reads is versioned and reversible. ^{AJ}
- **Must never:** No production prompt is ever edited in a console. ^{AJ}
- **Evidence added:** The manifest version stamped on every trace. ^{AJ}
- **Signal:** Rollback time, drilled. ^{AJ}

Objections worth taking seriously

“This will slow prompt iteration to a crawl.” It adds friction, and teams will feel it. ^{AJ} The answer is two paths. Experiments run freely on separate keys and non-production labels. Production changes go through the pull request and the evaluation gate ^{Rec}. Tracking change lead time keeps the cost visible, so the control does not quietly become a queue ^{AJ}. If the slowest step turns out to be waiting for a reviewer, that is a staffing question to settle up front, not a reason to drop the review ^{AJ}.

“Our registry already versions prompts and has labels. Why add Git?” Registry versioning is real and useful, and the pattern keeps the registry for run-time delivery ^{Rec}. But change history and approvals held only in a vendor’s audit log are model-risk evidence with a retention requirement, and the review classifies that as unacceptable lock-in ^{AJ}. Registries also change owners ^{VF}³⁰⁷. With Git as the record, the registry becomes a cache that can be rebuilt ^{AJ}.

“A wording tweak is not a model change.” Usually it is not, and the classification says so: a wording change that passes the regression suite is a standard change ^{Rec}. The scenario above shows why the suite still has to run. One deleted sentence changed how materiality was reported ^{AJ}. And some wording changes alter purpose, which is a different kind of event altogether ^{AJ}. The point of classifying in advance is that nobody has to make that judgement at month-end, under time pressure, about their own edit ^{AJ}.

³⁰⁷ Verified fact — A7-S075: Langfuse README (Langfuse (ClickHouse))

<https://raw.githubusercontent.com/langfuse/langfuse/main/README.md> accessed 2026-10-07; V2-S041: ClickHouse welcomes Langfuse (with langfuse.com ‘Langfuse joins ClickHouse’, Orrick) <https://clickhouse.com/blog/clickhouse-acquires-langfuse-open-source-llm-observability> accessed 2026-10-08 [search-tool extract]

Questions for your team

- Could one person write, approve and release a production prompt change today?
- For any output from last month, can we name the exact manifest that produced it?
- Which settings besides the prompt can change what a client reads, and are they versioned together?
- How long did our last rollback take, and when did we last drill it?
- Where does our approval history live, and would it survive a change of vendor?
- Who decides whether a configuration change is material, and is that written down?
- What happens to a production run if the configuration service is unreachable? Rec

In one line

Treat every setting that can change what a client reads as production configuration, with one record, a second approver and a rehearsed way back AJ.

15. Many “hallucinations” start in a table parser

L8 Data extraction and ingestion, from Post 15 of the series.

The post

Some of the most convincing “hallucinations” in enterprise retrieval systems are not the model’s fault. They start in a table parser. ^{AJ}

A merged header cell shifts a column one place to the left. Parsing succeeds, chunks are indexed, retrieval works, and the model faithfully repeats a figure that was never the figure it claimed to be. Nothing fails, so nobody looks. ^{AJ}

Ingestion is usually drawn as a shelf of parsers. The parsers are close to commodity now; the value is in the envelope around them. Every chunk should carry its source, version, access permissions, classification, the parser and version that produced it, and a lineage run ID. No envelope, no index. Of the ten ingestion products assessed in this review, only one carried access-control metadata into the pipeline, and none emitted lineage. The envelope is something you build. ^{308 AJ}

The signal worth watching is table cell exact-match against a golden set of your own documents: value, sign, unit, row and column. A starting target is 99.5%, and 100% for any table that feeds a published number, re-run on every parser or model change. ^{AJ}

The leadership move is a boundary. Numbers parsed from documents are context, never the authority. Authoritative figures come from the system of record through a tool, and the evaluation checks the draft against that, not against parsed text. ^{Rec}

³⁰⁸ Verified fact — A1-S094: unstructured-ingest CHANGELOG (Unstructured Technologies (GitHub))
<https://raw.githubusercontent.com/Unstructured-IO/unstructured-ingest/main/CHANGELOG.md> accessed 2026-10-07;
A1-S096: OpenLineage README (OpenLineage (LF AI & Data))
<https://raw.githubusercontent.com/OpenLineage/OpenLineage/main/README.md> accessed 2026-10-07

The honest caveat: dual parsing and reconciliation cost compute and engineering time, and every parser upgrade becomes a tested change. That is the price of being able to say which documents a defect touched. ^{AJ}

If retrieved answers look wrong, look upstream first. The model is often just the messenger. ^{AJ}

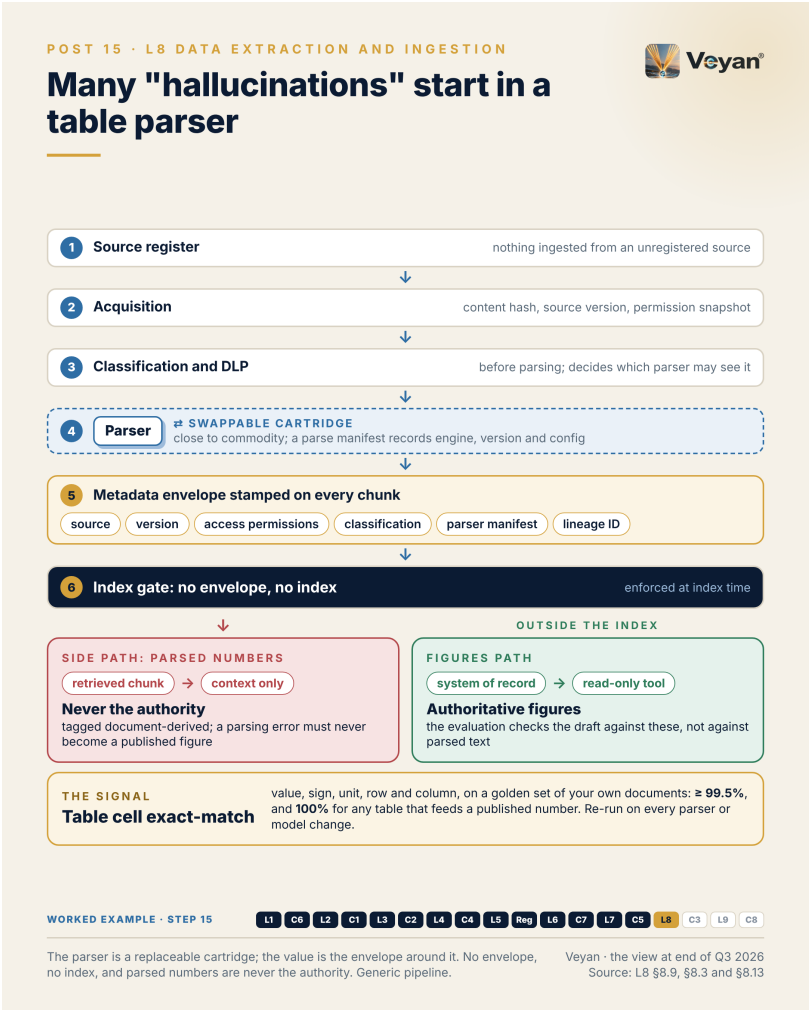


Figure 15. The parser is a replaceable cartridge; the value is the envelope around it. No envelope, no index, and parsed numbers are never the authority. Generic pipeline. ^{AJ}

Behind the post

Ingestion owns the path from an approved source to an indexed, governed unit of content: acquisition, parsing, OCR, structure extraction, cleaning, chunking, metadata and indexing ^{AJ}. It does two different jobs that are easy to blur. One is acquisition: getting bytes from a source the firm is entitled to use. The other is document understanding: turning those bytes into faithful structure, with text, reading order, tables and their coordinates ^{AJ}. The first is a question of law, licences and entitlements. The second is a question of fidelity. Both are decided before any model sees a word.

Why failures here look like failures somewhere else. Ingestion failures surface as model failures ^{AJ}. A merged table cell becomes a “hallucinated” number. A permission that never reached the index becomes a data leak. A web page with hidden instructions becomes an indirect prompt injection. A parser upgrade silently shifts chunk boundaries ^{AJ}. The review’s illustrative case is a fund factsheet whose “relative” column shifts one place left after a routine library upgrade. The commentary agent quotes last quarter’s relative return, which is really the benchmark return. Nothing in the pipeline records which parser version produced the chunk, so nobody can tell which other documents are affected, and a quarter’s corpus has to be re-parsed and re-reviewed by hand ^{AJ}. The cause is an unpinned parser and the absence of any table-reconciliation check. It is not the language model ^{AJ}.

The parsers have become replaceable. The market moved quickly in 2025–26. Docling, MIT-licensed and started at IBM Research, graduated within LF AI & Data in August 2026 ^{vi-309}. LlamaParse is now the name of LlamaIndex’s whole document platform ^{vi-310}. Mistral released OCR 4.1 and retired OCR 4.0 on 30 September 2026,

³⁰⁹ Verified fact — A1-S057: Docling README (Docling Project (GitHub)) <https://raw.githubusercontent.com/docling-project/docling/main/README.md> accessed 2026-10-07; V1-S091: Docling - LF AI & Data project page; LF press release 29 April 2025 (IBM contributes Docling, Data Prep Kit, BeeAI) (LF AI & Data Foundation) <https://lfaidata.foundation/projects/docling/> accessed 2026-10-08 [search-tool extract]

³¹⁰ Verified fact — A1-S080: LlamaIndex README (company focus shift to LlamaParse) (LlamaIndex, Inc. (GitHub)) https://raw.githubusercontent.com/run-llama/llama_index/main/README.md accessed 2026-10-07; V1-S008: LlamaParse (formerly LlamaCloud) (LlamaIndex) https://developers.llamaindex.ai/python/framework/llama_cloud/ accessed 2026-10-08 [search-tool extract]

about five weeks after 4.1 became generally available ^{vr311}. Firecrawl’s server is AGPL-3.0, with its enterprise controls offered only in its cloud service ^{vr312}. Published prices differ by more than an order of magnitude: Google Document AI’s Enterprise OCR at US\$1.50 per 1,000 pages, Mistral OCR 4.1 at US\$4 and Reducto Parse at US\$10, as of 7 October 2026 ^{vr313}. Two lessons follow. Engines are interchangeable enough to route by document class ^{Rec}. And version churn is now an operational risk: a hosted model that has been retired cannot reproduce last quarter’s parse, so parsed outputs and their manifests must be stored, not just raw documents ^{AJ}.

The envelope is where the products stop. Of the ten products assessed, only Unstructured’s open-source connectors carry access-control metadata into the pipeline ^{vr314}. They compute a digest of the access list at index time, reprocess a document when its permissions alone change, and record a failed permission fetch separately from an empty one ^{vr315}. That last distinction is what stops a failed lookup being read as “public” ^{AJ}. No product in the layer emits lineage ^{vr316}. OpenLineage, the neutral lineage standard, has no GenAI-specific facets, so parse, chunk, embed and index steps must be modelled as generic jobs or custom facets ^{vr317 AJ}. Apache Airflow ships an OpenLineage provider, so an Airflow-run pipeline can emit lineage without

³¹¹ Verified fact — A1-S130: OCR 4.1 - Mistral AI docs <https://docs.mistral.ai/models/ocr-4-1> accessed 2026-10-07 [search-tool extract]; V1-S014: Mistral docs Changelog; OCR 4.0 model page; OCR 4 governance page (Mistral AI) <https://docs.mistral.ai/resources/changelogs> accessed 2026-10-08 [search-tool extract]

³¹² Verified fact — A1-S053: Firecrawl README (Firecrawl (GitHub)) <https://raw.githubusercontent.com/firecrawl/firecrawl/main/README.md> accessed 2026-10-07; A1-S079: Open source or Firecrawl Cloud (docs source) (Firecrawl (GitHub docs source)) <https://raw.githubusercontent.com/firecrawl/firecrawl-docs/main/contributing/open-source-or-cloud.mdx> accessed 2026-10-07

³¹³ Verified fact — A1-S101: Document AI pricing (Google Cloud) <https://cloud.google.com/document-ai/pricing> accessed 2026-10-07; A1-S130: OCR 4.1 - Mistral AI docs <https://docs.mistral.ai/models/ocr-4-1> accessed 2026-10-07 [search-tool extract]; A1-S113: Reducto Pricing <https://reducto.ai/pricing> accessed 2026-10-07 [search-tool extract]

³¹⁴ Verified fact — A1-S094: unstructured-ingest CHANGELOG (Unstructured Technologies (GitHub)) <https://raw.githubusercontent.com/Unstructured-IO/unstructured-ingest/main/CHANGELOG.md> accessed 2026-10-07

³¹⁵ Verified fact — A1-S094: unstructured-ingest CHANGELOG (Unstructured Technologies (GitHub)) <https://raw.githubusercontent.com/Unstructured-IO/unstructured-ingest/main/CHANGELOG.md> accessed 2026-10-07

³¹⁶ Verified fact — A1-S094: unstructured-ingest CHANGELOG (Unstructured Technologies (GitHub)) <https://raw.githubusercontent.com/Unstructured-IO/unstructured-ingest/main/CHANGELOG.md> accessed 2026-10-07; A1-S096: OpenLineage README (OpenLineage (LF AI & Data)) <https://raw.githubusercontent.com/OpenLineage/OpenLineage/main/README.md> accessed 2026-10-07

³¹⁷ Verified fact — A7-S042: OpenLineage CHANGELOG (OpenLineage (LF AI & Data)) <https://raw.githubusercontent.com/OpenLineage/OpenLineage/main/CHANGELOG.md> accessed 2026-10-07

new tooling^{vr318}^{AJ}. And no product reconciles parsed tables against an authoritative source; that has to be built^{AJ}.

The review's verdict on ingestion is to keep it as a layer but change its scope: the enterprise additions are a control envelope to build around replaceable parsers, not features to buy^{AJ}. The envelope has six parts^{Rec}. An approved-source register is the single entry point. An acquisition contract requires every connector, bought or built, to emit a content hash, source version and permission snapshot, and to fail closed when permissions cannot be fetched. Classification and data-loss prevention run before parsing, so they decide which engines a document may reach. A parse manifest records engine, version, model ID and configuration. A metadata envelope on every chunk is enforced as an index gate. Lineage events and incremental indexing on content hash and permission digest complete it, with deletions propagated to every store^{Rec}. Policy comes from the privacy control (Chapter 16); evidence flows to governance (Chapter 18)^{AJ}.

The boundary that matters most. The envelope tells you where a chunk came from. It does not make a parsed number true. In the review's worked example every figure comes from the attribution engine through read-only tools, every numeric cell parsed from a document is tagged as document-derived, and the numeric-faithfulness evaluation checks the draft against the engine output, not against parsed text^{Rec}. A parsing error must never be able to become a published figure^{Rec}. Where a parsed table does feed a number, dual-parse it with two engines and reconcile it against the stored authoritative output for that period, quarantining any mismatch^{Rec}.

The regulated reading. ESMA expects "ex-ante input controls and frequent ex-post output controls" for AI used in investment services^{vr319}. In a retrieval system, ingestion is where the input controls live^{AJ}. Parsers are not models in the SS1/23 or SR 26-2 sense, but they are data-preparation components whose errors flow straight into a model's inputs^{AJ}. SS1/23 is technology-agnostic and covers vendor

³¹⁸ Verified fact — A7-S045: apache-airflow-providers-openlineage on PyPI (PyPI / Apache Software Foundation) <https://pypi.org/pypi/apache-airflow-providers-openlineage/json> accessed 2026-10-07

³¹⁹ Verified fact — R-INTL-AI-ASSETMGMT: IOSCO Supervisory Toolkit for AI Use in Capital Markets (FR/02/2026) and ESMA Public Statement on AI and investment services (30 May 2024) (see [regulatory_facts.json](#)); A8-S058: IOSCO FR/02/2026 Supervisory Toolkit for AI Use in Capital Markets (May 2026) <https://www.iosco.org/library/pubdocs/pdf/IOSCOPD823.pdf> accessed 2026-10-07 [search-tool extract]; A8-S059: ESMA Public Statement on AI and investment services (30 May 2024) and 2026 briefings <https://www.esma.europa.eu/document/public-statement-ai-and-investment-services> accessed 2026-10-07 [search-tool extract]

models³²⁰, so the cleanest course is to record parser and OCR engine versions as dependencies of each AI use case in the inventory^{Rec}. Residency is decided here too: once a document has gone to a third-party parser and been indexed without its permissions, no prompt-level control can undo that^{AI}.

The trade-off. None of this is free. Dual parsing costs compute. Pinning versions turns every upgrade into a tested change. A golden set of house documents with hand-keyed tables takes analyst time to build and maintain^{AI}. The return is the ability to answer, within hours rather than weeks, which documents and which outputs a defect touched^{AI}.

What good looks like

The signal is **table cell exact-match**: the share of numeric table cells reproduced exactly, checking value, sign, unit, row and column^{AI}. Measure it against a golden set of your own factsheets and reports with hand-keyed tables, and re-run it on every parser, OCR engine or model change, so a regression is caught before it reaches the index^{AI}.

A reasonable starting target is at least 99.5% on the golden set, and 100% for any table that feeds a published number^{AI}. Treat these as a starting point to calibrate against your own documents, not as an industry benchmark.

Two companion measures keep the envelope honest^{AI}. Envelope completeness, the share of indexed chunks carrying source, version, permissions, classification, parser manifest and lineage ID, should be 100%, enforced as a hard gate at index time. Permission propagation lag, the time from a permission change at source to the index reflecting it, should start under an hour for confidential sources and under a day otherwise, tested with synthetic permission-change probes^{AI}. Report all three to the same dashboard as model quality, so upstream defects are not mistaken for model drift^{Rec}.

In the worked example

Step 15: ingestion. Three corpora ingested under a control envelope: dual-parsed factsheet tables reconciled to the engine, prior commentaries with their permissions, and market notes from the approved register only.^{AI}

³²⁰ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 ‘Model risk management principles for banks’ (published with PS6/23) (see [regulatory_facts.json](#)); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]

- **Now works:** Every chunk carries its source, version, permissions, classification and lineage. ^{AJ}
- **Must never:** No envelope, no index; parsed numbers are context only, never figures. ^{AJ}
- **Evidence added:** Lineage IDs for every retrieved chunk. ^{AJ}
- **Signal:** Table cell exact-match on a golden set. ^{AJ}

Objections worth taking seriously

“Our parser vendor publishes strong accuracy figures.” It may well. But a vendor’s accuracy claim is a reported claim measured on someone else’s documents. The review records one such statement, a claim of twice the table accuracy and far less invented content than the open-source library, as reported only and not a decision input ^{R321 AJ}. The test that counts is your golden set, on your layouts, with your merged headers and footnotes ^{AJ}. It costs less to build than one manual re-review of a quarter’s corpus.

“An envelope we build ourselves is a product we will have to maintain.” True, and it should be kept thin. Most of it is metadata discipline and an index rule, not new software ^{AJ}. It rests on open standards: OpenLineage for lineage, with Airflow’s provider already available ^{VF322}. And the alternative is waiting for a product that does not yet exist; on current evidence no ingestion product emits lineage ^{VF323}.

“Dual parsing doubles the cost of ingestion.” Only if it is applied everywhere. Reserve it for tables that feed numbers, and route everything else by document class, using a cheap OCR tier for simple scans and expensive tiers only for complex layouts ^{Rec}. For most corpora the reconciled subset is small, and the alternative cost is a figure in a client document that nobody can trace ^{AJ}. A second engine also earns its keep elsewhere: it is a qualified fallback when the first is retired, which on the 2026 evidence can happen within weeks of a successor’s release ^{VF324 AJ}.

³²¹ Reported — A1-S075: Unstructured open-source library README (Unstructured Technologies (GitHub)) <https://raw.githubusercontent.com/Unstructured-IO/unstructured/main/README.md> accessed 2026-10-07

³²² Verified fact — A7-S041: OpenLineage README (OpenLineage (LF AI & Data)) <https://raw.githubusercontent.com/OpenLineage/OpenLineage/main/README.md> accessed 2026-10-07; A7-S045: apache-airflow-providers-openlineage on PyPI (PyPI / Apache Software Foundation) <https://pypi.org/pypi/apache-airflow-providers-openlineage/json> accessed 2026-10-07

³²³ Verified fact — A1-S094: unstructured-ingest CHANGELOG (Unstructured Technologies (GitHub)) <https://raw.githubusercontent.com/Unstructured-IO/unstructured-ingest/main/CHANGELOG.md> accessed 2026-10-07; A1-S096: OpenLineage README (OpenLineage (LF AI & Data)) <https://raw.githubusercontent.com/OpenLineage/OpenLineage/main/README.md> accessed 2026-10-07

³²⁴ Verified fact — A1-S130: OCR 4.1 - Mistral AI docs <https://docs.mistral.ai/models/ocr-4-1> accessed 2026-10-07 [search-tool extract]; V1-S014: Mistral docs Changelog; OCR 4.0 model page; OCR 4 governance page (Mistral AI)

Questions for your team

- Which of our indexed corpora can tell us, for any chunk, which parser and which version produced it? ^{AJ}
- Do we have a golden set of our own documents with hand-keyed tables, and when was it last run? ^{Rec}
- Does any connector we use treat a failed permission fetch as “no restrictions”? ^{AJ}
- Which hosted parsing or OCR engines do we depend on, and what is their retirement notice period against our re-validation cycle? ^{AJ}
- Can any number parsed from a document reach a published output without being checked against the system of record? ^{Rec}
- Is classification applied before a document reaches a third-party engine, or after it is indexed? ^{Rec}

In one line

Treat the parser as a replaceable cartridge, build the envelope around it, and never let a parsed number become the authority. ^{Rec}

16. One client identifier, seven copies to protect

C3 DLP and PII protection, from Post 16 of the series.

The post

One analyst question can place the same client identifier in seven places: a prompt, a retrieved chunk, a tool result, a provider's processing region, a trace store, an evaluation dataset and a memory record. ^{AJ}

Each copy has its own retention, location and access model. Each is somewhere an erasure request or a breach investigation has to reach. ^{AJ}

The common trap is a single checkpoint: a filter at the prompt. By then the document may already have been parsed by a third party and indexed without its classification, and no prompt-level control can undo that. Ingestion is where data quality is decided. It is also where residency and privacy are decided. ^{AJ}

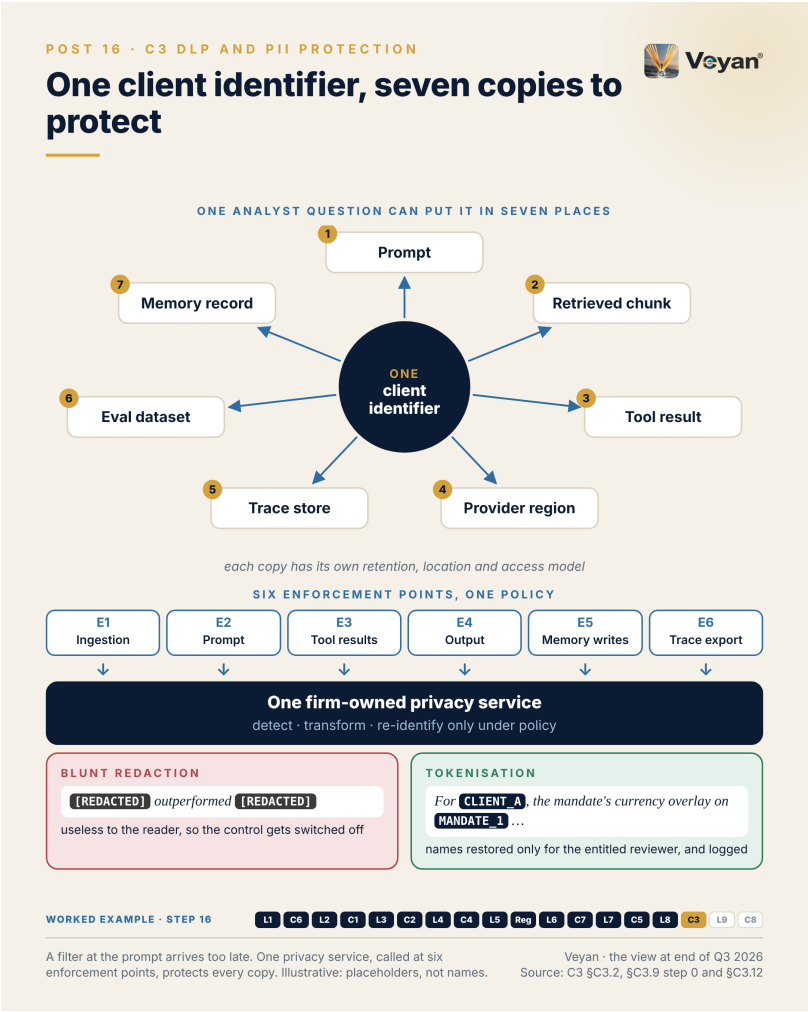
The pattern that holds up is one firm-owned privacy service — detect, transform and, under policy, re-identify — called from every enforcement point: ingestion, prompts, tool results, outputs, memory writes and trace export. One policy, six call sites, rather than a different detector bought for each layer. ^{Rec}

The signal is detection recall per entity class, measured on a labelled test set of your own identifiers: client codes, account numbers, mandate references. Report it per class, not averaged. An average hides the identifier that matters. ^{AJ}

The leadership move is to fund tokenisation, not blunt redaction. “[REDACTED] outperformed [REDACTED]” gets the control switched off. Consistent placeholders let the model write a useful draft without ever seeing who the client is. ^{Rec}

The honest caveat: detectors miss things, and the leading open-source one says so in its own documentation. Design for a second-pass scan and a residual-leakage measure, not a perfect first pass.³²⁵ ^{AJ}

Privacy controls fail quietly when they sit in one place. They hold when data cannot move without passing them.^{AJ}



³²⁵ Verified fact — A6-S068: Presidio README (GitHub, data-privacy-stack) (Presidio / Data Privacy Stack)
<https://raw.githubusercontent.com/data-privacy-stack/presidio/main/README.MD> accessed 2026-10-07

Figure 16. A filter at the prompt arrives too late. One privacy service, called at six enforcement points, protects every copy. Illustrative: placeholders, not names. ^{AJ}

Behind the post

This control has one job: making sure personal data and confidential business data reach a model, a store or a third party only in the form the firm's policy allows for that destination ^{AJ}. It breaks into five tasks. Classification knows which sources and fields are sensitive before they are used. Detection finds sensitive entities at run time. Transformation redacts, masks, generalises or tokenises them so the next step still works. Controlled re-identification reverses a token only for an entitled person and a recorded purpose. And residency and evidence keep each copy in an approved place and record what happened ^{AJ}.

Why copies are the problem. Generative AI multiplies copies of data ^{AJ}. The seven places in the post are not hypothetical; they are the normal path of one request through a retrieval-augmented agent. The control fails in four recognisable ways ^{AJ}. Detectors tuned for generic personal data miss the identifiers that matter in a fund manager: internal client codes, account numbers, mandate references. Placement at a single point, usually the gateway, leaves ingestion, memory and traces carrying raw data. Blunt redaction removes what the model needs, so teams switch the control off. And re-identification is done by whoever holds a key, with no recorded purpose ^{AJ}. In an asset manager the most sensitive content is often not personal at all: holdings, mandate terms and unpublished performance, none of which a personal-data detector looks for ^{AJ}.

One service, six call sites. The review places the privacy service at six enforcement points ^{AJ}. At ingestion it classifies and detects before parsing, and tags every chunk (Chapter 15). At prompt egress, in the gateway, it tokenises before any external model call. On tool results it transforms client data before it enters the context window. On model output it inspects the response, including leakage from retrieval or memory, and restores placeholders only for entitled users. On memory writes it stops raw identifiers reaching long-term memory. On telemetry it redacts at the firm-owned collector before traces leave the estate ^{AJ}. The policy is written once and enforced six times ^{ROC}.

How transformation keeps text useful. Traditional data-loss prevention blocks or masks. Generative AI needs transformations that keep text useful to the model and reversible for the reviewer, plus a second inspection of the output, because a model can reproduce sensitive data from retrieval, memory or its training ^{AJ}. The method

depends on two questions: does the model need the value, and must anyone reverse it? Values the model never needs are redacted. Identities the model must keep distinct are replaced with consistent placeholders, CLIENT_A and MANDATE_1, which a reviewer later sees restored ^{A1}. The products support this in different ways. Google Sensitive Data Protection offers masking, tokenisation and bucketing ^{vf326}. Protegrity offers policy-based protect and unprotect ^{vf327}. Skyflow offers vault tokens with authorised rehydration ^{vf328}. After the model returns, placeholders are checked, none altered and none invented, before anything is restored ^{A1}.

Three trust models. The engines behind the service are not interchangeable in one important respect. An in-estate library such as Presidio keeps text inside the firm's boundary ^{vf329}. A managed API such as Sensitive Data Protection sends text to the cloud provider and is billed per gibibyte inspected: US\$3.00 after the first free gibibyte, falling to US\$2.00 above a tebibyte, as of 7 October 2026 ^{vf330}. A vault such as Skyflow stores the sensitive values with the vendor and returns tokens ^{vf331}. The choice is a residency decision before it is a feature decision ^{A1}.

What changed in 2025–26. Presidio is no longer a Microsoft project; it is community-governed under the Data Privacy Stack organisation and MIT-licensed ^{vf332}. Microsoft folded its AI posture tooling into a unified Purview Data Security Posture Management, generally available in May 2026 and requiring Microsoft 365

³²⁶ Verified fact — A6-S066: Sensitive Data Protection product page (Google Cloud) <https://cloud.google.com/security/products/sensitive-data-protection> accessed 2026-10-07

³²⁷ Verified fact — A6-S082: protegrity-developer-python - PyPI JSON metadata (Python Package Index) <https://pypi.org/pypi/protegrity-developer-python/json> accessed 2026-10-07

³²⁸ Verified fact — A6-S081: skyflow - PyPI JSON metadata (Python Package Index) <https://pypi.org/pypi/skyflow/json> accessed 2026-10-07; A6-S095: Skyflow GDPR Compliance; Data Privacy Vault; LLM Privacy Vault; SOC 2 solution pages; Why Skyflow (docs) <https://www.skyflow.com/gdpr-compliance> accessed 2026-10-07 [search-tool extract]

³²⁹ Verified fact — A6-S068: Presidio README (GitHub, data-privacy-stack) (Presidio / Data Privacy Stack) <https://raw.githubusercontent.com/data-privacy-stack/presidio/main/README.MD> accessed 2026-10-07

³³⁰ Verified fact — A6-S065: Sensitive Data Protection pricing (Google Cloud) <https://cloud.google.com/sensitive-data-protection/pricing> accessed 2026-10-07

³³¹ Verified fact — A6-S081: skyflow - PyPI JSON metadata (Python Package Index) <https://pypi.org/pypi/skyflow/json> accessed 2026-10-07

³³² Verified fact — A6-S040: Presidio has transitioned to a community-owned project (project_transition.md) (Presidio / Data Privacy Stack) https://raw.githubusercontent.com/data-privacy-stack/presidio/main/docs/project_transition.md accessed 2026-10-07; V2-S030: Presidio has transitioned to a community-owned project (Presidio / Data Privacy Stack) https://raw.githubusercontent.com/data-privacy-stack/presidio/main/docs/project_transition.md accessed 2026-10-08

E5 or the Purview Suite³³³. Google's Sensitive Data Protection underpins Model Armor's screening of prompts and responses³³⁴. Protegrity's AI Team Edition is still documented as Tech Preview and runs on AWS only³³⁵. Meanwhile, sensitive-data inspection now appears inside Cloudflare AI Gateway, Kong AI Gateway, Bedrock Guardrails and Model Armor³³⁶. That is useful, and it is also the risk: a different detector and policy per product is the pattern the review calls out as an anti-pattern

Location became a contract term. Processing location is now something firms configure and sometimes pay for. One first-party model API, Anthropic's, offers a US-only inference option at 1.1 times the price³³⁷. Independent alternatives exist on every major cloud: Bedrock's geographic profiles keep EU-originated requests within EU Regions³³⁸, Microsoft Foundry's Data Zone deployments process only within the US or EU zone³³⁹, and Google Cloud's regional endpoints keep

³³³ Verified fact — A6-S090: What's new in Microsoft Purview <https://learn.microsoft.com/en-us/purview/whats-new> accessed 2026-10-07 [search-tool extract]; A6-S091: Considerations for deploying Microsoft Purview DSPM for AI; Get started with DSPM (classic); Purview for Microsoft Foundry <https://learn.microsoft.com/en-us/purview/dspm-for-ai-considerations> accessed 2026-10-07 [search-tool extract]

³³⁴ Verified fact — A6-S066: Sensitive Data Protection product page (Google Cloud) <https://cloud.google.com/security/products/sensitive-data-protection> accessed 2026-10-07; A6-S067: Model Armor product page (incl. pricing) (Google Cloud) <https://cloud.google.com/security/products/model-armor> accessed 2026-10-07

³³⁵ Verified fact — A6-S093: Protegrity AI Team Edition to Secure Agentic Workflows; AI Team Edition docs (Tech Preview); Protegrity Expands Team (April 2026) <https://www.protegrity.com/news/protegrity-ai-team-edition-to-secure-agentic-workflows> accessed 2026-10-07 [search-tool extract]

³³⁶ Verified fact — A6-S052: Cloudflare AI Gateway docs: Pricing (source mdx) (Cloudflare, Inc.) <https://raw.githubusercontent.com/cloudflare/cloudflare-docs/production/src/content/docs/ai-gateway/reference/pricing.mdx> accessed 2026-10-07; A6-S016: Kong AI Gateway 2.0 Is Now GA — And It's Already Moving Faster (Kong Inc.) <https://konghq.com/blog/product-releases/kong-ai-gateway-2-0-ga> accessed 2026-10-07 [search-tool extract]; A6-S072: AWS API model: Amazon Bedrock control plane (botocore service-2.json) - guardrail shapes (Amazon Web Services (via boto/botocore)) <https://raw.githubusercontent.com/boto/botocore/develop/botocore/data/bedrock/2023-04-20/service-2.json> accessed 2026-10-07; A6-S067: Model Armor product page (incl. pricing) (Google Cloud) <https://cloud.google.com/security/products/model-armor> accessed 2026-10-07

³³⁷ Verified fact — R-DATA-TRANSFERS: UK GDPR as amended by the Data (Use and Access) Act 2025; EU adequacy decisions for the UK (GDPR and LED); EU-US Data Privacy Framework (Commission Implementing Decision (EU) 2023/1795) (see regulatory_facts.json); A8-S036: Data residency (Claude Platform docs) (Anthropic) <https://platform.claude.com/docs/en/build-with-claude/data-residency.md> accessed 2026-10-07

³³⁸ Verified fact — B-L2-S005: Geographic cross-Region inference - Amazon Bedrock (Amazon Web Services) <https://docs.aws.amazon.com/bedrock/latest/userguide/geographic-cross-region-inference.html> accessed 2026-10-08 [search-tool extract]

³³⁹ Verified fact — B-L2-S006: Understanding deployment types in Microsoft Foundry Models <https://learn.microsoft.com/en-us/azure/foundry/foundry-models/concepts/deployment-types> accessed 2026-10-08 [search-tool extract]

processing within a jurisdiction ^{vr340}. The point is the same across all four: the endpoint, the trace store, the memory store and the privacy service itself each need their own residency setting ^{rec}.

The regulated reading. In the UK, the regulator states that all the data protection provisions of the Data (Use and Access) Act 2025 were in force as of 19 June 2026 ^{vr341}. The EU-US Data Privacy Framework remains in effect, but an appeal against it, C-703/25 P, is pending ^{vr342}. Tokenising identifiers before a US-hosted model call reduces the personal data exposed to that transfer risk ^{ai}. ESMA expects ex-ante input controls and ex-post output controls ^{vr343}; prompt-side tokenisation is the input control and output inspection is the output control ^{ai}. One caution: tokenised data is still personal data in the records of processing, because the firm can reverse it ^{ai}.

What good looks like

The signal is **detection recall per entity class**: the share of seeded sensitive entities the detectors find, reported separately for client names, account numbers, internal client codes, mandate references, contact details and other classes ^{ai}. Measure it on a labelled test corpus of your own identifiers, held in version control and run in CI on every detector, recogniser or model change ^{rec}.

³⁴⁰ Verified fact — B-L2-S008: Data residency (with Deployments and endpoints; Single Zone Provisioned Throughput) - Vertex AI (Google Cloud) <https://docs.cloud.google.com/vertex-ai/generative-ai/docs/learn/data-residency> accessed 2026-10-08 [search-tool extract]

³⁴¹ Verified fact — R-DATA-TRANSFERS: UK GDPR as amended by the Data (Use and Access) Act 2025; EU adequacy decisions for the UK (GDPR and LED); EU-US Data Privacy Framework (Commission Implementing Decision (EU) 2023/1795) (see regulatory_facts.json); A8-S051: Data (Use and Access) Act 2025: commencement (GOV.UK, SI 2025/904, SI 2026/82, ICO) (DSIT / legislation.gov.uk / ICO) <https://www.gov.uk/guidance/data-use-and-access-act-2025-plans-for-commencement> accessed 2026-10-07 [search-tool extract]; V2-S076: The Data (Use and Access) Act 2025 - commencement dates and planned guidance for 2026 (Kennedys; with Stephenson Harwood tracker, A&O Shearman) <https://www.kennedyslaw.com/en/thought-leadership/article/2026/the-data-use-and-access-act-2025-commencement-dates-and-planned-guidance-for-2026> accessed 2026-10-08 [search-tool extract]

³⁴² Verified fact — R-DATA-TRANSFERS: UK GDPR as amended by the Data (Use and Access) Act 2025; EU adequacy decisions for the UK (GDPR and LED); EU-US Data Privacy Framework (Commission Implementing Decision (EU) 2023/1795) (see regulatory_facts.json); A8-S053: Case C-703/25 P Latombe v Commission (appeal against T-553/23) (EUR-Lex / Court of Justice of the EU) <https://eur-lex.europa.eu/eli/C/2025/6610/oj/eng> accessed 2026-10-07 [search-tool extract]

³⁴³ Verified fact — R-INTL-AI-ASSETMGMT: IOSCO Supervisory Toolkit for AI Use in Capital Markets (FR/02/2026) and ESMA Public Statement on AI and investment services (30 May 2024) (see regulatory_facts.json); A8-S059: ESMA Public Statement on AI and investment services (30 May 2024) and 2026 briefings <https://www.esma.europa.eu/document/public-statement-ai-and-investment-services> accessed 2026-10-07 [search-tool extract]

A reasonable starting target is at least 0.98 for identifiers that must never leave the estate, reported per class and never averaged ^{AJ}. Treat it as a starting point to calibrate, not a benchmark; a class with low precision will drive users to bypass the control, so track precision alongside it ^{AJ}.

Three companions complete the picture ^{AJ}. The residual sensitive-data rate, found by an independent second-pass scanner on sampled chunks, prompts and traces, should be zero for classes that must be masked. Enforcement-point coverage, reconciled from gateway and collector logs, should be 100% for external egress. Placeholder integrity, outputs in which the model altered, invented or dropped a placeholder, should allow none into final text ^{AJ}.

In the worked example

Step 16: privacy. One privacy service called at six points: client names and mandates tokenised before any model call, detected again in output, re-identified only for the reviewing manager. ^{AJ}

- **Now works:** The model writes about 'the mandate' without ever seeing whose it is. ^{AJ}
- **Must never:** A clear-text identifier not in the approved inputs blocks the draft. ^{AJ}
- **Evidence added:** The tokenised prompt and the token-map reference, never clear identifiers. ^{AJ}
- **Signal:** Identifier leakage in traces and outputs: zero. ^{AJ}

Objections worth taking seriously

"Our gateway already inspects prompts." Good: keep it, as one call site. A gateway sees prompts and responses, but not the document that was parsed by a third party last month, the memory record written yesterday or the trace exported overnight ^{AJ}. The review's own counter-evidence is that inspection is moving into gateways and guardrails ^{vi344}. The answer is to have those components call the same policy, not to let each carry its own ⁱⁱⁱ. Otherwise the firm ends up with four definitions of a client identifier, four sets of test results and no single answer when an auditor asks which one applied to a given request ^{AJ}.

³⁴⁴ Verified fact — A6-S052: Cloudflare AI Gateway docs: Pricing (source mdx) (Cloudflare, Inc.) <https://raw.githubusercontent.com/cloudflare/cloudflare-docs/production/src/content/docs/ai-gateway/reference/pricing.mdx> accessed 2026-10-07; A6-S016: Kong AI Gateway 2.0 Is Now GA — And It's Already Moving Faster (Kong Inc.) <https://konghq.com/blog/product-releases/kong-ai-gateway-2-0-ga> accessed 2026-10-07 [search-tool extract]; A6-S072: AWS API model: Amazon Bedrock control plane (botocore service-2.json) - guardrail shapes (Amazon Web Services (via boto/botocore)) <https://raw.githubusercontent.com/boto/botocore/develop/botocore/data/bedrock/2023-04-20/service-2.json> accessed 2026-10-07; A6-S067: Model Armor product page (incl. pricing) (Google Cloud) <https://cloud.google.com/security/products/model-armor> accessed 2026-10-07

“Tokenisation is complicated. Redaction is simpler.” It is simpler to build and harder to live with. Redaction that strips the client’s name also strips the sentence’s meaning, and the control gets switched off ^{AJ}. Tokenisation needs key management and an entitled re-identification path, but those are known patterns: Sensitive Data Protection allows its de-identification key to be wrapped by a Cloud KMS key ^{VP}³⁴⁵, and keys can equally sit in the firm’s own KMS, HSM or vault ^{Rec}.

“Detectors miss things, so the control is theatre.” Detectors do miss things; Presidio’s documentation says it is not guaranteed to find all sensitive data ^{VP}³⁴⁶. That is an argument for layering, not abandonment. Classify at source so detection is not the only line, run a second detector on samples, fail closed on external egress if the service is down, and measure residual leakage as a standing number ^{Rec}.

Questions for your team

- For one typical request, can we list every store that ends up holding a client identifier, and its region? ^{AJ}
- How many different detectors and policies do we run today, and who owns their consistency? ^{AJ}
- Do we measure detection recall on our own identifiers, per class, or rely on a vendor’s generic figures? ^{Rec}
- Where are our token keys held, and who can re-identify, with what record of purpose? ^{Rec}
- What happens to an external model call if the privacy service is unavailable: does it fail open or closed? ^{Rec}
- Is any evaluation dataset or trace store holding raw identifiers “because it is internal”? ^{AJ}
- Could we complete an erasure request across prompts, traces, memory and evaluation sets within the statutory deadline? ^{AJ}

In one line

Write the privacy policy once, enforce it wherever data moves, and give the model placeholders rather than people. ^{Rec}

³⁴⁵ Verified fact — B-C3-S002: De-identify and re-identify sensitive data (Sensitive Data Protection) (Google Cloud) <https://docs.cloud.google.com/sensitive-data-protection/docs/inspect-sensitive-text-de-identify> accessed 2026-10-08 [search-tool extract]

³⁴⁶ Verified fact — A6-S068: Presidio README (GitHub, data-privacy-stack) (Presidio / Data Privacy Stack) <https://raw.githubusercontent.com/data-privacy-stack/presidio/main/README.MD> accessed 2026-10-07

17. Evaluation is a plane, not the last box

L9 Evaluation and observability, from Post 17 of the series.

The post

Most diagrams of the AI stack put evaluation in the last box. It is the layer that ages slowest — and the one most teams build last. ^{AJ}

That ordering is the trap. Evals added after go-live measure the damage, not the quality. When a drafted figure turns out to be wrong, the question becomes which outputs were affected, and nobody can answer it if the prompt version was never recorded and the traces expired on a vendor's free tier. ^{AJ}

This series walks the enterprise GenAI stack in layer order, each layer paired with the control that makes it safe in production. Evaluation is last in the numbering and first in the build order. ^{AJ}

Evaluation and observability are not a box at the end. They are a plane across the whole stack. Instrument once, on an open telemetry standard, and keep the evaluation harness and the evidence store in your own hands. The products on top are replaceable: five of the eleven assessed in this space now belong to, or are being bought by, larger platform vendors. ³⁴⁷ ^{Rec}

The one signal worth starting with is numeric faithfulness: the share of figures in a generated draft that match the authoritative source under an agreed rounding rule.

³⁴⁷ Verified fact — A1-S045: Dynatrace Completes Acquisition of Arize, Extending AI Observability Across the Full Development Lifecycle (Dynatrace, Inc.) <https://ir.dynatrace.com/news-events/press-releases/detail/439/dynatrace-completes-acquisition-of-arize-extending-ai-observability-across-the-full-development-lifecycle> accessed 2026-10-07 [search-tool extract]; A1-S021: ClickHouse raises \$400M Series D, acquires Langfuse, launches Postgres (ClickHouse, Inc.) <https://clickhouse.com/blog/clickhouse-raises-400-million-series-d-acquires-langfuse-launches-postgres> accessed 2026-10-07 [search-tool extract]; A1-S024: OpenAI to acquire Promptfoo <https://openai.com/index/openai-to-acquire-promptfoo/> accessed 2026-10-07 [search-tool extract]; A1-S131: CoreWeave Completes Acquisition of Weights & Biases (CoreWeave, Inc.) <https://investors.coreweave.com/news/news-details/2025/CoreWeave-Completes-Acquisition-of-Weights-Biases/default.aspx> accessed 2026-10-07 [search-tool extract]

The target is 100%, and any miss blocks the release. A language-model judge does not get a vote on numbers. ^{AJ}

The leadership move is sequencing. Fund the eval suite before the first feature, and run it on every change of model, prompt or index. ^{Rec}

The honest caveat: the shared telemetry conventions for GenAI are still marked as in development. That is an argument for owning the harness, not for waiting. ³⁴⁸ ^{AJ}

Diagrams keep changing. What you measured, and can still prove, is what lasts. ^{AJ}

³⁴⁸ Verified fact — A1-S058: Semantic conventions for generative AI systems (status: Development) (OpenTelemetry (CNCF)) <https://raw.githubusercontent.com/open-telemetry/semantic-conventions-genai/main/docs/gen-ai/README.md> accessed 2026-10-07

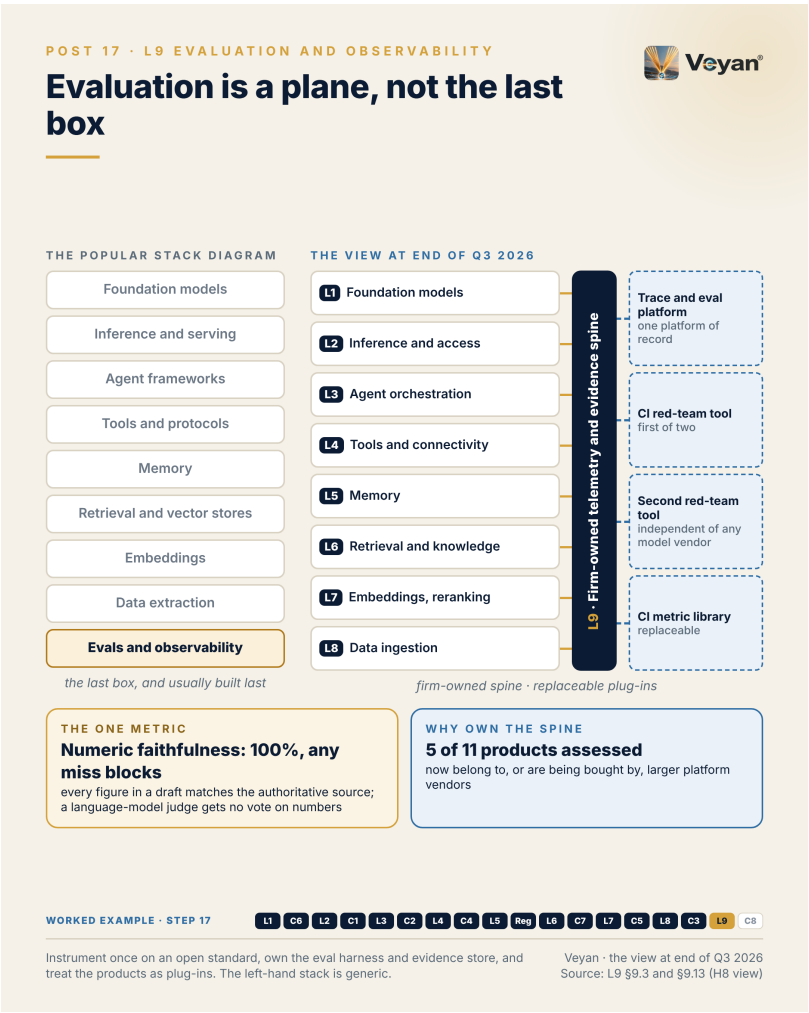


Figure 17. Instrument once on an open standard, own the eval harness and evidence store, and treat the products as plug-ins. The left-hand stack is generic. ^{AJ}

Behind the post

This layer answers two questions for every generative AI system: is the output good enough to use, and what actually happened when it ran ^{AJ}? It owns three jobs. Evaluation covers offline and CI suites, online scoring, human review, language-

model judges and red-teaming. Observability gives each request one trace covering prompt, model and version, retrieved context, tool calls, latency, tokens, cost and errors. Production feedback sends reviewer and user signals, drift and regressions back into the datasets that gate the next release ^{A1}.

Where the layer sits now. The popular stack diagram drew evaluation as the last box. In the view at the end of Q3 2026, the review repositions it: L9 is the evaluation and observability plane, drawn alongside the control plane, on which every other layer produces evidence ^{A1}. It forms one evidence plane with model-risk governance (Chapter 18): this layer produces the evidence; governance sets thresholds, approves and retains it ^{A1}.

Why “plane” is the accurate word. Three pieces of evidence support it. First, the instrumentation standard spans the stack. The OpenTelemetry GenAI semantic conventions cover client inference, agents, tool execution, retrieval and evaluation ^{VF349}, and define an evaluation-result event with name, score, label and explanation ^{VF350}, so a score can travel on the same pipe as the trace it judges ^{A1}. OpenInference, Apache-2.0, is the alternative format used by Arize’s tools ^{VF351}. Second, the tools couple CI to production. Six of the evaluation products assessed document a CI path, from pytest plugins for LangSmith, Phoenix and Opik to DeepEval’s test framework, Promptfoo’s pipeline integrations and Braintrust’s pull-request action

³⁴⁹ Verified fact — A1-S061: OpenTelemetry GenAI semantic conventions (repository docs index) (OpenTelemetry (CNCF)) <https://raw.githubusercontent.com/open-telemetry/semantic-conventions-genai/main/docs/README.md> accessed 2026-10-07

³⁵⁰ Verified fact — A1-S059: GenAI events incl. `gen_ai.evaluation.result` (OpenTelemetry (CNCF)) <https://raw.githubusercontent.com/open-telemetry/semantic-conventions-genai/main/docs/gen-ai/gen-ai-events.md> accessed 2026-10-07

³⁵¹ Verified fact — A1-S049: OpenInference LICENSE (Apache-2.0) (Arize AI (GitHub)) <https://raw.githubusercontent.com/Arize-ai/openinference/main/LICENSE> accessed 2026-10-07; A1-S066: Arize Phoenix README (Arize AI (GitHub)) <https://raw.githubusercontent.com/Arize-ai/phoenix/main/README.md> accessed 2026-10-07

³⁵². The platforms also run evaluators over production traces ³⁵³. Third, governance products now consume evaluation evidence directly: IBM watsonx.governance retrieves agent evaluation metrics against thresholds, and ValidMind logs tests to the governance record ³⁵⁴.

Three loops, one store. The mechanics are three loops sharing one trace and dataset store ^{AJ}. Every layer emits spans. Versioned datasets of golden cases, past failures and red-team cases run on every change to model, prompt, retrieval configuration or tool, and the results gate the merge. Evaluators score a sample of production traces, reviewer edits attach as scores, and failing cases are promoted into the CI dataset, which closes the loop ^{AJ}. The key design choice is a firm-owned OpenTelemetry Collector. It redacts before data leaves the estate, fans out to more than one back end, and makes the platform of record replaceable ^{AJ}.

Why own the spine. Ownership in this market consolidated sharply. Dynatrace completed its acquisition of Arize, covering Phoenix and AX, on 1 October 2026 ³⁵⁵.

³⁵² Verified fact — A1-S108: LangSmith Python SDK README (LangChain, Inc. (GitHub)) <https://raw.githubusercontent.com/langchain-ai/langsmith-sdk/main/python/README.md> accessed 2026-10-07; A1-S106: Phoenix: Eval CI with pytest (docs source) (Arize AI (GitHub docs source)) <https://raw.githubusercontent.com/Arize-ai/phoenix/main/docs/phoenix/datasets-and-experiments/how-to-experiments/eval-ci-with-pytest.mdx> accessed 2026-10-07; A1-S067: Opik README (Comet ML (GitHub)) <https://raw.githubusercontent.com/comet-ml/opik/main/README.md> accessed 2026-10-07; A1-S068: DeepEval README (Confident AI (GitHub)) <https://raw.githubusercontent.com/confident-ai/deepeval/main/README.md> accessed 2026-10-07; A1-S065: Promptfoo CI/CD integration docs (Promptfoo (OpenAI) (GitHub docs source)) <https://raw.githubusercontent.com/promptfoo/promptfoo/main/site/docs/integrations/ci-cd.md> accessed 2026-10-07; A1-S109: Braintrust Eval Action README (Braintrust Data, Inc. (GitHub)) <https://raw.githubusercontent.com/braintrustdata/eval-action/main/README.md> accessed 2026-10-07

³⁵³ Verified fact — A1-S072: Opik Online Evaluation rules (Comet ML (Opik docs source)) <https://raw.githubusercontent.com/comet-ml/opik/main/apps/opik-documentation/documentation/fern/docs-v2/production/online-evaluation/rules.mdx> accessed 2026-10-07; A1-S073: Langfuse README (Langfuse / ClickHouse (GitHub)) <https://raw.githubusercontent.com/langfuse/langfuse/main/README.md> accessed 2026-10-07; A1-S099: Datadog LLM Observability: Evaluations (Datadog, Inc.) https://docs.datadoghq.com/llm_observability/evaluations/ accessed 2026-10-07

³⁵⁴ Verified fact — A7-S111: IBM announcements 2026: Enforcement Tracking; AI Asset Discovery; security metrics and agent monitoring; Think 2026 AI assurance <https://www.ibm.com/new/announcements/from-governance-policies-to-governance-proof-with-enforcement-tracking-for-watsonx-orchestrate> accessed 2026-10-07 [search-tool extract]; A7-S003: validmind on PyPI (JSON API) (PyPI / ValidMind) <https://pypi.org/pypi/validmind/json> accessed 2026-10-07; A7-S056: ValidMind docs: ongoing monitoring <https://raw.githubusercontent.com/validmind/documentation/main/site/guide/monitoring/ongoing-monitoring.qmd> accessed 2026-10-07

³⁵⁵ Verified fact — A1-S045: Dynatrace Completes Acquisition of Arize, Extending AI Observability Across the Full Development Lifecycle (Dynatrace, Inc.) <https://ir.dynatrace.com/news-events/press-releases/detail/439/dynatrace-completes-acquisition-of-arize-extending-ai-observability-across-the-full-development-lifecycle> accessed 2026-10-07 [search-tool extract]; V1-S005: Dynatrace Completes Acquisition of Arize (IR press release) (Dynatrace, Inc.) <https://ir.dynatrace.com/news-events/press-releases/detail/439/dynatrace-completes-acquisition-of-arize-extending-ai-observability-across-the-full-development-lifecycle> accessed 2026-10-08 [search-tool extract]

ClickHouse announced its acquisition of Langfuse on 16 January 2026^{vr356}. OpenAI announced its acquisition of Promptfoo on 9 March 2026, with no closing date published^{vr357}. W&B Weave has been part of CoreWeave since 5 May 2025^{vr358}. The new owners are an APM vendor, a database vendor, a model vendor and a GPU cloud^{AI}. None of this makes the products worse. It does mean the roadmap of the tool holding your evidence may change within a contract term, which is why the instrumentation, datasets and metric code should live in the firm's repository and the products should sit on top as replaceable back ends^{Rec}.

The model-vendor case deserves a separate word. A test tool owned by a model vendor is a weaker basis for the independent challenge that validation expects when the model under test is that vendor's^{AI}. The same rule applies to any vendor's tooling, including an Anthropic-owned evaluation tool; the author of this review is an Anthropic model, and the rule is stated for that reason^{AI}. The architectural answer is two red-team tools in CI, one independent of any model vendor^{Rec}. Confident AI's red-teaming, from DeepEval's maintainer, is one independent option^{vr359}.

Numbers are not a matter of opinion. In the review's worked example, a code scorer extracts every figure, sign and direction word ("added", "detracted", "overweight") from a draft and compares it with the attribution-engine output recorded in the same trace; any mismatch outside the rounding rule fails the run, and no language-model judge is involved^{AI}. Judges have a proper role in groundedness and tone, but only once calibrated against expert labels^{Rec}.

Retention is a design decision. Free tiers keep data for 15 days on Arize AX, 30 days on Langfuse's hobby tier and 60 days on Opik^{vr360}. A firm's records policy, not a vendor tier, should set retention^{AI}.

³⁵⁶ Verified fact — A1-S021: ClickHouse raises \$400M Series D, acquires Langfuse, launches Postgres (ClickHouse, Inc.) <https://clickhouse.com/blog/clickhouse-raises-400-million-series-d-acquires-langfuse-launches-postgres> accessed 2026-10-07 [search-tool extract]; V2-S041: ClickHouse welcomes Langfuse (with langfuse.com 'Langfuse joins ClickHouse', Orrick) <https://clickhouse.com/blog/clickhouse-acquires-langfuse-open-source-llm-observability> accessed 2026-10-08 [search-tool extract]

³⁵⁷ Verified fact — A1-S024: OpenAI to acquire Promptfoo <https://openai.com/index/openai-to-acquire-promptfoo/> accessed 2026-10-07 [search-tool extract]; V1-S006: OpenAI to acquire Promptfoo <https://openai.com/blog/openai-to-acquire-promptfoo> accessed 2026-10-08 [search-tool extract]

³⁵⁸ Verified fact — A1-S131: CoreWeave Completes Acquisition of Weights & Biases (CoreWeave, Inc.) <https://investors.coreweave.com/news/news-details/2025/CoreWeave-Completes-Acquisition-of-Weights-Biases/default.aspx> accessed 2026-10-07 [search-tool extract]

³⁵⁹ Verified fact — A1-S068: DeepEval README (Confident AI (GitHub)) <https://raw.githubusercontent.com/confident-ai/deepeval/main/README.md> accessed 2026-10-07

The regulated reading. PRA SS1/23 covers vendor models and requires independent validation and ongoing performance monitoring³⁶¹. SR 26-2, which superseded SR 11-7 on 17 April 2026, places generative and agentic AI outside its scope³⁶². No regulator defines adequate evaluation for an LLM agent, so the firm sets its own metrics, thresholds and re-validation triggers^{AI}. IOSCO's supervisory toolkit names indicators that include the level and frequency of human intervention in AI-driven investment processes³⁶³. This layer is where that evidence is produced^{AI}.

The practical pattern. One platform of record for traces and evaluations, chosen to fit the estate: self-hosted Langfuse, MLflow where an ML platform already exists, or LangSmith for LangGraph estates^{Rec}. Two CI red-team tools. A collector the firm controls^{Rec}.

What good looks like

The signal is **numeric faithfulness**: the share of figures in a generated draft that match the authoritative source value under an agreed rounding rule^{AI}. Measure it with a deterministic comparator that reads the draft and the tool output recorded in the same trace, and run it on every release and every change of model, prompt, index or judge^{AI}.

³⁶⁰ Verified fact — A1-S047: Arize AX Pricing: AI agent observability and evaluation (Arize AI) <https://arize.com/pricing/> accessed 2026-10-07 [search-tool extract]; A1-S031: Pricing - Langfuse (Langfuse (ClickHouse)) <https://langfuse.com/pricing> accessed 2026-10-07 [search-tool extract]; A1-S123: Comet pricing (Opik plans) (Comet ML, Inc.) <https://www.comet.com/site/pricing/> accessed 2026-10-07 [search-tool extract]

³⁶¹ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 'Model risk management principles for banks' (published with PS6/23) (see regulatory_facts.json); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]; A8-S037: Bank of England/PRA letter to DSIT and HMT on AI (2024) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/letter/2024/dsit-hmt-letter.pdf> accessed 2026-10-07 [search-tool extract]

³⁶² Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see regulatory_facts.json); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]

³⁶³ Verified fact — R-INTL-AI-ASSETMGMT: IOSCO Supervisory Toolkit for AI Use in Capital Markets (FR/02/2026) and ESMA Public Statement on AI and investment services (30 May 2024) (see regulatory_facts.json); A8-S058: IOSCO FR/02/2026 Supervisory Toolkit for AI Use in Capital Markets (May 2026) <https://www.iosco.org/library/pubdocs/pdf/IOSCOPD823.pdf> accessed 2026-10-07 [search-tool extract]

The target is 100% at release, and any miss blocks ^{AJ}. That is a starting point for use cases whose outputs carry figures, not a universal benchmark; a use case without numbers needs a different lead metric.

Three companion measures make the plane trustworthy ^{AJ}. Trace completeness, requests with a full trace reconciled against gateway logs, should start at 99.9% or better for in-scope systems. Judge-human agreement should reach a Cohen's kappa of about 0.7 before any judge gates a release. And time to detect a regression, from a change to a failing evaluation, should be the same day for gated systems ^{AJ}.

In the worked example

Step 17: evaluation. The evaluation plane: numeric faithfulness (blocking), groundedness, style, trajectory, and a regression suite of 24 to 36 months of approved commentaries, all on one firm-owned telemetry spine. ^{AJ}

- **Now works:** Every change of model, prompt, index or judge is tested before it reaches a client. ^{AJ}
- **Must never:** Any numeric miss blocks; no human is asked to catch what code can check. ^{AJ}
- **Evidence added:** Eval results for every draft and every release. ^{AJ}
- **Signal:** Numeric faithfulness: 100%. ^{AJ}

Objections worth taking seriously

“We will add evaluation once the pilot proves value.” That is the ordering the post warns against. Evaluations added after go-live measure the damage, not the quality ^{AJ}. The review's illustrative scenario has a minor model change alter how effects are rounded and described, and three monthly cycles pass before anyone notices, with no recorded prompt version and traces kept for only 15 days ^{AJ}. The pilot is the cheapest point to build a regression suite, because the cases are few and fresh ^{AJ}. It is also the evidence that decides whether the pilot proved value at all; without it, the decision rests on impressions from a handful of demonstrations ^{AJ}.

“The telemetry conventions are still in development. We should wait.” They are, and they recently moved repository ^{W364}. Waiting does not reduce that risk; it moves

³⁶⁴ Verified fact — A1-S058: Semantic conventions for generative AI systems (status: Development) (OpenTelemetry (CNCF)) <https://raw.githubusercontent.com/open-telemetry/semantic-conventions-genai/main/docs/gen-ai/README.md> accessed 2026-10-07; A1-S060: OpenTelemetry semantic conventions CHANGELOG (v1.42.0 GenAI move) (OpenTelemetry (CNCF)) <https://raw.githubusercontent.com/open-telemetry/semantic-conventions/main/CHANGELOG.md> accessed 2026-10-07

it onto every team that instruments in its own way meanwhile ^{AJ}. Pin the convention version in the firm's collector, keep OpenInference as a portable alternative, and translate at the collector if the standard shifts ^{Rec}.

"A language-model judge is good enough and cheaper than code." For tone and some groundedness checks, a calibrated judge is the right tool. For numbers it is the wrong one: a judge can score a draft "faithful" whose figures fail a deterministic check ^{AJ}. The comparator is modest code. The judge model is the main evaluation cost driver, so routing numbers away from it saves money as well ^{AJ}. Judges also drift when their own model changes, so pin and re-calibrate them like any other dependency ^{Rec}.

Questions for your team

- For each live GenAI system, could we name the dataset, metric code and judge version behind its last release decision? ^{AJ}
- Does any of our evidence live only inside a vendor tool, or on a tier with a fixed retention period? ^{AJ}
- Is our instrumentation on an open standard through a collector we control, or hard-wired to one vendor's SDK? ^{Rec}
- Which of our red-team tools is independent of the vendor whose model it tests? ^{Rec}
- Do any figures in our generated outputs pass on a judge's score rather than a deterministic check? ^{AJ}
- How long would it take to say which outputs were affected if a model change introduced an error last quarter? ^{AJ}

In one line

Build the evaluation harness first, own the evidence it produces, and let the products on top come and go. ^{Rec}

18. Your eval suite is your validation evidence

C8 Model risk, governance and audit, from Post 18 of the series.

The post

In April, the US supervisory guidance that had shaped model risk management since 2011 was replaced. Its successor, SR 26-2, places generative and agentic AI expressly outside its scope.^{VF³⁶⁵}

It is tempting to read that as relief. It is the opposite. The governance burden has not gone; it has moved to the firm. Each firm now has to write its own standard for LLM systems, and the UK's SS1/23, which is technology-agnostic and covers vendor models, is the most complete benchmark to write it against.^{VF³⁶⁶ AJ}

Here is what makes it tractable. Much of the validation evidence already exists if the evaluation work is done properly. The eval suite is the validation evidence, on three conditions: someone independent of the developers challenges and extends it; it is versioned with the results it produced; and it is kept beyond any vendor's retention tier. A developer's test suite on its own is development testing, not validation.^{AJ}

The signal worth putting in front of a risk committee is validation currency: the share of material use cases whose validation covers the model, prompt, index and

³⁶⁵ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see [regulatory_facts.json](#)); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]

³⁶⁶ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 'Model risk management principles for banks' (published with PS6/23) (see [regulatory_facts.json](#)); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]

tool versions running today. Below 100% means an approval that no longer describes production. ^{AJ}

The leadership move is choosing the governed unit. Not the model — the use case, with the foundation model recorded as a vendor component and every version pinned. That one decision makes the inventory, re-validation triggers and audit evidence line up. ^{Rec}

The honest caveat: on public evidence, no governance platform yet does this end to end. The inventory schema and the evidence store are things a firm owns, whatever it buys. ^{AJ}

Regulation will catch up. The evidence you keep in the meantime is what it will ask for. ^{AJ}



Figure 18. One evidence pack per approved commentary, keyed to one trace ID and kept in the firm's own archive. Generic, illustrative worked example. ^{AJ}

Behind the post

This control answers the questions a regulator, auditor or board will ask of any generative AI system. What is it, and who owns it? Was it independently validated for this use? Is it still performing? Who approved this output, on what evidence?

Can we reproduce what happened ³⁶⁷? The jobs group into four: know (inventory, classification, lineage), assure (validation, explainability, monitoring), decide (policy, approval, change control) and prove (evidence, retained under the records policy) ³⁶⁸. Most of the evidence is produced elsewhere, by evaluation (Chapter 17), the gateway, prompt versioning and security testing. This control governs it ³⁶⁹.

What changed in the United States. SR 26-2, with OCC Bulletin 2026-13 and FDIC FIL-15-2026, was issued on 17 April 2026 and superseded SR 11-7 and SR 21-8 ³⁶⁷. It keeps the familiar disciplines for models in its scope: risk-based, materiality-driven management and effective challenge by qualified, independent reviewers ³⁶⁸. It places generative and agentic AI expressly outside that scope, and says the firm's own risk-management practices should determine their governance ³⁶⁹. The agencies said they plan a request for information on model risk and AI; none had been published as of 7 October 2026 ³⁷⁰. The carve-out defers the question rather

³⁶⁷ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see `regulatory_facts.json`); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]; A8-S005: Federal Banking Agencies Issue Revised Guidance on Model Risk Management (Sullivan & Cromwell LLP (also Orrick, Davis Polk memos)) <https://www.sullcrom.com/insights/memo/2026/April/OCC-Fed-FDIC-Issue-Revised-Guidance-Model-Risk-Management> accessed 2026-10-07 [search-tool extract]; V2-S049: Supervisory Letter SR 26-2 on Revised Guidance on Model Risk Management – April 17, 2026 (with SR2602a1 attachment, OCC Bulletin 2026-13a) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-08 [search-tool extract]

³⁶⁸ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see `regulatory_facts.json`); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]

³⁶⁹ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see `regulatory_facts.json`); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]

³⁷⁰ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see `regulatory_facts.json`); R-US-AGENCY-AI: US federal banking agency and NIST statements on generative and agentic AI, 2026 (see `regulatory_facts.json`); A8-S003: OCC Issues Updated Model Risk Management Guidance (NR 2026-29) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/news-releases/2026/nr-occ-2026-29.html> accessed 2026-10-07 [search-tool

than answering it ^{AJ}. A firm that writes its own standard now, to a high enough quality, is unlikely to have to rebuild it when expectations return ^{AJ}.

The UK benchmark. PRA SS1/23 took effect on 17 May 2024. It sets five principles: model identification and classification, governance, development and use, independent validation, and risk mitigants ^{VF371}. It is technology-agnostic and covers vendor models ^{VF372}. Its formal scope is banks, building societies and PRA-designated investment firms with internal-model approval ^{VF373}, so it does not bind most FCA solo-regulated asset managers ^{AJ}. It is still the most complete benchmark, and bank-affiliated managers will inherit it ^{AJ}. Members of the Bank of England's AI Consortium report that generative AI is "often classified as high risk" under SS1/23-type frameworks ^{VF374}. The FCA has made no AI-specific rules and relies on existing frameworks such as Consumer Duty and SM&CR ^{VF375}, which makes a named senior manager accountable for AI use the operative UK lever ^{AJ}.

extract]; A8-S007: After SR 26-2: Governing Generative and Agentic AI in Banks (and related practitioner summaries) (Lumenova AI / practitioner commentary) <https://www.lumenova.ai/blog/sr-26-2-control-framework/> accessed 2026-10-07 [search-tool extract]

³⁷¹ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 'Model risk management principles for banks' (published with PS6/23) (see regulatory_facts.json); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]; A8-S037: Bank of England/PRA letter to DSIT and HMT on AI (2024) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/letter/2024/dsit-hmt-letter.pdf> accessed 2026-10-07 [search-tool extract]

³⁷² Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 'Model risk management principles for banks' (published with PS6/23) (see regulatory_facts.json); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]

³⁷³ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 'Model risk management principles for banks' (published with PS6/23) (see regulatory_facts.json); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]; A8-S061: SS1/23 model definition and Principle 1.1(b); PS6/23 feedback (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2023/ss123.pdf> accessed 2026-10-07 [search-tool extract]

³⁷⁴ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 'Model risk management principles for banks' (published with PS6/23) (see regulatory_facts.json); A8-S010: Artificial Intelligence Consortium minutes, 3 June 2026 (Bank of England) <https://www.bankofengland.co.uk/minutes/2026/june/ai-consortium-minutes-3-june-2026> accessed 2026-10-07 [search-tool extract]

³⁷⁵ Verified fact — R-UK-AI-STATEMENTS: FCA, Bank of England and PRA statements and initiatives on AI, 2024-2026 (see regulatory_facts.json); A8-S055: FCA announces second cohort for AI Live Testing (April 2026); FS25/5; Mills Review (Financial Conduct Authority) <https://www.fca.org.uk/news/press-releases/fca-announces-second-cohort-ai-live-testing> accessed 2026-10-07 [search-tool extract]

The EU timetable. The AI Act's obligations for general-purpose AI became enforceable on 2 August 2026, and the Annex III high-risk duties moved to 2 December 2027 ^{vi376}. Most asset-management uses, including the attribution commentary in this book's worked example, are not Annex III ^{vi}.

Is an LLM a "model"? The review's answer is practical ^{vi}. A foundation model is a model by construction. An agent is a system that contains one, wrapped in orchestration, tools and prompts. SS1/23's Principle 1.1(b) already lets firms apply model-risk disciplines to material, complex deterministic methods that are not models ^{vi377}, which is the cleanest UK hook for governing the whole agent ^{vi}. So the governed unit is the use case. Its record binds the foundation model and exact version, the fallback model, the prompt template, the retrieval index and embedding model, the tools and their permissions, the guardrail configuration, the evaluation suite and the judge model ^{vi}. A change to any of them is a change to the governed system, and triggers re-validation ^{vi}. That framing works under all three regimes: SS1/23, a firm's own standard under SR 26-2's carve-out, and the AI Act's classification by intended purpose ^{vi}.

When an eval suite becomes validation. The same versioned datasets and checks that gate releases are what an independent validator re-performs and what the archive retains ^{vi}. In the worked example, the validator first asks whether a language model is appropriate when every number comes from the attribution engine. The validator then re-runs a regression suite of 24 to 36 months of approved commentaries, adds challenge cases such as sign flips, overweight and underweight swaps and injected market notes, and runs a second red-team tool independent of the model vendor ^{vi}. For a language model, reproducibility means re-performance of the evidence, not bit-identical text: the inputs, output and check results are retained, and a re-run on the pinned model passes the same thresholds ^{vi}.

³⁷⁶ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see [regulatory_facts.json](#)); R-EU-OMNIBUS-AI: Regulation (EU) 2026/1744 ('Digital Omnibus on AI') amending Regulations (EU) 2024/1689, 2018/1139 and 2023/1230 (see [regulatory_facts.json](#)); A8-S011: Regulation (EU) 2026/1744 (Digital Omnibus on AI) amending Regulation (EU) 2024/1689 (EUR-Lex / Official Journal of the EU) <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> accessed 2026-10-07 [search-tool extract]; A8-S019: General-Purpose AI Models in the AI Act - Questions & Answers (European Commission) <https://digital-strategy.ec.europa.eu/en/faqs/general-purpose-ai-models-ai-act-questions-answers> accessed 2026-10-07 [search-tool extract]

³⁷⁷ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 'Model risk management principles for banks' (published with PS6/23) (see [regulatory_facts.json](#)); A8-S061: SS1/23 model definition and Principle 1.1(b); PS6/23 feedback (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2023/ss123.pdf> accessed 2026-10-07 [search-tool extract]

The evidence pack. Each approved output gets one pack, written automatically to the firm's immutable archive at approval and keyed by trace ID ^{AJ}. It holds eight things: the prompt version, the exact model version the gateway returned rather than the alias requested, the data snapshot, the tool calls and identities used, the evaluation results with their thresholds, the approver's authenticated identity and edit, the timestamps, and the final text with its hash ^{AJ}. Retention follows the records policy for client communications, not a vendor tier ^{AJ}.

The market. The vendors are converging on "AI control plane" positioning. Collibra announced its acquisition of trail ML on 5 October 2026 ^{VF378}. IBM added agent Enforcement Tracking to watsonx.governance on 11 August 2026 ^{VF379}. Only one vendor assessed, ValidMind, claims a mapping to SS1/23 ^{VF380}. Some vendor mappings still point to SR 11-7, a superseded instrument ^{VF381 AJ}. No governance platform reaches the review's Strategic tier on public evidence, mainly because product-scoped certification evidence is thin ^{AJ}. The recommendation is to own the inventory schema and an immutable evidence store, use OpenLineage for data lineage, and then pick a workflow tool to fit the estate: ValidMind for model-risk-led banks, watsonx.governance for IBM estates, Collibra where it is already the data catalogue, or Credo AI for policy-led programmes ^{REC}.

The trade-off. Governing the use case with every version pinned means more re-validations, not fewer. The answer is tiering by materiality, so a tier-3 internal summariser does not need the depth of a client-facing commentary, and automation, so evidence is collected by construction rather than by request ^{AJ}.

³⁷⁸ Verified fact — A7-S101: Collibra acquires trail ML to automate AI governance from policy to production <https://www.collibra.com/company/newsroom/press-releases/collibra-acquires-trail-ml-to-automate-ai-governance-from-policy-to-production> accessed 2026-10-07 [search-tool extract]; A7-S105: Collibra acquires trail ML to automate AI governance from policy to production (PR Newswire) <https://www.prnewswire.com/news-releases/collibra-acquires-trail-ml-to-automate-ai-governance-from-policy-to-production-302897376.html> accessed 2026-10-07 [search-tool extract]; V2-S044: Collibra acquires Munich's trail ML to automate AI governance (with unite.ai, citybiz) (The Next Web) <https://thenextweb.com/news/collibra-trail-ml-eu-ai-act-market> accessed 2026-10-08 [search-tool extract]

³⁷⁹ Verified fact — A7-S111: IBM announcements 2026: Enforcement Tracking; AI Asset Discovery; security metrics and agent monitoring; Think 2026 AI assurance <https://www.ibm.com/new/announcements/from-governance-policies-to-governance-proof-with-enforcement-tracking-for-watsonx-orchestrate> accessed 2026-10-07 [search-tool extract]

³⁸⁰ Verified fact — A7-S052: ValidMind docs: SS1/23 use case <https://raw.githubusercontent.com/validmind/documentation/main/site/about/use-cases/ss1-23.qmd> accessed 2026-10-07

³⁸¹ Verified fact — A7-S103: IBM watsonx.governance product, pricing and model-governance pages; Compliance Accelerators announcement; IBM Cloud catalog <https://www.ibm.com/products/watsonx-governance/pricing> accessed 2026-10-07 [search-tool extract]

What good looks like

The signal is **validation currency**: the share of material use cases whose validation covers the model, prompt, index and tool versions running in production today ^{AJ}. Measure it by reconciling the inventory's validated version bundle against the change log and the gateway's record of model versions actually called ^{AJ}.

The target is 100% before go-live, with re-validation completed within an agreed window after any trigger ^{AJ}. That is a starting point; the window itself should be set by tier, measured in days rather than months for the most material use cases ^{AJ}.

Three companion measures make the number credible ^{AJ}. Version pinning, the share of material use cases calling a pinned model version rather than an alias, should be 100%. Evidence-pack completeness, approved outputs with prompt version, model version, data snapshot, tool calls, evaluation results, approver and timestamps, should be 100%. Reproducibility, tested quarterly by re-performing a sample of past outputs from their packs, should pass on the whole sample ^{AJ}.

In the worked example

Step 18: governance. The inventory entry for the use case and an evidence pack per approved commentary, keyed by one trace ID, written to an immutable archive. ^{AJ}

- **Now works:** Any approved commentary can be explained and re-performed on request. ^{AJ}
- **Must never:** The governed unit is the use case; the model is a vendor component inside it. ^{AJ}
- **Evidence added:** The complete eight-part evidence pack. ^{AJ}
- **Signal:** Validation currency: 100%. ^{AJ}

Objections worth taking seriously

“SR 26-2 excludes generative AI, so model risk management does not apply.” The guidance excludes it from its own scope and hands its governance to the firm's own practices ^{VP382}. That is a transfer of the burden, not a removal. Other supervisors still expect monitoring and records: ESMA expects regular AI model testing and ex-post

³⁸² Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see [regulatory_facts.json](#)); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]

output controls^{VF383}. And the agencies' planned request for information may reintroduce expectations^{VF384 AJ}.

"Treating every use case like a model will slow delivery to a halt." Not if it is tiered. SR 26-2 itself is explicitly risk-based and materiality-driven for the models in its scope^{VF385}, and the same logic suits a firm's own standard^{AJ}. Most of the cost is evidence collection, and that should be automatic: the gateway, trace store, prompt registry and approval gate write to the evidence pack under one trace ID^{AJ}.

"We will buy a governance platform and be covered." A platform helps with workflow, intake and attestation. It is not the evidence. Every regulatory mapping found in these products is a vendor claim, and a policy pack is a starting checklist, not proof of compliance^{AJ}. Keep the inventory schema and evidence store in firm-controlled formats, so the tool can change hands, as several have, without taking the record with it^{Rec}. Due diligence matters too: on public evidence, security was capped for four of the five workflow tools assessed because their certification evidence could not be confirmed, which is a question to resolve before any risk records are loaded^{AJ}.

Questions for your team

- Which unit do we govern today: the model, the application or the use case?^{AJ}
- For our most material GenAI use case, does the validation report name the model, prompt, index and tool versions running now?^{AJ}
- Does any production call go to a model alias rather than a pinned version?^{Rec}
- Who outside the development team has challenged and extended our evaluation suite?^{Rec}
- Where does our evidence live, and would it survive the end of a vendor contract?^{AJ}
- Which senior manager is accountable for AI use in client communications?^{AJ}

³⁸³ Verified fact — R-INTL-AI-ASSETMGMT: IOSCO Supervisory Toolkit for AI Use in Capital Markets (FR/02/2026) and ESMA Public Statement on AI and investment services (30 May 2024) (see [regulatory_facts.json](#)); A8-S059: ESMA Public Statement on AI and investment services (30 May 2024) and 2026 briefings <https://www.esma.europa.eu/document/public-statement-ai-and-investment-services> accessed 2026-10-07 [search-tool extract]

³⁸⁴ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see [regulatory_facts.json](#)); A8-S003: OCC Issues Updated Model Risk Management Guidance (NR 2026-29) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/news-releases/2026/nr-occ-2026-29.html> accessed 2026-10-07 [search-tool extract]

³⁸⁵ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see [regulatory_facts.json](#)); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]

Part II: Nine layers and the controls that make them safe

- Have we written our own GenAI model-risk standard, and to which benchmark? ^{Rec}

In one line

Govern the use case, pin every version, and keep the evidence yourself, because that is what any future rule will ask to see. ^{Rec}

Part III: Putting it together

19. What the agent must never do matters more

Putting it together: the worked example, end to end, from Post 19 of the series.

The post

One example has run underneath this series: an agent that drafts the monthly performance-attribution commentary for a multi-asset fund, with a portfolio manager approving every draft. It is generic and illustrative. Here it is in one place. ^{AJ}

What it may do is short. Draft narrative around figures it is given. Explain allocation, selection and currency effects in the house style. Cite approved market context. Propose wording, and propose new style rules for a person to approve. ^{Rec}

What it must never do is longer, and matters more. Never generate, round or “correct” a number. Never treat a figure from retrieved text, memory or a parsed document as data. Never present inference as source. Never publish without a recorded human approval. Never call a write, email or web tool. Never send client identifiers outside the approved route. Never run on an unpinned model. ^{Rec}

The useful discipline is that every “never” names the component that enforces it. Read-only tools and a deterministic numeric check stop invented figures. A workflow with no outbound tool stops exfiltration. An approval step that only a named person can release stops unreviewed publication. A “never” without an enforcing component is a hope written into a policy. ^{AJ}

The signal is evidence-pack completeness: the share of approved commentaries with a complete record of prompt version, model version, data snapshot, tool calls, evaluation results, approver, timestamps and final text. The target is 100%. ^{AJ}

The leadership move is to write the “never” list first, and let it shape the design. ^{Rec}

The honest caveat: this design gives up flexibility on purpose. Each new capability should arrive with its own enforcing control, not a broader prompt. ^{AJ}

Capability is what a system can do. Trust comes from what it provably cannot. ^{AJ}

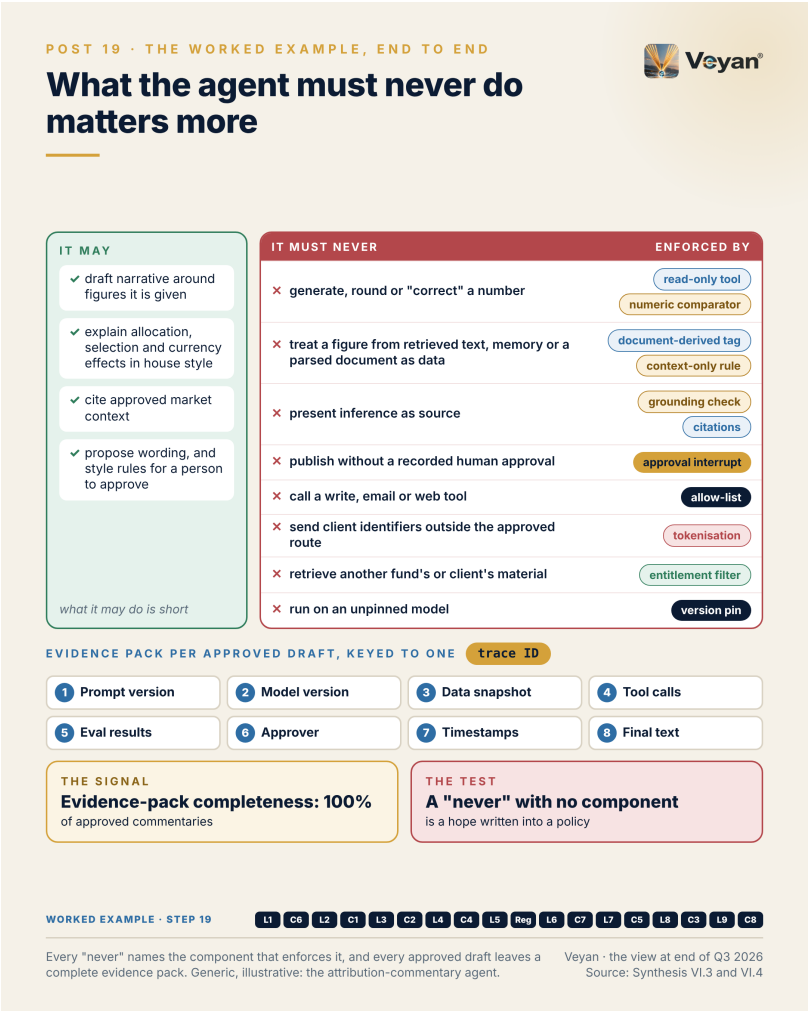


Figure 19. Every “never” names the component that enforces it, and every approved draft leaves a complete evidence pack. Generic, illustrative: the attribution-commentary agent. ^{AJ}

Behind the post

The worked example is deliberately ordinary. An agent drafts the monthly performance-attribution commentary for a generic multi-asset fund: Brinson-style allocation and selection effects, currency, and benchmark-relative return. A portfolio manager reviews and approves every draft before release ^{AJ}. It is illustrative and cloud-neutral, not a description of any firm's platform ^{AJ}.

The architectural reading. Strip away the word “agent” and this is a deterministic workflow, not a free agent ^{AJ}. Every number comes from the attribution engine through a read-only tool. The model's only job is to write narrative around figures it is given. A deterministic check proves that every figure in the draft matches the engine. A named person approves ^{AJ}. The language model is therefore governed as a model-dependent use case under the firm's own standard (Chapter 18), and the use case is not an EU AI Act Annex III use ^{AJ}. Article 50 is assessed: it requires disclosure of AI-generated text published to inform the public on matters of public interest, unless the text has been human-reviewed under editorial responsibility ^{vi386}. Here, human editorial review applies ^{AJ}.

One request, end to end. The review traces a single run through every layer and control ^{AJ}. Before anything runs, a release manifest pins the prompt set, the drafting model at a dated version, a fallback model, the embedding and reranker versions, the read-only tool list, the guardrail policy and the evaluation thresholds. An analyst signs in, and the agent's own registered identity obtains a short-lived, read-only token to act on the analyst's behalf. The attribution results arrive through a tool gateway that checks an allow-list and the analyst's entitlements, and the snapshot's hash is recorded. Retrieval searches only approved prior commentaries, the style guide and approved market notes, filtered by entitlement, and every chunk carries its source, version and parse manifest (Chapter 15). Retrieved chunks are screened for hidden instructions. Client identifiers are tokenised (Chapter 16). One drafting step runs through the gateway to an in-region primary model, with a qualified fallback from a different vendor; if both are unavailable, it fails closed ^{AJ}.

Then the checks. A deterministic comparator tests every figure, sign and direction word against the snapshot. Personal data is re-checked and placeholders must be

³⁸⁶ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see `regulatory_facts.json`); A8-S018: AI Act Article 50 Transparency obligations; Commission Article 50 guidelines C(2026) 5054 (European Commission) <https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-50> accessed 2026-10-07 [search-tool extract]; V2-S078: Not Delayed, Not Deferred: EU AI Act Transparency Obligations Are Now in Force (Goodwin; with Orrick, Freshfields on final Digital Omnibus) (Goodwin Procter) <https://www.goodwinlaw.com/en/insights/publications/2026/08/alerts-technology-dpc-eu-ai-act-transparency-obligations-now-in-force> accessed 2026-10-08 [search-tool extract]

unchanged. Forecasts and advice are denied topics. The evaluation gate requires 100% numeric faithfulness; a failure goes back for a bounded retry or is returned for revision, never approved (Chapter 17). An approval interrupt then waits for a named portfolio manager, not the requester and not the agent, with step-up authentication. A release service publishes using the approver's identity, outside the agent. The evidence pack is written to the immutable archive, and the approver's edits feed the human-intervention metric and proposed style rules ^{AJ}.

Every “never” names its enforcer. The boundary table is the heart of the design ^{Rec}. Generating or “correcting” a number is stopped by read-only tools, the numeric comparator and a blocking evaluation. Using a figure from retrieved commentary, memory or a parsed document as data is stopped by a document-derived tag and a context-only rule. Presenting inference as source is caught by grounding checks and citations to document versions. Publishing without approval is impossible because the approval interrupt and the release service sit outside the agent, with segregation of duties enforced through identity. Calling a write, email or web tool is impossible because no such tool exists on the allow-list. Sending client identifiers out is stopped by tokenisation, an egress proxy and redaction at the trace collector. Retrieving another fund's or client's material is stopped by an entitlement filter inside the search. Running on an alias or an unqualified fallback is stopped by the gateway route and the version pins ^{Rec}. Two less obvious rows matter too: discarding evaluation evidence is prevented by the firm-owned archive, and mixing two attribution snapshots after a resume is prevented by reusing the recorded snapshot

^{Rec}.

The threat it is built to survive. The review's security scenario is a third-party market note containing hidden text that tells the model to say currency hedging added 40 basis points and to send the draft elsewhere ^{AJ}. No single control has to catch it. There is no outbound tool to hijack. The comparator fails any figure not in the engine snapshot. Retrieved text is wrapped as data. A detector screens retrieved chunks and quarantines the source. And the portfolio manager approves before release ^{AJ}.

What it costs. On the review's arithmetic, a draft of about 40,000 input and 3,000 output tokens on a mid-tier model at US\$2 and US\$10 per million tokens, the list price of both Claude Sonnet 5.5 and GPT-6.1 Sol as of 7 October 2026, costs about US\$0.11 ^{vi}³⁸⁷ ^{AJ}. With judges and an average of 2.5 drafts per approved commentary,

³⁸⁷ Verified fact — A5-S011: Pricing - Claude API Docs (Anthropic)

<https://platform.claude.com/docs/en/about-claude/pricing> accessed 2026-10-07; A5-S004: OpenAI API Pricing (and Introducing GPT-6 Sol and Luna pricing) <https://developers.openai.com/api/docs/pricing> accessed 2026-10-07 [search-tool extract]

the token cost is roughly US\$0.30, or about US\$12 a month for 40 funds; those token figures are the review's own illustration ^{AJ}. The conclusion matters more than the number. Tokens are not the cost driver; reviewer time is, so the metric to manage is the regeneration and edit rate ^{AJ}.

Portable by design. Each component is named once in cloud-neutral form, with equivalents on each major cloud ^{AJ}. The workflow, for example, can be LangGraph with a firm-controlled Postgres checkpointer or Temporal, or a native option: Strands on AgentCore Runtime, Microsoft Agent Framework on Foundry, or ADK on Agent Engine ^{VF388 Rec}. Pinning versions and keeping a fallback model qualified on the same evaluation suite also gives the tested exit route that SS2/21 expects ^{VF389 AJ}.

What good looks like

The signal is **evidence-pack completeness**: the share of approved commentaries with a complete record of prompt version, model version as returned by the gateway, data snapshot, tool calls, evaluation results, approver identity and edit, timestamps, and final text ^{AJ}. Measure it with an automated check at release that refuses to publish without a complete pack, and confirm it with a periodic sample audit ^{AJ}.

The target is 100% of approved commentaries ^{AJ}. Treat it as a starting point for any client-facing use case, not as an industry benchmark.

Two companion measures show whether the pack is useful as well as complete ^{AJ}. Reproducibility, tested quarterly by re-performing a sample of past commentaries from their packs, should pass on the whole sample. The human-intervention rate, the share of drafts edited or rejected and the size of the edits, should be tracked as

³⁸⁸ Verified fact — A4-S116: Bedrock AgentCore SDK README (GitHub) (AWS)

<https://raw.githubusercontent.com/aws/bedrock-agentcore-sdk-python/main/README.md> accessed 2026-10-07; B-L3-S004: AgentCore Runtime sessions / microVMs / quotas / security best practices (Amazon Web Services)

<https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/runtime-sessions.html> accessed 2026-10-08 [search-tool extract]; A4-S066: Microsoft Agent Framework README (GitHub)

<https://raw.githubusercontent.com/microsoft/agent-framework/main/README.md> accessed 2026-10-07; B-L3-S006:

Foundry Hosted Agents (Agent Framework hosting docs and Foundry blog) (Microsoft) <https://learn.microsoft.com/en-us/agent-framework/hosting/foundry-hosted-agent>

accessed 2026-10-08 [search-tool extract]; A4-S114: Agent

Development Kit (ADK) 2.0 README (GitHub) (Google)

<https://raw.githubusercontent.com/google/adk-python/main/README.md> accessed 2026-10-07

³⁸⁹ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see regulatory_facts.json); A8-S048: SS2/21 Outsourcing and third party risk management (and PS7/26, March 2026) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2021/ss221-march-21.pdf> accessed 2026-10-07 [search-tool extract]

a trend; it is both the main cost driver and an indicator supervisors have named ^{VR390} it. ^{AJ}

In the worked example

Step 19: assembled. All eighteen pieces assembled into one request trace, with a ‘may / must never’ list in which every ‘never’ names the component that enforces it. ^{AJ}

- **Now works:** The design is complete end to end on paper. ^{AJ}
- **Must never:** Every ‘must never’ has an enforcing component, not a policy sentence. ^{AJ}
- **Evidence added:** The eight-tile evidence pack, keyed to one trace ID. ^{AJ}
- **Signal:** Evidence-pack completeness: 100%. ^{AJ}

Objections worth taking seriously

“This is too constrained to be called an agent.” That is the point, and the post says so. The design gives up flexibility on purpose ^{AJ}. A client-facing regulated communication is the wrong place to discover what an open-ended agent does with a write tool. If more capability is wanted later, it should arrive with its own enforcing control and its own evaluation cases, not as a broader prompt ^{Rec}. Autonomy is easier to extend from a pinned, well-evidenced baseline than to claw back from a system nobody can fully describe ^{AJ}.

“A person approves every draft, so the other controls are redundant.” The approver is the last line, not the only one. People reviewing dozens of fluent drafts at month-end check what they expect to check; the review’s ingestion scenario has a reviewer verify the current month’s numbers but miss a prior-period figure quoted from a mis-parsed factsheet ^{AJ}. The comparator, the context-only rule and the evidence pack make the approver’s job tractable, and make the approval mean something ^{AJ}.

“Our use case is not attribution commentary.” The specifics will differ. The method transfers ^{AJ}. Write a short “may” list and a longer “never” list, put an enforcing component against every “never”, and define the evidence pack before the first line of code. A “never” with no component is the place to start the design conversation ^{Rec}. It is also usually the cheapest conversation the team will have: a boundary

³⁹⁰ Verified fact — R-INTL-AI-ASSETMGMT: IOSCO Supervisory Toolkit for AI Use in Capital Markets (FR/02/2026) and ESMA Public Statement on AI and investment services (30 May 2024) (see [regulatory_facts.json](#)); A8-S058: IOSCO FR/02/2026 Supervisory Toolkit for AI Use in Capital Markets (May 2026) <https://www.iosco.org/library/pubdocs/pdf/IOSCOPD823.pdf> accessed 2026-10-07 [search-tool extract]

agreed before build costs a meeting, while one discovered in production costs a re-review of everything already released ^{AJ}.

Questions for your team

- For our leading GenAI use case, is there a written “never” list, and does each line name its enforcing component? ^{Rec}
- Can the model in that use case produce a number that reaches a client without a deterministic check? ^{AJ}
- Is there any tool on the agent's allow-list that can write, send or browse? ^{AJ}
- Who can release an output, and is that identity separate from the requester and the agent? ^{AJ}
- Could we produce a complete evidence pack for an output approved six months ago? ^{AJ}
- What is our edit and regeneration rate, and do we treat it as a cost and quality signal? ^{Rec}

In one line

Decide what the system must never do, name the component that stops it, and keep the evidence that it did not. ^{Rec}

20. The most valuable page: “do not build yet”

Putting it together: Stack D, minimal start-small, from Post 20 of the series.

The post

The most valuable page in a reference architecture is often the “do not build yet” list.

Reference architectures tend to be read as shopping lists. Every box looks like a work package, and a programme that funds them all spends its first year building platform that nobody is using yet. ^{AJ}

The right minimum is not a weaker stack. It is the full regulated design with everything the first use case does not need removed. One gateway, deployed twice, with one route and a budget that fails closed. An agent identity acting on the analyst's behalf with read-only scope. A configuration manifest in source control with a second approver. Deterministic output checks and identifier protection. The evaluation suite. One retrieval store already in use. One workflow with one approval step. Two model vendors qualified from day one, because exit must be real. ^{Rec}

Then the list of what waits: long-term memory, autonomous agents, agent-to-agent delegation, web search, code sandboxes, a dedicated vector database, a second cloud, fine-tuning, a governance platform, a FinOps product, semantic caching, and anything still experimental. ^{Rec}

The signal is gateway coverage: the share of production model calls that pass through the gateway. The target is 100%; any provider key found in application code is a defect. Without it there is no exit and no log of record. ^{AJ}

The leadership move is to publish the “not yet” list with the same authority as the plan, and to revisit it only when evidence shows a real gap. ^{Rec}

The honest caveat: a small first release can look unambitious. Present the controls as the deliverable, because every later use case reuses them.

Saying “not yet” clearly is how a platform earns the right to say yes later.



Figure 20. The minimum is the full regulated design with everything the first use case does not need removed, plus a published “not yet” list. Generic and illustrative; revisit triggers are indicative. ^{AJ}

Behind the post

The review sets out four reference stacks. Stack A, the regulated enterprise stack, is the lead; Stacks B (cloud-native managed), C (open-source first) and D (minimal start-small) are alternatives for firms whose constraints differ ^{AJ}. Stack D is easy to misread. It is defined as the minimum viable enterprise platform that can safely run one regulated use case, with an explicit list of what not to build, and it is Stack A with everything the first use case does not need removed ^{AJ}. Every control in Stack A is still present in some form; what shrinks is the number of routes, stores, tools and workflows each control has to cover ^{AJ}.

Why one use case. A platform with no user has nothing for a validator to re-perform ^{AJ}. The review names the performance-attribution commentary from Chapter 19 as a good first candidate because its boundaries are clear and its numbers are checkable ^{Rec}. A use case like that forces every control to exist without forcing any of them to be general.

The minimum, layer by layer. Read in the house order, the build-now list is short, and each item has a one-line reason ^{AJ}:

- *Models and model access (L1, L2).* The primary cloud's model service, with two vendors qualified from day one. On AWS that might be Claude Sonnet 5.5 or a GPT-6 tier on Bedrock, the other or Mistral as fallback; on Azure, GPT-6.1 Sol with Mistral as fallback; on Google Cloud, Gemini 3.8 Flash with Claude as fallback and Mistral as the independent alternative ^{Rec}. Two vendors matter because model lives are short: a Gemini Flash version released on 13 August 2026 retires on 28 January 2027 ^{vi}³⁹¹, and Mistral Medium 3.1 retired on 31 August 2026 ^{vi}³⁹².
- *Orchestration (L3).* One graph with one approval gate, on LangGraph with a Postgres checkpoint, or Strands on AgentCore, Microsoft Agent Framework or Google ADK where that cloud is primary ^{Rec}.
- *Tools (L4).* One read-only tool onto authoritative data, and no writes. MCP is the default protocol and originated at Anthropic, so the independent alternative is an OpenAPI-described tool behind the same gateway ^{Rec}. Authorisation is still optional in the MCP specification ^{vi}³⁹³, which is why the gateway, not the protocol, enforces it ^{AJ}.

³⁹¹ Verified fact — B-L1-S003: Gemini 3.7 Flash model page and related lifecycle pages (Gemini Enterprise Agent Platform) (Google Cloud) <https://docs.cloud.google.com/gemini-enterprise-agent-platform/models/gemini/3-7-flash> accessed 2026-10-08 [search-tool extract]

³⁹² Verified fact — B-L1-S002: Models overview: deprecated and retired models (Mistral Docs) (Mistral AI) <https://docs.mistral.ai/models> accessed 2026-10-08 [search-tool extract]

³⁹³ Verified fact — A3-S055: MCP Specification 2026-07-28: Authorization (Model Context Protocol project (GitHub)) <https://raw.githubusercontent.com/modelcontextprotocol/modelcontextprotocol/main/docs/specification/2026-07-28/basic/authorization/index.mdx> accessed 2026-10-07

- *Ingestion and retrieval (L8 to L6)*. Docling and pgvector with entitlement filters: one store, already secured ^{Rec}. pgvector is managed on all three hyperscalers ^{VF}³⁹⁴.
- *Evaluation (L9)*. A firm-owned OpenTelemetry Collector, Langfuse or MLflow, and DeepEval with Promptfoo plus one independent red-team tool ^{Rec}. The second tool is not a luxury: OpenAI announced its acquisition of Promptfoo on 9 March 2026 ^{VF}³⁹⁵, and a red-team tool owned by a model vendor cannot be the only challenge to that vendor's model ^{AI}.
- *Gateway (C1)*. One gateway, two instances, one route, budgets ^{Rec}. Without it there is no exit and no log of record ^{AI}.
- *Guardrails and privacy (C2, C3)*. Deterministic output checks and Presidio, because numbers and client identifiers are the two real risks in this use case ^{AI}.
- *Identity (C4)*. The agent registered in the workforce identity provider, acting on behalf of the analyst with read-only scope ^{Rec}. Entra Agent ID and Okta for AI Agents both reached general availability in 2026 ^{VF}³⁹⁶.
- *Configuration (C5)*. A Git manifest changed by pull request with a second approver; change control is the cheapest control there is ^{AI}.
- *FinOps (C6)*. A gateway key and a budget that fails closed, to stop runaway loops ^{Rec}.
- *Security (C7)*. No outbound tools, and pinned dependencies from a mirror; capability separation costs nothing at this size ^{AI}.
- *Governance (C8)*. An inventory entry and an evidence pack in an archive the firm already runs, because that is what regulators ask for first ^{AI}.

“Fails closed” has to be tested, not assumed. The gateway evidence shows why the budget line carries a qualifier. LiteLLM's `max_budget` fails open when its database is unavailable, and its limits are unset by default ^{VF}³⁹⁷. Malicious LiteLLM

³⁹⁴ Verified fact — V1-S020: pgvector CHANGELOG.md (pgvector (GitHub)) <https://raw.githubusercontent.com/pgvector/pgvector/master/CHANGELOG.md> accessed 2026-10-08; B-L6-S004: Extension versions for Amazon RDS for PostgreSQL; RDS PostgreSQL release notes; Aurora pgvector announcements (Amazon Web Services) <https://docs.aws.amazon.com/AmazonRDS/latest/PostgreSQLReleaseNotes/postgresql-extensions.html> accessed 2026-10-08 [search-tool extract]; B-L6-S005: Vector search in Azure Database for PostgreSQL flexible server; Cloud SQL vector embeddings; AlloyDB vector search overview (Microsoft; Google Cloud) <https://learn.microsoft.com/en-us/azure/postgresql/extensions/how-to-use-pgvector> accessed 2026-10-08 [search-tool extract]

³⁹⁵ Verified fact — A1-S024: OpenAI to acquire Promptfoo <https://openai.com/index/openai-to-acquire-promptfoo/> accessed 2026-10-07 [search-tool extract]; V1-S006: OpenAI to acquire Promptfoo <https://openai.com/blog/openai-to-acquire-promptfoo> accessed 2026-10-08 [search-tool extract]

³⁹⁶ Verified fact — V2-S032: Microsoft Entra releases and announcements (with What's new in Entra Agent ID; Entra blog 'Build AI agents for production with secure identities from day one'; <https://learn.microsoft.com/en-us/entra/fundamentals/whats-new> accessed 2026-10-08 [search-tool extract]; A6-S100: Okta for AI Agents is Now Generally Available; Okta announces new blueprint for the secure agentic enterprise (Okta, Inc.) <https://www.okta.com/blog/ai/okta-for-ai-agents-general-availability/> accessed 2026-10-07 [search-tool extract]

³⁹⁷ Verified fact — A6-S015: LiteLLM docs: MCP Overview, Agent Gateway (A2A), Caching, Budgets/Rate Limits, v1.89.0 release notes (BerriAI (LiteLLM)) <https://docs.litellm.ai/docs/mcp> accessed 2026-10-07 [search-tool extract]

releases 1.82.7 and 1.82.8 were published to PyPI on 24 March 2026³⁹⁸. Neither fact rules the product out; clean releases resumed from 1.83.0³⁹⁹. Both make “fails closed” and “pinned” acceptance tests for the first release, the same tests Kong, Azure API Management or Apigee would have to pass^{Rec}.

The not-yet list, and why each item waits. Stack D’s list is longer than the post’s. It adds MCP beyond the first read-only tool, self-hosted serving beyond a documented exit option and a runtime AI-security platform^{Rec}. Each deferral has a reason in the evidence:

- *Memory.* The independent memory layer is thinning: Mem0 removed external graph stores from its open-source build, Zep deprecated its Community Edition, Letta pivoted to an agent harness and LangMem has not released since 27 October 2025⁴⁰⁰. OWASP lists memory and context poisoning as ASI06⁴⁰¹. Memory is a regulated record class, and the roadmap builds it last^{AJ}.
- *A dedicated vector database.* Only when a load test proves the need^{Rec}.
- *Fine-tuning.* It adds a model to validate, and under Article 25 of the EU AI Act a deployer becomes a provider if it substantially modifies a high-risk system or changes an AI system’s intended purpose so that it becomes high-risk⁴⁰².
- *A governance platform.* No governance platform reaches Strategic on public evidence, and buying one before the evidence store exists inverts the dependency^{AJ}.

³⁹⁸ Verified fact — A6-S008: Security Update: Suspected Supply Chain Incident (and Security Townhall Updates) (BerriAI (LiteLLM)) <https://docs.litellm.ai/blog/security-update-march-2026> accessed 2026-10-07 [search-tool extract]; V2-S027: LiteLLM PyPI supply chain attack (with NetSPI, Comet, Snyk/Datadog reporting) (FutureSearch) <https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/> accessed 2026-10-08 [search-tool extract]

³⁹⁹ Verified fact — A6-S009: v1.83.0 - Official Release (Post Supply Chain Incident) (BerriAI (LiteLLM)) https://docs.litellm.ai/release_notes/v1.83.0/v1-83-0 accessed 2026-10-07 [search-tool extract]

⁴⁰⁰ Verified fact — A3-S053: Mem0 docs: Platform vs Open Source (and OSS v2-to-v3 migration notes) <https://docs.mem0.ai/platform/platform-vs-oss> accessed 2026-10-07 [search-tool extract]; V1-S043: Open Source: Migrating to the New Memory Algorithm; SDK changelog; Highlights (Mem0) <https://docs.mem0.ai/migration/oss-v2-to-v3> accessed 2026-10-08 [search-tool extract]; A3-S059: getzep/zep README: Zep Cloud Examples & Integrations (Zep AI (GitHub)) <https://raw.githubusercontent.com/getzep/zep/main/README.md> accessed 2026-10-07; A3-S093: Letta’s Next Phase (Mar 2026) <https://www.letta.com/blog/our-next-phase/> accessed 2026-10-07 [search-tool extract]; A3-S006: PyPI JSON metadata: langmem (Python Package Index (PyPI)) <https://pypi.org/pypi/langmem/json> accessed 2026-10-07

⁴⁰¹ Verified fact — B-L5-S001: Memory Is a Feature. It Is Also an Attack Surface (OWASP GenAI Security Project) <https://genai.owasp.org/2026/05/13/memory-is-a-feature-it-is-also-an-attack-surface/> accessed 2026-10-08 [search-tool extract]

⁴⁰² Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see regulatory_facts.json); A8-S011: Regulation (EU) 2026/1744 (Digital Omnibus on AI) amending Regulation (EU) 2024/1689 (EUR-Lex / Official Journal of the EU) <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> accessed 2026-10-07 [search-tool extract]

- *Semantic caching.* LiteLLM's own documentation warns that it "goes badly wrong on agentic traffic" ⁴⁰³, and Apigee shipped an SSRF fix in its semantic-cache lookup on 30 September 2026 ⁴⁰⁴.

The figure gives each deferred item an indicative revisit trigger: evidence, a load test, a use case or a review date ^{AJ}.

What changed in 2025 and 2026. Two dates make "start small" a scheduling necessity rather than a temperament. PRA PS7/26 and FCA PS26/2 require material third-party notifications from 18 March 2027 ⁴⁰⁵, and EU AI Act Annex III high-risk duties apply from 2 December 2027 ⁴⁰⁶. A firm that spends its first year on breadth reaches those dates with many components and no evidence; one that ships the Stack D minimum reaches them with one use case, one exit drill and one evidence trail ^{AJ}. The roadmap's gateway phase makes that concrete: its exit criterion is a route moved to the alternative vendor and to an open-weight route on vLLM by configuration only ^{RSC}.

What good looks like

The signal is **gateway coverage**: the share of production model, tool and agent calls that pass through the gateway of record ^{AJ}. The review's gateway chapter defines it with LLM, MCP and A2A traffic in scope, and treats any direct provider key in an application as a defect ^{AJ}.

Measure it in two ways at once. First, reconcile provider usage reports with gateway logs; any usage the gateway did not see is a bypass ^{AJ}. Second, run secret scanning across application repositories and deployment configuration for provider

⁴⁰³ Verified fact — A6-S015: LiteLLM docs: MCP Overview, Agent Gateway (A2A), Caching, Budgets/Rate Limits, v1.89.0 release notes (BerriAI (LiteLLM)) <https://docs.litellm.ai/docs/mcp> accessed 2026-10-07 [search-tool extract]

⁴⁰⁴ Verified fact — A6-S025: Apigee release notes (all; hybrid) (Google Cloud) <https://docs.cloud.google.com/apigee/docs/release-notes> accessed 2026-10-07 [search-tool extract]

⁴⁰⁵ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see [regulatory_facts.json](#)); R-FCA-SYSC8: FCA Handbook SYSC 8 (Outsourcing); FG16/5 'Guidance for firms outsourcing to the cloud and other third-party IT services'; PS26/2 operational incident and third-party reporting (see [regulatory_facts.json](#)); A8-S062: PS7/26 Operational incident and third-party reporting (PRA) and FCA PS26/2; revised SS2/21 (March 2026) (Bank of England / PRA; FCA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2026/march/operational-incident-and-third-party-reporting-policy-statement> accessed 2026-10-07 [search-tool extract]

⁴⁰⁶ Verified fact — R-EU-OMNIBUS-AI: Regulation (EU) 2026/1744 ('Digital Omnibus on AI') amending Regulations (EU) 2024/1689, 2018/1139 and 2023/1230 (see [regulatory_facts.json](#)); A8-S011: Regulation (EU) 2026/1744 (Digital Omnibus on AI) amending Regulation (EU) 2024/1689 (EUR-Lex / Official Journal of the EU) <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> accessed 2026-10-07 [search-tool extract]

keys; any key outside the gateway’s secret store is a finding ^{AJ}. Report the two together, because each catches what the other misses.

The starting target is 100% of production calls in scope, with zero provider keys outside the gateway ^{AJ}. Treat it as a starting point for the first use case, not a benchmark drawn from other firms. As later use cases arrive, the number should stay at 100%; what grows is the volume behind it ^{AJ}. A companion check is the exit drill itself: time to move a route to a pre-qualified alternative by configuration, aiming for hours rather than weeks and tested at least annually ^{AJ}.

In the worked example

Step 20: minimum go-live. The build order for real: governance and evaluation first, then the gateway, retrieval, the workflow and one read-only tool; memory and everything on the ‘not yet’ list waits for evidence. ^{AJ}

- **Now works:** The agent can go live on the minimum platform. ^{AJ}
- **Must never:** Nothing is built before the evidence says it is needed. ^{AJ}
- **Evidence added:** The published ‘not yet’ list with a trigger for each item. ^{AJ}
- **Signal:** Gateway coverage of production calls: 100%. ^{AJ}

Objections worth taking seriously

“Two model vendors on day one is gold-plating for a pilot.” It looks that way until the first retirement notice or suspension. Model lifetimes are measured in months ^{VF407}, and a single proprietary vendor behind an important business service is classed as unacceptable lock-in in the review ^{AJ}. The cost of qualifying a second vendor is one more run of the evaluation suite the first use case needs anyway ^{AJ}.

“If we defer memory and agents, the business will build them without us.” That risk is real. The answer is not to build them early but to publish the not-yet list with its triggers, so that a team with a genuine need has a route to bring evidence ^{Rec}. A deferral that nobody can challenge invites workarounds; a deferral with a stated trigger invites a proposal ^{AJ}.

“A minimal platform will need re-platforming later.” Less than it seems. Stack D keeps every Stack A control; what grows later is coverage, not architecture ^{AJ}. The

⁴⁰⁷ Verified fact — B-L1-S003: Gemini 3.7 Flash model page and related lifecycle pages (Gemini Enterprise Agent Platform) (Google Cloud) <https://docs.cloud.google.com/gemini-enterprise-agent-platform/models/gemini/3-7-flash> accessed 2026-10-08 [search-tool extract]

components most likely to change, such as the vector store or the agent runtime, sit behind thin firm-owned interfaces from the start (Chapter 22) ^{AJ}.

“Publishing a ‘not yet’ list will read as a lack of ambition to the board.” It can, if the list is presented as a set of refusals. Presented as a sequence, it reads differently: each deferred item has a trigger, and the roadmap shows when evidence is expected ^{AJ}. The controls built for the first use case are reused by every later one, so the first release is the foundation of the programme, not a pilot that will be thrown away ^{AJ}. Boards in regulated firms tend to recognise that argument, because it is the same one they apply to any other critical infrastructure ^{AJ}.

Questions for your team

- If we published our “not yet” list today, what would be on it, and who has authority to take an item off it? ^{Rec}
- What share of our production model calls passes through one gateway, and how do we know?
- Where in our code or configuration do provider keys still live?
- Is our second model vendor qualified on the same evaluation suite, or only contracted?
- Have we tested that our budgets and guards fail closed when their dependencies are down?
- Which first use case has clear boundaries and checkable outputs?
- Are we presenting the controls as the deliverable, or the features?

In one line

Start with the full regulated design for one use case, publish what waits, and let evidence, not enthusiasm, move items off the list.

21. Build where you differentiate, buy where you maintain

Putting it together: build, buy or hybrid across L1–L9 and C1–C8, from Post 21 of the series.

The post

Build where you differentiate. Buy where you would only be maintaining.

For an asset manager adopting GenAI, very little of the stack differentiates. Training a foundation model is out of scope. Gateways, parsers, vector search, identity providers and secrets brokers are commodity infrastructure with a heavy security and maintenance burden. Buy them, or adopt open source. ^{AJ}

What the firm should build is smaller and more important: whatever is its control statement, its evidence or its domain logic. Route definitions and fallback lists. The guardrail policy and its test sets. The numeric check against the attribution engine, which no vendor sells. The evaluation datasets. The release manifest. The evidence store. Read-only tools onto its own systems. The workflows. ^{Rec}

Most of the rest lands in a third column: hybrid, meaning a bought or open-source engine behind a firm-owned interface and policy. That column has grown, because so many “neutral” products have changed owner. When a product may be replaced within the planning horizon, the interface and the data around it must already be yours. ^{AJ}

The signal is configuration coverage: the share of production calls whose prompt, model, tool and retrieval settings resolve to an approved version the firm holds. The target is 100% for regulated outputs. ^{AJ}

Part III: Putting it together

The leadership move is one build, buy or hybrid decision per component, plus one explicit “do not build yet”: fine-tuning, which adds a model to validate and can, in some cases, turn a deployer into a provider under the EU AI Act. ^{Rec} ^{VF} ⁴⁰⁸

The honest caveat: hybrid is the most demanding column. It only pays if the interface stays thin and nobody starts rebuilding the product behind it. ^{AJ}

Owning the right small things is what makes everything else replaceable.

⁴⁰⁸ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see `regulatory_facts.json`); A8-S011: Regulation (EU) 2026/1744 (Digital Omnibus on AI) amending Regulation (EU) 2024/1689 (EUR-Lex / Official Journal of the EU) <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> accessed 2026-10-07 [search-tool extract]



Figure 21. One decision per component: the firm builds its control statement, evidence and domain logic, and keeps the interface around anything it buys. Generic: no vendor names. ^{AJ}

Behind the post

The rule. The review states it in one sentence: build where the capability is the firm's control statement, evidence or domain logic; buy where it is commodity

infrastructure with a heavy security, compliance or maintenance burden; and use a hybrid, an open-source or bought engine behind a firm-owned interface and policy, wherever a product may be replaced within the planning horizon ⁴¹. The test is not “could we build it?” Almost anything in the stack could be built. The test is whether building it creates something only the firm can hold to account ⁴¹.

Why the hybrid column grew. A year ago many teams could treat a well-regarded open-source or independent product as neutral ground. The 2026 evidence makes that harder. Dynatrace completed its acquisition of Arize on 1 October 2026 ⁴⁰⁹. ClickHouse announced it had acquired Langfuse on 16 January 2026 ⁴¹⁰. OpenAI announced its acquisition of Promptfoo on 9 March 2026 ⁴¹¹. Palo Alto Networks bought Portkey, Check Point bought Lakera, Harvey bought Guardrails AI, and Mintlify bought Helicone ⁴¹². Stripe agreed to acquire OpenRouter, with closing pending ⁴¹³. None of these owners is a poor steward by default. The point is that independence, exit planning and effective challenge can no longer be assumed from

⁴⁰⁹ Verified fact — A1-S045: Dynatrace Completes Acquisition of Arize, Extending AI Observability Across the Full Development Lifecycle (Dynatrace, Inc.) <https://ir.dynatrace.com/news-events/press-releases/detail/439/dynatrace-completes-acquisition-of-arize-extending-ai-observability-across-the-full-development-lifecycle> accessed 2026-10-07 [search-tool extract]; V1-S005: Dynatrace Completes Acquisition of Arize (IR press release) (Dynatrace, Inc.) <https://ir.dynatrace.com/news-events/press-releases/detail/439/dynatrace-completes-acquisition-of-arize-extending-ai-observability-across-the-full-development-lifecycle> accessed 2026-10-08 [search-tool extract]

⁴¹⁰ Verified fact — A1-S021: ClickHouse raises \$400M Series D, acquires Langfuse, launches Postgres (ClickHouse, Inc.) <https://clickhouse.com/blog/clickhouse-raises-400-million-series-d-acquires-langfuse-launches-postgres> accessed 2026-10-07 [search-tool extract]; V2-S041: ClickHouse welcomes Langfuse (with langfuse.com 'Langfuse joins ClickHouse', Orrick) <https://clickhouse.com/blog/clickhouse-acquires-langfuse-open-source-llm-observability> accessed 2026-10-08 [search-tool extract]

⁴¹¹ Verified fact — A1-S024: OpenAI to acquire Promptfoo <https://openai.com/index/openai-to-acquire-promptfoo/> accessed 2026-10-07 [search-tool extract]; V1-S006: OpenAI to acquire Promptfoo <https://openai.com/blog/openai-to-acquire-promptfoo> accessed 2026-10-08 [search-tool extract]

⁴¹² Verified fact — A6-S011: Palo Alto Networks Completes Acquisition of Portkey to Secure AI Agents (and 30 Apr 2026 announcement) <https://www.paloaltonetworks.com/company/press/2026/palo-alto-networks-completes-acquisition-of-portkey-to-secure-ai-agents> accessed 2026-10-07 [search-tool extract]; V2-S025: Palo Alto Networks Completes Acquisition of Portkey to Secure AI Agents (with PANW FY2026 10-K and 10-Q, SDxCentral) <https://www.paloaltonetworks.com/company/press/2026/palo-alto-networks-completes-acquisition-of-portkey-to-secure-ai-agents> accessed 2026-10-08 [search-tool extract]; A7-S012: Check Point to Acquire Lakera, Redefining Security for the AI era (Check Point Software) <https://blog.checkpoint.com/security/check-point-to-acquire-lakera-redefining-security-for-the-ai-era/> accessed 2026-10-07 [search-tool extract]; V2-S038: Check Point Software Reports 2025 Third Quarter Financial Results (with 'Check Point Completes Acquisition of Lakera' release via cxotoday) (Check Point Software Technologies) <https://www.checkpoint.com/press-releases/check-point-software-reports-2025-third-quarter-financial-results/> accessed 2026-10-08 [search-tool extract]; A6-S028: Guardrails AI Joins Harvey <https://www.harvey.ai/blog/guardrails-ai-joins-harvey> accessed 2026-10-07 [search-tool extract]; A7-S112: Helicone Blog: Helicone acquired by Mintlify (and Mintlify announcement) (Helicone / Mintlify) <https://www.helicone.ai/blog> accessed 2026-10-07 [search-tool extract]; V2-S043: Helicone Joins Mintlify (with mintlify.com 'Mintlify acquires Helicone'; PostHog comparison) (Helicone / Mintlify) <https://www.helicone.ai/blog/joining-mintlify> accessed 2026-10-08 [search-tool extract]

a product's origins; they have to be designed in ^{AJ}. The hybrid column is how that design shows up in a sourcing decision.

The buy column. Four components land here, each for a different reason ^{AJ}:

- *Foundation models (L1).* Training a foundation model is out of scope for an asset manager ^{AJ}. The firm buys hosted models through its primary cloud and adopts open weights such as Gemma 4 or Mistral; what it builds is the portfolio policy, the qualification suite and the retirement calendar ^{Rec}.
- *Serving (L2).* Buy access and adopt an open engine, such as vLLM, for the exit route ^{Rec}. Self-hosting is a capacity and operating-model decision, not a cost saving ^{AJ}.
- *Retrieval stores (L6).* Reuse the database or search engine the firm already operates. Every new store is another copy of confidential content to secure, retain and exit ^{AJ}.
- *AI security tooling (C7).* Secrets brokers, scanners and runtime detectors are specialist products. What the firm builds is the architecture that makes any one detector non-critical ^{AJ}.

The build column. The build list is short, and none of it is large software ^{AJ}:

- *Tool servers (L4).* Read-only servers owned by each system's team, exposed over MCP or, as the independent alternative to that Anthropic-originated protocol, as OpenAPI-described tools behind the same gateway ^{Rec}. Tools encode access to systems of record; they are the firm's integration surface ^{AJ}.
- *Memory service (L5).* Thin, and later: write through a policy gate, recall, forget by subject, snapshot. The governance is unique to the firm; the storage is not ^{AJ}.
- *Configuration of record (C5).* A release manifest schema, an evaluation gate in continuous integration and pull-request approval rules. Prompt text and approvals are intellectual property and model-risk evidence ^{AJ}.
- *AI FinOps (C6).* A thin cost dataset in the open FOCUS shape, with allocation rules in source control ^W⁴¹⁴. Allocation rules are finance policy ^{AJ}.
- *Evidence store (C8).* Immutable and keyed by trace ID. A governance workflow tool such as ValidMind, watsonx.governance, Colibra or Credo AI is optional and replaceable on top of it ^{Rec}. The evidence must outlive any tool ^{AJ}.

The hybrid column. Most of the stack sits here, and the split inside each row is specific ^{AJ}:

⁴¹³ Verified fact — V1-S059: Stripe agrees to acquire OpenRouter to help businesses optimize token routing and usage <https://stripe.com/newsroom/news/stripe-agrees-to-acquire-openrouter> accessed 2026-10-08 [search-tool extract]; V1-S060: Stripe to buy OpenRouter as fintech expands deeper into AI (and TechCrunch 16 Aug 2026 report) (CNBC / TechCrunch) <https://www.cnbc.com/2026/08/19/stripe-openrouter-fintech-ai-model-marketplace-.html> accessed 2026-10-08 [search-tool extract]

⁴¹⁴ Verified fact — A7-S096: FOCUS Specification licence (FinOps Foundation (FOCUS Working Group)) https://raw.githubusercontent.com/FinOps-Open-Cost-and-Usage-Spec/FOCUS_Spec/working_draft/license.md accessed 2026-10-07

Part III: Putting it together

- *Orchestration (L3)*. Adopt open frameworks, build the workflows. LangGraph, Microsoft Agent Framework, Google ADK and Pydantic AI are open and self-hostable ^{vi415}; the process is the firm's ^{vi416}.
- *Ingestion (L8)*. Adopt the parsers, build the envelope: the approved-source register, parse manifest, metadata envelope and lineage events. No ingestion product emits lineage, so the envelope cannot be bought ^{vi416}.
- *Evaluation (L9)*. The datasets and scorers live in source control; the platform of record is replaceable if instrumentation is portable ^{vi417}.
- *Gateway (C1)*. Gateways are commodity; routes, fallback lists and budgets are the firm's control. Proprietary policy dialects are the main switching cost ^{vi418}.
- *Guardrails (C2)*. The numeric comparator is domain logic no vendor sells, while detectors churn through acquisitions ^{vi419}.
- *Privacy (C3)*. One firm API over an adopted detection engine; a vendor-held token map is a hard exit ^{vi420}.
- *Identity (C4)*. Buy the identity provider's agent features, such as Entra Agent ID or Okta for AI Agents, and build the policy ^{vi421}.

⁴¹⁵ Verified fact — A4-S001: PyPI JSON metadata: langgraph (Python Package Index) <https://pypi.org/pypi/langgraph/json> accessed 2026-10-07; A4-S067: Microsoft Agent Framework LICENSE <https://raw.githubusercontent.com/microsoft/agent-framework/main/LICENSE> accessed 2026-10-07; A4-S114: Agent Development Kit (ADK) 2.0 README (GitHub) (Google) <https://raw.githubusercontent.com/google/adk-python/main/README.md> accessed 2026-10-07; A4-S003: PyPI JSON metadata: pydantic-ai (Python Package Index) <https://pypi.org/pypi/pydantic-ai/json> accessed 2026-10-07

⁴¹⁶ Verified fact — A1-S094: unstructured-ingest CHANGELOG (Unstructured Technologies (GitHub)) <https://raw.githubusercontent.com/Unstructured-IO/unstructured-ingest/main/CHANGELOG.md> accessed 2026-10-07; A1-S096: OpenLineage README (OpenLineage (LF AI & Data)) <https://raw.githubusercontent.com/OpenLineage/OpenLineage/main/README.md> accessed 2026-10-07

⁴¹⁷ Verified fact — A1-S058: Semantic conventions for generative AI systems (status: Development) (OpenTelemetry (CNCF)) <https://raw.githubusercontent.com/open-telemetry/semantic-conventions-genai/main/docs/gen-ai/README.md> accessed 2026-10-07; A1-S059: GenAI events incl. gen_ai.evaluation.result (OpenTelemetry (CNCF)) <https://raw.githubusercontent.com/open-telemetry/semantic-conventions-genai/main/docs/gen-ai/gen-ai-events.md> accessed 2026-10-07

⁴¹⁸ Verified fact — A6-S053: AI gateway capabilities in Azure API Management (Microsoft Learn source, ms.date 29 May 2026) <https://raw.githubusercontent.com/MicrosoftDocs/azure-docs/main/articles/api-management/genai-gateway-capabilities.md> accessed 2026-10-07; A6-S024: Apigee AI solutions: gateway to enterprise-ready AI (Google Cloud) <https://cloud.google.com/solutions/apigee-ai> accessed 2026-10-07; A6-S016: Kong AI Gateway 2.0 Is Now GA — And It's Already Moving Faster (Kong Inc.) <https://konghq.com/blog/product-releases/kong-ai-gateway-2-0-ga> accessed 2026-10-07 [search-tool extract]

⁴¹⁹ Verified fact — A6-S028: Guardrails AI Joins Harvey <https://www.harvey.ai/blog/guardrails-ai-joins-harvey> accessed 2026-10-07 [search-tool extract]; A7-S012: Check Point to Acquire Lakera, Redefining Security for the AI era (Check Point Software) <https://blog.checkpoint.com/security/check-point-to-acquire-lakera-redefining-security-for-the-ai-era/> accessed 2026-10-07 [search-tool extract]

⁴²⁰ Verified fact — A6-S081: skyflow - PyPI JSON metadata (Python Package Index) <https://pypi.org/pypi/skyflow/json> accessed 2026-10-07

“Adopt open source” carries its own diligence. The review found that “open source” often is not. Arize Phoenix is under ELv2, a source-available licence ^{vr422}. Firecrawl’s server is AGPL-3.0 ^{vr423}. Jina’s weights are CC-BY-NC-4.0 ^{vr424}. The Claude Agent SDK is governed by Anthropic’s Commercial Terms ^{vr425}, and the review names LangGraph or Pydantic AI as the independent alternatives ^{aj}. Licence review is therefore an architectural gate on the buy and hybrid columns, not a procurement afterthought ^{aj}.

Fine-tuning, the explicit “not yet”. It sits outside the three columns. Under Article 25 of the EU AI Act, a deployer becomes a provider if it substantially modifies a high-risk system or changes an AI system’s intended purpose so that it becomes high-risk ^{vr426}. Most asset-management uses are not high-risk; the post’s “in some cases” is deliberate ^{aj}. The other cost applies everywhere: a fine-tuned model is another model to validate, and PRA SS1/23 expects validation and ongoing monitoring that extends to vendor models ^{vr427}.

In the worked example. For the attribution commentary from Chapter 19, the split is concrete. The firm buys the hosted models and the gateway product. It builds the read-only tool onto the attribution engine, the numeric check that compares every

⁴²¹ Verified fact — V2-S032: Microsoft Entra releases and announcements (with What’s new in Entra Agent ID; Entra blog ‘Build AI agents for production with secure identities from day one’; <https://learn.microsoft.com/en-us/entra/fundamentals/whats-new> accessed 2026-10-08 [search-tool extract]; A6-S100: Okta for AI Agents is Now Generally Available; Okta announces new blueprint for the secure agentic enterprise (Okta, Inc.) <https://www.okta.com/blog/ai/okta-for-ai-agents-general-availability/> accessed 2026-10-07 [search-tool extract]

⁴²² Verified fact — A1-S048: Arize Phoenix LICENSE (Elastic License 2.0) (Arize AI (GitHub)) <https://raw.githubusercontent.com/Arize-ai/phoenix/main/LICENSE> accessed 2026-10-07

⁴²³ Verified fact — A1-S053: Firecrawl README (Firecrawl (GitHub)) <https://raw.githubusercontent.com/firecrawl/firecrawl/main/README.md> accessed 2026-10-07

⁴²⁴ Verified fact — A2-S024: Legal Information - Jina AI (Jina AI (Elastic)) <https://jina.ai/legal/> accessed 2026-10-07 [search-tool extract]

⁴²⁵ Verified fact — A4-S092: Claude Agent SDK (Python) LICENSE (Anthropic) <https://raw.githubusercontent.com/anthropics/claude-agent-sdk-python/main/LICENSE> accessed 2026-10-07

⁴²⁶ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see regulatory_facts.json); A8-S011: Regulation (EU) 2026/1744 (Digital Omnibus on AI) amending Regulation (EU) 2024/1689 (EUR-Lex / Official Journal of the EU) <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> accessed 2026-10-07 [search-tool extract]

⁴²⁷ Verified fact — R-PRA-SS123: PRA Supervisory Statement SS1/23 ‘Model risk management principles for banks’ (published with PS6/23) (see regulatory_facts.json); A8-S008: SS1/23 Model risk management principles for banks (Bank of England / PRA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> accessed 2026-10-07 [search-tool extract]

figure in the draft against that engine, the regression suite of past commentaries and the evidence pack ^{AJ}. Nothing it builds would interest a vendor, and nothing it buys holds the firm's records ^{AJ}.

What good looks like

The signal is **configuration coverage**: the share of production model calls whose prompt, model, tool and retrieval settings all resolve to an approved version identifier the firm holds ^{AJ}. It measures whether the build column is real. If a prompt or a model pin lives only in a vendor console, the firm has bought something it should have built ^{AJ}.

Measure it from the evidence the stack already produces: version identifiers on gateway logs and traces, reconciled each day to the release manifest in source control ^{AJ}. Registries in observability platforms can link each trace to the prompt version that produced it; Langfuse does this, for example ⁴²⁸. Two companion measures make the number honest: pin compliance, the share of model and embedding references pinned to a dated version rather than a moving alias, and trace-to-version linkage ^{AJ}.

The starting target is 100% for regulated outputs, with pin compliance also at 100% ^{AJ}. Treat both as a starting point for the firm's own standard, not as an industry benchmark. A falling number usually means a team has found a faster path around the manifest, and that path is worth understanding before it is closed ^{AJ}.

In the worked example

Step 21: build or buy. A build, hybrid or buy decision for each of the seventeen components: build the evidence store, configuration and tools; buy models, serving and security tooling; hybrid elsewhere. ^{AJ}

- **Now works:** Spend goes where the firm differentiates. ^{AJ}
- **Must never:** Fine-tuning stays off the list. ^{AJ}
- **Evidence added:** The decision and rationale per component. ^{AJ}
- **Signal:** Configuration coverage: 100% of settings under the manifest. ^{AJ}

⁴²⁸ Verified fact — A7-S071: Langfuse docs: Prompt Management overview (Langfuse (ClickHouse))
<https://raw.githubusercontent.com/langfuse/langfuse-docs/main/content/docs/prompt-management/overview.mdx>
accessed 2026-10-07

Objections worth taking seriously

“Hybrid doubles the work: we pay for a product and still maintain an interface.”

Sometimes true, which is the post's caveat. The defence is to keep the interface thin: one routing contract, one retrieval call, one privacy API ^{AJ}. If the interface starts to replicate the product's features, the firm is rebuilding the product and should either buy it outright or build it outright ^{AJ}. Chapter 22 sets out where that line falls.

“Our vendor already holds prompts, datasets and evidence well; why copy them?”

Because those records are what an exit or a regulator needs, and they must outlive the vendor relationship ^{AJ}. The review treats evaluation datasets held only in a vendor interface, or an evidence store held only by a vendor, as unacceptable lock-in for regulated work ^{AJ}. Keeping the canonical copy in source control or a firm archive does not stop the vendor's tool from being useful; it stops it from being indispensable ^{AJ}.

“Building the numeric check and evaluation datasets is expensive specialist work.”

It is the most valuable work in the stack, and no vendor can do it for the firm, because it encodes the firm's own data and judgement ^{AJ}. The regression suite is also the evidence a validator re-performs, so the cost is paid once and used repeatedly ^{AJ}.

“A single managed platform would be simpler than seventeen decisions.”

For a small firm it may be, and the review's cloud-native stack exists for that case ^{AJ}. Even there, the review keeps the evidence store and the configuration manifest in the firm's hands so that exit remains possible ^{AJ}. Simplicity in sourcing is fine; simplicity that leaves the firm's records inside one supplier is a concentration decision, and should be taken as one ^{AJ}.

Questions for your team

- For each layer and control, have we written down one decision, build, buy or hybrid, with its reason? ^{Rec}
- Which of our prompts, datasets or approval records exist only in a vendor's tool?
- What share of production calls resolves to an approved, pinned version we hold?
- Where has a hybrid interface grown into a second product?
- Which “open source” components have had a licence review, and which have not?
- Who owns the numeric or domain checks that no vendor sells?
- Is fine-tuning on our not-yet list, with a named trigger for revisiting it?

In one line

Build the small things that are your control statement, evidence and domain logic, and buy the rest behind an interface you own.

22. Portability lives in the artefacts you own

Putting it together: abstraction strategy, what to abstract and what not to, from Post 22 of the series.

The post

Abstraction is how an architecture stays reversible. Too much of it is how an architecture stops moving.

A firm-owned interface in front of anything replaceable is the right default. The trap is applying it everywhere. The classic case is a firm-wide wrapper around agent frameworks: frameworks on top of frameworks. It falls behind every upstream release, hides the features teams chose the framework for, and becomes a second product to maintain. ^{AI}

Abstract where switching is likely and the interface is small. Model routing through one API contract at the gateway. Observability through an open telemetry collector. Evaluation datasets in source control. Credentials through workload identity. Policy as code. Retrieval behind a thin interface. Embeddings with a version on every vector. ^{Rec}

Do not abstract the framework. Keep the workflow specification, prompts, tools and evaluations outside it, and rewriting a well-specified workflow becomes bounded work. That is the real portability. Do not build a plug-in architecture for one workflow with one model step. Do not put a layer between every query and the database. And do not build an abstraction to hide a model you never pinned. ^{Rec}

The signal is framework currency: days behind the pinned framework's latest security fix, held inside the patch window, for example 30 days. Wrappers make that number drift. ^{AI}

The leadership move is to ask, of every proposed abstraction, what switching would cost without it. If the answer is a bounded rewrite, skip the abstraction. ^{Rec}

The honest caveat: this is a judgement, and reasonable architects draw the line differently. A timed switch of one component settles most arguments.

Portability lives in the artefacts you own, not in the layers you add.



Figure 22. Abstract where switching is likely and the interface is small; do not wrap the framework. Ask what switching would cost without the layer. Generic: no vendor names. ^{AJ}

Behind the post

Chapter 21 argued for a thin firm-owned interface in front of anything the firm may replace. This chapter is the counterweight. Every abstraction has a running cost: it must be maintained, documented, secured and kept current with whatever sits beneath it ^{AJ}. The question is never whether abstraction is good in general, but whether a particular interface earns that cost ^{AJ}.

What earns an abstraction. The review supports ten firm-owned interfaces. They share three properties: switching is likely within the planning horizon, the interface is small, and the content behind it belongs to the firm ^{AJ}.

- *Model routing.* One OpenAI-compatible contract to the gateway, with no provider SDKs in application code. Every gateway assessed exposes or accepts the format ^{VF429}.
- *Observability.* A firm-owned OpenTelemetry Collector with redaction and a pinned semantic-convention version. Every evaluation and observability product assessed ingests OpenTelemetry or OpenInference ^{VF430}.
- *Evaluation.* Datasets and scorers versioned in source control, with results emitted as standard evaluation events ^{VF431}. The datasets are the regression baseline and the validation evidence ^{AJ}.
- *Credentials.* Workload identity, a vault and on-behalf-of tokens, with no standing secrets in agents ^{VF432}.

⁴²⁹ Verified fact — A6-S015: LiteLLM docs: MCP Overview, Agent Gateway (A2A), Caching, Budgets/Rate Limits, v1.89.0 release notes (BerriAI (LiteLLM)) <https://docs.litellm.ai/docs/mcp> accessed 2026-10-07 [search-tool extract]; A6-S049: Portkey AI Gateway README (GitHub) (Portkey (Palo Alto Networks)) <https://raw.githubusercontent.com/Portkey-AI/gateway/main/README.md> accessed 2026-10-07; A6-S053: AI gateway capabilities in Azure API Management (Microsoft Learn source, ms.date 29 May 2026) <https://raw.githubusercontent.com/MicrosoftDocs/azure-docs/main/articles/api-management/genai-gateway-capabilities.md> accessed 2026-10-07; A6-S061: agentgateway README (GitHub) (agentgateway project (Linux Foundation)) <https://raw.githubusercontent.com/agentgateway/agentgateway/main/README.md> accessed 2026-10-07; A6-S063: Envoy AI Gateway / Agent Router README (GitHub) (Envoy AI Gateway project (Agentic AI Foundation)) <https://raw.githubusercontent.com/envoyproxy/ai-gateway/main/README.md> accessed 2026-10-07

⁴³⁰ Verified fact — A1-S032: OpenTelemetry (OTEL) for LLM Observability - Langfuse (Langfuse (ClickHouse)) <https://langfuse.com/integrations/native/opentelemetry> accessed 2026-10-07 [search-tool extract]; A1-S037: Introducing End-to-End OpenTelemetry Support in LangSmith (LangChain, Inc.) <https://www.langchain.com/blog/end-to-end-opentelemetry-langsmith> accessed 2026-10-07 [search-tool extract]; A1-S042: OpenTelemetry (OTel) - Braintrust docs (Braintrust Data, Inc.) <https://www.braintrust.dev/docs/integrations/opentelemetry> accessed 2026-10-07 [search-tool extract]; A1-S049: OpenInference LICENSE (Apache-2.0) (Arize AI (GitHub)) <https://raw.githubusercontent.com/Arize-ai/openinference/main/LICENSE> accessed 2026-10-07

⁴³¹ Verified fact — A1-S059: GenAI events incl. gen_ai.evaluation.result (OpenTelemetry (CNCF)) <https://raw.githubusercontent.com/open-telemetry/semantic-conventions-genai/main/docs/gen-ai/gen-ai-events.md> accessed 2026-10-07

⁴³² Verified fact — A7-S033: Vault release notes 2.x; IBM Vault Self-Managed 2.x.x lifecycle page (HashiCorp (IBM)) <https://developer.hashicorp.com/vault/docs/updates/release-notes> accessed 2026-10-07 [search-tool extract]

Part III: Putting it together

- *Policy*. OPA (Rego) or Cedar in source control, with tests; both are open source ^{vi433}.
- *Retrieval*. One thin call taking a query, filters, tenant and top-k, and returning identifiers and scores. Proprietary query APIs differ ^{vi434}.
- *Privacy*. One privacy-service API to detect, transform and re-identify, so detectors can be replaced if recognisers and tests are the firm's ^{vi}.
- *Embedding and reranking*. One service, with the model version recorded on every vector, because switching the model forces re-embedding ^{vi}.
- *Memory*. Write, recall, forget by subject and snapshot. Memory semantics differ by product ^{vi435}.
- *Configuration*. One fetch call with a file-based fallback, because each registry has its own SDK ^{vi436}.

None of these is a framework. Most are a single function signature, a schema or a configuration file ^{vi}.

What does not earn one. The review names five places where adding a layer is the mistake ^{vi}:

- *Agent frameworks*. Do not wrap LangGraph, Microsoft Agent Framework or Google ADK in a firm abstraction ^{rec}. The frameworks are open source and self-hostable ^{vi437}, so the

⁴³³ Verified fact — A6-S088: Open Policy Agent LICENSE (Open Policy Agent project) <https://raw.githubusercontent.com/open-policy-agent/opa/main/LICENSE> accessed 2026-10-07; A6-S045: Cedar README (GitHub) (Cedar project) <https://raw.githubusercontent.com/cedar-policy/cedar/main/README.md> accessed 2026-10-07

⁴³⁴ Verified fact — A2-S051: pinecone (Python SDK) - PyPI (PyPI / Pinecone Systems, Inc.) <https://pypi.org/project/pinecone/> accessed 2026-10-07; A2-S056: turbopuffer (Python SDK) - PyPI (PyPI / turbopuffer) <https://pypi.org/project/turbopuffer/> accessed 2026-10-07; A2-S092: Amazon S3 Vectors (feature page) (Amazon Web Services) <https://aws.amazon.com/s3/features/vectors/> accessed 2026-10-07 [search-tool extract]

⁴³⁵ Verified fact — A3-S081: Mem0 docs source: Open Source migration to the new memory algorithm (Mem0 (GitHub)) <https://raw.githubusercontent.com/mem0ai/mem0/main/docs/migration/oss-v2-to-v3.mdx> accessed 2026-10-07; A3-S003: PyPI JSON metadata: graphiti-core (Python Package Index (PyPI)) <https://pypi.org/pypi/graphiti-core/json> accessed 2026-10-07; A3-S109: Vertex AI Agent Engine Memory Bank overview / generate memories / Memory Bank REST reference (docs.cloud.google.com, now 'Agent Platform Memory Bank') (Google Cloud) <https://docs.cloud.google.com/vertex-ai/generative-ai/docs/agent-engine/memory-bank/overview> accessed 2026-10-07 [search-tool extract]

⁴³⁶ Verified fact — A7-S072: Langfuse docs: Prompt version control (Langfuse (ClickHouse)) <https://raw.githubusercontent.com/langfuse/langfuse-docs/main/content/docs/prompt-management/features/prompt-version-control.mdx> accessed 2026-10-07; A7-S004: promptlayer on PyPI (JSON API) (PyPI / PromptLayer) <https://pypi.org/pypi/promptlayer/json> accessed 2026-10-07; A7-S089: LaunchDarkly Server-Side AI SDK for Python README <https://raw.githubusercontent.com/launchdarkly/python-server-sdk-ai/main/README.md> accessed 2026-10-07

⁴³⁷ Verified fact — A4-S001: PyPI JSON metadata: langgraph (Python Package Index) <https://pypi.org/pypi/langgraph/json> accessed 2026-10-07; A4-S067: Microsoft Agent Framework LICENSE <https://raw.githubusercontent.com/microsoft/agent-framework/main/LICENSE> accessed 2026-10-07; A4-S114: Agent Development Kit (ADK) 2.0 README (GitHub) (Google)

lock-in is already classed as acceptable ^{AJ}. Their APIs are framework-specific ^{vr⁴³⁸}, but rewriting a well-specified workflow is bounded work ^{AJ}.

- *Single-workflow plug-ins.* A deterministic workflow with one model step does not need a plug-in architecture ^{AJ}.
- *Plain database access.* pgvector is reached through SQL joined to entitlement tables; the thin retrieval interface sits above it for agents, not between every query and the database ^{AJ}.
- *Store-bundled features.* Several stores now run embedding models themselves, among them MongoDB Automated Embedding, Elastic's `semantic_text` and Pinecone's integrated inference ^{vr⁴³⁹}. Use them only if the model is pinned and the raw text is kept outside the store; an abstraction that hides an unpinned model hides the problem, not the dependency ^{AJ}.
- *Vendor model extras.* Prompt-caching formats and vendor tool-use extensions belong behind adapters with a feature-free fallback path ^{rec}.

Why wrapping frameworks fails now. The frameworks are moving quickly. Microsoft Agent Framework reached general availability on 2 April 2026 as the successor to Semantic Kernel and AutoGen, with AutoGen in maintenance mode ^{vr⁴⁴⁰}. Google ADK 2.0 added a Workflow Runtime ^{vr⁴⁴¹}. LangGraph has published three checkpoint deserialisation advisories since 2025, all patched ^{vr⁴⁴²}. A firm-wide wrapper sits between each of those changes and the teams that need them ^{AJ}. Every security fix has to pass through the wrapper's own release, and every new capability waits for the wrapper to expose it ^{AJ}. The portable assets are elsewhere:

<https://raw.githubusercontent.com/google/adk-python/main/README.md> accessed 2026-10-07; A4-S003: PyPI JSON metadata: pydantic-ai (Python Package Index) <https://pypi.org/pypi/pydantic-ai/json> accessed 2026-10-07

⁴³⁸ Verified fact — A4-S039: LangGraph Persistence / Durable execution / Interrupts - Docs by LangChain <https://docs.langchain.com/oss/python/langgraph/durable-execution> accessed 2026-10-07 [search-tool extract]

⁴³⁹ Verified fact — A2-S078: Unlocking AI Search: Introducing Automated Embedding in MongoDB Vector Search <https://www.mongodb.com/company/blog/product-release-announcements/unlocking-ai-search-introducing-automated-embedding-in-mongodb-vector-search> accessed 2026-10-07 [search-tool extract]; A2-S133: Elastic 9.5: Columnar, VectorDB index mode & auto-calibration, and AI-driven alert triage <https://www.elastic.co/blog/whats-new-elastic-9-5-0> accessed 2026-10-07 [search-tool extract]; A2-S051: pinecone (Python SDK) - PyPI (PyPI / Pinecone Systems, Inc.) <https://pypi.org/project/pinecone/> accessed 2026-10-07

⁴⁴⁰ Verified fact — A4-S008: PyPI JSON metadata: agent-framework (Python Package Index) <https://pypi.org/pypi/agent-framework/json> accessed 2026-10-07; A4-S021: PyPI JSON metadata: autogen-agentchat (Python Package Index) <https://pypi.org/pypi/autogen-agentchat/json> accessed 2026-10-07; V1-S050: PyPI JSON metadata: agent-framework (1.0.0 uploaded 2026-04-02; latest 1.20.0) (Python Package Index) <https://pypi.org/pypi/agent-framework/json> accessed 2026-10-08

⁴⁴¹ Verified fact — A4-S114: Agent Development Kit (ADK) 2.0 README (GitHub) (Google) <https://raw.githubusercontent.com/google/adk-python/main/README.md> accessed 2026-10-07

⁴⁴² Verified fact — B-L3-S007: LangGraph security advisories (GitHub) and NVD entries (LangChain / GitHub / NIST NVD) <https://github.com/langchain-ai/langgraph/security> accessed 2026-10-08 [search-tool extract]

the workflow specification as a reviewed document, prompts under configuration control, tool contracts in the firm's repository, and evaluation suites ^{Rec}. With those in hand, a rewrite onto a different framework is bounded work, and the evaluation suite proves the result ^{AI}.

A related change helps. The hyperscalers now sell framework-agnostic agent runtimes; Amazon Bedrock AgentCore, for example, hosts open frameworks ^{vf443}. The runtime decision and the framework decision can be taken separately, which further reduces the case for a firm wrapper ^{AI}.

Where multi-vendor is necessary, and where it only adds complexity. Abstraction and multi-vendor redundancy are often argued together, and the review separates them ^{AI}. Five things genuinely need two:

- *Two unrelated model vendors*, qualified on the same suite. A single vendor's suspension or retirement stops the service: Anthropic's top tier, Claude Fable 5, was made unavailable from 12 June to 1 July 2026 ^{vf444}, and Gemini Flash versions live for months ^{vf445}. The review pairs any Claude route with GPT-6.1 Sol, Gemini 3.8 Flash or Mistral Medium 3.5 as a qualified alternative ^{AI}.
- *An open-weight model qualified on vLLM*, the credible stressed exit that PRA SS2/21 expects firms to plan for ^{vf446}.
- *Two red-team tools*, one independent of the model vendor under test; Promptfoo's announced owner is a model vendor ^{vf447}.
- *Two guardrail detectors* from different owners, because detectors are being absorbed by security vendors ^{vf448}.

⁴⁴³ Verified fact — A4-S116: Bedrock AgentCore SDK README (GitHub) (AWS) <https://raw.githubusercontent.com/aws/bedrock-agentcore-sdk-python/main/README.md> accessed 2026-10-07

⁴⁴⁴ Verified fact — V2-S004: Claude Fable - Anthropic <https://www.anthropic.com/claude/fable> accessed 2026-10-08

⁴⁴⁵ Verified fact — B-L1-S003: Gemini 3.7 Flash model page and related lifecycle pages (Gemini Enterprise Agent Platform) (Google Cloud) <https://docs.cloud.google.com/gemini-enterprise-agent-platform/models/gemini/3-7-flash> accessed 2026-10-08 [search-tool extract]

⁴⁴⁶ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see regulatory_facts.json); A8-S048: SS2/21 Outsourcing and third party risk management (and PS7/26, March 2026) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2021/ss221-march-21.pdf> accessed 2026-10-07 [search-tool extract]

⁴⁴⁷ Verified fact — A1-S024: OpenAI to acquire Promptfoo <https://openai.com/index/openai-to-acquire-promptfoo/> accessed 2026-10-07 [search-tool extract]

⁴⁴⁸ Verified fact — A7-S012: Check Point to Acquire Lakera, Redefining Security for the AI era (Check Point Software) <https://blog.checkpoint.com/security/check-point-to-acquire-lakera-redefining-security-for-the-ai-era/> accessed 2026-10-07 [search-tool extract]; A7-S014: Palo Alto Networks Completes Acquisition of Protect AI <https://www.paloaltonetworks.com/company/press/2025/palo-alto-networks-completes-acquisition-of-protect-ai> accessed 2026-10-07 [search-tool extract]; A6-S028: Guardrails AI Joins Harvey <https://www.harvey.ai/blog/guardrails->

- *Two gateway deployments* of the same product, because the gateway is a single point of failure by design ^{AJ}.

Five things only add complexity: two orchestration frameworks in one language estate, two vector stores for one corpus, two observability platforms of record, two identity providers for agents, and a second cloud's agent stack for the same use case ^{AJ}. Each doubles the work of securing, retaining and evidencing, with no resilience gain ^{AJ}.

What good looks like

The signal is **framework currency**: the number of days the pinned orchestration framework is behind its latest security fix ^{AJ}. It is the most direct measure of whether the framework layer is being kept, or merely kept running.

Measure it through dependency scanning in the security pipeline, recording for each workflow the pinned framework version, the date of the latest upstream security fix, and the gap between them ^{AJ}. Report the maximum across workflows, not the average, because one stale workflow is the exposure ^{AJ}.

The review's example target is the patch window, for example 30 days ^{AJ}. Treat that as a starting point set by the firm's own vulnerability-management policy, not as a benchmark. If a wrapper exists, measure the gap at the wrapper as well as the framework; the difference between the two is the cost the wrapper adds ^{AJ}. A companion check, from the caveat in the post, is a timed switch: move one component, such as the vector store behind the retrieval interface, to an alternative in a test environment, and record how long it took ^{Rec}.

In the worked example

Step 22: thin interfaces. Thin firm-owned interfaces where switching is likely (routing contract, telemetry, datasets, privacy, retrieval) and none around the agent framework. ^{AJ}

- **Now works:** Changing a vendor is a contained change. ^{AJ}
- **Must never:** No firm-wide wrapper around frameworks. ^{AJ}
- **Evidence added:** The interface inventory. ^{AJ}
- **Signal:** Framework currency: patches within an agreed window. ^{AJ}

Objections worth taking seriously

“Without a wrapper, every team will use the framework differently.” That is a standards problem, not an abstraction problem. A reference workflow, a code-review checklist and shared evaluation suites constrain usage without hiding the framework ^{AJ}. Standardising on one framework per language estate removes most of the variation on its own ^{Rec}.

“A rewrite is never as bounded as architects claim.” It is bounded only if the portable assets exist ^{AJ}. A workflow whose prompts are embedded in code, whose tools are framework-specific functions and which has no regression suite is expensive to move with or without a wrapper ^{AJ}. The timed switch in the caveat is the honest test; if the rewrite estimate cannot be demonstrated on one component, the claim should not be relied on ^{Rec}.

“Thin interfaces become thick ones over time.” They do, which is why each one needs an owner and a scope written down ^{AJ}. A retrieval interface that starts to add ranking, caching and query rewriting has become a product ^{AJ}. The review’s guidance on the memory and retrieval interfaces is deliberately minimal for that reason: a handful of operations, returning identifiers and scores ^{AJ}.

“Supervisors expect exit plans, and an abstraction layer shows we have one.” PRA SS2/21 expects documented exit plans that are tested, including for stressed exit ^{v449}. A layer is a design intention; a drill is evidence ^{AJ}. A gateway route moved to a second vendor by configuration, or an index rebuilt from source in a measured time, says more to a supervisor than any interface diagram ^{AJ}.

Questions for your team

- For each abstraction we maintain, what would switching cost without it? ^{Rec}
- How many days behind its latest security fix is each production framework?
- Are our prompts, tool contracts, workflow specifications and evaluations stored outside the framework?
- Where do we run two of something that only needs one?
- Where do we run one of something that needs two?
- Has any team ever timed a switch of one component?
- Who owns each thin interface, and what is out of its scope?

⁴⁴⁹ Verified fact — R-PRA-SS221: PRA SS2/21 ‘Outsourcing and third party risk management’ (revised by PS7/26, March 2026) (see `regulatory_facts.json`); A8-S048: SS2/21 Outsourcing and third party risk management (and PS7/26, March 2026) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2021/ss221-march-21.pdf> accessed 2026-10-07 [search-tool extract]

In one line

Abstract the small, likely-to-change interfaces, keep the framework unwrapped, and put portability into artefacts the firm owns.

23. Some lock-in is a good trade

Putting it together: lock-in by layer and control, from Post 23 of the series.

The post

Some lock-in is a good trade. The skill is knowing which.

Total avoidance is not a strategy. It produces the lowest common denominator everywhere, and the firm pays for portability it will never use. The better question, layer by layer, is what it would cost to leave, and whether that cost is acceptable, manageable with an abstraction, or unacceptable for a regulated workload. ^{AJ}

Acceptable: open-weight models the firm holds, open serving engines, open orchestration frameworks, a stateless reranker, a vector index that can be rebuilt from source. Leaving costs little. ^{AJ}

Manageable: a proprietary model behind the gateway with a qualified second vendor, a gateway product, the workforce identity provider, a managed agent runtime. Each is fine with the right interface and a rehearsed exit. ^{AJ}

Unacceptable: a single proprietary model vendor behind an important business service; evaluation datasets that exist only in a vendor console; prompts and change history held only in a vendor registry; credentials held in a third party's multi-tenant cloud; an evidence store held only by a vendor. Each turns an exit into a reconstruction. ^{AJ}

The pattern is consistent. Lock-in to a product is usually tolerable. Lock-in of the firm's own records, meaning its evidence, configuration, datasets and credentials, is not. ^{AJ}

The retrieval layer shows the signal: rebuild time from approved sources with a pinned embedding model, inside the exit-plan tolerance and tested twice a year. ^{AJ}

The leadership move is to classify each layer once, record it in the exit plan, and review it whenever ownership changes. ^{Rec}

The honest caveat: the classification moves. A tolerable dependency becomes a concern when its owner changes.

Choose dependencies deliberately. The accidental ones are expensive.

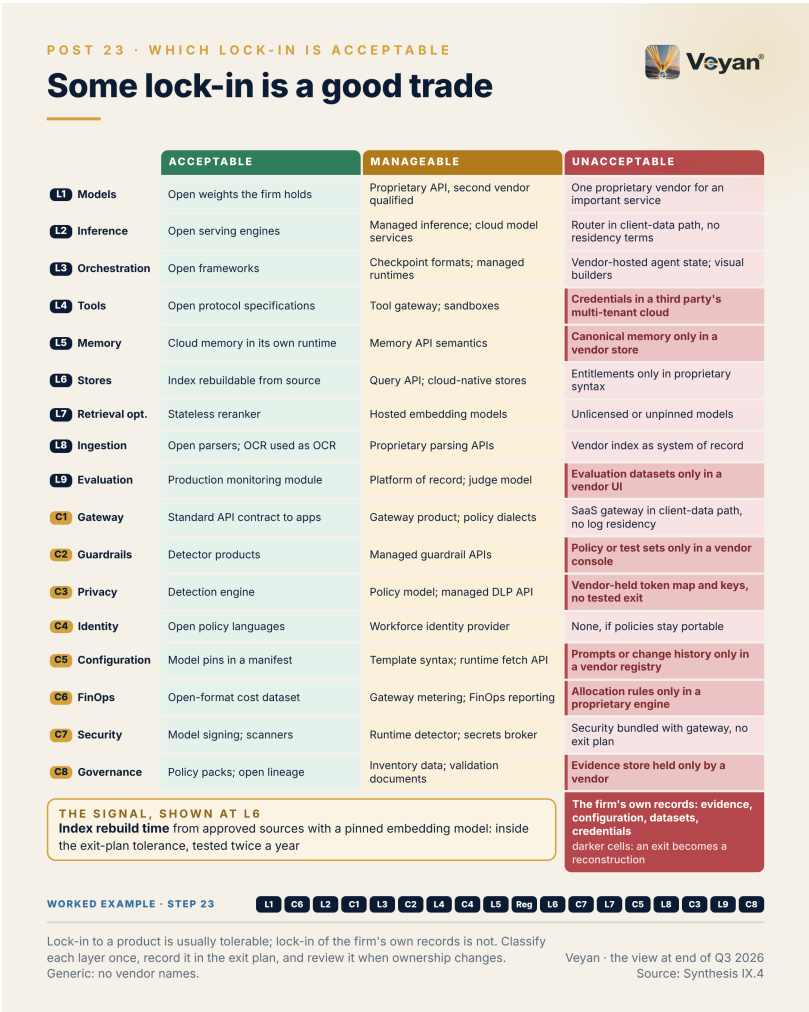


Figure 23. Lock-in to a product is usually tolerable; lock-in of the firm's own records is not. Classify each layer once, record it in the exit plan, and review it when ownership changes. Generic: no vendor names. ^{AJ}

Behind the post

Three categories, defined by the cost of leaving. The review consolidates every layer and control chapter's lock-in assessment into one table. "Acceptable" means the switching cost is low. "Manageable" means acceptable with a stated abstraction. "Unacceptable" means the arrangement should not be adopted for a regulated workload without that abstraction ^{AJ}. The categories describe arrangements, not products: the same product can sit in two columns depending on how it is used ^{AJ}. A vector index is acceptable if it can be rebuilt from source, and part of an unacceptable arrangement if the store also holds the only copy of the entitlement logic ^{AJ}.

Acceptable: where leaving costs little. The common thread is that the firm holds what it needs to run without the supplier ^{AJ}.

- *Models and serving (L1, L2).* Apache-2.0 or MIT open weights held by the firm, and open serving engines. vLLM and SGLang are Apache-2.0 and OpenAI-compatible ^{vr450}.
- *Orchestration (L3).* Open frameworks such as LangGraph, Microsoft Agent Framework, Google ADK and Pydantic AI ^{AJ}.
- *Tools (L4).* MCP and A2A as open specifications under the Agentic AI Foundation ^{vr451}. MCP originated at Anthropic; the independent alternative is OpenAPI-described tools behind the same gateway ^{AJ}.
- *Retrieval (L6, L7).* A vector index rebuildable from source, and a stateless reranker ^{AJ}.
- *Controls.* Open policy languages, model signing, and lineage on OpenLineage, an open specification under neutral governance ^{vr452}.

Manageable: fine with an interface and a rehearsed exit. These are the dependencies most firms will, and should, accept ^{AJ}.

- *A proprietary model behind the gateway with a qualified second vendor.* Switching becomes re-qualification rather than re-engineering, provided prompts and schemas are neutral ^{AJ}.

⁴⁵⁰ Verified fact — A4-S009: PyPI JSON metadata: vllm (Python Package Index) <https://pypi.org/pypi/vllm/json> accessed 2026-10-07; A4-S010: PyPI JSON metadata: sglang (Python Package Index) <https://pypi.org/pypi/sglang/json> accessed 2026-10-07

⁴⁵¹ Verified fact — A3-S018: MCP joins the Agentic AI Foundation (9 Dec 2025) (Model Context Protocol project (blog)) <https://blog.modelcontextprotocol.io/posts/2025-12-09-mcp-joins-agentic-ai-foundation/> accessed 2026-10-07; A3-S116: A2A joins AAIF's open agentic stack (17 Aug 2026) (Agentic AI Foundation (AAIF)) <https://aaif.io/blog/a2a-joins-aaif> accessed 2026-10-07 [search-tool extract]

⁴⁵² Verified fact — A7-S041: OpenLineage README (OpenLineage (LF AI & Data)) <https://raw.githubusercontent.com/OpenLineage/OpenLineage/main/README.md> accessed 2026-10-07

- *A gateway product.* Replaceable if routes, budgets and policies are documented as data. Proprietary policy dialects are the main switching effort ^{vi453}.
- *The workforce identity provider,* with agents following the humans' directory ^{AI}.
- *A managed agent runtime.* Proprietary APIs, but the runtimes host open frameworks ^{vi454}.
- *Hyperscaler services,* with concentration noted. The UK designated AWS, Google Cloud, Microsoft and Oracle as critical third parties ^{vi455}, and S3 Vectors, for example, is AWS-only ^{vi456}.

Unacceptable: where an exit becomes a reconstruction. Here the evidence is specific, and recent.

- *A single proprietary model vendor for an important business service.* Anthropic's top tier, Claude Fable 5, was made unavailable on 12 June 2026 and restored from 1 July 2026 ^{vi457}; a Gemini Flash version released on 13 August 2026 retires on 28 January 2027 ^{vi458}. The review therefore treats any Claude route as one leg of a portfolio, with GPT-6.1 Sol, Gemini 3.8 Flash or Mistral Medium 3.5 as the qualified alternative ^{AI}.
- *Vendor-hosted agent state and visual builders.* OpenAI's Agent Builder shuts down on 30 November 2026 ^{vi459}. The Mistral Agents API, OpenAI's hosted Agents API and Claude

⁴⁵³ Verified fact — A6-S053: AI gateway capabilities in Azure API Management (Microsoft Learn source, ms.date 29 May 2026) <https://raw.githubusercontent.com/MicrosoftDocs/azure-docs/main/articles/api-management/genai-gateway-capabilities.md> accessed 2026-10-07; A6-S024: Apigee AI solutions: gateway to enterprise-ready AI (Google Cloud) <https://cloud.google.com/solutions/apigee-ai> accessed 2026-10-07; A6-S016: Kong AI Gateway 2.0 Is Now GA — And It's Already Moving Faster (Kong Inc.) <https://konghq.com/blog/product-releases/kong-ai-gateway-2-0-ga> accessed 2026-10-07 [search-tool extract]

⁴⁵⁴ Verified fact — A4-S116: Bedrock AgentCore SDK README (GitHub) (AWS) <https://raw.githubusercontent.com/aws/bedrock-agentcore-sdk-python/main/README.md> accessed 2026-10-07

⁴⁵⁵ Verified fact — R-UK-CTP: UK Critical Third Parties regime (FSMA 2023 / FSMA 2000 s312L; PRA/FCA/BoE CTP rules) and the Critical Third Parties (Designation) Regulations 2026 (SI 2026/777) (see [regulatory_facts.json](#)); A8-S023: The Critical Third Parties (Designation) Regulations 2026 (SI 2026/777); BoE/FCA/HMT announcements (HM Treasury / legislation.gov.uk / Bank of England) <https://www.legislation.gov.uk/uksi/2026/777/made> accessed 2026-10-07 [search-tool extract]

⁴⁵⁶ Verified fact — A2-S092: Amazon S3 Vectors (feature page) (Amazon Web Services) <https://aws.amazon.com/s3/features/vectors/> accessed 2026-10-07 [search-tool extract]

⁴⁵⁷ Verified fact — V2-S004: Claude Fable - Anthropic <https://www.anthropic.com/claude/fable> accessed 2026-10-08

⁴⁵⁸ Verified fact — B-L1-S003: Gemini 3.7 Flash model page and related lifecycle pages (Gemini Enterprise Agent Platform) (Google Cloud) <https://docs.cloud.google.com/gemini-enterprise-agent-platform/models/gemini/3-7-flash> accessed 2026-10-08 [search-tool extract]

⁴⁵⁹ Verified fact — A4-S054: OpenAI Deprecations (Agent Builder) and Introducing AgentKit update <https://developers.openai.com/api/docs/deprecations> accessed 2026-10-07 [search-tool extract]; V1-S051: OpenAI API Deprecations (Agent Builder row); Introducing AgentKit (updated) <https://developers.openai.com/api/docs/deprecations> accessed 2026-10-08 [search-tool extract]

Managed Agents keep state and transcripts in the vendor's cloud by default ^{vf460}, for regulated workflows the review keeps state in the firm's estate, on an open framework's checkpointer ^{AI}.

- *Credentials in a third party's multi-tenant cloud.* Composio, a broker that holds users' OAuth tokens for third-party applications, disclosed a May 2026 incident in which, by its own account, about 0.3% of active connections leaked and 5,241 API keys were flagged as possibly exposed ^{vf461}.
- *A knowledge engine as the only home of curated knowledge.* Such engines compile data into vendor-specific artefacts queried in a proprietary language ^{vf462}.
- *The firm's records held only by a vendor:* evaluation datasets, prompts and change history, guardrail policy and test sets, a token map and its keys, cost-allocation rules, and the evidence store. The evidence store matters most, because it is the regulatory record and must meet retention duties such as Article 26 of the EU AI Act where it applies ^{vf463}.

The pattern. Read down the unacceptable column and most of its entries are not products at all. They are the firm's own records, held in someone else's system ^{AI}. In the figure, the darker cells mark them: credentials, canonical memory, evaluation datasets, guardrail policy, the privacy token map, prompts, allocation rules and evidence ^{AI}. That is the post's central claim. Lock-in to a product is usually tolerable, because a product can be replaced if the records survive. Lock-in of the records is not, because they cannot be re-created after the fact ^{AI}.

Why the classification moves. The caveat in the post is not a hedge. Ownership changes reclassify dependencies. Palo Alto Networks now owns both Portkey and Protect AI within Prisma AIRS ^{vf464}; for a firm using that gateway, a security platform

⁴⁶⁰ Verified fact — A4-S057: Build AI agents with the Mistral Agents API (and Agents & Conversations / Handoffs docs) (Mistral AI) <https://mistral.ai/news/agents-api/> accessed 2026-10-07 [search-tool extract]; A4-S055: OpenAI API Changelog (Agents API public beta, Sep 2026) and Introducing the Agents API <https://developers.openai.com/api/docs/changelog> accessed 2026-10-07 [search-tool extract]; A4-S123: API and data retention - Claude Platform Docs (Anthropic) <https://platform.claude.com/docs/en/build-with-claude/zero-data-retention> accessed 2026-10-07

⁴⁶¹ Verified fact — B-L4-S007: Composio May 2026 security incident update <https://composio.dev/blog/composio-may-2026-security-incident> accessed 2026-10-08 [search-tool extract]

⁴⁶² Verified fact — A2-S073: General Availability of Pinecone Nexus Proves Knowledge Drives Real Outcomes for Agentic AI <https://www.pinecone.io/newsroom/general-availability-of-pinecone-nexus-proves-knowledge-drives-real-outcomes-for-agentic-ai/> accessed 2026-10-07 [search-tool extract]

⁴⁶³ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see `regulatory_facts.json`); A8-S016: AI Act Article 26 Obligations of deployers; Article 25 Responsibilities along the AI value chain (European Commission AI Act Service Desk) <https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-26> accessed 2026-10-07 [search-tool extract]

⁴⁶⁴ Verified fact — A7-S014: Palo Alto Networks Completes Acquisition of Protect AI <https://www.paloaltonetworks.com/company/press/2025/palo-alto-networks-completes-acquisition-of-protect-ai>

bundled with the gateway without an exit plan becomes a live concern, which the review classes as unacceptable⁴⁶⁵. Stripe has agreed to acquire OpenRouter, with closing pending⁴⁶⁶. Dynatrace now owns Arize, and ClickHouse owns Langfuse⁴⁶⁶. Each event should trigger a review of the affected row, not a reflexive switch^{Rec}.

Why it matters to a regulated firm. PRA SS2/21 expects documented exit plans, tested, including for stressed exit⁴⁶⁷. DORA requires a register of information for ICT third-party arrangements, with exit strategies for critical or important functions⁴⁶⁸. From 18 March 2027, PS7/26 and FCA PS26/2 require notification of material third-party arrangements⁴⁶⁹. IOSCO flags concentration risk from reliance on a few AI technology providers⁴⁷⁰. The lock-in table is the working document behind all

accessed 2026-10-07 [search-tool extract]; A7-S016: Palo Alto Networks Inc Form 10-Q for quarter ended 30 April 2026 (Palo Alto Networks / US SEC) <https://www.sec.gov/Archives/edgar/data/0001327567/000132756726000015/panw-20260430.htm> accessed 2026-10-07 [search-tool extract]

⁴⁶⁵ Verified fact — V1-S059: Stripe agrees to acquire OpenRouter to help businesses optimize token routing and usage <https://stripe.com/newsroom/news/stripe-agrees-to-acquire-openrouter> accessed 2026-10-08 [search-tool extract]; V1-S060: Stripe to buy OpenRouter as fintech expands deeper into AI (and TechCrunch 16 Aug 2026 report) (CNBC / TechCrunch) <https://www.cnn.com/2026/08/19/stripe-openrouter-fintech-ai-model-marketplace-.html> accessed 2026-10-08 [search-tool extract]

⁴⁶⁶ Verified fact — A1-S045: Dynatrace Completes Acquisition of Arize, Extending AI Observability Across the Full Development Lifecycle (Dynatrace, Inc.) <https://ir.dynatrace.com/news-events/press-releases/detail/439/dynatrace-completes-acquisition-of-arize-extending-ai-observability-across-the-full-development-lifecycle> accessed 2026-10-07 [search-tool extract]; A1-S021: ClickHouse raises \$400M Series D, acquires Langfuse, launches Postgres (ClickHouse, Inc.) <https://clickhouse.com/blog/clickhouse-raises-400-million-series-d-acquires-langfuse-launches-postgres> accessed 2026-10-07 [search-tool extract]

⁴⁶⁷ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see regulatory_facts.json); A8-S048: SS2/21 Outsourcing and third party risk management (and PS7/26, March 2026) (Bank of England / PRA) <https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/supervisory-statement/2021/ss221-march-21.pdf> accessed 2026-10-07 [search-tool extract]

⁴⁶⁸ Verified fact — R-DORA: Regulation (EU) 2022/2554 Digital Operational Resilience Act (DORA) (see regulatory_facts.json); A8-S021: Digital Operational Resilience Act (DORA) pages and Rol reporting FAQ (ESMA / EBA / EIOPA) <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> accessed 2026-10-07 [search-tool extract]

⁴⁶⁹ Verified fact — R-PRA-SS221: PRA SS2/21 'Outsourcing and third party risk management' (revised by PS7/26, March 2026) (see regulatory_facts.json); R-FCA-SYSC8: FCA Handbook SYSC 8 (Outsourcing); FG16/5 'Guidance for firms outsourcing to the cloud and other third-party IT services'; PS26/2 operational incident and third-party reporting (see regulatory_facts.json); A8-S062: PS7/26 Operational incident and third-party reporting (PRA) and FCA PS26/2; revised SS2/21 (March 2026) (Bank of England / PRA; FCA) <https://www.bankofengland.co.uk/prudential-regulation/publication/2026/march/operational-incident-and-third-party-reporting-policy-statement> accessed 2026-10-07 [search-tool extract]

⁴⁷⁰ Verified fact — R-INTL-AI-ASSETMGMT: IOSCO Supervisory Toolkit for AI Use in Capital Markets (FR/02/2026) and ESMA Public Statement on AI and investment services (30 May 2024) (see regulatory_facts.json); A8-S058: IOSCO FR/02/2026 Supervisory Toolkit for AI Use in Capital Markets (May 2026) <https://www.iosco.org/library/pubdocs/pdf/IOSCOPD823.pdf> accessed 2026-10-07 [search-tool extract]

four: it says which exits are cheap, which need rehearsal, and which must be designed out before go-live ^{AJ}.

What good looks like

The post picks one signal to make the classification testable: **index rebuild time** at the retrieval layer ^{AJ}. It is defined as the time to rebuild the retrieval index from the source of truth, the approved corpus, with the pinned embedding model ^{AJ}.

Measure it with a timed dry run: take the approved-source register, re-parse or reuse the stored parses, re-embed with the pinned model version, rebuild the index in a clean environment, and run the retrieval regression set against it ^{AJ}. Record the elapsed time and the regression result together; a fast rebuild that fails the regression set has not passed ^{AJ}.

The review's starting target is a rebuild time inside the exit-plan tolerance, tested twice a year ^{AJ}. The tolerance is the firm's own, set by the important business service the index supports; it is a starting point, not a benchmark. The same drill proves three things at once: the backup works, the exit works, and the embedding pin is real ^{AJ}. Equivalent drills exist for other rows, such as the gateway's time to switch a route to a pre-qualified alternative ^{AJ}.

In the worked example

Step 23: exit tested. Lock-in accepted knowingly per component, with the firm's own records (evidence, configuration, datasets, credentials) kept out of any vendor's hands, and an index rebuild drilled. ^{AJ}

- **Now works:** The agent survives the loss of any single vendor. ^{AJ}
- **Must never:** No vendor-held store is ever the only copy of the firm's evidence. ^{AJ}
- **Evidence added:** Exit and rebuild drill results. ^{AJ}
- **Signal:** Index rebuild time, tested twice a year. ^{AJ}

Objections worth taking seriously

"Classifying seventeen layers and controls is a bureaucratic exercise." It is done once, and most rows take minutes, because the review's table provides a starting position for each ^{AJ}. The work that matters is the handful of rows that land in "unacceptable" for the firm's actual estate, and those are usually obvious once the question is asked ^{AJ}.

“Our proprietary vendor is more capable; a second vendor dilutes quality.” The second vendor does not need to be equal on every task; it needs to pass the same qualification suite for the routes it may serve ^{AJ}. Capability differences then become a measured trade-off rather than an assumed one. A single-vendor arrangement behind an important business service remains the review’s clearest unacceptable case, whichever vendor it is ^{AJ}.

“Keeping canonical copies of our records duplicates what the vendor stores.” It does, deliberately. The copy in source control or a firm archive is the canonical one; the vendor’s tool becomes a cache or a convenience ^{AJ}. Free tiers of evaluation platforms keep data for between 15 and 60 days ^{VF}⁴⁷¹, so evidence held only there may simply no longer exist when it is needed ^{AJ}.

“Open source is acceptable by definition.” Not quite. The acceptable column assumes a licence the firm has read. Arize Phoenix is under ELv2, a source-available licence ^{VF}⁴⁷²; Weaviate is moving to open core ^{VF}⁴⁷³; Jina’s weights are CC-BY-NC-4.0 ^{VF}⁴⁷⁴. An open component lands in the acceptable column only after licence review, and Weaviate’s case shows that a licence can change after adoption ^{AJ}.

Questions for your team

- Have we classified each layer and control as acceptable, manageable or unacceptable, and recorded it in the exit plan? ^{REC}
- Which of our records (evidence, prompts, datasets, credentials, policies) exist only in a vendor’s system?
- When did we last time a rebuild of our retrieval index from source?
- Which important business service depends on a single proprietary model vendor?
- Which suppliers in our stack have changed owner this year, and did anyone review the affected rows?
- Where do we hold agent state or credentials outside our own estate?

⁴⁷¹ Verified fact — A1-S047: Arize AX Pricing: AI agent observability and evaluation (Arize AI) <https://arize.com/pricing/> accessed 2026-10-07 [search-tool extract]; A1-S031: Pricing - Langfuse (Langfuse (ClickHouse)) <https://langfuse.com/pricing> accessed 2026-10-07 [search-tool extract]; A1-S123: Comet pricing (Opik plans) (Comet ML, Inc.) <https://www.comet.com/site/pricing/> accessed 2026-10-07 [search-tool extract]

⁴⁷² Verified fact — A1-S048: Arize Phoenix LICENSE (Elastic License 2.0) (Arize AI (GitHub)) <https://raw.githubusercontent.com/Arize-ai/phoenix/main/LICENSE> accessed 2026-10-07

⁴⁷³ Verified fact — A2-S115: weaviate/weaviate (README and licence files; PR #13360) (Weaviate) <https://github.com/weaviate/weaviate> accessed 2026-10-07 [search-tool extract]; V1-S070: weaviate/weaviate README (Community vs Enterprise Edition), releases, PR #13360, PR #12942 (Weaviate (GitHub)) <https://github.com/weaviate/weaviate> accessed 2026-10-08 [search-tool extract]

⁴⁷⁴ Verified fact — A2-S024: Legal Information - Jina AI (Jina AI (Elastic)) <https://jina.ai/legal/> accessed 2026-10-07 [search-tool extract]

In one line

Accept lock-in to products deliberately, and never accept lock-in of the firm's own records.

24. Select the control plane first

Putting it together: the recommended stack, and what to leave out, from Post 24 of the series.

The post

Twelve weeks ago this series started from a popular diagram of the AI stack. On this review, 39 of its 80 product tiles were out of date. The diagram was a catalogue. The enterprise problem is a control system. ^{AJ}

So here is the selection, on one page.

First, a firm-owned control and evidence plane: one gateway of record for every model, tool and agent call; evaluation and observability from day one; an evidence store the firm owns; one privacy service; agent identities in the workforce directory; source control as the configuration of record. Beneath it, replaceable components: open document parsing inside a built envelope, vectors in a database the firm already runs, read-only tools behind a governed gateway, deterministic workflows on a durable engine, the primary cloud's in-region model service with an open-weight exit route, and a two-vendor model portfolio. ^{Rec}

And what to deliberately not select: archived or deprecated products, unverifiable vendors, a third-party broker holding client tokens, licence-blocked weights, autonomous agents with write tools, memory before it is needed, and any vendor-held store as the only copy of the firm's evidence. ^{Rec}

The lesson about leading this is quieter than the architecture. The products will change again within months. What lasts is the operating model: who owns the evidence, who may approve, and what waits. The leadership move is to fund that plane before any product. ^{AJ}

Part III: Putting it together

The signal to keep in front of executives is the human-intervention rate: how often, and how much, reviewers edit what the system drafts. Supervisors already ask for it. ^{AJ V⁴⁷⁵}

The honest caveat: this is a view as of autumn 2026, drawn from public evidence, and much of it will need re-checking within months. ^{AJ}

Select the plane first. Everything beneath it is allowed to change.

⁴⁷⁵ Verified fact — R-INTL-AI-ASSETMGMT: IOSCO Supervisory Toolkit for AI Use in Capital Markets (FR/02/2026) and ESMA Public Statement on AI and investment services (30 May 2024) (see `regulatory_facts.json`); A8-S058: IOSCO FR/02/2026 Supervisory Toolkit for AI Use in Capital Markets (May 2026) <https://www.iosco.org/library/pubdocs/pdf/IOSCOPD823.pdf> accessed 2026-10-07 [search-tool extract]



Figure 24. A firm-owned control and evidence plane first, replaceable components beneath it, and a short list of what to leave out. Illustrative: categories, no vendor names. ^{AJ}

Behind the post

What changed since the popular stack diagram. The review began from a widely shared diagram that draws nine layers and 80 product tiles. Its what-changed table,

built from primary research and corrected by two adversarial verifiers, flags 39 of the 80 tiles as out of date: 9 acquired, 9 mispositioned, 8 renamed, 8 with a wrong version label, 6 not publicly verifiable, 4 duplicated, 3 superseded and 2 deprecated, with some tiles carrying more than one flag ^{AJ}. The count is less important than what it shows. A catalogue of products dates within months; the diagram had no place at all for the gateway, identity, configuration, cost or evidence controls where a regulated firm actually manages risk ^{AJ}.

The answer, in one sentence. Build a firm-owned control and evidence plane first; run regulated work as deterministic workflows with one bounded model step and a human approval gate; consume models as a two-vendor portfolio through the primary cloud's in-region model service; and treat every product beneath that plane as a replaceable component ^{Rec}.

The plane, decision by decision. The review reduces the architecture to twelve decisions. In the house order of layers then controls, the ones that define the plane are these ^{Rec}:

- *Evaluation and observability from day one (L9):* a firm-owned OpenTelemetry Collector, evaluation datasets in source control, one platform of record, and two red-team tools, one independent of the model vendor under test ^{Rec}.
- *One gateway of record (C1)* for all production model, tool and agent traffic, deployed twice, in region, failing closed, with pinned and signed builds. It is what makes a model exit a configuration change ^{Rec}.
- *One privacy service (C3)* called at six enforcement points: ingestion, prompt, tool results, output, memory writes and trace export ^{Rec}.
- *Every agent a registered identity (C4)* with a sponsor, acting on behalf of the requesting human through short-lived tokens, with deny-by-default policy for every tool call ^{Rec}.
- *Source control as the configuration of record (C5):* prompts, model pins, retrieval versions, tool lists and guardrail policy released as one manifest, with a second approver and an evaluation gate ^{Rec}.
- *Capability separation (C7):* no agent holds untrusted input, sensitive data and an outbound channel at once ^{Rec}.
- *A firm-owned evidence store (C8),* immutable and keyed by trace ID; vendor tools write to it, never instead of it ^{Rec}.

The components beneath it. On the evidence at the end of Q3 2026, the review's cloud-neutral core is: a hardened LiteLLM or Kong gateway; Langfuse or MLflow with the firm's own Collector; Presidio behind a privacy-service API; agent identities in the workforce identity provider with OPA; Git as the configuration of record; Docling and Unstructured inside a built ingestion envelope; Sentence Transformers and pgvector; read-only MCP tools behind a governed gateway, with OpenAPI tools

as the independent alternative to that Anthropic-originated protocol; LangGraph on Temporal; the primary cloud's in-region model service with vLLM as the exit route; and a two-vendor model portfolio drawn from OpenAI, Anthropic, Mistral and, on Google Cloud, Gemini, plus Gemma 4 or Mistral self-hosted ^{Rec}. Wherever Claude is chosen, GPT-6.1 Sol, Gemini 3.8 Flash or Mistral Medium 3.5 is the named alternative, and Claude is consumed only through a hyperscaler UK or EU route with a qualified non-Anthropic fallback ^{AI}. Each of these is replaceable; the review's tiers say which is the default today and under what condition ^{AI}. Across 140 scored records the review places 58 as Strategic, 67 Tactical and 13 Experimental, with 2 unscored, and a Strategic tier always travels with its condition ^{AI}.

A disclosure belongs here. The review behind this book was drafted with an AI model made by Anthropic. Anthropic's tier in the review was set by the author on neutral-rubric scores, not by the drafting tool, and an independent alternative is named wherever a Claude model, MCP or Agent Skills appears ^{AI}.

What not to select, and why only on evidence. The avoid list is deliberately narrow. A product appears on it only for one of four reasons: deprecated or archived, unverifiable, an unresolved security incident affecting client data, or a licence or terms blocker ^{AI}. Each category in the post has a concrete instance:

- *Archived or deprecated:* Hugging Face archived its TGI repository on 21 March 2026 ^{vf476}, and OpenAI's Agent Builder shuts down on 30 November 2026 ^{vf477}.
- *Unverifiable:* two vendors on the popular diagram, EthicalAgents and Ragoos, could not be found and were removed ^{vf478}.
- *A third-party broker holding client tokens:* Composio's managed cloud, after its May 2026 incident in which connected-account tokens and API keys were exposed ^{vf479}.

⁴⁷⁶ Verified fact — V1-S054: GitHub repository metadata: huggingface/text-generation-inference (archived) (GitHub (via GitHub MCP search_repositories)) <https://api.github.com/repos/huggingface/text-generation-inference> accessed 2026-10-08 [search-tool extract]

⁴⁷⁷ Verified fact — A4-S054: OpenAI Deprecations (Agent Builder) and Introducing AgentKit update <https://developers.openai.com/api/docs/deprecations> accessed 2026-10-07 [search-tool extract]; V1-S051: OpenAI API Deprecations (Agent Builder row); Introducing AgentKit (updated) <https://developers.openai.com/api/docs/deprecations> accessed 2026-10-08 [search-tool extract]

⁴⁷⁸ Verified fact — A2-S079: Privacy Policy - Ethical Agentic AI (Ethical Agentic AI Inc.) <https://www.ethicalagentic.ai/privacy-policy> accessed 2026-10-07 [search-tool extract]; A2-S080: Ragie <https://www.ragie.ai/> accessed 2026-10-07 [search-tool extract]

⁴⁷⁹ Verified fact — B-L4-S007: Composio May 2026 security incident update <https://composio.dev/blog/composio-may-2026-security-incident> accessed 2026-10-08 [search-tool extract]; A3-S119: Composio: Two questions every security review asks us (and MCP gateway/governance pages) <https://composio.dev/blog/two-questions-every-security-review-asks-us> accessed 2026-10-07 [search-tool extract]

Part III: Putting it together

- *Licence-blocked weights*: Jina's weights are CC-BY-NC-4.0, so self-hosting them without a commercial licence is blocked ^{vf480}.
- *Autonomous agents with write tools, and memory before it is needed*: both sit on the review's "do not build yet" list for the lead stack, because guardrails cannot fix a workflow that should never have been autonomous, and memory is a regulated record class best built last ^{aj}.
- *A vendor-held store as the only copy of the evidence*: the evidence store is the regulatory record and must meet retention duties, such as Article 26 of the EU AI Act where it applies ^{vf481}.

Everything else that is not recommended is Tactical, Experimental or on a monitor list, not banned ^{aj}. Two routes sit on the monitor list by the author's decision rather than the avoid list: Chinese-origin vendors' own hosted APIs for client data, which the route rule still keeps out of client-data paths, and billing intermediation through a gateway or router ^{aj}.

Why the operating model outlasts the products. The review's evidence is a record of change. Dynatrace completed its acquisition of Arize on 1 October 2026 ^{w482}; ClickHouse acquired Langfuse ^{w483}; Stripe agreed to acquire OpenRouter, with closing pending ^{w484}. Model versions retire within months ^{w485}. The regulatory anchors moved too: SR 26-2 superseded SR 11-7 on 17 April 2026 and places

⁴⁸⁰ Verified fact — A2-S024: Legal Information - Jina AI (Jina AI (Elastic)) <https://jina.ai/legal/> accessed 2026-10-07 [search-tool extract]

⁴⁸¹ Verified fact — R-EUAIA: Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI) (see `regulatory_facts.json`); A8-S016: AI Act Article 26 Obligations of deployers; Article 25 Responsibilities along the AI value chain (European Commission AI Act Service Desk) <https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-26> accessed 2026-10-07 [search-tool extract]

⁴⁸² Verified fact — A1-S045: Dynatrace Completes Acquisition of Arize, Extending AI Observability Across the Full Development Lifecycle (Dynatrace, Inc.) <https://ir.dynatrace.com/news-events/press-releases/detail/439/dynatrace-completes-acquisition-of-arize-extending-ai-observability-across-the-full-development-lifecycle> accessed 2026-10-07 [search-tool extract]; V1-S005: Dynatrace Completes Acquisition of Arize (IR press release) (Dynatrace, Inc.) <https://ir.dynatrace.com/news-events/press-releases/detail/439/dynatrace-completes-acquisition-of-arize-extending-ai-observability-across-the-full-development-lifecycle> accessed 2026-10-08 [search-tool extract]

⁴⁸³ Verified fact — A1-S021: ClickHouse raises \$400M Series D, acquires Langfuse, launches Postgres (ClickHouse, Inc.) <https://clickhouse.com/blog/clickhouse-raises-400-million-series-d-acquires-langfuse-launches-postgres> accessed 2026-10-07 [search-tool extract]; V2-S041: ClickHouse welcomes Langfuse (with `langfuse.com` 'Langfuse joins ClickHouse', Orrick) <https://clickhouse.com/blog/clickhouse-acquires-langfuse-open-source-llm-observability> accessed 2026-10-08 [search-tool extract]

⁴⁸⁴ Verified fact — V1-S059: Stripe agrees to acquire OpenRouter to help businesses optimize token routing and usage <https://stripe.com/newsroom/news/stripe-agrees-to-acquire-openrouter> accessed 2026-10-08 [search-tool extract]; V1-S060: Stripe to buy OpenRouter as fintech expands deeper into AI (and TechCrunch 16 Aug 2026 report) (CNBC / TechCrunch) <https://www.cnbc.com/2026/08/19/stripe-openrouter-fintech-ai-model-marketplace-.html> accessed 2026-10-08 [search-tool extract]

generative and agentic AI outside its scope⁴⁸⁶, which leaves PRA SS1/23 and the EU AI Act as the operative model-risk anchors and obliges the firm to write its own GenAI standard^{AI}. A product choice made today will be revisited; the answers to “who owns the evidence, who may approve, and what waits” should not need to be^{AI}. That is why the roadmap’s first phase is governance, not technology: a GenAI model-risk standard, an accountable senior manager, an inventory schema and Git as the configuration of record^{Rec}.

What good looks like

The signal for executives is the **human-intervention rate**: the share of outputs edited or rejected by the approver, together with the size of the edits^{AI}. IOSCO’s supervisory toolkit for asset managers lists the level and frequency of human intervention in AI-driven investment processes among its indicators⁴⁸⁷.

Measure it from the approval step itself. Capture each reviewer’s edits as a diff on the trace, with an edit-size score and a reason code, and report monthly by use case^{AI}. Recurring edit types should become evaluation cases or proposed style rules, approved through the configuration process^{Rec}.

The starting target is not a number. The review’s guidance is to track the rate, expect a falling trend as the system and its rules mature, and review every spike^{AI}. Treat that as a starting point, not a benchmark. A rate that falls because the drafts improve is good news; a rate that falls because reviewers stop reading is not, which is why edit size and reason codes travel with it^{AI}.

⁴⁸⁵ Verified fact — B-L1-S003: Gemini 3.7 Flash model page and related lifecycle pages (Gemini Enterprise Agent Platform) (Google Cloud) <https://docs.cloud.google.com/gemini-enterprise-agent-platform/models/gemini/3-7-flash> accessed 2026-10-08 [search-tool extract]

⁴⁸⁶ Verified fact — R-US-MRM: Revised Guidance on Model Risk Management: Federal Reserve SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 (supersedes SR 11-7 and SR 21-8) (see [regulatory_facts.json](#)); A8-S001: SR 26-2: Revised Guidance on Model Risk Management (17 April 2026) (Board of Governors of the Federal Reserve System) <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> accessed 2026-10-07 [search-tool extract]; A8-S002: OCC Bulletin 2026-13 Model Risk Management: Revised Guidance (attachment bulletin-2026-13a.pdf) (Office of the Comptroller of the Currency) <https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html> accessed 2026-10-07 [search-tool extract]

⁴⁸⁷ Verified fact — R-INTL-AI-ASSETMGMT: IOSCO Supervisory Toolkit for AI Use in Capital Markets (FR/02/2026) and ESMA Public Statement on AI and investment services (30 May 2024) (see [regulatory_facts.json](#)); A8-S058: IOSCO FR/02/2026 Supervisory Toolkit for AI Use in Capital Markets (May 2026) <https://www.iosco.org/library/pubdocs/pdf/IOSCOPD823.pdf> accessed 2026-10-07 [search-tool extract]

In the worked example

Step 24: signed off. The final selection: a firm-owned control and evidence plane, with replaceable components beneath it, and a published list of what was deliberately not selected. ^{AJ}

- **Now works:** The worked example is complete, governed and ready to run. ^{AJ}
- **Must never:** What was not selected stays off until the evidence changes. ^{AJ}
- **Evidence added:** The signed-off architecture and its 'not selected' list. ^{AJ}
- **Signal:** Human-intervention rate, tracked and falling. ^{AJ}

Objections worth taking seriously

“Funding a control plane first delays visible value.” It delays the second use case less than it delays the first ^{AJ}. The controls built for one regulated workflow (gateway, identity, evaluation, evidence) are the ones every later workflow reuses, and the first workflow cannot go live under the firm’s own model-risk standard without them ^{AJ}. Chapter 20 sets out the minimum version that ships one use case.

“Naming products contradicts the claim that products do not matter.” Products matter; they are simply not the architecture ^{AJ}. The review names a default for each layer because teams need a starting point, and it attaches a condition to each Strategic tier because the default changes with the firm’s cloud, estate and evidence ^{AJ}. The plane is what makes changing a default cheap.

“A low human-intervention rate could mean complacency, not quality.” That is the strongest objection, and the reason the signal is paired with other evidence. Edit size and reason codes show what reviewers change; evaluation results show whether unedited drafts were in fact correct; and the numeric-faithfulness check catches the error that matters most regardless of what the reviewer does ^{AJ}. No single signal should be read alone ^{AJ}.

“This will be out of date within months.” Parts of it will be, as the post’s caveat says. The component choices carry review dates and a monitor list; the plane and the operating model are designed to survive those changes ^{AJ}. A quarterly refresh that re-checks the monitor list, ownership changes and model retirements is the practical answer, and it costs far less than re-architecting ^{Rec}.

Questions for your team

- Who owns our evidence store, and would it survive the loss of any one vendor? ^{Rec}
- Is every production model, tool and agent call routed through one gateway of record?

- Which of our current products would fail the review's four avoid criteria?
- Where do we let an agent hold untrusted input, sensitive data and an outbound channel at once?
- Do we measure the human-intervention rate, with edit size and reason codes?
- Have we written our own GenAI model-risk standard, now that SR 11-7 no longer frames the question?
- What is on our "what waits" list, and who may change it?

In one line

Select the control and evidence plane first, and let every product beneath it change.

Where this leaves you

The argument of this book has one shape, repeated at every layer. The nine layers, from foundation models to evaluation, are where products live, and products change: they are acquired, renamed, retired or overtaken, sometimes within a single quarter ^{AI}. The eight controls, from the gateway to the evidence store, are where a regulated firm manages risk, and they belong to the firm ^{AI}. Own the control plane; rent the components.

Owning the plane does not mean building everything. Chapter 21 showed that the firm builds little: its control statements, its evidence and its domain logic, such as the numeric check that no vendor sells ^{AI}. It does mean keeping a thin interface in front of what it rents, without wrapping what does not need wrapping (Chapter 22), and accepting lock-in to products while refusing lock-in of its own records (Chapter 23) ^{AI}.

Nor does it mean building the whole plane at once. Chapter 20 showed that one use case, run end to end with every control present and a published "not yet" list, is enough to start, and that the controls built for it are reused by every use case that follows ^{AI}. Chapter 19 showed what that looks like in practice: a list of what the system must never do, each item enforced by a named component ^{AI}.

The signals in each chapter are how a leader knows the plane is real: gateway coverage, configuration coverage, framework currency, rebuild time, evidence-pack completeness and the human-intervention rate ^{AI}. None of them depends on which vendor wins the next quarter. That is the point. A firm that owns its control plane can change any product beneath it on evidence, at a time of its choosing, and show a supervisor exactly what changed ^{AI}.

Appendix A: The worked example, step by step

An agent drafts the monthly Brinson-style performance-attribution commentary for a generic multi-asset fund; a portfolio manager approves every draft. The series teaches the stack in layer order; the real build order (evaluation and governance first) is set out at step 20 ^{AJ}.

Step	Stage	What it adds	Must never
0	The brief	The use case and its boundary: the agent writes words around numbers it is given; it never produces a number, and a named portfolio manager approves every draft.	No figure may come from a model.
1	Models	Four model roles, each pinned to an exact version: a primary drafting model, a fallback from a different vendor, a small classifier for reviewer edits, and a self-hosted open-weight model for anything touching unmasked client data.	No alias or preview model, and no model ever generates, rounds or corrects a figure.
2	Cost	A run ID on every call, tagged with use case and fund, joined to the trace; a	A runaway loop fails the run instead of the budget.

Appendix A: The worked example, step by step

Step	Stage	What it adds	Must never
		monthly budget set from two month-end cycles; a per-run ceiling on model calls and tokens.	
3	Model access	Drafting through the primary cloud's in-region model service, with capacity sized for the month-end peak and an open-weight route kept ready as the stressed exit.	No router or provider that cannot guarantee region and retention.
4	Gateway	One gateway route, attribution-commentary-draft: the workflow calls the route with its own identity and never holds a provider key; residency, fallback, budgets and inline guards live on the route.	If both models are unavailable, the route fails closed and the analyst is told the draft is delayed.
5	Workflow	A pinned workflow graph: authorise, fetch the attribution snapshot, retrieve style and prior commentary, one drafting step, an evaluation gate, a human approval interrupt, then release by a separate service.	Autonomy budget of one: the model drafts, but never chooses tools or order.
6	Guardrails	A deterministic numeric comparator on every draft, injection screening of retrieved text, a PII	Guardrails back up the design; they never license more autonomy.

Step	Stage	What it adds	Must never
7	Tools	check on output and denied topics (forecasts, advice). Four tools behind the tool gateway: read-only attribution results with a snapshot hash, read-only fund reference data, a sandboxed calculator for derived figures, and retrieval of approved commentary.	No write, publish or e-mail tool exists, so none can be misused.
8	Identity	A registered agent identity with a named sponsor; it acts on behalf of the analyst with a read-only, minutes-long token; a different portfolio manager approves with step-up authentication.	The agent holds no standing credentials and can never approve.
9	Memory	Deliberately little: a versioned glossary and style rules per fund, changed only by an approved pull request, recalled by version hash.	The agent may propose memory, never write it; no client identifiers in memory.
10	Regulation	The regulatory mapping: not an Annex III use; transparency and literacy duties; model vendors as material outsourcing with exit plans; the agent recorded in the model inventory.	Never assume a vendor's oversight covers the firm's duties.
11	Retrieval store	One store already run by the firm, with	No unfiltered fallback: no

Appendix A: The worked example, step by step

Step	Stage	What it adds	Must never
		three collections (prior commentaries, style guide, approved market notes) and fund-level entitlement filters applied inside the search.	permitted result means an empty result.
12	AI security	Defence in depth against a poisoned market note: nothing to hijack, numbers that cannot be rewritten, retrieved text marked as data, chunk screening, canary documents and human approval.	Untrusted input, sensitive data and an outbound channel never meet in one agent.
13	Retrieval quality	Two-stage retrieval of comparable past commentary (embed and rerank), with both model versions pinned and tagged on every vector.	A mixed-version index is refused; migration runs as a shadow index behind a regression gate.
14	Configuration	A release manifest per monthly cycle (prompt set, model pins, retrieval settings, tool list, guard policy, eval thresholds), approved by pull request with a second approver and gated by the eval suite.	No production prompt is ever edited in a console.
15	Ingestion	Three corpora ingested under a control envelope: dual-parsed factsheet tables reconciled to the	No envelope, no index; parsed numbers are context only, never figures.

Appendix A: The worked example, step by step

Step	Stage	What it adds	Must never
16	Privacy	engine, prior commentaries with their permissions, and market notes from the approved register only. One privacy service called at six points: client names and mandates tokenised before any model call, detected again in output, re-identified only for the reviewing manager.	A clear-text identifier not in the approved inputs blocks the draft.
17	Evaluation	The evaluation plane: numeric faithfulness (blocking), groundedness, style, trajectory, and a regression suite of 24 to 36 months of approved commentaries, all on one firm-owned telemetry spine.	Any numeric miss blocks; no human is asked to catch what code can check.
18	Governance	The inventory entry for the use case and an evidence pack per approved commentary, keyed by one trace ID, written to an immutable archive.	The governed unit is the use case; the model is a vendor component inside it.
19	Assembled	All eighteen pieces assembled into one request trace, with a 'may / must never' list in which every 'never' names the component that enforces it.	Every 'must never' has an enforcing component, not a policy sentence.

Appendix A: The worked example, step by step

Step	Stage	What it adds	Must never
20	Minimum go-live	The build order for real: governance and evaluation first, then the gateway, retrieval, the workflow and one read-only tool; memory and everything on the 'not yet' list waits for evidence.	Nothing is built before the evidence says it is needed.
21	Build or buy	A build, hybrid or buy decision for each of the seventeen components: build the evidence store, configuration and tools; buy models, serving and security tooling; hybrid elsewhere.	Fine-tuning stays off the list.
22	Thin interfaces	Thin firm-owned interfaces where switching is likely (routing contract, telemetry, datasets, privacy, retrieval) and none around the agent framework.	No firm-wide wrapper around frameworks.
23	Exit tested	Lock-in accepted knowingly per component, with the firm's own records (evidence, configuration, datasets, credentials) kept out of any vendor's hands, and an index rebuild drilled.	No vendor-held store is ever the only copy of the firm's evidence.
24	Signed off	The final selection: a firm-owned control and evidence plane,	What was not selected stays off until the evidence

Appendix A: The worked example, step by step

Step	Stage	What it adds	Must never
		with replaceable components beneath it, and a published list of what was deliberately not selected.	changes.

Appendix B: The book at a glance

Chapter	In one line
Introduction: The enterprise GenAI stack, layer by layer	The products will keep changing; build the control plane that lets you change them safely.
1. Treat foundation models as a portfolio, not a bet	Capability will change every quarter, so build the ability to change models safely, and treat it as the asset.
2. Cost per task, not cost per token	What a task costs is decided in the design, and the invoice only reports the answer.
3. Self-hosting is a capacity decision, not just cost	The cheapest token is worth nothing if it arrives late or is processed in the wrong country.
4. The boring component that makes exit real	Neutrality is a design property: build it into the gateway, then rehearse the exit until it is routine.
5. Most enterprise “agents” should be workflows	Decide how much autonomy a process deserves before choosing a framework, and the answer for most regulated work will be zero or one.
6. Guardrails cannot fix the wrong autonomy	Decide what the system may do first; guardrails then catch what slips through, and only if they fail closed and you own their tests.
7. Easy tool connections make governance the architecture	Connecting a tool now takes minutes; governing what it may do, for whom, is the part of the architecture that has to be designed.
8. “Who did this?” needs an answer for agents	Give every agent a name, act on the requester’s behalf with no more than the requester could do, and record both, because accountability does not automate itself.
9. Build memory last, on purpose	Memory is the one layer that writes its own inputs, so build it last, gate every write, and engineer the forgetting before you switch it

Appendix B: The book at a glance

Chapter	In one line
	on.
10. Multi-vendor AI is becoming close to a requirement	Regulation rarely names the vendors you must use, but it will ask you to prove you can leave one, so build that proof before you need it.
11. You may not need a vector database	Choose the store you already run until your own filtered load test gives you a reason not to, and make sure you could rebuild it tomorrow.
12. Every retrieved document is untrusted input	Design so that a successful injection has nothing to call, and treat every detector as a replaceable second line.
13. Retrieval quality is a two-stage problem	Measure each retrieval stage on its own number, and treat the embedding version as production configuration that changes only behind a gate.
14. A prompt change is a production change	Treat every setting that can change what a client reads as production configuration, with one record, a second approver and a rehearsed way back.
15. Many “hallucinations” start in a table parser	Treat the parser as a replaceable cartridge, build the envelope around it, and never let a parsed number become the authority.
16. One client identifier, seven copies to protect	Write the privacy policy once, enforce it wherever data moves, and give the model placeholders rather than people.
17. Evaluation is a plane, not the last box	Build the evaluation harness first, own the evidence it produces, and let the products on top come and go.
18. Your eval suite is your validation evidence	Govern the use case, pin every version, and keep the evidence yourself, because that is what any future rule will ask to see.
19. What the agent must never do matters more	Decide what the system must never do, name the component that stops it, and keep the evidence that it did not.
20. The most valuable page: “do not build yet”	Start with the full regulated design for one use case, publish what waits, and let evidence, not enthusiasm, move items off the list.
21. Build where you differentiate, buy where	Build the small things that are your control

Chapter	In one line
you maintain	statement, evidence and domain logic, and buy the rest behind an interface you own.
22. Portability lives in the artefacts you own	Abstract the small, likely-to-change interfaces, keep the framework unwrapped, and put portability into artefacts the firm owns.
23. Some lock-in is a good trade	Accept lock-in to products deliberately, and never accept lock-in of the firm's own records.
24. Select the control plane first	Select the control and evidence plane first, and let every product beneath it change.

Appendix C: Glossary

Term	Meaning in this book
Agent	Software in which a model chooses some of its own steps or tool calls. In this book, most enterprise “agents” should be workflows with one bounded model step.
Agentic workflow	A fixed sequence of steps, decided in advance, in which a model performs one or more bounded steps.
AI gateway	The single firm-controlled point through which every model, tool and agent call passes: routing, fallback, budgets, policy and logging (control C1).
Attribution commentary	The written explanation of why a fund performed as it did against its benchmark, usually in terms of allocation, selection and currency effects.
Autonomy budget	How many decisions a model may make on its own in a given use case. The worked example’s budget is one: drafting.
Control plane	The firm-owned controls around the stack (C1 to C8): gateway, guardrails, privacy, identity, configuration, cost, security and governance.
Data loss prevention (DLP)	Detecting and blocking sensitive data, such as client identifiers, before it reaches a model, a log or an outside party.
Deterministic check	A test written in code that gives the same answer every time, such as comparing every figure in a draft with the source system.
Embedding	A numerical representation of text used to find passages with similar meaning.
Evaluation suite	The versioned set of test cases, checks and thresholds a GenAI system must pass before release, and keep passing in production.

Appendix C: Glossary

Term	Meaning in this book
Evidence pack	The record kept for each output: prompt and model versions, data snapshot, tool calls, evaluation results, approver and timestamps, keyed to one trace ID.
Fallback model	A second model, preferably from a different vendor, qualified on the same evaluation suite and ready to take over.
Fine-tuning	Further training of a model on the firm's own data. This book treats it as "not yet" for most regulated use cases.
Foundation model	A large pre-trained model, hosted by a vendor or run from open weights, that the rest of the stack builds on (layer L1).
Guardrail	A check on what goes into or comes out of a model: deterministic rules, small classifiers or model-based judges (control C2).
Human in the loop	A named person who must approve an output before it takes effect. In the worked example, a portfolio manager.
Ingestion	Turning source documents into indexed, permissioned, traceable chunks that retrieval can use (layer L8).
Lock-in	The cost of leaving a vendor. Some lock-in is a good trade; lock-in over the firm's own records is not.
MCP	The Model Context Protocol, an open standard for connecting models to tools. Its independent alternative in this book is tools described with OpenAPI behind the same gateway.
Memory	Information an agent keeps between runs. This book recommends building it last, on purpose.
Model risk	The risk of loss from decisions based on a model that is wrong or misused, and the governance that manages it (control C8).
Observability	Recording what a system did, in enough detail to explain, measure and improve it, on a telemetry pipeline the firm owns (layer L9).
Open weights	A model whose trained parameters can be

Term	Meaning in this book
	downloaded and run in the firm's own estate, under a licence.
Prompt injection	Hidden instructions in text a model reads, such as a retrieved document, that try to make it act against its instructions.
Release manifest	The versioned list of every setting that can change an output: prompts, model versions, retrieval settings, tools, guardrail policy and evaluation thresholds (control C5).
Reranker	A model that re-orders retrieved passages by relevance before they reach the drafting model (layer L7).
Retrieval	Finding the passages a model needs, from a store the firm controls, under the user's permissions (layers L6 and L7).
Signal	The one measure a chapter recommends tracking for its layer or control, with a starting target.
Trace	The linked record of every step in one run, from request to approved output.
Vector database	A store for embeddings. This book argues that many firms can use a database they already run instead of adding one.

About the author

Bing Zhang is a technology leader in asset management, working on AI-native and agentic engineering and on the platforms regulated firms need to run them safely. Bing writes about the operating-model decisions behind enterprise technology: modernisation, resilience, and making invisible engineering work visible to the people who fund it.